


# Product & Technical Specification

Version 1.2 — Baseline · 4 October 2026 · Confidential

*Private chemistry. Intelligent discretion.*

# TRYST Specification v1.3 — Baseline

**Private chemistry. Intelligent discretion.** · *Discretion is the product.*

| | |
|---|---|
| Version | **1.3 — Baseline (stable)**. v1.2 added the brand identity and account-holder-only login; v1.3 adds the internal operating system (09; 06 §4) |
| Date | 4 October 2026 |
| Status | Stable for engineering planning and estimation. **Build start remains gated** on the written UK legal opinion and completed DPIA (Phase P0; see 01 §14). |
| Owner | Office of the Group Chief Executive → TRYST SPV (pre-incorporation) |
| Classification | Confidential |

## 1. Document set

The specification is split by audience. Each document owns its topics; the others link to it rather than restating it.

| # | Document | Audience | Owns |
|---|---|---|---|
| 00 | **README** (this file) | Everyone | Index, source precedence, change control |
| 01 | Product | Leadership, product, investors, counsel | Thesis, segments, modes, principles, loops, agent roles, business model, unit economics, GTM, roadmap, team, budget, KPIs, risks, compliance envelope, admission policy, liability architecture |
| 02 | Shared Contracts | Backend **and** frontend | Glossary, enums, verification tiers and gates, data model, API contract, event taxonomy, agent message schemas, retention, error model, requirement catalogue (FR/NFR) with owners |
| 03 | Backend | Backend, ML, security, SRE, T&S engineering | Services, stack, agents, learning models, matching pipeline, cryptography, identity split, erasure, PSI server, Guardian server side, admission control, MLOps, commerce, backend backlog |
| 04 | Frontend | iOS, Android, web, design | Two-surface strategy, client stacks, screens and flows, client discretion, client cryptography, on-device Guardian, PSI client, safety UX, copy rules, store compliance, frontend backlog |
| 05 | Terms of Service — draft 0.9.5 | Counsel | Consumer terms for counsel review. **Not for publication.** |
| 06 | Decisions, errata and change log | Product owner, tech leads | How v1.1 reconciled its sources, resolved and open decisions, errata fixed |
| 07 | Source B — founder brief (verbatim) and traceability | Everyone | The founder's 17 Sep 2026 specification word for word, plus where each part is implemented, the agent mapping and the FR-ID crosswalk |
| 08 | Source A — traceability | Everyone | Where each section of the consolidated Spec + ToS lives in the spec and the code |
| 09 | Operating System (internal) | Leadership, engineering, security, payments, operations | Agent workforce and governance (autonomy levels, always-human actions, kill switch, audit chain), command centres for every user type, self-managing platform layer, BitriPay API door, connector register, ops and partner schemas and APIs, B2B licensing and ACU, Admin Super Control Centre, roadmap |

A combined PDF of 00–09 is at `TRYST_Spec_v1.3.pdf`. Brand assets (logo exactly as supplied, colour tokens) are in `shared/brand/`.

## 2. Sources and precedence

v1.1 merges three inputs. Where they conflict, the higher-ranked source wins unless 06 records a decision otherwise.

| Rank | Source | File |
|---|---|---|
| **A** | Product & Technical Specification and Terms of Service — consolidated edition (4 Oct 2026; Part A §1–21, Part B ToS draft 0.9) | `source/TRYST_Spec_and_ToS_Consolidated_2026-10-04.pdf` |
| **B** | AI Discreet Relationship Platform — Developer Specification (17 Sep 2026) | `source/TRYST_Developer_Specification_2026-09-17.docx` |

| Rank | Source | File |
|---|---|---|
| **C** | PRD & Business Plan draft v0.1 (4 Oct 2026) | `archive/TRYST_PRD_v0.1.md` |

Both A and B call themselves "v1.0", so v1.1 refers to them as **Source A** and **Source B**. In v1.1, references such as `[A §9.3]` point to the source section a requirement came from.

## 3. Identifier conventions (stable across documents)

| Prefix | Meaning | Defined in |
|---|---|---|
| `S1–S6` | Member segments | 02 §2.2 |
| `V0–V3`, `VC` | Verification tiers | 02 §3 |
| `A1–A8` | Threat-model adversaries | 03 §6.1 |
| `M1–M9`, `M6a–M6h`, `M7b` | Models | 03 §4.3, §7.7 |
| `L1–L5` | Admission-control layers | 03 §8 |
| `FR-nnn`, `NFR-nn` | Functional and non-functional requirements | 02 §10 |
| `D-nn` | Decisions | 06 §2 |
| `L0–L3` (agents) | Agent autonomy levels | 09 §5.2 |
| `E-nn` | Errata fixed in v1.1 | 06 §3 |
| `G-xx` | Phase exit gates and no-go conditions | 01 §12–13 |

IDs are never reused or renumbered. A retired requirement keeps its ID with status `Retired`.

## 4. Change control (stabilisation rules)

1. **v1.1 is a baseline.** Changes go through a pull request that edits the owning document and adds a row to 06 §4.
2. **Contract changes come first.** Any change to an API, entity, enum, event or schema is made in **02 Shared Contracts** before 03 or 04 depend on it.
3. **Open decisions** (`D-nn`, status *Open*) carry a stated default. Engineering may build against the default, and the owner must close the decision before the phase gate shown.
4. **Consistency check.** `python3 scripts/check_spec.py` checks that every `FR`/`NFR`/`D`/`E` ID referenced anywhere is defined exactly once, every FR has an owner, and relative links resolve. It must pass before merge.
5. **Version bumps:** editorial → 1.1.x; new or changed requirement → 1.2; change to a principle in 01 §4 → 2.0 (requires sign-off from the Group CEO).

## 5. Source register (revalidate before launch)

Policies, prices and legal requirements must be revalidated before launch, and again at each phase gate.

- **Source B's register** (accessed 17 Sep 2026) is reproduced verbatim in 07 §3: Ashley Madison, Gleeden, Victoria Milan, the FTC Ashley Madison settlement, ICO special-category guidance, UK GDPR Art. 9, Apple App Review Guidelines, Google Play inappropriate-content policy, NIST AI RMF and OWASP MAS.
- **Source A's citations** (Ofcom OSA and dating guidance, CRA 2015, CCR 2013, DMCC Act 2024, DPA 2018, card-scheme rules) are in the consolidated PDF.

**Added for v1.2 — not yet checked, verify in P0:**

| Topic | Source to check | Why |
|---|---|---|
| Stripe acceptance | https://stripe.com/legal/restricted-businesses and a written confirmation from Stripe | D-22: Stripe as primary processor (could not be fetched from the build environment) |
| Search-engine spam and AI-content policies | https://developers.google.com/search/docs/essentials/spam-policies | D-21: Herald link and content rules |
| Passkeys / WebAuthn | https://www.w3.org/TR/webauthn-3/ and https://fidoalliance.org/passkeys/ | D-16: login factors |
| Liveness PAD certification | ISO/IEC 30107-3; the provider's iBeta (or equivalent) Level 2 report | NFR-17 |
| Biometric data | ICO biometric data guidance | D-17, D-18, ToS Q14 |

| Topic | Source to check | Why |
|---|---|---|
| BitriPay API and webhook formats | The BitriPay API reference and OpenAPI document (supplied developer docs, 4 Oct 2026) | D-26: refund field names and the `BitriPay-Signature` layout are marked ASSUMED in the adapter |
| EU AI Act obligations for P4 markets | Regulation (EU) 2024/1689 and Commission guidance | 09 §13.4 |

# 01 — TRYST Product Specification v1.1

Part of the TRYST v1.1 baseline. Contracts live in 02; implementation in 03 and 04.

## 1. Executive summary

> **PRODUCT SCOPE**
>
> TRYST is designed specifically for adults who are already in a relationship and want a discreet one-off affair, a continuing extramarital connection, another couple, or a threesome. Existing-partner permission is not a condition of membership. Every person using TRYST must nevertheless be an independently consenting adult; the platform prohibits coercion, stalking, blackmail, impersonation, minors, non-consensual imagery and commercial sexual services.
>
> *Founder scope statement, verbatim (Source B; re-confirmed 4 Oct 2026). Applied through §4, §5 and D-01.*

TRYST is a discretion-first connection platform for attached adults, solo adults open to couples, and couples. It covers one-off encounters, ongoing extramarital connections, couples seeking a third, and couple-to-couple connections, for all genders and orientations.

Two things make it different:

1. **An agent-to-agent handshake (Envoy).** It resolves intent, boundaries, logistics, discretion needs and verification parity *before* two people speak.
2. **A breach-assumed architecture.** End-to-end encrypted messaging, client-side encrypted media, split identity and profile stores, cryptographic erasure in under 60 seconds, and partner-collision avoidance through private set intersection. Together these make the category's defining disaster — the 2015 Ashley Madison breach — technically very hard to repeat.

**Board summary [A §21].** The category leader in affairs has vacated that position under regulatory and payments pressure. The leader in non-monogamy is a browsing product with a resolution problem. The opportunity is real. The hard part is not the software but the compliance envelope, marketplace liquidity, and an acquisition-cost model that only works through invitation. Build the envelope first, seed the scarce side first, and let the agent layer earn its place against a measured control.

**Gating.** No engineering build starts before a written UK legal opinion and a completed DPIA (§14).

### 1.1 Executive product decision

*Founder text, verbatim (Source B; re-confirmed 4 Oct 2026).*

Build TRYST as a privacy-first, affair-specific connection platform rather than a generic dating app. Its strategic advantage is an AI relationship-intelligence layer that learns attraction, discretion requirements, availability, risk tolerance and interaction quality while deliberately collecting less identifying data than incumbents.

| Decision | Specification | Why it wins |
|---|---|---|
| Name | TRYST | One sharp word meaning a private romantic meeting; instantly communicates the category. |
| Audience | Partnered adults of any gender/orientation; couples seeking a third or another couple | Clear, high-intent niche rather than mass-market dating. |
| Promise | Private chemistry. Intelligent discretion. | Combines emotional benefit with the functional moat. |
| Core modes | One-off, Ongoing, Couple+, Threesome, Couple-to-Couple | Intent is explicit before matching. |
| Moat | Discretion Graph + Behavioural Compatibility Engine | Learns fit without exposing identity or partner data. |
| Revenue | Subscription-led with credits and premium privacy | Predictable recurring revenue plus high-margin intent transactions. |
| Launch | Web/PWA first, then native apps subject to store review | Reduces store dependency and permits rapid privacy iteration. |

> **ONE-SENTENCE PITCH**

> TRYST is the intelligent private network where attached adults and couples find precisely matched affairs, extra-relationship connections and threesome partners without exposing more of their identity than necessary.

**How this decision maps onto the rest of v1.2:**

| Decision row | Implemented as |
|---|---|
| Core modes | One-off → SPARK; Ongoing → EMBER; Couple+ and Threesome → THIRD (Couple+ = a couple seeking a third; Threesome = a solo joining a couple); Couple-to-Couple → QUAD; plus OPEN for exploration (§5.2) |
| Moat | Discretion Graph = Discretion Policy + ExclusionRing + zones enforced on every read (Curtain); Behavioural Compatibility Engine = Mirror + Broker + Envoy (§7) |
| Revenue | "Credits" = Keys; "premium privacy" = the GHOST add-on, subject to D-05 (§10) |
| Launch | Web PWA is the full product and the revenue surface; native apps follow store review, approved by G-P3 (§12, §14.3) |
| Audience | See D-01 on unattached solos |

# 2. Thesis and market gap

The discreet-connection market is large, proven and badly served. The incumbents monetise frustration; TRYST monetises resolution. [A §1]

**Founder market thesis, verbatim (Source B §1; re-confirmed 4 Oct 2026):**

> The category is already validated. Ashley Madison markets private, anonymous connections and claims more than 91 million members. Gleeden uses a credit economy for extramarital connections; Victoria Milan markets a rapid-exit "panic button." The opportunity is not to prove demand but to rebuild the category around modern privacy engineering, verified authenticity, gender-neutral pricing, transparent AI and higher-quality matching.

| Incumbent pattern | Observed weakness | TRYST response |
|---|---|---|
| Large anonymous inventory | Fake profiles, low trust and expensive dead-end messaging | Liveness, authenticity confidence and conversation-quality scoring. |
| Credit-heavy messaging | Revenue can conflict with real connection outcomes | Subscription provides core value; credits enhance but do not manufacture access. |
| Basic privacy theatre | A panic button cannot protect server-side data | Pseudonymity, data minimisation, isolated vaults, short retention and discreet billing. |
| Pairwise matching | Poor fit for couples and threesomes | Native multi-person matching and room consent. |
| Swipe engagement | High noise and fatigue | Small daily set of high-confidence, intent-aligned introductions. |

*Membership figures differ between sources: Source B cites Ashley Madison's claim of 91M+ members, Source A cites 80M+. Both are the company's own unaudited claims; use the current figure from Ashley Madison's site, with an access date, in any external material (E-32). "Gender-neutral pricing" supports the default in D-06.*

## 2.1 Market

| Player | Position | Observed weakness | TRYST response |
|---|---|---|---|
| **Ashley Madison** | Affair category leader (claims 80M+ members). Rebranded globally as a "discreet dating app" on 24 Feb 2026, moving away from married dating. | Pay-to-initiate credits (men pay to start conversations); recurring bot and cost complaints; 2015 breach (FTC: about 36M users exposed, deletion failures). | Take the affair position it is vacating, and survive the pressure through §9 and §14. Subscription-led pricing; replying is always free. |
| **Feeld** | Owns ethical non-monogamy and couple-seeks-third. Revenue £48.9M in 2024 (+26%, Companies House); 2M+ active users by 2026. | Thin free tier; high-noise discovery; a browsing product, not a resolution product. | Envoy handshake; daily curated slate; meets as the north star. |
| **Gleeden**, **Victoria Milan**, **Illicit Encounters** | Regional affair sites (credits; panic button). | Fake profiles; "privacy theatre" that does not protect server-side data. | Liveness plus age assurance for everyone; real cryptography. |

| Player | Position | Observed weakness | TRYST response |
|---|---|---|---|
| **3Fun / #Open / swinger communities** | Couples and thirds niche. | Fake "couples", moderation gaps, dated UX. | Mandatory dual-verified couple profiles (VC). |
| **Mainstream apps** (Tinder, Hinge, Bumble, Grindr) | Mass market. | Not discreet; exposure through social graphs. | ExclusionRing; decoy skin; no social login. |

*Third-party figures are as reported by the sources cited in Source A and have not been independently audited.*

### 2.2 Four failures TRYST fixes

*Source: A §1*

| Failure | Why it persists | TRYST answer |
|---|---|---|
| Stated ≠ real intent | Profiles are self-authored marketing | Behaviour-learned RevealedPreferenceVector matched against IntentVector; divergence is a feature |
| 200 messages, zero meets | Engagement-maximising ranking rewards long unresolved threads | Envoy handshake pre-qualifies; the reward function penalises time in app |
| Attention collapse | Rich-get-richer ranking; couples broadcast to everyone | Inbound caps, Gini constraint, asymmetric Key pricing |
| Discretion as marketing | Retention by default and server plaintext are cheaper | E2EE, cryptographic erasure, token-only verification, PSI ExclusionRing |

## 3. Name and brand

*Source: A §2*

**TRYST** — *a private, prearranged meeting between lovers.* One syllable, five letters, no explanation needed, and deniable on a lock screen. Tagline: **Private chemistry. Intelligent discretion.** Internal line: **Discretion is the product.**

- **Brand codes:** oxblood and gold on night; serif display, tight tracking. No pink, hearts, silhouettes or lipstick. Reference: a private members' club, not a nightclub.
- **Fallback names** if trademark clearance fails: ASIDE, DUPLEX.
- **Domains:** tryst.app / tryst.co / trystapp.com plus defensive registrations before any UKIPO Class 9/45 filing becomes public.

### 3.1 Logo




The master logo is `shared/brand/tryst-logo.png` (1254 × 1254 px, transparent background), supplied by the founder (D-19).

- **Use it exactly as supplied.** Do not redraw, recolour, crop, stretch, re-shadow or separate the mark from the wordmark. The repository keeps the original file byte-for-byte (SHA-256 `5f2ceb55…eae2761`).

- **Background:** the logo is designed for the dark `night` ground (§3.2), and is only placed on `night`, `oxblood-deep` or `oxblood`.
- **Never shown where it would expose a member (P3, P9):**
  - on a device in decoy mode;
  - on the lock screen or in notifications;
  - in the app-switcher snapshot;
  - in billing descriptors;
  - in the home-screen icon of a member who has chosen a decoy skin;
  - in Share My Plan messages.
- **Where it appears:**
  - the web PWA (landing page, sign-in, header);
  - inside the native apps after unlock;
  - store listings, subject to the sanitised-store rules (§14.3);
  - investor and press materials.

### 3.2 Colour palette

The palette is sampled from the logo. Tokens live in `shared/brand/tokens.json` and `shared/brand/tokens.css`.

| Token | Hex | Role | Contrast on `night` |
|---|---|---|---|
| `night` | `#0B0607` | Primary background | — |
| `oxblood-deep` | `#3F0000` | Deep surfaces, pressed states | — |
| `oxblood` | `#560001` | Brand surface, primary buttons | 1.34 (surfaces only) |
| `oxblood-light` | `#702A2E` | Hover, borders, dividers | 1.97 (never text) |
| `bronze` | `#836042` | Secondary lines, disabled states | 3.56 (large text only) |
| `gold` | `#CB944F` | Accent, links, icons, headings | 7.56 AA/AAA |
| `champagne` | `#F5D3AC` | Highlight text, active states | 14.18 |
| `cream` | `#FCF2DD` | Body text; light surface (replaces "bone") | 18.1 |

**Text pairs that pass WCAG 2.2 AA (NFR-07):**

- cream, champagne or gold on `night`;
- cream (13.5), champagne (10.6) or gold (5.65) on `oxblood`;
- oxblood on cream (13.5).

Oxblood and oxblood-light are never used for text on dark grounds.

### 3.3 No "AI" in the name or brand (founder, v1.3)

TRYST is never named, branded or marketed as AI (D-33).

- The words "AI", "A.I." and "artificial intelligence" never appear in the name, tagline, logo, app-store listings, marketing site, Herald content, ads, press materials, product UI or notifications.
- The product describes what members get, not the technology: "your agent compares intentions and limits", "we settle the details before you speak".
- Internal engineering documents (02, 03, 09) may describe models and agents in technical terms. That vocabulary never reaches a member or the public.
- Enforced by `frontend/test/brand.test.ts`, which fails the build if any user-facing source contains these words.
- Member-facing safety copy follows the same rule: images made by generators are described as "computer-generated" (FR-093), so the photo rules never put the word on screen.

## 4. Operating stance and principles

### 4.1 Stance

*Source: A §1*

> **We are indifferent to your marriage; we are absolutist about consent and safety on our surface.**

TRYST does not police whether a member's partner knows; that is unverifiable and not the platform's business. It does enforce, without exception:

- Verified adults only, through highly effective age assurance.
- Consent from every party *on the platform*. Couples are dual-verified; no one is listed by a partner without co-signature. No permission is required from anyone not on TRYST.
- Zero tolerance for image abuse, sextortion, coercion, commercial sexual services, and minors.

### 4.2 Product principles (changing one requires v2.0)

| # | Principle | Source |
|---|---|---|
| P1 | **Resolution over engagement.** Optimise for confirmed, positively rated meets (QCAM), never time in app or message volume. | A §6.4, §18 |
| P2 | **Hard limits are inviolable.** No learned signal can surface a candidate who violates a hard limit, exclusion zone or structure incompatibility. Enforced by tests, not policy. | A §6.2 |
| P3 | **Breach-assumed by design.** Assume breach, subpoena, and a suspicious partner holding the phone. | A §9 |
| P4 | **Agents never impersonate.** Agents negotiate only with other agents; every Brief is labelled as machine-generated; only a double human accept opens a thread. | A §5.4 |
| P5 | **Stated preference keeps a floor.** Revealed behaviour never drops stated preference below 15% weight; members can view, correct and reset learning. | A §6.2, B FR-010 |
| P6 | **No safety theatre.** No "safe", "vetted" or "background-checked" badges, ever. Only factual, dated statements. | A §19.2, §19.8 |
| P7 | **Safety beats discretion in an emergency.** Panic preserves and releases what emergency services need, regardless of retention settings. | A §19.7 |
| P8 | **Revenue ethic.** No advertising, data sale, affiliates, fake profiles, unreadable credit mechanics, engagement paywalls, or charging for deletion or data access. Replying is always free. | A §15, B §11 |
| P9 | **Truthful privacy claims.** Never promise an affair is undetectable. Disclose the limits (device owner, bank, network, recipient screenshots, legal process) and the declared exceptions (ban anchors, legal holds). | B §4, A §19.3 |

### 4.3 Never

- Never the "cheat better" message; the positioning is "Discretion is the product." [A §16]
- Never a "catch a cheater" feature, partner search or exposure tool.
- Never random or anonymous chat; messaging is between matched members only. [A §14.3]
- Never operate in markets that criminalise adultery or same-sex conduct, and never in Africa or MENA under any brand. [A §14.5]

## 5. Segments, modes and intent shapes

### 5.1 Segments

*Source: A §3*

Every segment is first-class in the data model.

| Code | Segment | Job to be done | Primary anxiety |
|---|---|---|---|
| S1 | Attached, undisclosed | Meet one person discreetly without changing my primary life | Exposure |
| S2 | Attached, disclosed / open | Quality connections without re-explaining my structure | Judgement, wasted time |
| S3 | Couple seeking a third | Someone both of us want, who wants both of us | Ghosting; friction between partners |
| S4 | Solo open to couples | Be treated as a person, not a utility; a veto that is respected | Harassment volume; bait-and-switch |
| S5 | Couple seeking a couple | Four-way compatibility with low coordination cost | Coordination collapse |
| S6 | Curious / never acted | Find out whether this is for me, at low risk | Committing too early; discovery |

> **S4 is the scarce asset.** S4 supply decides whether S3 and S5 have a product. S4 inbound is rationed, priced and capped (03 §5.4). Any ranking change that pushes S4 inbound above the cap is a regression, whatever it does to session metrics.

**People in open relationships are welcome** (founder, v1.3): consensually non-monogamous and polyamorous members, solo or as a couple, join as S2 (solo) or S3/S5 (couples), mainly through the OPEN, SPARK and EMBER

modes. Nothing in the product assumes secrecy from a partner. Solo members may be attached or unattached. Partner awareness is self-declared, never verified, and never shown to others. (D-01)

### 5.2 Modes (member-facing) ↔ intent shapes (data)

Source B's mode names are kept as the **member-facing labels**; Source A's intent shapes are the **canonical data values** (02 §2.3).

| Mode (UI) | Intent shape(s) | Typical segments | Notes |
|---|---|---|---|
| **SPARK** | `one_off` | S1, S2, S4, S6 | Matched on availability, distance and chemistry. **Tonight** (v1.3): go free for a few hours and see who nearby is also free; reciprocal, approximate distance, mutual interest only (FR-109) |
| **EMBER** | `recurring`, `ongoing` | S1, S2 | Matched on cadence, emotional depth, communication windows |
| **THIRD** | `third` | S3 ↔ S4 | Couple profile must be `VC`; the third is an equal member with a respected veto |
| **QUAD** | `couple` | S5 ↔ S5 | Four independent verified accounts; match only after each couple's veto mode is satisfied |
| **OPEN** | `exploratory` | S2, S6 | Member picks allowed configurations and visibility |

A member may enable several modes, each with its own visibility and filters.

## 6. Product loops

*Source: A §4*

| Loop | Cadence | Flow |
|---|---|---|
| **A — Intake** | Once (~7 min, conversational) | Age assurance → Cartographer interview → IntentVector v0 → ExclusionRing enrolment → Discretion Policy → first slate |
| **B — Discovery** | Daily (< 6 min per session target) | Curated slate (up to 18 cards, 15% exploration) → Intent sent (costed) / pass / save → Mirror updates RevealedPreferenceVector → slate recomputed |
| **C — Handshake** *(the product)* | Per mutual intent | Envoy A ⇄ Envoy B negotiate over a fixed schema → asymmetric Brief to each human → accept / decline / amend → E2EE thread opens **only** on double accept |
| **D — Resolution** | Per connection | Thread → logistics agreed → Safe Meet checklist → meet confirmed → Aftercare prompt at 48 h → reward signal |
| **E — Discretion** | Continuous | Curtain scores session risk → geofence, collision suppression, notification masking, retention enforcement |

> Loop C is the product. If it does not measurably raise meets per intent sent over a control cohort (gate **G-P2**), TRYST is a me-too and should not raise a Series A.

## 7. Agents (roles)

**The AI agents facilitate matching; members make every decision.** Agents learn, rank, pre-qualify and draft. They never send an intent, open a conversation, reveal a member or act as a member without that member's explicit action (P4, FR-055, FR-066).

Seven agents, each an independently deployable service with its own tool surface, memory scope, policy file and eval suite. They talk over a typed internal bus, never by passing free text. [A §5] Implementation: 03 §3.

| Agent | Role | Autonomy boundary |
|---|---|---|
| **Cartographer** | Conversational intake → signed IntentVector; re-run quarterly or on drift | Member confirms every structured field [B] |
| **Mirror** | Behaviour learning; sole writer of RevealedPreferenceVector | Approved features only; message content never used |
| **Broker** | Retrieval and ranking under hard gates and fairness constraints | Cannot bypass Stage 0 gates; paid status cannot override eligibility |
| **Envoy** | Agent-to-agent handshake; asymmetric Briefs; logistics and timing negotiation | Never talks to a human as the member; cannot open a thread; output is advisory |

| Agent | Role | Autonomy boundary |
|---|---|---|
| **Curtain** | Discretion risk; owns and enforces the versioned Discretion Policy | May tighten exposure automatically; may never loosen it [B] |
| **Guardian** | Safety; veto over every other agent | No permanent action without a named human; never reads message content server-side |
| **Aftercare** | 48 h private outcome capture → reward | Never shown to the counterparty; never a public rating |

Two release-gate functions that are not agents: **Privacy Auditor** (continuous access, retention and model-leakage tests; can block a release) [B] and the **agent eval harness** (03 §9).

**Growth agent (outside the member platform): Herald**, the dynamic AI SEO agent (v1.2). It researches topics, drafts and optimises content for the public marketing site, manages internal linking, tracks rankings and drafts link-earning outreach. It has **no access to any member data**, and a human editor approves everything before it is published (03 §3.2, D-21).

# 8. Trust, verification and admission policy

## 8.1 Verification ladder

The tier definitions and what each one unlocks are canonical in 02 §3. In summary:

- **V0** = contact handle, onboarding only.
- **V1** = liveness.
- **V2** = highly effective age assurance. **Required for discovery, intents, threads, media, Envoy and meets** (E-01).
- **V3** = optional bank or digital ID.
- **VC** = couple co-signature: both partners independently at V2, each confirming from their own device.

> **VC is the most important trust feature in the product.** It will cost 20–30% of couple sign-ups in year one. Pay it.

## 8.2 Screening reality and admission control

*Source: A §19*

In the UK you cannot lawfully buy sex-offender or criminal-record screening for platform users (ViSOR is not accessible; DBS checks are employer-only). TRYST builds five-layer admission control instead (03 §8):

| Layer | What it does |
|---|---|
| L1 Identity binding | One human, one account, permanently: liveness challenge, ID match through the provider, device attestation, payment fingerprint, £9.99 refundable deposit |
| L2 Ban anchor | One-way identifiers that survive deletion. **The declared exception to erasure.** |
| L3 Voluntary attestation | Self-submitted Basic DBS shown as a dated fact; Clare's Law explainer (answer never asked for or stored); conduct declaration at V2 |
| L4 Behavioural detection | Guardian M6a–M6e and M7b; most dangerous users have no record, but they do have a pattern |
| L5 Consortium | Industry hash sharing (e.g., Online Dating Association) of anchors plus reason codes only; gated on competition-law and data-protection opinions |

**"Declared unsafe" grounds** (auditable): (1) self-declared intent to harm or coerce; (2) corroborated reports from two or more independent reporters; (3) a court order (SHPO, restraining or non-molestation order); (4) law-enforcement notification; (5) a model signal confirmed by human review; (6) a knowingly false conduct attestation.

**Ladder:** warn → shadow-limit → suspend → permanent ban + Ban Anchor → law-enforcement referral. Grounds 1, 3 and 4 go straight to permanent.

**Due process:** a named human makes every permanent decision; appeals go to a different reviewer within 10 working days; reporter-reputation scoring (retaliatory or coordinated reporting is itself removable — suspicious spouses and rejected counterparties are predictable abuse vectors); the transparency report publishes the overturn rate.

### 8.3 Safety floor

- **Safe Meet:** public venue first; check-in timer with silent escalation.
- **Share My Plan:** encrypted, unbranded, auto-deleting share with a trusted contact.
- **Panic:** escalation to 999 with location, separate from the discretion **Burn** control (E-21).
- **Emergency override:** safety beats discretion (P7).
- **Victim-support routing** after an incident.
- **24/7 T&S rota** from P3, with published SLAs.
- **Door check** (v1.3, FR-099): on arrival both phones show the other's verified main photo and the same three words; if the person doesn't match, leave.
- **Duress PIN** (v1.3, FR-100): a check-in PIN that looks normal on screen but silently raises the alarm.
- **TRYST safety line** (v1.3, FR-100, D-42): opt-in second step after the trusted contact; staffed 24/7 from launch by a contracted alarm-receiving centre (BS EN 50518 / BS 8484), with the on-call T&S rota as backup (D-48); location for that meet only.
- **Video first** (v1.3, FR-103): an in-app video call is offered before every first meet and can be made a hard limit; a first meet at a private address triggers an on-device warning.

The full defence against fake profiles and criminal use (grooming, trafficking, fraud, extortion, drugs) is in 03 §7.7.

## 9. Discretion promise

TRYST minimises platform exposure. It cannot guarantee secrecy from a device owner, bank, employer, network administrator, recipient screenshot, legal process or a determined third party, and it says so (P9).

The design starts from the eight adversaries in 03 §6.1:

- A1 partner holding the device — daily case
- A2 shared bank statement
- A3 social-graph recognition
- A4 mass breach — existential
- A5 extortion by a counterparty
- A6 civil discovery in divorce
- A7 insider
- A8 face-search de-anonymisation

Member-facing controls are in 04 §5. Retention defaults are canonical in 02 §7.

### 9.1 Keeping a member's secret (founder, v1.3)

*Founder: "One person in a couple can want a secret affair without the other partner knowing, and the platform must keep people's secrets buried."* (D-45)

1. **Joining alone is the default.** A person in a relationship joins on their own. Their partner is never needed, asked, contacted or told. Couple verification (FR-095) applies **only** to the optional joint couple profile, for partners who want to meet others together.
2. **Partner shield** (FR-106). A member can add their partner's phone number or email; it is blinded on the phone before it leaves. If the partner ever joins TRYST, each becomes invisible to the other, in both directions, permanently, and neither is ever told. The same silent suppression applies to couple partners on TRYST, to the member's contacts (ExclusionRing) and to household signals (shared home area, card, phone or Wi-Fi).
3. **A private solo profile alongside a joint couple profile** (FR-107). Still one account per person (D-41). The partner never sees the solo profile, and nothing from it (intents, Briefs, threads, matches, notifications, payments, activity) appears in the couple profile or on the partner's phone. Enforced as a Stage 0 gate (`partner_secret`, property-tested).
4. **We never confirm or deny** (FR-108). To anyone (a partner, family member, employer, private investigator, journalist or caller claiming an emergency) TRYST says only: "We can't say whether any person has an account." Account information goes only to the signed-in account holder, to a court order or lawful police request reviewed by counsel, or under the emergency rule (P7).
5. **Nothing internal leaks out.** Review signals such as a shared card or phone never notify or visibly affect another member; members are known by pseudonym only; real names are never collected.
6. **The phone and the bank** (04 §5): decoy app icon, notifications off by default and always masked, duress PIN for the app, Burn, a neutral card descriptor that never says TRYST, vouchers and a separate billing email.
7. **The honest limits** (P9): TRYST cannot protect a secret from someone who unlocks the member's phone, reads their bank statement closely, is shown a screenshot by the other person, or obtains a court order. The main photo shows the member's face (D-38) to other verified members, so a stranger who knows them could recognise them; the partner shield and contact exclusion hide them from the people they choose.

# 10. Business model and unit economics

## 10.1 Principle

*Source: A §15.1*

Charge for agency and discretion; make resolution the profitable outcome. Subscription plus success-weighted retention, never pay-per-message. The economic model and the loss function must agree.

## 10.2 Tiers (UK)

| Tier | Price | Includes |
|---|---|---|
| **Verified** (free) | £0 + £9.99 refundable deposit (credited 100% as Keys) | Full profile; be discovered; **reply to anyone free**; 3 outbound intents a week; Envoy handshake on mutual intent; full safety suite and core discretion suite |
| **TRYST+** | £24.99/mo · £14.99/mo billed annually | Unlimited intents, filters, incognito, travel mode, extended media, read-receipt control |
| **ENVOY** | £49.99/mo | The agent tier: Envoy *proposes* outreach and pre-qualification, screens risk, negotiates logistics. Every outbound intent needs a one-tap human approval (D-04) |
| **DUO** | £39.99/mo per couple | Linked VC profile, dual-consent controls, joint-veto model, third-screening Envoy |
| **Keys** | £9.99 / 60 | Non-subscribers: intent = 5 Keys solo→solo, 15 Keys couple→solo; **fully refunded on reply** |
| **GHOST** add-on | £7.99/mo | Advanced discretion: multiple decoy skins, custom TTLs, extended ExclusionRing heuristics. Core decoy, duress PIN, Burn, masking and voucher billing stay free (D-05) |

Source B's Black / Duo £34.99 / Signals / Vault+ / Concierge Black tiers are superseded (E-14). Concierge is deferred beyond P4.

## 10.3 Unit economics (illustrative; replace with beta cohorts)

*Source: A §15.3*

| Metric | Value |
|---|---|
| Blended CAC per sign-up (paid + referral, UK) | £38 |
| Sign-up → V2 verified | 52% |
| Verified → payer (month 3) | 11% |
| Blended ARPPU | £31.50/mo |
| Payer gross churn | 19%/mo (average life 5.3 months) |
| Gross revenue per payer (lifetime) | £167 |
| less PSP (high-risk, 5.0%) / verification (2 × £1.10) / infra + inference | −£8 / −£2 / −£14 |
| **Contribution per payer** | **£143** |
| CAC per payer at £38 per sign-up (£38 ÷ 0.11 ÷ 0.52) | **£664 — paid acquisition alone does not work** |

**Corrected viability thresholds** (E-03): break-even blended CAC per sign-up = £143 × payer rate × 0.52.

| Verified → payer | Break-even CAC per sign-up | CAC for 3× LTV:CAC |
|---|---|---|
| 11% | **£8.18** | £2.73 |
| 16% | £11.90 | £3.97 |
| 18% | £13.38 | £4.46 |

Source A's "< £12" target is only viable at a payer rate of about 16% or more. Two levers decide the business; track both weekly from beta day one:

1. Raise verified → payer toward 18% (ENVOY is the instrument).
2. Drive blended CAC down through member referrals and organic channels.

Treat paid acquisition as a seeding cost, never a growth engine.

# 11. Liquidity and go-to-market

*Source: A §16*

*Changed by the founder in v1.3 (D-35): public sign-up replaces Source A's 9-month invite-only period. The proven density-first sequence is kept: matching opens one city at a time, London first, and the balance waitlist stays.*

1. **Density gate (G-City-1).** Sign-up is open from day one in all four launch cities, but **matching opens one city at a time, in launch order**: a city goes live at 2,000 verified members once the city before it is live, and stays live. Until then, members verify, set up their profile and discretion settings, and see how close their city is. An empty grid is never shown.
2. **Balance gate (G-City-2) — the demand-balance waitlist, gender-neutral** (D-36). Nobody waits because of who they are. Each member belongs to the groups that describe them and seeks the groups they asked to meet. A new member waits only if a group they want to meet is already saturated: more than 2.2 seekers per member of that group in their city (2.0 by P3). The same rule protects whoever is being overwhelmed: women in a straight pool, men in a gay pool, singles sought by couples. Waiting is first come, first served; members see their position and which group is busy, and are admitted automatically as that group grows. The per-city gender ratio stays a monitored KPI and is achieved through this rule, not by admitting by gender. Price and ranking never use any of it (D-06; 03 §3). Implemented and tested in `backend/internal/launch` (FR-090).
3. **Seed the scarce side first.** Outreach waves and founding-member status for S4 (and, subject to D-06, under-represented cohorts) with free ENVOY for 6 months.

4. **Public sign-up, no invitation needed** (founder, v1.3). Member referrals stay as a growth channel: 3 per member, refreshed monthly for members in good standing. Referral rewards never reveal the referrer to the invitee [B]. 4a. **Paid-acquisition brake** (v1.3, FR-091). Each week, per city, blended cost per verified sign-up is compared with the E-03 break-even line (£8.18 at the base case, recalculated from observed payer and V2 rates). Paid spend in the city **stops automatically** after two weeks above break-even, or immediately at 50% above it; restarting needs a named approver. Referrals and organic search continue. Acquisition cost therefore cannot run above break-even for more than one week (above 1.5× it, not at all) without a person deciding it should.

5. **Cities:** sign-up open in **London, Manchester, Birmingham and Brighton** from launch; matching opens **London → Manchester → Birmingham → Brighton**, and seeding spend is focused on the next city to open, not spread across all four. Dublin opens with the Irish launch in P3. Adults elsewhere in the UK can register interest, and a new city opens when its sign-ups approach the density gate.

6. **Channels:** assume Meta and Google reject the ad account. Use podcast host-reads in adjacent verticals, ENM and relationship creators, technology-led PR (agent handshake, breach-proof architecture), and an editorial presence. Never synthetic personas or staff posing as members [B].
7. **Positioning:** "Discretion is the product." Never "cheat better."
8. **Organic search as the growth engine (v1.2).** Paid social is closed and paid CAC is fatal (§10.3), so search is the main scalable low-CAC channel alongside referrals. The Herald agent runs it:
    - **Dynamic content:** topic clusters on privacy, discretion, safety (Safe Meet, Clare's Law), ethical non-monogamy and couples, plus genuinely useful launch-city pages (no doorway pages). Pages are refreshed from search-performance data. Source B §11.2's "privacy-led content" channel is delivered here.
    - **Hyperlinks:** automated internal-link graph across the topic clusters (hub and spoke), with no orphan pages and descriptive anchors.
    - **Backlinks, earned and never bought:** digital PR on the technology story (agent handshake, breach-proof architecture, transparency reports); open-sourcing the audited crypto core; expert contributions; podcast and creator partnerships marked `rel="sponsored"` where paid; relationship and lifestyle publishers.
    - **Top ranking:** target top-3 positions for the priority keyword set in each launch market (e.g., "discreet dating app UK", "couples looking for a third", "ethical non-monogamy app"), tracked weekly. Rankings can be targeted and measured, never guaranteed.
    - **Never:** paid links, private blog networks, link exchanges, comment or forum spam, expired-domain or parasite-SEO abuse, cloaking, doorway pages, unreviewed mass AI content, or fake reviews. Each breaches search-engine spam policies and risks the domain, which is the channel the business depends on.

**Markets:** launch UK + IE · wave 2 NL, BE, DE, SE, DK, ES, PT · wave 3 CA, AU, NZ. The US is out of scope (E-16). Every market needs its own written legal opinion.

# 12. Roadmap, team, budget and phase gates

*Source: A §17*

| Phase | Window | Scope | Exit gate |
|---|---|---|---|
| **P0 Legal & foundation** | M0–M2 | SPV, counsel, DPIA, OSA assessments, PSP + backup MID, two age-assurance providers, threat model | **G-P0:** SPV incorporated · written counsel opinion · DPIA complete · OSA risk assessments drafted · high-risk PSP + backup MID approved · two assurance providers contracted · threat model signed off |
| **P1 Core MVP** | M2–M6 | Public web beta: open sign-up in four UK cities, matching live in London first; Loops A, B, D; E2EE; V2 gating; VC co-sign; Guardian baseline (on-device); deletion and DSR machinery; web PWA + native shells. **No Envoy** — this is the control cohort | **G-P1:** matching live in London with ≥ 2,000 verified; sign-up open in all four launch cities · erasure < 60 s p99 · no-go list (§13.2) clear |
| **P2 Differentiator** | M6–M10 | Envoy, Mirror v1, ExclusionRing PSI | **G-P2:** meets per intent sent up ≥ 40% vs the P1 control. If not met, **stop and rethink** |
| **P3 Public UK + IE** | M10–M15 | Full public launch, Dublin added; DUO + GHOST; native apps approved on both stores; 24/7 T&S | **G-P3:** 25,000 verified · payer rate ≥ 11% · both stores approved |
| **P4 EU wave 2** | M15–M24 | NL/BE/DE/SE/DK/ES/PT; per-market opinions; localised assurance and Guardian | **G-P4:** 150,000 verified · contribution-positive |

Source B's phase-level exit criteria are folded into the gates above and into the phase backlogs in 03 §12 and 04 §10.

**Team to P3 (17):**

- **Product & engineering (12):** Head of Product · Principal Engineer, security-led (**hire first**) · 2 Backend (Go) · iOS · Android · Web · 2 ML/Agents · Data Engineer · Security Engineer · Design.
- **Trust, legal & growth (5):** Head of Trust & Safety (**hire in P0**) · 2 T&S ops · DPO/Counsel (fractional until P2) · Growth/Community.

**24-month budget ≈ £5.9M:**

| Line | Amount |
|---|---|
| People | £3.4M |
| Legal, DPIA, counsel | £260k |
| Age assurance | £180k |
| Infra + inference | £420k |
| Security audits | £150k |
| Seeding & community | £480k |
| PSP reserves & fees | £220k |
| Contingency (15%) | £780k |

**Plus insurance of £85–140k a year at P3 scale** (§15.3), which is not in Source A's total. **Plus biometric login checks** (v1.2): an estimated £0.10–0.60 per mobile MAU per month, pending the vendor quote (03 §6.7).

# 13. KPIs, no-go conditions and risk register

## 13.1 North star and KPIs

*Source: A §18*

**QCAM — Quality Connections per Active Month:** confirmed meets with a positive aftercare score, per active member, per month. If a change raises engagement and lowers QCAM, it does not ship.

| Metric | P1 | P3 |
|---|---|---|
| QCAM | 0.18 | 0.45 |
| Meets per intent sent | 1.8% | 4.5% |
| Mutual reply rate | 22% | 34% |
| Inbound Gini (per city, per segment) | < 0.60 | < 0.55 |
| Gender ratio (per city) | ≤ 2.2:1 | ≤ 2.0:1 |
| S4 30-day retention | 45% | 62% |
| Report rate per 1k threads | < 12 | < 6 |

| Metric | P1 | P3 |
|---|---|---|
| V2 completion | 52% | 68% |
| Chargeback ratio | < 0.65% always (above 0.9% the MID is lost) | |
| Erasure latency | < 60 s p99 | |

Secondary (Source B): qualified reciprocal conversations per 1,000 verified weekly active members; exposure incidents; location-inference success in red-team tests; notification leakage; calibration and hard-boundary violations (target 0).

**Source B KPI dimensions** (verbatim in 07) are kept as the secondary dashboard set. Match quality, discretion, authenticity, safety, AI, commercial and reliability are each reported weekly from P1. B's north star (qualified reciprocal conversations per 1,000 verified weekly active members) is the leading indicator for QCAM. v1.2 adds emergency-lock latency (FR-064; target < 5 s p95) and login factor failures (FR-057/058) to reliability.

Growth/SEO (v1.2): organic sign-ups and organic CAC; share of priority keywords ranking top 3 and top 10; quality referring domains earned; marketing-site Core Web Vitals pass rate (NFR-20); spam-policy incidents (target 0).

## 13.2 No-go conditions

Do not launch or scale if any of these hold. Each is backed by an automated or audited test (03 §9). [B §14, A]

| ID | Condition |
|---|---|
| G-NG-1 | Private media can be accessed outside an active reveal grant |
| G-NG-2 | Deletion or erasure claims are not technically true (including the declared exceptions) |
| G-NG-3 | Exact location can be triangulated in red-team testing |
| G-NG-4 | Age assurance is not "highly effective" across all four Ofcom criteria, or any gated surface is reachable below V2 |
| G-NG-5 | A couple profile can represent an unverified person or be co-signed from one device |
| G-NG-6 | High-severity reports lack 24/7 response within published SLAs |
| G-NG-7 | Ranking violates any hard limit, exclusion zone or ExclusionRing pair |
| G-NG-8 | Any third-party analytics, advertising or attribution SDK is present in a client |
| G-NG-9 | Staff can read message content |
| G-NG-10 | Any login or recovery path issues a session with fewer factors than 02 §3.3 requires, or allows SMS/email/staff-assisted sign-in |

## 13.3 Risk register

| Risk | Severity | Mitigation |
|---|---|---|
| Breach (existential) | Critical | E2EE, identity split, cryptographic erasure, short TTLs, zero standing access, quarterly pen test, annual red team on A4/A7, rehearsed 72 h playbook |
| App-store rejection or removal (Apple 1.1.4) | High | Sanitised store build; explicit media web-only; matched-only messaging; web-first revenue |
| Merchant account loss | High | Backup MID from day one; alert at 0.5% chargebacks; Ethoca/Verifi; one-click cancel; pre-renewal notice; voucher path |
| Ofcom enforcement | High | Two assurance providers; inbox-level gating; documented assessments; named accountable manager; quarterly compliance review |
| Liquidity failure in month 4 | High | Density gate per city, opened in order (London first); balance waitlist; scarce side first; seeding focused on one city at a time (D-35) |
| Envoy does not move meets per intent | High | P1 control cohort; G-P2 at +40%; kill the thesis honestly |
| Agent seen as a bot / impersonation scandal | High | P4; labelled Briefs; publish the design |
| Harm incident attributed to the platform | High | T&S in P0; 24/7 from P3; published SLAs; Safe Meet; transparency reporting |
| CAC model unviable | High | §10.3 thresholds; referral loop; organic search; weekly tracking per city |
| Reputational contagion to parent group | Medium | Ring-fenced SPV, brand, counsel, cap table and PR |
| Feeld or Match Group ships an agent layer | Medium | Speed to P2; the moat is discretion architecture plus the aftercare dataset |
| Search penalty or deindexing of the marketing domain | Medium | White-hat only (D-21); human editorial approval; no bought links; monthly link-profile audit; marketing site on its own host, separate from the app |

| Risk | Severity | Mitigation |
|---|---|---|
| Two-factor biometric login hurts conversion or excludes disabled members | Medium | Fast provider flow (NFR-16); 30-day sessions; accessible alternative (D-17); measure login drop-off weekly |
| Guardian false positives on consensual kink | High | Trajectory-not-vocabulary design; matched-pair ship gate (03 §7) |

# 14. Compliance envelope

*This section gates the build. Everything here needs sign-off from UK counsel experienced in the OSA and Article 9; it says what to instruct counsel on, not what they will conclude. Statutory positions and commencement dates must be checked as at the date of use.* [A §14]

## 14.1 Online Safety Act 2023

TRYST is in scope as a user-to-user service. Ofcom treats dating services as posing a risk of significant harm to minors and published dating-specific guidance in May 2026.

Required before public launch:

- illegal-content and children's-access risk assessments;
- highly effective age assurance meeting all four criteria (accuracy, robustness, reliability, fairness), **applied to the inbox and media, not just sign-up**;
- clear terms, in-app reporting, rapid review and removal;
- controls mapped to Ofcom's named dating risks (romance fraud, intimate image abuse, sextortion, harassment, stalking, grooming);
- a named accountable senior manager.

Penalties reach the greater of £18M or 10% of global turnover, with possible criminal liability for senior managers.

## 14.2 UK GDPR / DPA 2018

- **Article 9 explicit consent** — granular, separate from the ToS, withdrawable, recorded in the consent ledger.
- **DPIA mandatory** — two triggers: large-scale special-category data and systematic evaluation.
- **Minimisation as architecture** — no legal name, exact DOB, ID images or coordinates.
- **Article 22** — human review path for suspensions.
- **DSR machinery from sprint one.**
- **Residency** — UK/EU only; no US sub-processor for Article 9 data without a TIA.
- **Article 6 lawful bases** (v1.2; counsel to confirm): contract, Art. 6(1)(b), for the core service; legitimate interests, 6(1)(f), for fraud and safety detection, with a documented LIA; legal obligation, 6(1)(c), for mandatory reporting and OSA duties. Each sits alongside the Article 9 condition for any special-category element (explicit consent, or DPA Sch. 1 for safeguarding and ban anchors).
- **Breach playbook** — 72 h, rehearsed twice a year.
- **Article 10 conviction data and the ban-anchor lawful basis** — DPA Sch. 1 Pt 2 para 18 assumed; counsel must confirm.

## 14.3 Distribution — two-surface strategy

- **Apple 1.1.4** rejects "hookup" apps that may include pornography or facilitate prostitution.
- **Google Play** requires minor-blocking for dating apps and restricts anonymous or random chat.

Native store builds are therefore **sanitised**: no nudity or explicit copy, matched-only messaging, 18+, "discreet dating" positioning. The **web PWA** carries the full product: explicit media behind V2, and all billing. Details: 04 §2.

## 14.4 Payments

- MCC 7273, high-risk; Visa Integrity Risk Program Tier 1 registration.
- **Stripe is the chosen payment processor (founder decision, v1.2; D-22)**: Stripe Checkout / Payment Element on the web, Stripe Billing for subscriptions, the Customer Portal for one-step cancellation, Radar for fraud screening, and Stripe Tax for VAT. **Condition:** Source A states that Stripe, Square and PayPal prohibit adult content, and TRYST's web surface carries explicit media behind V2. Before any build commitment, P0 must obtain **Stripe's written approval of TRYST's exact business model** (affair-positioned dating, couples, explicit media on web). A dedicated high-risk acquirer (3–7%) is contracted in parallel as the backup MID from day one, and becomes primary if Stripe declines or later restricts the account.

- **Spousal chargebacks** are the category-specific risk. Mitigations: neutral but truthful descriptor with a customer-service URL, offline voucher/gift-code path, pre-renewal email, one-click cancel, Ethoca/Verifi alerts, backup MID, correct MCC.
- **DMCC Act 2024 subscription regime:** commencement has moved repeatedly; build to the full regime now.

### 14.5 Jurisdiction gating and structure

- Hard geo-block at the edge and at sign-up for any market that criminalises adultery or same-sex conduct, or prohibits the category.
- Travel into a blocked market auto-locks the app to the decoy.
- Ring-fenced SPV with its own controller registration, brand, counsel, cap table and PR, and no public link to the parent group.

## 15. Liability, claims and insurance

*Source: A §19.8, §20*

### 15.1 Claims discipline

| Never say | Say |
|---|---|
| "Background checked", "Safe", "Vetted" | "Identity verified", "Age assured" |
| "No sex offenders on TRYST" | "We permanently remove and block re-registration where we find harmful conduct" |
| "Screened for domestic violence" | "We detect and act on coercive and abusive behaviour, and we'll show you how to use Clare's Law" |
| "Guaranteed real people" | "Every member completes liveness and ID verification" |
| Green "verified safe" tick | Factual, dated attestations only |

Overclaiming is a misleading commercial practice under CPUT and the DMCC Act, and the first thing a claimant's solicitor will point to.

### 15.2 Liability architecture

- **CRA 2015 s.65** bars excluding liability for death or personal injury caused by negligence (including mental impairment). Under s.65(2), agreeing to a term does not mean accepting a risk.
- **s.62** strikes unfair terms in full.

The draft ToS therefore uses narrow, honestly carved limits:

- correct characterisation of the service;
- an explicit list of what is and isn't verified;
- no liability for consequences to members' relationships;
- a financial cap of the greater of 12 months' fees or £100;
- a load-bearing "what we do not exclude" clause.

**Keep out:** death/injury exclusions, "use at your own risk", mandatory arbitration or class waivers, unilateral no-notice amendment, any screening implication, and forfeiting Keys before an appeal concludes.

The real protection is §8, not the clauses: liability will turn on whether TRYST took reasonable care. The ToS draft is 05.

### 15.3 Insurance and structure

Cover needed:

- cyber and data liability, sized for an Article 9 breach;
- tech E&O / professional indemnity;
- public and product liability;
- D&O (OSA named-manager exposure);
- media liability.

The SPV provides structural containment. Indicative premium at P3 scale is **£85–140k a year**.

# 02 — TRYST Shared Contracts v1.1

Part of the TRYST v1.1 baseline. This document is the **single source of truth** for everything both backend (03) and frontend (04) depend on. Change it first (00 §4).

## 1. Conventions

| Topic | Rule |
|---|---|
| Contract formats | Edge API: **OpenAPI 3.1** (`shared/contracts/openapi/`). Internal gRPC, the agent bus and events: **Protobuf** in the schema registry (`shared/contracts/proto/`). Generated client and server types; no hand-written DTOs (D-07). |
| IDs | UUIDv7, opaque, never sequential or enumerable. Prefixed in logs only (`usr_`, `prf_`, `thr_`). |
| Time | RFC 3339 UTC on the wire. Availability windows carry an IANA `tz`. |
| Money | Integer minor units + ISO 4217 (`{"amount": 2499, "currency": "GBP"}`). |
| Location | **Geohash-5 (~5 km) or coarser** on the wire and at rest. Exact coordinates are sent to the server **only** by the Panic flow (§5.8). |
| Age | Shown to members **in whole years**, from the verified birth **year and month** (`identity.birth_ym`, read from the ID document at V2). The full date of birth is never stored. `age_band` (`18-24` … `60+`) is kept for matching filters (D-37). |
| Free text | Everything a counterparty writes (bios, messages, agent turns) is **untrusted input**: schema-validated, never executed or interpreted as instructions. |
| Versioning | URL major version (`/v1`). Additive changes only within a major version. Enum additions are additive; clients must tolerate unknown values. |

## 2. Glossary and enumerations

### 2.1 Glossary

| Term | Definition |
|---|---|
| **Member** | A person with a TRYST account (one human, one account). |
| **Entity** | The matchable unit: a `solo` profile or a `couple` profile. |
| **Couple profile** | An entity linking two members, each verified to V2 and each co-signing from a distinct device (`VC`). |
| **Intent** | A costed outbound expression of interest from one entity to another. |
| **Mutual intent** | Both entities have sent an intent to each other. In P2+ it triggers a handshake. |
| **Handshake** | Envoy-to-Envoy negotiation over a fixed schema (§6). |
| **Brief** | The asymmetric, agent-generated summary each side receives after a handshake. Always labelled as machine-generated. |
| **Thread** | An E2EE conversation (MLS group) between the entities' members. Opens on double accept (P2+) or mutual intent (P1 control). |
| **Keys** | Prepaid credits. Spent on intents; refunded in full on reply. |
| **Discretion Policy** | A member's versioned privacy configuration, enforced on every read path (§6.4). |
| **Reveal grant** | A recipient-specific, expiring, revocable permission to view a media item or move up the reveal ladder. |
| **ExclusionRing** | A set of bidirectional, silent suppression pairs (PSI contacts, heuristics, manual). |
| **Exclusion Identifier / Ban anchor** | An irreversible one-way identifier kept after deletion for permanently removed members. The **declared exception** to erasure. |
| **Burn** | Discretion control: wipe local data, revoke device keys, sign out everywhere. |
| **Panic** | Safety control: escalate to emergency services with live location. **Never the same control as Burn.** |
| **QCAM** | Quality Connections per Active Month (north star; 01 §13). |

### 2.2 Segments

`segment ∈ {S1, S2, S3, S4, S5, S6}` — definitions in 01 §5.1. A solo entity is S1, S2, S4 or S6; a couple entity is S3 or S5.

### 2.3 Intent shapes and modes

| `intent_shape` (data) | Mode label (UI) | Entity pairs allowed |
|---|---|---|
| `one_off` | SPARK | solo↔solo |
| `recurring` | EMBER | solo↔solo |
| `ongoing` | EMBER | solo↔solo |
| `exploratory` | OPEN | any, subject to `seeking` |
| `third` | THIRD | couple(S3)↔solo(S4) |
| `couple` | QUAD | couple(S5)↔couple(S5) |

### 2.4 Other enumerations

| Enum | Values |
|---|---|
| `structure` | `attached_undisclosed`, `attached_disclosed`, `open_relationship`, `unattached`, `couple_seeking_third`, `couple_seeking_couple`, `prefer_not_to_say` |
| `visibility` | `public` (discoverable to eligible), `matched` (visible only to matches), `incognito` (discoverable only after own outbound intent) |
| `veto_mode` (couple) | `either` (either partner can decline), `both` (both must accept before an intent or decision counts) |
| `handshake_decision` | `pending`, `accept`, `decline`, `amend` |
| `intent_state` | `sent`, `queued_inbound_cap`, `delivered`, `replied`, `declined`, `expired`, `refunded` |
| `desire_tag_level` | `yes`, `curious`, `no` |
| `consent_kind` | `art9_processing`, `media_view`, `meet`, `couple_link`, `retention`, `conduct_attestation`, `safety_training_use`, `biometric_login` |
| `reveal_scope` | `alias`, `blurred_gallery`, `photo_set`, `voice`, `video` (the reveal ladder, in order) |
| `report_category` | `minor`, `ncii`, `sextortion`, `coercion`, `threat_violence`, `stalking`, `romance_fraud`, `commercial_sex`, `harassment`, `impersonation`, `protected_trait_harassment`, `exposure_threat`, `other` |
| `enforcement_action` | `warn`, `shadow_limit`, `suspend`, `permanent`, `law_enforcement_referral` |
| `unsafe_ground` | `g1_self_declared`, `g2_corroborated_reports`, `g3_court_order`, `g4_law_enforcement`, `g5_model_confirmed`, `g6_false_attestation` |
| `guardian_reason_code` | `m6a_coercive_control`, `m6b_boundary_violation`, `m6c_off_platform_pressure`, `m6d_identity_location_pressure`, `m6e_image_coercion`, `m7_authenticity`, `m7b_ban_evasion`, `payment_solicitation` |
| `tier` (commerce) | `verified_free`, `tryst_plus`, `envoy`, `duo`; add-on `ghost` |

## 3. Verification tiers and gates

### 3.1 Tiers

| Tier | Method | Retained | Source |
|---|---|---|---|
| **V0** | Email or phone OTP; device attestation | HMAC contact hash; device key | A §8.1 |
| **V1** | Liveness selfie with randomised challenge, matched to profile photos | Boolean + match score. **No biometric template.** | A §8.1, §19.3 |
| **V2** | Highly effective age assurance through a third-party provider (one of two, abstracted): photo-ID document (NFC chip read where the document has one) + liveness + face match to the document photo; over-18 decided by the provider and re-checked by TRYST (FR-094, D-39) | `is_adult` boolean + birth year-month + method + provider token + ban-anchor candidates (§4.1). **No ID image, no full DOB.** | A §8.1, §19.3 L1 |
| **V3** | Optional open banking or digital ID | Boolean + token | A §8.1 |
| **VC** | Couple verification: two different verified adults (distinct ID documents and faces), each co-signing from their own device, a live in-app photo of both together matched to each partner, in-person phone pairing, and reconfirmation every 90 days (FR-095, FR-096, D-40) | Link record, both profile IDs, device hashes, verified and confirmation dates | A §8.1 |

## 3.2 Capability gates (enforced server-side; mirrored in UI)

**Corrected in v1.1:** Source A's tier table let V1 send intents and open threads, which contradicted ToS cl. 5.1, Source B FR-001 and the OSA inbox requirement. V2 is now the gate for all interaction (E-01).

| Capability | V0 | V1 | V2 | V3 | Couple (VC) |
|---|---|---|---|---|---|
| Onboarding, Cartographer intake, discretion setup, waitlist | ✓ | ✓ | ✓ | ✓ | ✓ |
| See other members' profiles (slate) | — | — | ✓ | ✓ | ✓ |
| Send intents / receive deliveries | — | — | ✓ | ✓ | ✓ |
| Envoy handshake / Briefs | — | — | ✓ | ✓ | ✓ |
| Threads (E2EE) | — | — | ✓ | ✓ | ✓ |
| Media exchange; explicit media (web only) | — | — | ✓ | ✓ | ✓ |
| Meets, Safe Meet, Share My Plan | — | — | ✓ | ✓ | ✓ |
| Trust badge; set `min_counterparty_tier = V3` | — | — | — | ✓ | — |
| Publish couple profile | — | — | — | — | requires both partners at V2 + co-sign |

**Rules:**

- No other member's content is shown before V2, and none during the verification flow itself.
- `min_counterparty_tier` (default `V2`, option `V3`) is a Stage 0 hard gate in both directions.
- Re-verification triggers: a Guardian `minor` signal, a change of device plus a profile-photo change, a credible report, or a 12-month expiry.

## 3.3 Login assurance — account holder only

**v1.2, founder requirement (D-16).** Only the account holder can sign in. The rules depend on the surface:

| Surface | Factors required at every login | Both required? |
|---|---|---|
| **Native app** (iOS, Android) and **PWA on a mobile device** | **B1** device-bound biometric passkey **+ B2** liveness face match to the account holder | Yes — two biometric factors |
| **Desktop** (web browser or installed PWA on a computer) | **F1** passkey (platform authenticator with user verification, or FIDO2 security key) **+ F2** approval from the member's registered mobile device, which itself requires B1 (or a second registered FIDO2 security key) | Yes — two factors |

**Factor definitions:**

- **B1 — Device biometric passkey.** A WebAuthn/FIDO2 credential bound to the device's secure element. `userVerification = required` and must be satisfied by **biometrics only** for login:
  - iOS: `biometryCurrentSet`;
  - Android: `BIOMETRIC_STRONG`, key invalidated on biometric enrolment change;
  - mobile PWA: platform authenticator. The biometric never leaves the device. **If anyone adds or changes a fingerprint or face on the device, the credential is invalidated** and the member must log in again with B1 re-registration + B2 (FR-059). This defeats the partner who enrols their own fingerprint (A1).
- **B2 — Liveness face match.** A randomised challenge-response liveness check (ISO 30107-3 PAD Level 2 certified provider), matched 1:1 against the account holder's reference enrolled at V1. The reference is held by the provider under a deletion obligation, never by TRYST (D-18). Requires the explicit `biometric_login` consent.
- **F1 — Desktop passkey.** Windows Hello, Touch ID or a roaming FIDO2 key with PIN or biometric. Phishing-resistant, origin-bound.
- **F2 — Registered-device approval.** The desktop shows a QR code; the member scans it **in the TRYST app** on a registered mobile device and approves with B1. No push notification is sent, so nothing appears on a lock screen. Alternative: a second registered FIDO2 security key.

**Never accepted as a login factor:** passwords (TRYST has none), SMS or email OTP, magic links, security questions, or support-desk overrides. Contact OTP is used **only** at sign-up to prove ownership of the contact handle (V0).

**Login vs unlock:**

- **Login** creates a session on a device: first use on a device, after sign-out or Burn, after session expiry, after a biometric-enrolment change, or on a risk step-up.

- **Unlock** reopens the app within a live session: device biometric (or the duress PIN, which opens the decoy) per FR-027.

| Session rule | Mobile (app / PWA) | Desktop |
|---|---|---|
| Maximum session | 30 days | 12 hours |
| Idle lock | 2 min default (member-adjustable 1–15) | 15 min → full re-login |
| Token binding | DPoP to the device key | DPoP to a non-extractable WebCrypto key |

**Step-up** (repeat both factors for the surface, valid 5 min) is required to:

- add or revoke a device;
- broaden the Discretion Policy;
- change contact handle or payment method;
- co-sign or change a couple link or veto mode;
- export data;
- view the device list.

(Account recovery is the path for a member with **no** working device, so it can't need step-up; it has its own checks and hold below, D-62.)

It is **never** required for Burn, Panic, report, block, subscription cancel or account deletion. Deletion requires B1 only, so it stays one step (ToS cl. 16.3, 25.1).

**Before V1:** a V0 member has no B2 reference, so they can only continue onboarding on the device they signed up on. Login on any other device is unavailable until V1 is complete.

**Downgrade resistance:** the server decides the surface from attestation (native) and from the registered authenticator's properties. It does not trust a client claim. The desktop path still requires a second, separately registered authenticator, so claiming "desktop" from a phone gains nothing.

**Account recovery** (lost or replaced device, FR-061):

1. B2 liveness match.
2. Fresh V2 age assurance with an ID match, whose document anchor must equal the account's stored `anchor_doc` (same document).
3. A 24-hour hold, cancellable from any still-registered device.
4. New passkey registration.

No staff member can bypass recovery.

As built (FR-125, D-62): `begin` answers the same for any contact (an unknown one gets a recovery that can never complete) and is limited to 3 a day per contact. The member is told when recovery starts and again when the hold begins. A document that doesn't match ends the attempt. Checks must finish within 24 hours of `begin`; the hold is 24 hours; `finish` must follow within 7 days. `finish` revokes every passkey and session and issues a 15-minute recovery session that can only register a passkey. Only V2 accounts (with a document code) can be recovered. Recovery never changes the tier.

# 4. Data model

Three isolated PostgreSQL 16 clusters with separate credentials and separate KMS domains. **No plaintext join between identity and profile.** The join key is `HMAC(identity_id, HSM pepper_join)`, computed only inside the identity service. [A §9.2, §10]

## 4.1 IDENTITY-DB

```
CREATE TABLE identity (
  identity_id      UUID PRIMARY KEY,
  contact_hash     BYTEA UNIQUE NOT NULL,   -- HMAC(phone|email, HSM pepper_contact)
  contact_ct       BYTEA,                   -- encrypted under root key; for OTP/notices only
  age_assured      BOOLEAN NOT NULL DEFAULT FALSE,
  assurance_tier   TEXT CHECK (assurance_tier IN ('V0','V1','V2','V3')),
  assurance_token  TEXT,                    -- provider ref. NO ID image, NO full DOB
  assurance_method TEXT CHECK (assurance_method IN ('id_document_nfc','id_document','id_document_assisted')),
  birth_ym         CHAR(7) CHECK (birth_ym ~ '^[0-9]{4}-(0[1-9]|1[0-2])$'), -- from the ID document; day never
stored (D-37)
  assurance_at     TIMESTAMPTZ,
  billing_ref      TEXT,                    -- PSP token. No PAN, ever
  jurisdiction     CHAR(2) NOT NULL,
  root_key_ref     TEXT NOT NULL,           -- KMS handle; destroy = erasure
  created_at       TIMESTAMPTZ DEFAULT now(),
  deleted_at       TIMESTAMPTZ
);

-- v1.1 addition (E-02): ban anchors can only be written at ban time if candidates exist.
-- Candidates are erased with the account unless a permanent ban copies them to BAN-DB.
CREATE TABLE anchor_candidate (
  identity_id      UUID PRIMARY KEY REFERENCES identity,
  anchor_doc       BYTEA NOT NULL,          -- HMAC(doc_number, HSM pepper_ban)
  anchor_device    BYTEA[] NOT NULL,        -- HMAC(attestation_id, pepper_ban)
  anchor_payment   BYTEA,                   -- HMAC(psp_instrument_token, pepper_ban)
  created_at       TIMESTAMPTZ DEFAULT now()
);

CREATE TABLE device (
  device_id        UUID PRIMARY KEY,
  identity_id      UUID NOT NULL REFERENCES identity,
  device_pubkey    BYTEA NOT NULL,          -- DPoP + MLS credential binding
  device_hash      BYTEA NOT NULL,          -- HMAC(attestation_id, pepper_device)
  platform         TEXT CHECK (platform IN ('ios','android','web')),
  surface          TEXT CHECK (surface IN ('mobile_app','mobile_pwa','desktop')), -- v1.2
  revoked_at       TIMESTAMPTZ
);

-- v1.2 addition (D-16): login authenticators. No biometric data is stored by TRYST.
CREATE TABLE authenticator (
  credential_id    BYTEA PRIMARY KEY,       -- WebAuthn credential id
  identity_id      UUID NOT NULL REFERENCES identity,
  device_id        UUID REFERENCES device,  -- NULL for roaming security keys
  public_key       BYTEA NOT NULL,
  aaguid           UUID,
  kind             TEXT CHECK (kind IN ('platform_biometric','platform_uv','roaming_key')),
  bio_enrolment_bound BOOLEAN NOT NULL,     -- invalidated on biometric enrolment change
  sign_count       BIGINT DEFAULT 0,
  created_at       TIMESTAMPTZ DEFAULT now(),
  revoked_at       TIMESTAMPTZ
);

CREATE TABLE login_reference (              -- pointer to the provider-held B2 face reference
  identity_id      UUID PRIMARY KEY REFERENCES identity,
  provider         TEXT NOT NULL,
  reference_token  TEXT NOT NULL,           -- provider ref only; deleted at provider on erasure
  enrolled_at      TIMESTAMPTZ NOT NULL
);

CREATE TABLE auth_event (                   -- 90-day retention, IP truncated (NFR-11)
  event_id UUID PRIMARY KEY, identity_id UUID, device_id UUID,
  kind TEXT,                                -- login_ok|login_fail|step_up|recovery_*|bio_change
  factors TEXT[], surface TEXT, created_at TIMESTAMPTZ DEFAULT now()
);
```

### 4.2 BAN-DB (separate store, separate key domain; survives erasure)

```
CREATE TABLE ban_anchor (
  anchor_id        UUID PRIMARY KEY,
  anchor_doc       BYTEA, anchor_device BYTEA[], anchor_payment BYTEA,
  anchor_biometric BYTEA,                    -- NULL unless counsel confirms lawful basis (D-08)
  reason_code      TEXT NOT NULL,            -- unsafe_ground enum; NOT free text, NOT evidence
  tier             TEXT CHECK (tier IN ('permanent','law_enforcement_referred')),
  reviewed_by      TEXT NOT NULL,            -- staff id; always a human decision
  created_at       TIMESTAMPTZ DEFAULT now(),
  expires_at       TIMESTAMPTZ,              -- NULL for permanent; destroyed on successful appeal
  consortium_share BOOLEAN DEFAULT FALSE     -- L5, gated on opinion (Q8)
);
```

## 4.3 PROFILE-DB

```
CREATE TABLE profile (
  profile_id       UUID PRIMARY KEY,
  segment          TEXT CHECK (segment IN ('S1','S2','S3','S4','S5','S6')),
  entity_type      TEXT CHECK (entity_type IN ('solo','couple')),
  display_name     TEXT,                    -- pseudonym; real name never required
  pronouns         TEXT,
  gender_identity  TEXT,                    -- free text, not enum
  seeking          TEXT[],
  modes            TEXT[],                  -- intent_shape values enabled
  age_band         TEXT,
  age_years        SMALLINT CHECK (age_years >= 18), -- shown to members; refreshed monthly from identity.birth_ym
  area_label_mode  TEXT DEFAULT 'district' CHECK (area_label_mode IN ('district','city')),
  city_geohash5    TEXT,
  bio_ct           BYTEA,
  visibility       TEXT CHECK (visibility IN ('public','matched','incognito')),
  status           TEXT DEFAULT 'active',   -- active|paused|vanished|suspended|deleted
  version          INT NOT NULL DEFAULT 1,  -- couple profiles publish a version both approved
  created_at       TIMESTAMPTZ DEFAULT now()
);

CREATE TABLE couple_invite (                -- v1.1 addition (E-23)
  invite_id        UUID PRIMARY KEY,
  inviter_profile  UUID NOT NULL REFERENCES profile,
  token_hash       BYTEA NOT NULL,
  inviter_device_hash BYTEA NOT NULL,
  expires_at       TIMESTAMPTZ NOT NULL,    -- 24h
  consumed_at      TIMESTAMPTZ
);

CREATE TABLE couple_link (
  couple_id        UUID PRIMARY KEY,
  couple_profile   UUID NOT NULL REFERENCES profile, -- the entity_type='couple' profile
  profile_a        UUID NOT NULL REFERENCES profile,
  profile_b        UUID NOT NULL REFERENCES profile,
  a_cosigned_at    TIMESTAMPTZ NOT NULL,
  b_cosigned_at    TIMESTAMPTZ NOT NULL,
  a_device_hash    BYTEA NOT NULL,
  b_device_hash    BYTEA NOT NULL,
  approved_version INT NOT NULL,            -- profile version both approved (B FR-005)
  veto_mode        TEXT DEFAULT 'either' CHECK (veto_mode IN ('either','both')),
  verified_at      TIMESTAMPTZ,              -- couple verification passed (FR-095)
  a_confirmed_at   TIMESTAMPTZ,              -- 90-day reconfirmation (FR-096)
  b_confirmed_at   TIMESTAMPTZ,
  dissolved_at     TIMESTAMPTZ,
  CONSTRAINT distinct_devices CHECK (a_device_hash <> b_device_hash),
  CONSTRAINT distinct_members CHECK (profile_a <> profile_b)
);

CREATE TABLE intent_vector (
  profile_id       UUID PRIMARY KEY REFERENCES profile,
  intent_shape     TEXT[],
  structure        TEXT,
  desire_tags      JSONB,                   -- {tag: yes|curious|no}; ~140 tags
  hard_limits      TEXT[] NOT NULL,         -- NEVER overridable
  discretion       JSONB,                   -- windows, device risk (zones live in discretion_policy)
  logistics        JSONB,                   -- radius_km, hosting, notice_hours, venue_budget_band
  min_counterparty_tier TEXT DEFAULT 'V2',  -- v1.1: V2 floor (E-01)
  embedding        VECTOR(128),
  private_fields   TEXT[],                  -- computable, never emitted by Envoy
  confirmed_at     TIMESTAMPTZ,             -- member confirmed structured output
  updated_at       TIMESTAMPTZ
);

CREATE TABLE revealed_preference (
  profile_id       UUID PRIMARY KEY REFERENCES profile,
  embedding        VECTOR(256),
  alpha            REAL CHECK (alpha BETWEEN 0.15 AND 0.85),
  divergence       REAL, confidence REAL, n_signals INT,
  personalisation_enabled BOOLEAN DEFAULT TRUE,
  computed_at      TIMESTAMPTZ
);

CREATE TABLE discretion_policy (            -- v1.1 addition from Source B (FR-004)
  profile_id       UUID REFERENCES profile,
  version          INT,
```

```
  policy_ct        BYTEA NOT NULL,          -- §6.4 schema, encrypted
  zones_geohash    TEXT[],                  -- home/work exclusion cells (geohash-6), encrypted column
  created_at       TIMESTAMPTZ DEFAULT now(),
  PRIMARY KEY (profile_id, version)
);

CREATE TABLE media (
  media_id         UUID PRIMARY KEY,
  owner_profile    UUID REFERENCES profile,
  object_key       TEXT NOT NULL,           -- client-encrypted ciphertext
  tier             TEXT CHECK (tier IN ('profile_public','profile_private','thread')),
  explicit         BOOLEAN DEFAULT FALSE,   -- web surface only, V2 only
  is_main          BOOLEAN NOT NULL DEFAULT FALSE, -- the main photo: face-matched, always shown (FR-092)
  position         SMALLINT CHECK (position BETWEEN 1 AND 10), -- gallery order; at most 10 photos
  revealed         BOOLEAN NOT NULL DEFAULT TRUE,  -- false = blurred until a reveal grant
  provenance       TEXT,                    -- c2pa_capture | none | (rejected uploads are never stored)
  moderation_state TEXT DEFAULT 'pending',
  expires_at       TIMESTAMPTZ,             -- thread media: 7d default
  created_at       TIMESTAMPTZ DEFAULT now()
);

CREATE UNIQUE INDEX media_one_main ON media (owner_profile) WHERE is_main AND tier = 'profile_public';
CREATE UNIQUE INDEX media_position ON media (owner_profile, position) WHERE tier IN
('profile_public','profile_private');
ALTER TABLE media ADD CONSTRAINT main_is_shown CHECK (NOT is_main OR (revealed AND NOT explicit));

CREATE TABLE reveal_grant (
  grant_id         UUID PRIMARY KEY,
  owner_profile    UUID, recipient_profile UUID,
  scope            TEXT,                    -- reveal_scope enum
  media_id         UUID,                    -- NULL for voice/video scope
  owner_version    INT,
  wrapped_key_ref  TEXT,                    -- destroyed on revoke
  expires_at       TIMESTAMPTZ, revoked_at TIMESTAMPTZ,
  created_at       TIMESTAMPTZ DEFAULT now()
);

CREATE TABLE slate_item (                   -- "Introduction" in Source B
  slate_id         UUID, profile_id UUID, candidate_id UUID,
  score            REAL, model_version TEXT,
  explanation_codes TEXT[],                 -- 2–4 non-sensitive codes
  exploration      BOOLEAN, paid_label BOOLEAN,
  created_at       TIMESTAMPTZ,
  PRIMARY KEY (slate_id, candidate_id)
);

CREATE TABLE intent (
  intent_id        UUID PRIMARY KEY,
  from_profile     UUID, to_profile UUID,
  keys_spent       INT NOT NULL DEFAULT 0,
  via_envoy_proposal UUID,                  -- ENVOY tier; always human-approved (D-04)
  state            TEXT NOT NULL,           -- intent_state enum
  created_at       TIMESTAMPTZ, delivered_at TIMESTAMPTZ
);

CREATE TABLE handshake (
  handshake_id     UUID PRIMARY KEY,
  a_profile UUID, b_profile UUID,
  transcript_ct    BYTEA,                   -- encrypted agent turns, 30d TTL
  brief_a_ct BYTEA, brief_b_ct BYTEA,
  compatibility REAL, meet_probability REAL,
  a_decision TEXT, b_decision TEXT,         -- handshake_decision
  opened_thread    UUID,                    -- non-null ONLY on double accept
  created_at       TIMESTAMPTZ
);

CREATE TABLE thread (
  thread_id        UUID PRIMARY KEY,
  handshake_id     UUID,                    -- NULL in P1 control cohort
  mls_group_id     BYTEA NOT NULL,
  participant_profiles UUID[] NOT NULL,
  retention_days   INT DEFAULT 30 CHECK (retention_days IN (7,30,90)),
  safety_state     TEXT DEFAULT 'normal',   -- normal|frozen|closed
  burned_at        TIMESTAMPTZ,
  created_at       TIMESTAMPTZ
);

CREATE TABLE message_envelope (             -- ciphertext only; server cannot decrypt
```

```
  thread_id UUID, seq BIGINT, sender_device UUID,
  ciphertext BYTEA NOT NULL, expires_at TIMESTAMPTZ NOT NULL,
  PRIMARY KEY (thread_id, seq)
);

CREATE TABLE meet (
  meet_id UUID PRIMARY KEY, thread_id UUID,
  state TEXT,                              -- proposed|confirmed|cancelled|occurred
  window_start TIMESTAMPTZ, checkin_due_at TIMESTAMPTZ,
  aftercare_due_at TIMESTAMPTZ             -- +48h
);

CREATE TABLE exclusion_ring (
  profile_id UUID, excluded_profile_id UUID,
  source TEXT,                             -- psi_contact|device_graph|manual|payment|geo|wifi
  confidence REAL,
  PRIMARY KEY (profile_id, excluded_profile_id)
);  -- ALWAYS bidirectional, ALWAYS silent

CREATE TABLE consent_ledger (
  consent_id UUID PRIMARY KEY, profile_id UUID NOT NULL,
  kind TEXT NOT NULL,                      -- consent_kind enum
  granted BOOLEAN NOT NULL, scope JSONB,
  prev_hash BYTEA, entry_hash BYTEA NOT NULL, -- hash chain; append-only
  created_at TIMESTAMPTZ DEFAULT now()
);

CREATE TABLE aftercare (
  meet_id UUID PRIMARY KEY, reporter UUID, counterparty UUID,
  occurred BOOLEAN, as_represented SMALLINT, would_repeat BOOLEAN, safety_flag BOOLEAN,
  created_at TIMESTAMPTZ
);  -- NEVER surfaced to counterparty. NEVER a public rating.
```

## 4.4 SAFETY-DB (T&S; access only through the trust console)

```
CREATE TABLE guardian_signal (             -- scores and reason codes only; no content
  signal_id UUID PRIMARY KEY, thread_id UUID, subject_profile UUID,
  model_id TEXT, model_version TEXT, score REAL, reason_code TEXT,
  source TEXT CHECK (source IN ('on_device','server_profile','server_graph')),
  created_at TIMESTAMPTZ
);
CREATE TABLE report_case (
  case_id UUID PRIMARY KEY, reporter_pseudo BYTEA, subject_profile UUID,
  category TEXT, severity SMALLINT, disclosed_content_ref TEXT, -- reporter-disclosed only
  training_consent BOOLEAN DEFAULT FALSE,   -- D4 source; never a condition of action
  state TEXT, sla_due_at TIMESTAMPTZ, legal_hold BOOLEAN DEFAULT FALSE,
  created_at TIMESTAMPTZ
);
CREATE TABLE enforcement (
  enforcement_id UUID PRIMARY KEY, subject_profile UUID,
  action TEXT, ground TEXT, reason_code TEXT,
  decided_by TEXT,                         -- REQUIRED for permanent (human)
  appeal_state TEXT, appeal_reviewer TEXT, created_at TIMESTAMPTZ
);
CREATE TABLE staff_access_log (            -- immutable (WORM)
  entry_id UUID PRIMARY KEY, staff_id TEXT, approver_id TEXT,
  resource TEXT, reason_code TEXT, created_at TIMESTAMPTZ
);
```

## 4.5 Commerce and operations (PROFILE-DB schema `commerce`, `ops`)

```
CREATE TABLE commerce.entitlement (profile_id UUID, tier TEXT, addon_ghost BOOLEAN,
  status TEXT, source TEXT CHECK (source IN ('web','voucher','app_store','play')),
  renews_at TIMESTAMPTZ, renewal_notice_sent_at TIMESTAMPTZ, PRIMARY KEY (profile_id));
CREATE TABLE commerce.keys_ledger (entry_id UUID PRIMARY KEY, profile_id UUID,
  delta INT, reason TEXT, intent_id UUID, balance_after INT, created_at TIMESTAMPTZ);
CREATE TABLE commerce.deposit (profile_id UUID PRIMARY KEY, amount_minor INT,
  state TEXT, credited_keys INT, created_at TIMESTAMPTZ);
CREATE TABLE ops.deletion_job (job_id UUID PRIMARY KEY, subject_ref BYTEA,
  systems TEXT[], started_at TIMESTAMPTZ, completed_at TIMESTAMPTZ,
  completion_proof BYTEA);                 -- signed record of key destruction + purges
```

# 5. Edge API contract (v1)

**Cross-cutting middleware, in order:**

1. TLS 1.3
2. OAuth2 access token **DPoP-bound** to the device key
3. Jurisdiction gate
4. Tier gate (§3.2)
5. Article 9 consent check
6. Per-endpoint rate limit
7. Idempotency (`Idempotency-Key` header required on all POST/PUT/DELETE)

The **Min** column is the minimum verification tier. `sys` means server-to-server only.

## 5.1 Auth, devices, assurance

| Method | Path | Min | Contract |
|---|---|---|---|
| POST | `/v1/auth/start` | — | **Sign-up only.** `{contact}` → OTP sent. Uniform response whether or not the account exists. **Never a login factor** (§3.3) |
| POST | `/v1/auth/verify` | — | **Sign-up only.** `{contact, otp, jurisdiction?}` → onboarding session (device binding via DPoP is a P1 hardening item, D-24). Refused with `account_exists_sign_in` if the account already has a passkey: an OTP can never add one. Ban-anchor check runs here for new identities (03 §8) |
| POST | `/v1/auth/passkeys/register` (`begin` / `finish`) | V0 | Register B1 (mobile) or F1 (desktop) WebAuthn credential; step-up required after the first one |
| POST | `/v1/auth/login/begin` | — | `{contact_hint?}` → WebAuthn challenge + `required_factors` (decided by the server, §3.3). Uniform response |
| POST | `/v1/auth/login/passkey` | — | WebAuthn assertion (B1 or F1) → `login_state = factor1_ok` (no session yet) |
| POST | `/v1/auth/login/liveness` | — | Mobile: start B2 provider session → provider callback (`sys`) → **session issued only on match** |
| POST | `/v1/auth/login/cross-device` | — | Desktop: → QR token (60 s); `GET .../{id}` polls status → **session issued only on approval** |
| POST | `/v1/auth/approvals/{qr_token}` | V1 | Called from the registered mobile app with a fresh B1 assertion; approves or denies the desktop login |
| POST | `/v1/auth/step-up` | V0 | Same factor flow as login (`/login/passkey`, then the second factor) bound to the caller's session and account; finishing marks **this session** stepped up for 5 minutes (`{step_up, until}`) instead of issuing a new one. A passkey of another account fails |
| POST | `/v1/auth/enrol-device` · `/v1/auth/enrol-device/redeem` | V0 (onboarding) | During onboarding only: one-time 10-minute link that lets the member's phone register its own passkey on the same account. Refused once the account is sealed (device add then needs step-up) |
| POST | `/v1/auth/login/second-key/begin` · `/v1/auth/login/second-key` | — | Desktop F2 alternative: assertion with a **different** registered security key |
| POST | `/v1/auth/approvals/{qr_token}/begin` | — | Assertion options restricted to the account's registered **phone** passkeys |
| GET | `/v1/me` | V0 | Session summary (kind, surface, tier, passkey count, `step_up`, `recovery_pending`). No contact or identity data |
| POST | `/v1/auth/logout` | V0 | Ends this session |
| POST | `/v1/auth/recovery/begin` | — | `{contact}` → 202 `{recovery_id}`, uniform for any contact; 3 a day per contact (FR-061, FR-125) |
| GET | `/v1/auth/recovery/{id}` | — | `{state: checks\|hold\|ready\|failed\|cancelled\|expired\|done, liveness_done, id_done, hold_until?}` |
| POST | `/v1/auth/recovery/{id}/check` | — | `{kind: liveness\|age}` → provider hand-off; `age` needs liveness first; the document must match `anchor_doc` |

| Method | Path | Min | Contract |
|---|---|---|---|
| POST | `/v1/auth/recovery/{id}/finish` | — | After the hold: revoke every passkey and session → 15-minute recovery session that may only register a passkey. 409 `recovery_hold` during the hold |
| POST | `/v1/auth/recovery/cancel` | V0 | Any signed-in device cancels every open recovery of the account. Never needs step-up |
| POST | `/v1/auth/refresh` | V0 | DPoP refresh |
| GET / DELETE | `/v1/auth/devices` · `/v1/auth/devices/{id}` | V0 | List and revoke passkeys (**step-up required**, §3.3). The only active passkey can't be revoked (409 `last_device`); use Burn. (`/v1/devices/*` is the E2EE device-key directory) |
| POST | `/v1/assurance/session` | V0 | `{kind: liveness\|age}` → `{session_id, url}` (provider hand-off). age needs V1. 503 while no provider holds a valid certificate for web capture (G-NG-4) (FR-124, D-61) |
| POST | `/v1/assurance/callback` | sys | Signed provider result → liveness pass raises to V1; ID pass + conduct declaration raises to V2. TRYST re-checks over-18 itself (FR-094); under-18 → account refused and signed out everywhere. The document number becomes a one-way code at once (one account per document; banned documents refused; recovery must match it). Raw document and biometric never stored. Applied once per session |
| GET | `/v1/assurance/status` | V0 | `{tier, liveness_done, conduct_accepted, id_checked, age_check, refused}` |
| POST | `/v1/attestations/conduct` | V0 | `{version, accept: true}`. Conduct declaration (ToS cl. 3.5) → consent ledger. Required to complete V2 |

## 5.2 Account, consent, data rights

| Method | Path | Min | Contract |
|---|---|---|---|
| GET / POST | `/v1/consents` | V0 | Read the ledger (`entries`, `current`, `chain_ok`); append a grant or withdrawal (never mutate). Members set `art9_processing`, `biometric_login` and `safety_training_use` here; the conduct declaration is recorded by `/v1/attestations/conduct`. Discovery (Tonight) needs `art9_processing` (403 `consent_required` + `consent_kind`); withdrawing it removes the member from discovery at once. The face check needs `biometric_login` (FR-126, D-63) |
| POST | `/v1/account/pause` | V0 | Removed from discovery immediately; conversations carry on |
| POST | `/v1/emergency-lock` | — | **No session needed.** `{contact, code}` → end every session, refuse sign-in, hide the profile and stop its photos being served (FR-064). Uniform 202; 5 a day per contact; the code (shown once at sign-up) is single-use and reissued by recovery, which is the only way to unlock (FR-127, D-64) |
| POST | `/v1/auth/emergency-code` | V0 | New emergency code (**step-up**) |
| POST | `/v1/account/vanish` | V0 | Hidden + threads closed; account kept |
| POST | `/v1/account/resume` | V0 | Back into discovery after pause or vanish (**step-up**) |
| POST | `/v1/account/export` | V0 | SAR/portability export, built on request (target < 24 h met immediately) and returned as a download over the signed-in session; no copy is kept on the server. Every service contributes its own part; messages are E2EE, so only their metadata is included; the contact is held only as a keyed hash and can't be shown back (FR-118) |
| DELETE | `/v1/account` | V0 | `{confirm: "delete my account"}`. Cryptographic erasure, **< 60 s p99**: data key destroyed first, out of discovery, then each service purges; identity last. Returns `deletion_job_id` and the signed `completion_proof` (Ed25519; names the member only by a one-way code; lists what each service erased and any declared exception kept). An interrupted erasure returns 202 and is finished by a sweep |
| GET | `/v1/deletion-proofs/{id}` · `/v1/deletion-proofs/key` | none | Fetch a proof; the verification key |
| GET / POST | `/v1/notices` · `/v1/notices/read` | V0 | Masked in-app inbox (newest first, last 100, unread count): what happened, never who (FR-119) |
| GET / PUT | `/v1/notifications/settings` | V0 | `{push, text}`. Push off by default; `text` ≤ 40 chars, no links, never "TRYST" (default "You have an update") (FR-026). Turning push off forgets every endpoint |

| Method | Path | Min | Contract |
|---|---|---|---|
| PUT / DELETE | `/v1/notifications/push` | V0 | `{endpoint}` of this device's Web Push subscription; browser push services only (no other host is ever called); ≤ 5 devices. Pushes are **empty** (no payload) and VAPID-signed; at most one per 2 minutes |

## 5.3 Intake, profile, discretion

| Method | Path | Min | Contract |
|---|---|---|---|
| POST | `/v1/intake/turn` | V0 | Cartographer conversational turn (**P2**; P1 intake is structured choices, D-65) |
| GET | `/v1/intake/vector` | V0 | The confirmed vector (`identity`, `seeking`, `intent_shape`, `hard_limits`, `interests`), its version count and the controlled vocabularies |
| POST | `/v1/intake/vector/confirm` | V0 | Member confirms every field; stored with `confirmed_at` as a new version (FR-079). A hard limit can't also be a wanted shape |
| GET / PUT | `/v1/profile` | V0 | Owner view and pseudonymous fields only: display name (screened, FR-098), area chosen from `/v1/profile/areas` (never GPS), city-only option. The owner view lists what still blocks publication |
| GET | `/v1/profile/areas` | V0 | Selectable launch-city areas; the profile stores only the area's geohash-5 cell |
| GET | `/v1/profile/card` | V0 | The member's card exactly as another verified member sees it (FR-092) |
| POST | `/v1/profile/photos` | V0 | Public-tier profile photo, multipart, JPEG/PNG ≤ 8 MB. Location stripped on device; provenance, vendor checks and FR-093 rules on the server; refused photos are never stored; accepted photos are re-encoded (all metadata dropped); at most 10. Uploading is allowed before V1 because the V1 face check is matched against these photos; nothing is visible to others below V2 |
| GET / PATCH / DELETE | `/v1/profile/photos/{id}` | V0 | Owner image · show or blur (`revealed`; the main photo can't be blurred) · delete |
| POST | `/v1/profile/photos/{id}/main` | V0 | Make main; only photos that passed the main-photo rules |
| PUT | `/v1/profile/photos/order` | V0 | Gallery order; the main photo stays first |
| POST / DELETE | `/v1/profile/media` · `/{id}` | V1 | **Private-tier** media: client-encrypted blob + wrapped keys (public-tier photos use `/v1/profile/photos`; moderation per 03 §7.5) |
| GET | `/v1/discretion` | V0 | `{status, policy, versions, shield}` |
| PUT | `/v1/discretion/policy` | V0 | New version (§6.4) of `{visibility: visible\|incognito, max_distance_km, min_counterparty_tier}`. **A change that broadens exposure needs a fresh step-up** (403 `step_up_required`); tightening never does. Incognito: shown only to people the member has shown interest in. The tier floor applies both ways |
| PUT | `/v1/discretion/zones` | V0 | Up to 4 hidden areas (area IDs). The member and people in those areas don't see each other, both ways; removing one needs step-up. Areas stand in for home/work geofences while discovery uses chosen areas, not live location (D-64) |
| POST / DELETE | `/v1/discretion/shield` | V0 | Partner shield (FR-106): add device-made SHA-256 digests of contacts (the server keys them at once); clear needs step-up. A match hides both members from each other, silently |
| POST | `/v1/exclusion/psi/blind` | V2 | OPRF round 1 |
| POST | `/v1/exclusion/psi/commit` | V2 | OPRF round 2 → suppression written. **Nothing returned about the intersection** |
| POST | `/v1/burn` | V0 | **Renamed from `/v1/panic` (E-21).** Revoke device keys, sign out everywhere; the client wipes local data |

## 5.4 Couples

| Method | Path | Min | Contract |
|---|---|---|---|
| GET | `/v1/couple` | V0 | The caller's link: partner's display name, veto mode, pending changes, reconfirmation due |
| POST | `/v1/couple/invite` | V2 | `{device_id}` → co-sign token (24 h). Needs a confirmed intake |
| GET | `/v1/couple/invite-preview?token=` | V2 | What the invitee approves: the inviter's name and exact intake version |

| Method | Path | Min | Contract |
|---|---|---|---|
| POST | `/v1/couple/cosign` | V2 | `{token, device_id, approved_version}`. **Must come from a device whose hash differs from the inviter's** (409 `same_device_cosign`). Both partners must approve the exact version (409 `version_changed`) |
| PUT | `/v1/couple/{id}/veto-mode` | V2 | `either\|both`; takes effect only when both partners have asked for the same mode |
| POST | `/v1/couple/{id}/reconfirm` | V2 | Every 90 days each partner reconfirms; 14 days after it's due the couple leaves introductions until both have (FR-096) |
| DELETE | `/v1/couple/{id}` | V2 | Either partner dissolves immediately; the other is told only that it ended |

## 5.5 Discovery and learning

| Method | Path | Min | Contract |
|---|---|---|---|
| GET | `/v1/slate` | V2 | Up to 18 cards incl. 15% exploration (a stable daily draw from below the cut); each with `explanation_codes` (2–4), `paid_label` (always false) and a per-viewer `handle`. Stage 0 first: both want each other's group, no hard limit crossed, blocks, discretion, partner shield, hidden areas, tier floors, Article 9 consent, same city within both distances, couple partners never paired; then the weighted baseline (intent 0.4, interests 0.3, distance 0.2, verification parity 0.1). Re-authorised on every read |
| GET | `/v1/slate/photos/{handle}/{n}` | V2 | The n-th photo the viewer may see (blurred never served) |
| POST | `/v1/intent` | V2 | `{target: handle}` → `202 {intent_id, state: sent\|mutual, handshake?}`. 3 free a week; unlimited on TRYST+, DUO or ENVOY; otherwise Keys held (5, or 15 couple→single), refunded on reply (402 `keys_insufficient`). Inbound cap 12 a day: overflow is queued and released later; the sender always sees `sent`, and never sees a decline |
| GET | `/v1/intents` | V2 | `{inbound, outbound, handshakes, free_left, unlimited}` |
| POST | `/v1/intents/{id}/reply` | V2 | `accept` (opens a handshake) or `decline`; either refunds the sender's Keys |
| POST | `/v1/pass` · `/v1/save` | V2 | `{handle}`; private |
| GET / PUT / DELETE | `/v1/tonight` | V2 | **Tonight** (FR-109): view; go free for 1–6 hours within about 5/10/25/50 km; stop. Needs a complete profile. Lists only members who are also free, within both members' radius, inside the Stage 0 gates; each identified by a per-viewer handle; approximate distance only |
| POST | `/v1/tonight/interest/{handle}` | V2 | Private interest; shown to neither side until mutual; at most 10 per evening |
| GET | `/v1/tonight/photos/{handle}/{n}` | V2 | The n-th photo the viewer may see (main + shown; blurred never served) while both are free |
| POST | `/v1/signals:batch` | V0 | ≤ 50 behaviour events (§8) |
| GET | `/v1/preferences/insights` | V2 | Category-level view of what has been learned (never a raw vector) |
| POST | `/v1/preferences/correction` | V2 | "More / less like this" and category corrections |
| POST | `/v1/preferences/reset` | V2 | Neutralise RevealedPreferenceVector; α returns to 0.15; rebuild from the IntentVector |
| PUT | `/v1/preferences/personalisation` | V2 | Turn personalisation on or off |

## 5.6 Handshake, ENVOY tier, reveal

| Method | Path | Min | Contract |
|---|---|---|---|
| — | *(system)* handshake created on mutual intent | — | Not client-callable in v1.1 (E-29) |
| GET | `/v1/handshake/{id}/brief` | V2 | The caller's own asymmetric Brief only (§6.2) |
| POST | `/v1/handshake/{id}/decision` | V2 | `accept\|decline` (`amend` is P2). Thread opens **only** when both sides accept and Stage 0 still passes; a couple's side follows its `veto_mode`, and partners see each other's choice. Nobody is told who declined |
| GET | `/v1/envoy/proposals` | V2 + envoy | Up to 3 proposals from the top of the slate (never exploration cards, never someone already sent an intent) with plain-language reasons |
| POST | `/v1/envoy/proposals/{handle}/approve` | V2 + envoy | **One-tap human approval required for every outbound intent (D-04)**; then the normal intent rules apply |
| POST | `/v1/reveal-grants` | V2 | `{recipient, scope, media_id?, expires_at}` |

| Method | Path | Min | Contract |
|---|---|---|---|
| DELETE | `/v1/reveal-grants/{id}` | V2 | Destroys the wrapped key; access ends at once (p95 < 5 s, including CDN) |

## 5.7 Threads (E2EE; the server relays ciphertext only)

| Method | Path | Min | Contract |
|---|---|---|---|
| GET | `/v1/threads` · `/v1/threads/{id}` | V2 | Conversations (opened only by mutual interest) and the device public keys of both members |
| PUT | `/v1/devices/key` | V0 | Register this device's ECDH P-256 public key; at most 5 devices; private keys never leave the device |
| POST / GET | `/v1/threads/{id}/messages` | V2 | One ciphertext envelope per device of both members (P1 scheme, D-51; MLS from P2); idempotent on `client_id`; `expires_at` from retention; expired envelopes purged |
| POST | `/v1/threads/{id}/block` | V2 | Closes the thread for both and hides the pair from each other everywhere; the other member is not told why |
| POST | `/v1/threads/{id}/signal` | V2 | On-device Guardian signal (kind and model only); child safety and extortion freeze the thread for review |
| PUT | `/v1/threads/{id}/retention` | V2 | 7 / 30 / 90 days; the shortest elected by any participant wins |
| POST | `/v1/threads/{id}/meets` · `/v1/meets/{meet}/confirm\|cancel` | V2 | Time window only; the place and door secret travel inside the encrypted thread. Only the other member can confirm |
| POST | `/v1/meets/{meet}/safety` · `/v1/meets/{meet}/checkin` | V2 | Start check-ins (interval, check-in PIN, duress PIN, trusted contact for this meet only, safety line); check in or end with "home safe". The duress PIN gets the identical reply and never ends check-ins; a missed check-in alerts the trusted contact, then the safety line. Timers run on the server |
| POST | `/v1/threads/{id}/burn` | V2 | Revoke keys on both sides; thread closed |
| POST | `/v1/aftercare/{meet_id}` | V2 | Private outcome (48 h after the meet) |

## 5.8 Safety

| Method | Path | Min | Contract |
|---|---|---|---|
| GET | `/v1/reports/categories` | V0 | Report categories with member-facing labels |
| POST | `/v1/reports` | V0 | `{thread_id, category, disclosed[]?, note?}` → `{reference}`. Opens a case with a deadline from the escalation matrix (minor 15 min; image abuse, sextortion, threats 1 h; fraud, commercial sex 4 h; others 24 h). `disclosed` holds only messages the reporter ticked (≤ 20); nothing else from an E2EE thread reaches TRYST. Suspected minor, threats of violence and stalking freeze the subject until a moderator decides (03 §7.3 "Automatic"); corroborating reports close with the decision. The reporter is never revealed and the other member is not told (FR-116) |
| GET | `/v1/me/standing` | V0 | `{standing, decisions[]}`: each enforcement decision with its reason and appeal state |
| POST | `/v1/block` | V0 | Bidirectional and immediate; removes thread access |
| POST | `/v1/guardian/signals` | V2 | On-device scores: `{thread_id, model_id, version, score, reason_code}`. **Never content** |
| POST | `/v1/safety/panic` | V0 | **Emergency.** Live location + preserved evidence → emergency escalation. Overrides TTLs (P7) |
| POST | `/v1/safety/share-plan` | V2 | Encrypted, unbranded, auto-deleting plan for a trusted contact |
| POST | `/v1/appeals` | V0 | `{decision_id, text}` (10–4000 chars). One appeal per decision; a reviewer not involved in the decision (or its confirmation) decides within 10 working days; overturning restores standing |
| POST | `/v1/attestations/dbs` | V2 | Self-submitted Basic DBS through the issuing route; shown as a dated fact (P3) |

**Moderator console** (`/ops/v1/*`, served by the standalone safety service with its own database (D-59, FR-123); staff only, on a separate host behind the company sign-in proxy. In production the proxy's signed token is verified against its published keys, issuer, audience and expiry, and roles come from the staff roster, never from the request; dev tokens are refused outside dev). Every call is written to a hash-chained audit log (`ops.admin_action`). Reports, appeals and standing (`/v1/reports*`, `/v1/appeals`, `/v1/me/standing`) are served by the same service; a member may send at most 20 reports a day (429).

| Method | Path | Contract |
|---|---|---|
| GET | `/ops/v1/cases` | Open cases and pending appeals, most urgent deadline first |
| GET | `/ops/v1/cases/{id}` | Subject pseudonym and city, disclosed messages, note, number of independent reporters, prior strikes. Reporter shown as `hidden` |
| GET | `/ops/v1/cases/{id}/photo?reason=` | Subject's main photo; reason ≥ 10 chars, recorded on the case and in the audit log |
| POST | `/ops/v1/cases/{id}/decision` | `{outcome: dismiss\|uphold, ground?, reason}`. Action follows the ladder (`enforcement.Decide`); one uncorroborated report can't remove anyone (422 `not_enough_grounds`). Permanent removal → `pending_second` with interim suspension |
| POST | `/ops/v1/cases/{id}/confirm` | `{agree?, reason?}`. A different moderator confirms (permanent) or sends back (case reopens, interim suspension lifted); same person → 403 |
| POST | `/ops/v1/cases/{id}/appeal` | `{member_wins, reason}`. Anyone involved in the decision → 403 `different_reviewer` |
| POST | `/ops/v1/cases/{id}/external-report` | `{agency: NCA\|police\|IWF, reference}`. Records a report to an authority. Required for every upheld suspected-minor (CSEA) case, which stays in the queue until recorded and becomes urgent 24 h after the decision. Audited |
| GET | `/ops/v1/audit/verify` · `/ops/v1/stats` | Chain integrity; transparency-report counts including external reports by agency (no member data) |

Standing is enforced on the member platform: `suspend` and `permanent` refuse member actions (403 `account_suspended`), close the member's conversations and hide them from Tonight; `shadow_limit` hides them from Tonight only.

## 5.9 Commerce (web-first)

Served by the commerce service (`commercesvc`, COMMERCE-DB; FR-117, D-53). The processor sees only an opaque `billing_ref` and the product key.

| Method | Path | Min | Contract |
|---|---|---|---|
| GET | `/v1/entitlements` | V0 | `{plan, ghost, keys, deposit_paid, subscriptions[] (period_end, cancel_at_period_end, in_cooling_off), voucher_plan?, catalogue, payments_available}` |
| POST | `/v1/deposit` | V1 | £9.99 refundable deposit → checkout; credited 100% as 60 Keys; 409 if already paid |
| POST | `/v1/keys/purchase` | V1 | `{pack: keys_60}` → checkout |
| POST | `/v1/vouchers/redeem` | V0 | `{code}`. Single use; codes stored only as hashes; 5 failed attempts an hour per member (429). Grants Keys or a plan for N days |
| POST | `/v1/subscription` | V1 | `{plan, pre_contract_ack: true, start_now: true}` → checkout. The pre-contract information is shown first and the express request to start within the cooling-off period is a separate confirmation (ToS 16.4); both are recorded. One plan at a time (409 `change_plan`); GHOST is an add-on. Neutral, truthful descriptor enforced at the PSP |
| POST | `/v1/billing/stripe/webhook` | sys | Stripe events (signature-verified, idempotent on event id, out-of-order safe) → entitlement and Keys-ledger updates: `checkout.session.completed`, `invoice.paid`, `customer.subscription.*`, `charge.refunded` (removes the refunded share of Keys; never below zero), `charge.dispute.created`, `invoice.upcoming` (in-app renewal notice; the processor emails the billing address ≥ 7 days ahead) (v1.2, D-22) |
| POST | `/v1/subscription/cancel` | V0 | `{item?}`. One step; no retention flow. Within 14 days of starting: ends now and refunds the unused days (whole days used are charged). After: runs to the end of the paid period, no further charge |

Only items on sale can be bought or granted by voucher (launch: TRYST+ only, D-60); others answer 409 `not_on_sale` and are left out of `catalogue`. Purchases answer 503 `payments_unavailable` until the processor is configured. Dev builds use a local test checkout (`/billing/checkout`, `POST /v1/billing/dev/complete`) that production refuses. Staff leads issue vouchers through `POST /ops/v1/vouchers` (console contract).

## 5.10 Error model

RFC 9457 `application/problem+json` with a stable `code`.

- **Existence must not leak.** Anything not visible to the caller, for any reason (block, ExclusionRing, policy, jurisdiction of the target), returns the same `404 not_found`.

| HTTP | code | Meaning |
|---|---|---|
| 401 | `auth_required`, `dpop_invalid`, `second_factor_required` (+`factor`), `step_up_required`, `authenticator_invalidated` (biometric enrolment changed) | |
| 409 | `account_exists_sign_in` | Sign-up attempted for an account that already has a passkey |
| 503 | `liveness_unavailable` | B2 provider unavailable; login fails closed |
| 403 | `tier_required` (+`required_tier`), `consent_required` (+`consent_kind`), `jurisdiction_blocked`, `entitlement_required` | |
| 404 | `not_found` | Uniform for invisible resources |
| 409 | `idempotency_conflict`, `version_conflict` | |
| 402 | `keys_insufficient` | |
| 422 | `validation_failed`, `broadening_requires_confirmation`, `same_device_cosign` | |
| 429 | `rate_limited` (+`retry_after`) | |

# 6. Agent and policy schemas

## 6.1 Envoy negotiation turn (internal bus; Protobuf mirror)

Six dimensions only: intent alignment, structure alignment, boundary intersection, logistics feasibility, discretion compatibility, verification parity. [A §5.4]

```
{
  "turn": 3,
  "from": "envoy:usr_7f3a",
  "to": "envoy:usr_91bc",
  "assert": {
    "intent_shape": "one_off",
    "structure": "attached_undisclosed",
    "notice_required_hours": 48,
    "availability": [{"dow": [2,3], "start": "18:00", "end": "23:00", "tz": "Europe/London"}],
    "travel_radius_km": 25,
    "hard_limits": ["no_photos_exchanged", "no_home_visit", "no_overnight"],
    "verification_tier": "V2",
    "min_counterparty_tier": "V2"
  },
  "query": ["intent_shape", "notice_required_hours", "hosting_capability"],
  "private_fields": ["exclusion_zones"]
}
```

**Rules:**

- No free-text fields.
- `private_fields` are computable but **never** appear in any output.
- Counterparty turns are untrusted data.
- At most 6 turns per handshake.
- The transcript is encrypted with a 30-day TTL.

## 6.2 Brief (caller-specific, asymmetric)

```
{
  "label": "agent_generated",
  "compatibility": 0.81,
  "aligned": ["intent_shape", "availability", "travel_radius", "verification"],
  "friction": [{"field": "hosting", "detail_code": "neither_can_host",
                "suggested_resolution": "hotel_or_venue"}],
  "blocking": [],
  "recommended_next": "open_thread",
  "estimated_meet_probability": 0.34
}
```

`detail_code` values map to localised copy on the client. A Brief never contains anything the counterparty marked private, nor any hard limit the counterparty has not chosen to disclose.

### 6.3 IntentVector (wire view)

The fields follow `intent_vector` (§4.3). `desire_tags` uses `yes|curious|no`. `hard_limits` is drawn from a controlled vocabulary (`shared/contracts/vocab/hard_limits.yaml`). Free-text goals entered during intake are converted by Cartographer into controlled values, and the member confirms them.

### 6.4 Discretion Policy (versioned)

```
{
  "version": 7,
  "visibility": "incognito",
  "distance_band_km": 10,
  "zones": {"home": ["gcpvj0"], "work": ["gcpuvx"]},
  "zone_behaviour": "hide_profile_while_inside",
  "reveal_rules": {"default_scope": "blurred_gallery", "require_mutual_handshake": true,
                   "max_grant_hours": 72},
  "notifications": {"enabled": false, "text": "1 update"},
  "device_risk": "high",
  "min_counterparty_tier": "V2",
  "retention": {"messages_days": 30, "media_days": 7}
}
```

**Monotonic safety:** Curtain may tighten any field automatically. Broadening needs an explicit member action, a fresh local authentication and a new version. Every read path evaluates `(requester, resource, reveal_grant, block graph, ExclusionRing, discretion version, safety_state, jurisdiction)` — ABAC [B §9].

## 7. Retention and erasure

This table is canonical; 03 and 04 implement it, and the ToS (cl. 15) and Privacy Notice must match it.

| Data | Default | Member options | Mechanism |
|---|---|---|---|
| Messages | 30 d | 7 / 90 d | Envelope `expires_at`; the client purges its copy too |
| Thread media | 7 d | — (GHOST: shorter) | Per-object key destroyed at expiry |
| Profile media | Until removed | — | Per-object key; removal destroys it |
| Handshake transcripts | 30 d | — | Encrypted; TTL |
| Behaviour events (raw) | 180 d → aggregated features | Reset / opt-out | ClickHouse TTL |
| Aftercare | 365 d, pseudonymous | — | |
| Logs | 90 d, IP truncated at ingest | — | |
| Consent ledger | Life of account + statutory period | Export | Hash chain |
| Ban anchors | Permanent (or until a successful appeal) | Appeal | **Declared exception** (ToS cl. 15.3) |
| Evidence under legal hold | Duration of hold | — | **Declared exception** (ToS cl. 17.4); narrowly scoped |
| Panic-preserved location/evidence | As required by emergency services | — | **Declared exception** (ToS cl. 20; P7) |
| B2 login face reference (v1.2) | Life of account; held by the provider, not TRYST | — | Deleted at the provider on erasure; deletion receipt included in `completion_proof` |
| Auth events | 90 d, IP truncated | — | TTL |
| Backups | 35 d rolling, disclosed in the Privacy Notice | — | Stored under per-member keys, so an erased member's data in backups is undecryptable from the moment of erasure |

**Account deletion:**

1. Destroy the root key in KMS.
2. Remove from discovery immediately.
3. Purge primaries.
4. Ciphertext in backups becomes undecryptable.
5. Issue a signed `completion_proof`.

Target < 60 s p99 (NFR-01).

# 8. Event taxonomy

Events go to Redpanda with schema-registry enforcement, are pseudonymous at rest, and are batched from clients through `/v1/signals:batch`. [A §6.1] **No message content, ever.**

| Class | Events |
|---|---|
| Attention | `card_impression`, `dwell_ms`, `photo_index_viewed`, `bio_scroll_depth`, `profile_revisit`, `expand_tag` |
| Decision | `intent_sent`, `pass`, `save`, `undo`, `hesitation_ms` |
| Conversation | `msg_sent`, `reply_latency_s`, `msg_len_bucket`, `typing_abandoned`, `question_ratio`, `thread_decay` — computed on device from metadata |
| Handshake | `brief_viewed`, `brief_accepted`, `friction_dismissed`, `amend_requested` |
| Resolution | `logistics_agreed`, `meet_scheduled`, `meet_confirmed`, `no_show`, `aftercare_score` |
| Discretion | `burn_invoked`, `session_aborted`, `geofence_hit`, `screenshot_detected`, `decoy_opened` |
| Negative | `report`, `block`, `unmatch`, `ghost_detected`, `refund_request` |

Envelope: `{event_id, pseudo_subject, type, ts, context:{surface, app_version}, consent_basis, ttl}`. The pseudo-subject rotates per training window (03 §4).

# 9. Couple and group semantics

- **Veto:** `veto_mode=either` means either partner can decline and a decline is final. `both` means both partners must accept before the couple's intent or handshake decision counts.
- **THIRD:** a couple(S3) ↔ solo(S4) handshake involves both partners' Envoy contexts. The solo's veto is always respected. The thread is an MLS group of 3 members.
- **QUAD:** couple ↔ couple; 4 MLS members. A thread opens only when both couples' veto rules are satisfied.
- **Leaving:** any participant can leave a group thread privately. The thread then closes for that member, and others see a neutral notice.
- **Dissolution:** immediately hides the couple profile, closes its threads and keeps both individual accounts.

# 10. Requirement catalogue

**Owner:** `BE` backend, `FE` frontend (native + web), `Both`. **Phase:** first phase in which the requirement must be met (01 §12). **Src:** A/B/C plus section.

## 10.1 Functional requirements

| ID | Requirement | Owner | Phase | Src |
|---|---|---|---|---|
| FR-001 | Discovery, intents, Envoy, threads, media and meets are locked below V2; nothing from other members is shown during verification | Both | P1 | A §8.1, B FR-001, E-01 |
| FR-002 | Pseudonymous identity: no legal name, employer or exact address is ever required or shown | Both | P1 | A §14.2, B FR-002 |
| FR-003 | Cartographer conversational intake produces an IntentVector; the member confirms every structured field; re-run quarterly or on drift | Both | P1 | A §5.1, B |
| FR-004 | A member can enable several modes, each with its own visibility and filters | Both | P1 | B FR-003 |
| FR-005 | Versioned Discretion Policy enforced on every read path; cannot be broadened silently | BE | P1 | B FR-004 |
| FR-006 | Couple profile requires `VC`: both at V2, distinct devices, 24 h invite, both approve the exact profile version | Both | P1 | A §8.1, B FR-005 |
| FR-007 | Either partner can dissolve a couple immediately, with no reason shown to the other | Both | P1 | Part B cl. 7.1 |
| FR-008 | Reveal ladder (alias → blurred → photo set → voice → video); each grant records recipient, scope, version and expiry, and is revocable | Both | P1 | B FR-006 |
| FR-009 | Incognito members are discoverable only after their own outbound intent | BE | P1 | B FR-007 |

| ID | Requirement | Owner | Phase | Src |
|---|---|---|---|---|
| FR-010 | ExclusionRing PSI: on-device blinding; the server never learns contacts; suppression is bidirectional and silent | Both | P2 | A §9.3, B FR-008 |
| FR-011 | Home/work exclusion zones suppress both sides and hide the profile while inside them | Both | P1 | A §5.5, §9.4 |
| FR-012 | Daily slate of up to 18 cards with a 15% exploration floor | Both | P1 | A §4, §7 |
| FR-013 | Intent costing: free tier 3/week; Keys 5 (solo→solo) / 15 (couple→solo); refund on reply; inbound cap default 12/24 h (adjustable 4–40), overflow queued and re-scored | BE | P1 | A §7.4, §15.2 |
| FR-014 | Hard limits, zones, structure compatibility, ExclusionRing, blocks, tier parity and jurisdiction are Stage 0 pre-retrieval gates; any violation is a P0 incident; enforced by property tests | BE | P1 | A §6.2, §7 |
| FR-015 | Handshake on mutual intent: six-dimension Envoy negotiation; asymmetric Briefs; private fields never emitted; Briefs labelled | Both | P2 | A §5.4 |
| FR-016 | A thread opens only on double human accept (P2+); in P1 the control cohort opens on mutual intent | Both | P1 | A §4, §17 |
| FR-017 | E2EE messaging (MLS, RFC 9420); the server stores ciphertext only and cannot read content | Both | P1 | A §9.2 |
| FR-018 | Thread media is client-encrypted with a per-object key wrapped per recipient; revocation destroys the wrapped key | Both | P1 | A §9.2 |
| FR-019 | Thread burn revokes keys on both sides and closes the thread | Both | P1 | A §11 |
| FR-020 | Meet propose/confirm/cancel; Safe Meet checklist (public venue first); check-in timer with silent escalation | Both | P1 | A §19.7 |
| FR-021 | Share My Plan: encrypted, unbranded, auto-deleting share with a trusted contact | Both | P1 | A §19.7 |
| FR-022 | Panic: escalation to 999 with live location and preserved evidence; a separate control from Burn | Both | P1 | A §19.7, E-21 |
| FR-023 | Private Aftercare prompt 48 h after a meet; never visible to the counterparty | Both | P1 | A §5.7 |
| FR-024 | Preference transparency: view learned categories, correct, disable personalisation, reset learning | Both | P2 | B FR-010 |
| FR-025 | Each slate card shows 2–4 non-sensitive reasons and a correction control | Both | P2 | B §6.2 |
| FR-026 | Notifications off by default; if enabled, content-free with member-chosen neutral wording (default "You have an update") — never a name, image or excerpt | FE | P1 | A §9.4, B §4 |
| FR-027 | Decoy skin (neutral icon/name) and silent duress PIN opening a populated innocuous state (native) | FE | P1 | A §9.4 |
| FR-028 | Burn: wipe local storage, revoke device keys, sign out everywhere; confirmable in < 2 s | Both | P1 | A §9.4 |
| FR-029 | Quick exit hides content and clears the client view and cache in < 500 ms on all surfaces; onboarding states plainly that it cannot hide network or device history | FE | P1 | B FR-011, B §4 |
| FR-030 | Screenshot protection (FLAG_SECURE) or detection with counterparty notice (iOS); obscured app switcher; no cloud backup; keys in Secure Enclave/StrongBox | FE | P1 | A §9.4 |
| FR-031 | Entering a blocked jurisdiction auto-locks to the decoy and hides the profile | Both | P1 | A §9.4, §14.5 |
| FR-032 | Report and block from every surface; the reporter is never revealed; reporters may disclose decrypted content and separately opt in to training use | Both | P1 | A §21.3, Part B cl. 19 |
| FR-033 | Guardian M6a–M6e run on device for E2EE threads and send only score + reason code | Both | P1 | A §21.6 |
| FR-034 | Escalation matrix routing and SLAs (03 §7.3) | BE | P1 | A §8.4 |
| FR-035 | Enforcement ladder; permanent actions need a named human; appeal to a different reviewer within 10 working days | BE | P1 | A §19.6 |
| FR-036 | Ban anchors are checked before account creation; a match is silently refused | BE | P1 | A §19.3 L2 |
| FR-037 | No commercial sex: solicitation and payment patterns go to review; no payments between members | Both | P1 | A §8.4, B FR-015 |

| ID | Requirement | Owner | Phase | Src |
|---|---|---|---|---|
| FR-038 | Account deletion = cryptographic erasure < 60 s; immediate discovery removal; signed completion proof | Both | P1 | A §9.2, B FR-012 |
| FR-039 | DSRs: SAR export including the consent ledger, rectification, portability | Both | P1 | A §14.2 |
| FR-040 | Hash-chained consent ledger; Article 9 consent separate from the ToS accept | BE | P1 | A §8.2 |
| FR-041 | Web-first billing: TRYST+ and Keys (P1), DUO, ENVOY and GHOST (P3); neutral truthful descriptor; vouchers; one-step cancel; pre-renewal and cooling-off notices | Both | P1 | A §14.4, §15 |
| FR-042 | £9.99 refundable verification deposit credited as Keys | Both | P1 | A §15.2 |
| FR-043 | Jurisdiction gate at the edge and at sign-up | BE | P1 | A §14.5 |
| FR-044 | Conduct attestation at V2, logged separately | Both | P1 | A §19.3 L3 |
| FR-045 | Basic DBS self-submission shown as a dated fact; Clare's Law explainer before the first meet (outcome never requested or stored) | Both | P3 | A §19.3 L3 |
| FR-046 | Pause and vanish | Both | P1 | B §3 |
| FR-047 | Profile-photo protection: EXIF strip, face-blur default for photos other than the main photo (D-38), AI-generation and reverse-image checks on every upload, adversarial perturbation on public-tier photos | Both | P1 | A §9.1 A8, §19.4 |
| FR-048 | ENVOY tier: agent-proposed outreach, each intent approved by the human with one tap | Both | P3 | A §15.2, D-04 |
| FR-049 | Couple `veto_mode` (`either`/`both`); THIRD and QUAD matching and MLS group threads | Both | P1 | A §3, §10 |
| FR-050 | Exposure-fairness monitor (M9) adjusts the fairness penalty when inbound Gini > 0.55 per city/segment | BE | P1 | A §7.4 |
| FR-051 | Native store builds are sanitised (no explicit media or copy); explicit media lives only on web behind V2 | FE | P1 | A §14.3 |
| FR-052 | Semi-annual transparency report: removals by ground, appeals, overturn rate, disclosures | BE | P3 | A §19.6, Part B cl. 18.3 |
| FR-053 | Travel mode: set a planned location for discovery (premium) | Both | P3 | A §15.2 |
| FR-054 | In-product safety notice at intake and before a first meet (04 §7) | FE | P1 | A §20.3 |
| FR-055 | Envoy and other agents never send messages to a human as the member | BE | P2 | A §5.4 |
| FR-056 | Passkey-only authentication: no passwords; SMS/email OTP, magic links and support overrides are never login factors (contact OTP only at sign-up) | Both | P1 | D-16 |
| FR-057 | Native app and mobile PWA login requires two biometric factors: B1 device-bound biometric passkey **and** B2 liveness face match to the account holder (§3.3) | Both | P1 | D-16 |
| FR-058 | Desktop login (browser or desktop PWA) requires two factors: F1 passkey **and** F2 approval from a registered mobile device via B1 (or a second FIDO2 key) (§3.3) | Both | P1 | D-16 |
| FR-059 | A change to the device's biometric enrolment invalidates its passkey and forces a full login (B1 re-registration + B2) | Both | P1 | D-16 |
| FR-060 | Step-up re-authentication for sensitive actions (§3.3); never for Burn, Panic, report, block, cancel or deletion | Both | P1 | D-16 |
| FR-061 | Account recovery needs B2 + fresh V2 matching the stored document anchor + 24 h hold cancellable from registered devices; no staff bypass | Both | P1 | D-16 |
| FR-062 | Session limits: mobile 30 d max with biometric unlock and 2 min idle lock; desktop 12 h max, 15 min idle → full login | Both | P1 | D-16 |
| FR-063 | Brand: logo used exactly as supplied and palette tokens applied on every branded surface; logo never shown in decoy mode, on lock screens, in notifications, app-switcher snapshots, descriptors or Share My Plan | FE | P1 | D-19 |
| FR-064 | Emergency lock from a separate path: with only the contact handle and a one-time emergency code issued at sign-up (no login), freeze all sessions, hide the profile and disable all media links; unlocking needs full recovery (FR-061). Uniform response; abuse only locks, never exposes | Both | P1 | B §3, §4 |

| ID | Requirement | Owner | Phase | Src |
|---|---|---|---|---|
| FR-065 | Location veil: distances shown only as bands, computed from approximate cells whose offset rotates at least daily; never live or exact home/work coordinates | Both | P1 | B §4 |
| FR-066 | Conversation suggestions (openers, boundary questions, respectful replies) are opt-in, generated on device, draft-only and never sent without the member's own action | FE | P3 | B §5, D-20 |
| FR-067 | Timing and availability matching use only member-provided windows, never routines inferred from location or activity | BE | P2 | B §5 |
| FR-068 | Behavioural signals decay over time (default half-life 90 days); members can reset all inferred preferences (FR-024) | BE | P2 | B §6.2 |
| FR-069 | Encrypted media safety: the sending device accepts only allow-listed image/video formats, re-encodes them (stripping active content) before encryption, and shows a consent/NCII warning before any intimate image is sent; public-tier media is malware-scanned on the server | Both | P1 | B §9, §10 |
| FR-070 | Role separation: finance and billing staff cannot access profile, intent or safety data; T&S staff cannot see billing identity; enforced in the ABAC policy engine | BE | P1 | B §9 |
| FR-071 | Viewing reporter-disclosed intimate evidence needs dual approval and a reason code, and is logged immutably | BE | P1 | B §9 |
| FR-072 | Community Rules and enforcement prohibit fetishisation of, and harassment based on, protected characteristics; reportable as `protected_trait_harassment` | Both | P1 | B §10 |
| FR-073 | Public marketing site built for search: server-rendered/static pages, XML sitemaps, canonical tags, hreflang (en-GB, en-IE, later wave-2 locales), schema.org markup (Organization, WebSite, Article, FAQPage, BreadcrumbList), descriptive internal links, a quick-exit button and a neutral-favicon option | FE | P1 | v1.2 |
| FR-074 | Herald SEO agent: keyword and topic research, content briefs and drafts, on-page optimisation, internal-link graph maintenance, content refresh from performance data, rank tracking, broken-link repair, and link-earning outreach drafts; **every publication and outreach message is approved by a human editor** | BE | P1 | v1.2, D-21 |
| FR-075 | Herald is isolated from member data: separate cloud account and network, no credentials for any member store, inputs limited to public web data, Search Console and cookieless aggregate site analytics; no member content, profiles or stories (unless separately consented and anonymised) are ever published | BE | P1 | v1.2 |
| FR-076 | No member surface is indexable: the app origin serves `noindex, nofollow` and robots disallow; there are no public profile URLs; shared links never reveal a member | Both | P1 | v1.2 |
| FR-077 | White-hat link policy: paid links, PBNs, link exchanges, spam, cloaking, doorway pages, unreviewed scaled AI content and fake reviews are prohibited; any paid or sponsored link carries `rel="sponsored"`; the link profile is audited monthly | BE | P1 | v1.2, D-21 |
| FR-078 | Payments run through a processor-agnostic `PaymentProvider` layer with **Stripe as primary** (Checkout, Billing, Customer Portal one-step cancel, Radar, Tax) and a high-risk acquirer as the live backup; Stripe receives only the opaque billing reference and payment data; the neutral descriptor never names TRYST | Both | P1 | v1.2, D-22 |
| FR-079 | Every IntentVector change (member edit or Cartographer re-run) is kept as an append-only, member-viewable version history with audit records | BE | P1 | B §13 |
| FR-080 | Every agent action passes the AI Governance gate before it runs: unknown agents or unlisted actions are denied; `irreversible`, `member_safety`, `money_movement` and `production_change` actions always need a registered named human; autonomy levels L0–L3 and daily budgets cap everything else (09 §5.4) | BE | P1 | founder OS brief, D-25 |
| FR-081 | Agents are declared by manifest (owner, level, actions, data scopes, budget). A member-data scope is refused unless the agent runs inside the member platform on a self-hosted model; no manifest may contain an act-as-member action | BE | P1 | founder OS brief, P4 |
| FR-082 | Agent decisions and admin actions are written to hash-chained, append-only logs anchored hourly to write-once storage; a kill switch per agent and for all agents takes effect immediately and is itself logged | BE | P1 | founder OS brief |
| FR-083 | Member Command Centre: private insights (own activity charts, security activity, "why this slate" from reason codes, what TRYST has learned with reset); no engagement counters or streaks; works with Leave, decoy and emergency lock | Both | P2 | founder OS brief, P1, P5 |
| FR-084 | BitriPay adapter behind `PaymentProvider`: sandbox supported; live keys refused unless the market is enabled for TRYST and BitriPay with a recorded legal opinion; deterministic idempotency keys; only amount, currency and a neutral descriptor are sent; signed webhooks verified | BE | P1 | founder OS brief, D-26 |
| FR-085 | Self-healing: SLO burn triggers incident creation and pre-approved runbooks (rollback, restart, scale out, halt canary) within budget; code or model changes reach production only through a reviewed pull request | BE | P1 | founder OS brief, D-28 |

| ID | Requirement | Owner | Phase | Src |
|---|---|---|---|---|
| FR-086 | Admin Super Control Centre on an internal origin: redacted by default; member-level access only via a case-scoped just-in-time grant approved by a second person (max 8 h); break-glass needs two people; every view and action logged | Both | P1 | founder OS brief |
| FR-087 | Connector register: every third-party connector records purpose, module, data sent and received, lawful basis, DPA, region, health, kill switch and owner; no member data to CRM, messaging-app, enrichment or advertising platforms; live mode needs a named approver | BE | P1 | founder OS brief, D-29 |
| FR-088 | Partner API (licensing): scoped `tk_` keys shown once and stored hashed, ACU metering with idempotent usage records, signed outbound webhooks with retries and replay; no TRYST member data is reachable from any partner scope | BE | P4 | founder OS brief, D-27 |
| FR-089 | Public sign-up in the launch cities (London, Manchester, Birmingham, Brighton) with no invitation required; matching opens one city at a time in that order, each at 2,000 verified members once the previous city is live, and never closes again; members see how many more are needed | Both | P1 | Founder v1.3, D-35 |
| FR-090 | Demand-balance waitlist per city, gender-neutral: a member waits only if a group they seek would exceed the load cap (2.2 seekers per group member in P1, 2.0 from P3); the rule never reads the applicant's own characteristics; waiting is first come, first served per sought groups, shows position and the busy group, and releases automatically as supply grows; departures never reopen seeding; nothing here affects price or ranking | BE | P1 | A §16, D-35, D-36 |
| FR-091 | Paid-acquisition brake per city: blended cost per verified sign-up checked weekly against break-even (contribution per payer × payer rate × V2 rate); paid spend stops automatically after 2 weeks above it or 1 week above 1.5×; only a named approver can restart it | BE | P1 | E-03, D-35 |
| FR-092 | Profile seen by other eligible members: the main photo (always shown, never blurred, must clearly show the member's face, or both partners' faces for a couple), age in whole years, area name (district or city, the member's choice) and an approximate distance; up to 10 photos in total, in the member's order, others optionally blurred behind the reveal ladder. Only V2 members inside the Stage 0 gates (blocks, ExclusionRing, jurisdiction, hard limits) ever see it; there are no public profile URLs (FR-076) | Both | P1 | Founder v1.3, D-37, D-38 |
| FR-093 | No AI-generated, AI-altered, borrowed or third-party images: every upload passes provenance reading (IPTC digital source type, C2PA), a synthetic-image detector (reject ≥ 0.90, human review ≥ 0.50, review if unavailable), reverse-image search, CSAM hash matching and face matching, where every face must be the member (or partner) and the main photo must match them; metadata is stripped after the check; rejected images are never stored | Both | P1 | Founder v1.3, FR-047 |
| FR-094 | Under-18s cannot join: V2 requires a photo-ID document (NFC chip read where available), liveness and a face match to the document; the provider's over-18 decision is re-checked by TRYST from the birth year-month, never admitting anyone whose 18th birthday could still be ahead; every mobile sign-in repeats the face match (B2), so an account cannot be handed to someone else; a Guardian minor signal or a credible report holds the account and forces re-verification | Both | P1 | Founder v1.3, D-39 |
| FR-095 | Couple verification before a couple profile is published: both partners V2 and adult; different accounts, phones, ID documents and faces (partner face match < 0.50); a live in-app photo of both together with liveness, exactly two faces, each matched ≥ 0.90; in-person phone pairing approved by both within 2 minutes, in the same session as the photo; neither partner in another active couple. The profile then shows a dated "both partners verified" statement | Both | P1 | Founder v1.3, D-40 |
| FR-096 | Couples stay true: either partner can dissolve the couple instantly; both reconfirm every 90 days with their own sign-in, after which the profile is flagged for 14 days and then paused from discovery until both confirm | Both | P1 | Founder v1.3, D-40 |
| FR-097 | One person, one account: an ID-document anchor may hold only one active account (lost access goes through recovery); a card may pay for at most two accounts (member and verified partner); a phone or card shared with a non-partner goes to review | BE | P1 | Founder v1.3, D-41 |
| FR-098 | Profile text (name, bio, couple description) is screened before display: contact and payment/crypto details refused; commercial sex, drug supply and any reference to a minor refused and routed to T&S within 15 minutes; shared test vectors with the on-device Guardian | Both | P1 | Founder v1.3 |
| FR-099 | Door check: at a meet, both phones show the other's verified main photo and the same three words derived from the handshake secret | Both | P1 | Founder v1.3 |
| FR-100 | Meet check-ins at a member-chosen interval with a check-in PIN and a separate duress PIN that looks identical on screen; duress or a missed check-in (after 10 min grace) alerts the trusted contact, then after 15 minutes (immediately for duress) TRYST's 24/7 safety team if the member opted in, with location for that meet only; a meet cannot start without a trusted contact or the safety line | Both | P1 | Founder v1.3, D-42 |

| ID | Requirement | Owner | Phase | Src |
|---|---|---|---|---|
| FR-101 | V2 identity capture only in the native app with platform attestation, or via a provider certified for injection-attack detection; the web hands off to the phone by QR | Both | P1 | Founder v1.3, D-44 |
| FR-102 | On-device Guardian adds M6f (romance and financial fraud), M6g (child safety) and M6h (exposure extortion), and blocks sending images that appear to contain a child | Both | P1 | Founder v1.3, Ofcom dating risks |
| FR-103 | Before a first meet: an in-app video call is offered and can be set as a hard limit; a private-address venue triggers an on-device warning; Panic shows the UK Silent Solution (999, then 55) | FE | P1 | Founder v1.3 |
| FR-104 | Private aftercare asks whether the member felt safe; two independent "felt unsafe" answers about the same member within 90 days trigger review; never shown to the counterparty | Both | P1 | Founder v1.3 |
| FR-105 | Law-enforcement cooperation: lawful-request process, emergency disclosure (DPO + Head of T&S), preservation, mandatory CSAM reporting to NCA/IWF, counts in the transparency report | BE | P1 | Founder v1.3, OSA |
| FR-106 | Partner shield: a member may add their partner's phone number or email, blinded on device (hashed match in P1, PSI in P2 with FR-010); if the partner joins, both are permanently and silently invisible to each other; couple partners on TRYST and household signals are shielded the same way | Both | P1 | Founder v1.3, D-45 |
| FR-107 | A member may hold a private solo profile and a joint couple profile under one account; the partner never sees the solo profile or any of its activity, notifications or payments, and the couple profile shows only couple activity; enforced as the Stage 0 `partner_secret` gate | Both | P1 | Founder v1.3, D-45 |
| FR-108 | Never confirm or deny: support, legal and every other channel answer only "We can't say whether any person has an account"; account information goes only to the signed-in holder, a court order or lawful request reviewed by counsel, or the emergency rule (P7) | BE | P1 | Founder v1.3, ToS 14.4 |
| FR-109 | Tonight: a member with a complete profile can go free for 1–6 hours and see who nearby is also free; visibility is reciprocal and ends when they stop or time runs out; approximate distance only; per-viewer handles; private interest revealed only when mutual; at most 10 interests an evening; all Stage 0 gates apply | Both | P1 | Founder v1.3, D-46 |
| FR-110 | Message-safety baseline: deterministic on-device rules for M6f, M6g and M6h ship at launch and must pass every labelled vector in `shared/contracts/vocab/guardian_vectors.json` (no misses, no false positives) on every client; a trained model replaces a rule only when it beats it on the held-out evaluation gate (03 §7.7) | Both | P1 | Founder v1.3, D-47 |
| FR-111 | Safety line staffed 24/7 from launch by a contracted alarm-receiving centre (BS EN 50518, BS 8484) with the on-call T&S rota as backup: acknowledgement within 60 s or the alert moves on; an ARC with no heartbeat for 5 minutes is skipped; if nobody acknowledges, the trusted contact is alerted and the member's phone shows the 999 / Silent Solution screen; alerts carry only alias, callback number, shared location, meet window and reason | BE | P1 | Founder v1.3, D-48 |
| FR-112 | V2 identity checks run only through a provider with a valid, evidenced liveness certificate (ISO/IEC 30107-3, iBeta Level 2 or equivalent); without a valid injection-attack certificate (CEN/TS 18099 or equivalent) capture is native-app only with platform attestation and the web hands off by QR; with no certified provider, V2 fails closed; certificate expiry is monitored | BE | P1 | Founder v1.3, D-49 |
| FR-113 | Everything a member creates survives restarts: identities, credentials, sessions and profiles persist in per-domain PostgreSQL databases; photos are stored encrypted under the member's own key and unreadable without the key vault; services refuse to start in production without their databases and key-encryption key | BE | P1 | D-50 |
| FR-114 | End-to-end encrypted conversations: a thread opens only after mutual interest; every message is encrypted on the sender's device separately for each device of both members; the server stores and relays ciphertext only, with expiry from retention; the on-device Guardian warns on fraud, refuses to send child-safety content and freezes threads on child-safety or extortion signals; either member can block, which closes the thread for both and hides them from each other | Both | P1 | A §9.2, D-51 |
| FR-124 | Identity and age assurance: liveness (V1) and photo-ID (V2) checks at a certified provider through a signed hand-off and callback; V2 also needs the conduct declaration; TRYST re-checks over-18 itself and locks out anyone under 18; one account per ID document and banned documents refused, using a one-way document code; discovery needs V2 in every environment; checks refused while no provider holds a valid certificate | Both | P1 | A §8.1, FR-094, FR-097, D-39, D-41, D-44, D-61 |

| ID | Requirement | Owner | Phase | Src |
|---|---|---|---|---|
| FR-128 | Introductions and couples: structured intake with every version kept; a daily slate of up to 18 behind the Stage 0 gates with a weighted baseline, about 15% exploration and 2–4 reason codes, nothing paid; private intents (3 free a week, unlimited on TRYST+, otherwise Keys refunded on reply) with a silent inbound cap; mutual interest opens a handshake with each side's own brief and a conversation only when both accept; ENVOY proposals that send nothing without the member's tap; couple links co-signed from two devices on the exact version, a veto mode both must agree to, instant dissolution and 90-day reconfirmation | Both | P1 | FR-003, FR-006, FR-013, FR-014, FR-079, FR-096, D-04, D-65 |
| FR-127 | Discretion controls: pause and vanish (vanish also closes every conversation), coming back only after step-up; a versioned Discretion Policy (visibility, distance, counterpart tier) where any broadening needs step-up; hidden areas and the partner shield applied both ways and silently; an emergency lock with a one-time code from sign-up that works without signing in, ends sessions, refuses sign-in and hides the profile and its photos until recovery, with uniform answers | Both | P1 | FR-005, FR-011, FR-046, FR-064, FR-106, D-45, D-64 |
| FR-126 | Consent ledger: one append-only, hash-chained chain per member (the hash covers the account, so a chain can't be moved), verified on load and continuously (metric and on-call page); Article 9 consent asked separately from the Terms and needed for discovery, with withdrawal taking effect at once; biometric consent before any face check; the conduct declaration recorded with its wording version; the whole ledger in the member's export and erased with the account | Both | P1 | FR-039, FR-040, D-63 |
| FR-125 | Step-up and recovery: step-up repeats both sign-in checks inside the session and allows sensitive actions for 5 minutes (device list, adding or removing a passkey, data export); never for Burn, Panic, report, block, cancel or deletion. Recovery for a member with no device: provider face check and an ID check on the same document (matched by its one-way code), a 24-hour hold the member is told about and can cancel from any signed-in device, then every old passkey and session revoked and a 15-minute session to register a new passkey; uniform answers, rate-limited, no staff bypass | Both | P1 | FR-060, FR-061, D-16, D-62 |
| FR-123 | Standalone Trust & Safety service with its own database: member reports (20 a day each), cases with deadlines from the escalation matrix, interim freezes, the moderator console with hidden reporters, reason-gated photos and a hash-chained audit log, two-person permanent removal, independent appeals, mandatory NCA reporting for upheld CSEA cases, staff sign-in by the proxy's verified token and a roster; it reaches the member platform only through signed internal APIs, with bans, freezes, notices and on-device signals delivered from durable outboxes so an outage or restart loses none; it takes part in data export, erasure and restores | Both | P1 | A §7.3, A §8, FR-116, D-59 |
| FR-122 | Security testing gates on every change: reachability-aware Go vulnerability scan, static analysis and gosec, npm audit, container image scan, a route-authorisation test generated from both OpenAPI contracts, web security-header tests and the restore drill; an independent penetration test before launch | Both | P1 | NFR-09, D-58 |
| FR-121 | Operability: container images (non-root, distroless API), infrastructure as code for a UK region, readiness checks on every database, graceful drain that lets safety alerts finish, Prometheus metrics with no member identifiers and on-call alerts for overdue urgent safety cases, failed safety alerts, error rate, erasure time and billing events; encrypted logical backups with the key database on a 7-day retention; an erasure ledger kept apart so every restore re-applies deletions; a restore drill run automatically in CI | BE | P1 | 03 §12, NFR-01, 02 §7, D-57 |
| FR-120 | Production vendor adapters that fail closed: Sightengine (synthetic image + nudity) and Microsoft PhotoDNA (known-CSAM hashes) run in parallel with the identity provider's face match and reverse-image search, and any failure sends the photo to a person; the identity provider's liveness check passes only with a match, presentation-attack detection, no injection signal and confidence ≥ 0.9; the alarm-receiving centre receives only the pinned alert fields and must return its case reference; trusted contacts get a neutral text naming only the member's alias. Production refuses to start without a sign-up code channel or the safety line | BE | P1 | 03 §6.7, §7.5, §7.7, FR-111, D-48, D-56 |
| FR-119 | Notifications: a masked in-app inbox for matches, messages, meets, safety decisions, appeals, billing and new-device sign-ins; optional Web Push with no payload (VAPID-signed, to browser push services only) that shows only the member's own wording; sign-up codes by email (Postmark, tracking off) or SMS (Twilio) in neutral words that never name the service; renewal reminders by the payment processor to the billing address, since TRYST holds no email in clear | Both | P1 | FR-026, FR-063, A §9.4, 03 §6.7, D-55 |
| FR-118 | Data rights: a full export of what every service holds about the member, and deletion by cryptographic erasure across identity, profile, conversations, meets, safety and commerce, finishing even if interrupted, with a signed completion proof that names the declared exceptions (permanent-removal standing; safety cases under review; the processor's statutory payment records). Erasure ends live plans (cooling-off refund within 14 days) and refunds an unspent deposit | Both | P1 | A §7, ToS cl. 15, FR-038, NFR-01, D-54 |

| ID | Requirement | Owner | Phase | Src |
|---|---|---|---|---|
| FR-117 | Payments: hosted checkout for plans, the GHOST add-on, Keys packs and the refundable deposit; entitlements and the Keys ledger change only from signature-verified, idempotent processor events; refunds and chargebacks remove the matching Keys; pre-contract information and a separate start-now request before subscribing; one-step cancellation with a proportionate refund inside 14 days; single-use vouchers; the processor sees only an opaque billing reference | Both | P1 | A §10, ToS cl. 16, D-22, D-53 |
| FR-116 | Report, enforce and appeal: members report from a conversation (category, optionally the messages they choose to share, and block in the same step); on-device Guardian signals open cases automatically; moderators work a deadline-ordered queue where reporters are hidden, photos are blurred until a reason is recorded, decisions follow the enforcement ladder, permanent removal needs a second moderator, every action is in a tamper-evident log; members see each decision with its reason and appeal to a different reviewer | Both | P1 | A §7.3, A §8, FR-033–FR-035, ToS cl. 17–18, D-52 |
| FR-115 | Meet planning and safety screens: propose and confirm a meet in the conversation (place never sent to TRYST), door-check words and verified photo on arrival, check-ins with duress PIN and "home safe", Share my plan (neutral text), and a Panic screen with a 999 call button and the Silent Solution; server-side timers alert the trusted contact and the safety line | Both | P1 | A §19.7, FR-020–FR-022, FR-099, FR-100 |

## 10.2 Non-functional requirements

| ID | Requirement | Owner |
|---|---|---|
| NFR-01 | Erasure < 60 s p99 | BE |
| NFR-02 | Retrieval < 40 ms p95; ranking < 120 ms p95 for 200 candidates; `/v1/slate` < 400 ms p95 | BE |
| NFR-03 | On-device Guardian inline < 80 ms p95 per thread turn | FE |
| NFR-04 | Quick exit < 500 ms; Burn confirmable < 2 s; reveal revocation effective < 5 s p95 | Both |
| NFR-05 | Availability: core API 99.9%; message relay 99.95% | BE |
| NFR-06 | UK/EU residency; primary AWS eu-west-2 | BE |
| NFR-07 | WCAG 2.2 AA (web), platform accessibility APIs (native) | FE |
| NFR-08 | OWASP ASVS L3 (API), MASVS L2 + R (mobile); quarterly pen test; annual red team on A4/A7 | Both |
| NFR-09 | No third-party analytics, advertising or attribution SDKs in any client | FE |
| NFR-10 | Zero standing production access; break-glass needs dual authorisation and writes an immutable log | BE |
| NFR-11 | Logs kept 90 d, IP truncated at ingest | BE |
| NFR-12 | Scale: P3 25k verified; P4 150k; design headroom 500k verified / 50k concurrent | BE |
| NFR-13 | RPO ≤ 5 min, RTO ≤ 1 h; backups stay under per-member keys | BE |
| NFR-14 | Localisation: EN-GB/EN-IE at P1; NL, DE, SV, DA, ES, PT at P4 (Guardian per-language evaluation) | Both |
| NFR-15 | Platforms: iOS 17+, Android 10+ (StrongBox where present), evergreen browsers (last 2 versions) | FE |
| NFR-16 | Login completion p95: mobile < 20 s including liveness; desktop < 30 s including cross-device approval | Both |
| NFR-17 | B2 provider: ISO/IEC 30107-3 PAD Level 2 certified; face-match FAR ≤ 1:10,000 at FRR ≤ 3%; fairness across demographic groups reported by the provider and audited (D-17) | BE |
| NFR-18 | Key management: automatic yearly rotation of KMS root keys and HSM peppers (dual-run); every KMS/HSM key use streamed to the SIEM with anomaly alerts | BE |
| NFR-19 | Assurance: public bug bounty from the end of P1 (public beta); annual independent privacy audit; quarterly pen test and annual red team (NFR-08) | Both |

| ID | Requirement | Owner |
|---|---|---|
| NFR-20 | Marketing site Core Web Vitals at p75: LCP < 2.5 s, INP < 200 ms, CLS < 0.1; WCAG 2.2 AA; no third-party tracking scripts (cookieless, self-hosted analytics only) | FE |

# 03 — TRYST Backend Specification v1.1

Part of the TRYST v1.1 baseline. Implements the contracts in 02. Product intent is in 01.

## 1. Scope

This document covers server-side services, agents, ML, data stores, cryptography (server side), trust and safety tooling, commerce, compliance machinery and operations. Everything a client can see or call is defined in 02. This document does not redefine those contracts.

## 2. Service topology and stack

### 2.1 Stack

*Source: A §12*

| Layer | Choice | Rationale |
|---|---|---|
| Edge API | **Go**, gRPC-gateway (REST/JSON out, gRPC in) | Concurrency, small attack surface, fast cold start |
| Agents | **Python**, FastAPI, typed state machines (LangGraph-style) | Deterministic orchestration; every agent turn can be replayed for evals |
| LLM, profile-touching | **Self-hosted open-weight models, UK region, vLLM** | Article 9 data must not leave the region or reach a third-party API. Non-negotiable |
| LLM, generic copy | Hosted frontier model, PII redacted at the boundary | Only where no personal data is involved |
| Primary stores | PostgreSQL 16 + pgvector — **identity, profile, safety and ban clusters isolated** | Identity split enforced in the infrastructure |
| Vector search | Qdrant | Filtered ANN after hard-gate pre-filtering |
| Events | Redpanda + Schema Registry (Protobuf) | Kafka API, lower ops burden |
| Analytics | ClickHouse | Behavioural aggregation; raw events purged at 180 d |
| Feature store | Feast | Train/serve parity (M3/M4) |
| Objects | S3-compatible; **client-side encrypted** | The server never holds plaintext media |
| Keys | AWS KMS + CloudHSM | Destroying the root key is the erasure primitive; peppers held in the HSM |
| E2EE | MLS (RFC 9420) via OpenMLS (delivery service + key packages) | Standardised; group threads for couples |
| Age assurance | Two providers behind one interface | Ofcom expects layered protection and due diligence; one provider is a single point of failure |
| Region | AWS eu-west-2 (London), UK/EU residency only | |
| IaC / CI / CD | Terraform, GitHub Actions, Argo CD | Auditable change control |

### 2.2 Deployables

Source A requires each agent to be independently deployable. Core domain services start as a **modular monolith** with hard module boundaries, to fit a 2-person backend team, and are split when load or team size justifies it (D-09).

| Deployable | Language | Owns | Store |
|---|---|---|---|
| `edge-gateway` | Go | AuthN (OAuth2 + DPoP), jurisdiction gate, tier gate, consent gate, rate limits, idempotency | Redis |
| `identity-svc` | Go | Identity, devices, **authenticators and login/step-up/recovery flows (§6.7)**, assurance adapters, anchor candidates, ban-anchor check, join-key HMAC, root keys | IDENTITY-DB, BAN-DB, KMS/HSM |
| `core-svc` (modular monolith) | Go | Modules: `profile`, `couple`, `intent`, `discretion`, `discovery-api`, `reveal`, `threads` (MLS delivery service), `meet`, `consent`, `deletion`, `commerce` | PROFILE-DB |

| Deployable | Language | Owns | Store |
|---|---|---|---|
| `agent-cartographer`, `agent-mirror`, `agent-broker`, `agent-envoy`, `agent-curtain`, `agent-guardian`, `agent-aftercare` | Python | One agent each (§3) | Own schemas / Feast / Qdrant |
| `llm-gateway` | Python | vLLM pool, prompt/policy registry, PII redaction, injection filters | — |
| `media-svc` | Go | Pre-signed upload/download, ciphertext lifecycle, public-tier moderation, perturbation | Object store |
| `safety-svc` | Go | Report intake, SLA routing, case management, enforcement, appeals, transparency data | SAFETY-DB |
| `trust-console` | Web (internal) | Moderator UI; redacted by default; break-glass flows | via `safety-svc` |
| `jobs` | Go | TTL purges, deletion orchestration, renewal notices, aftercare scheduling, Privacy Auditor probes | — |

**Bus.** Agents communicate over typed Protobuf messages on Redpanda topics (`agent.*`), never with free text [A §5]. Synchronous calls between agents use gRPC with mTLS and SPIFFE identities.

### 2.3 Request path (slate)

`edge-gateway` (DPoP, tier ≥ V2, jurisdiction, consent) → `core-svc/discovery-api` → `agent-broker`:

- Stage 0 gates
- Qdrant retrieval
- M3/M4 ranking
- constraints

→ `agent-curtain` exposure check → re-authorisation against the current Discretion Policy and block graph → response. Cached slates are **re-authorised on read** [B §8.2].

## 3. Agent services

Every agent has a policy file (`policies/<agent>.yaml`), a tool allow-list, a memory scope, a 400-case golden eval set, and an injection red-team suite (§9). [A §5, §13]

| Agent | Inputs | Writes | Tools | Hard constraints |
|---|---|---|---|---|
| **Cartographer** | Intake turns | Proposed IntentVector (unconfirmed) | `llm-gateway` (self-hosted), tag vocabulary | Structured output only; the member confirms each field (FR-003); re-runs quarterly or when Mirror reports drift |
| **Mirror** | Behaviour events, aftercare | RevealedPreferenceVector (**sole writer**), α, divergence | Feast, training pipeline | Message content excluded; personalisation off → α frozen at 0.15 and no updates; reset supported (FR-024) |
| **Broker** | Effective vectors, gates, fairness state | Slates, `slate_item` | Qdrant, M2/M3/M4/M9 | Stage 0 gates are not scored and cannot be bypassed; paid labels only within the eligible set; no gender-based uplift |
| **Envoy** | Both IntentVectors (incl. private fields), Discretion Policies, tiers | Handshake transcript, two Briefs; ENVOY-tier proposals | Rules engine + small model for friction ranking; `llm-gateway` only to render Brief copy from codes | Six dimensions; ≤ 6 turns; no free text; private fields never emitted; never messages a human; cannot open a thread (FR-015, FR-055) |
| **Curtain** | Session context, geofence hits, device risk, discretion events | Policy tightening, suppressions, nudges | M8, zone matcher | May only **tighten** policy; broadening needs a member action (02 §6.4) |
| **Guardian** | On-device scores, profile/media uploads, reports, graph | Signals, freezes, holds, case escalation | M6a–e, M7, M7b, hash lists | Veto over all agents; no permanent action without a human; never reads message content server-side (§7) |

| Agent | Inputs | Writes | Tools | Hard constraints |
|---|---|---|---|---|
| **Aftercare** | Meet events | Aftercare records → reward | Scheduler | Never visible to the counterparty; never aggregated into a public rating |

### 3.1 Envoy negotiation algorithm

1. **Trigger:** on mutual intent (P2+), `core-svc/intent` publishes `agent.handshake.requested`.
2. **Load both sides** inside Envoy's memory scope. Private fields stay inside it.
3. **Score each dimension deterministically:**
4. *intent:* shape compatibility matrix.
5. *structure:* segment pair, veto mode, partner participation.
6. *boundaries:* set intersection of hard limits and desire tags; any `no` × `yes` collision is **blocking**.
7. *logistics:* overlap of availability windows (tz-aware), intersection of travel radii, notice, hosting. Windows come **only** from what the member entered, never from inferred routines (FR-067).
8. *discretion:* zone intersection (must be empty), reveal pace, device risk.
9. *verification:* both sides' `min_counterparty_tier` satisfied.
10. **Up to 6 turns** in schema form to settle open queries (02 §6.1). Unknown fields → `friction`.
11. **Emit asymmetric Briefs** (02 §6.2) built from codes; `llm-gateway` renders only localised copy for codes, with no counterparty free text.
12. **Encrypt** the transcript and both Briefs (30 d TTL). Publish `agent.handshake.completed`.
13. **Guardian** may veto at any step (`blocking: ["safety_hold"]`, no detail disclosed).

**ENVOY tier:** Envoy generates `envoy_proposal` items (candidate + rationale codes). An intent exists **only** after `POST /v1/envoy/proposals/{id}/approve` (D-04).

### 3.2 Herald — dynamic SEO and growth agent (v1.2)

Herald is a growth agent that sits **outside the member platform** (FR-074, FR-075, FR-077; D-21).

| Aspect | Specification |
|---|---|
| Deployment | Separate cloud account and VPC; no network route or credentials to IDENTITY-, PROFILE-, SAFETY- or BAN-DB, the event bus or Feast. Python typed state machines, like the other agents, with their own policy file and eval set |
| Inputs | Public web and SERP data (licensed SEO data provider), Google Search Console / Bing Webmaster, cookieless aggregate site analytics, the editorial style guide and claims-discipline rules (01 §15.1) |
| Tools | Keyword and topic clustering; content-brief generation; draft writing through the hosted frontier LLM (no personal data involved, so allowed per §2.1); on-page optimiser (titles, meta, headings, schema.org); internal-link graph builder; rank tracker; broken-link and redirect checker; outreach-draft generator; link-profile auditor |
| Dynamic loop | Weekly: pull rankings and Search Console data → find decaying or near-miss pages (positions 4–15) → propose refreshes, internal-link changes and new briefs → **editor approves** → publish through the CMS → re-measure. Monthly: link-profile audit and disavow review |
| Hyperlinks | Maintains the internal-link graph: hub and spoke per topic cluster, no orphans, ≤ 3 clicks from home, descriptive anchors, automatic repair of broken internal links |
| Backlinks | Finds link-earning opportunities (journalists covering privacy or security, relationship publishers, podcasts, unlinked brand mentions) and drafts pitches. A human sends every message. **It never buys links or automates outreach volume** |
| Guardrails | Claims discipline and "never cheat better" checks on every draft; a factual-claim checklist with sources; no fabricated statistics, testimonials or reviews; AI-assisted content is human-edited and adds original value (search-engine helpful-content and spam policies); it never targets or mentions real individuals |
| Outputs | Draft pages and refresh proposals in the CMS (state `awaiting_editor`); rank and visibility dashboards; an outreach queue. **Nothing is published without approval** |

## 4. Behaviour learning (Mirror)

### 4.1 Vectors

*Source: A §6.2*

```
IntentVector              stated    dim 128   source Cartographer  updated quarterly / on confirm
RevealedPreferenceVector  revealed  dim 256   source Mirror        nightly batch + hourly delta
DivergenceScore = 1 − cosine(project(IntentVector), RevealedPreferenceVector)
EffectiveVector = α · Revealed + (1 − α) · project(Intent)
α = σ(w · [interaction_count, days_active, divergence_stability, aftercare_count]),  α ∈ [0.15, 0.85]
```

- Divergence is used as a signal, not corrected away.
- The 0.15 floor on stated preference is a **product rule** (P5) and is enforced as a constraint, not left to the optimiser.

## 4.2 Privacy constraints

- **Inputs:** only events in 02 §8. **No message content.** Conversation features are computed on device from metadata.
- **Pseudonyms:** pseudo-subject IDs rotate every training window. Deleted members are dropped from serving immediately and from the next training run.
- **Raw events:** kept 180 d, then aggregated features only. Cohort reporting needs k ≥ 50.
- **Decay:** behavioural signals are time-weighted (default half-life 90 days) so old behaviour fades (FR-068).
- **Emergency lock** (FR-064) is handled by `identity-svc`: it verifies the emergency-code HMAC, revokes all sessions and authenticators' sessions, sets the profile to `vanished` and destroys all active reveal-grant wrapped keys.
- **Excluded from training:** protected or sensitive characteristics are never targets or inferred labels. Orientation, kinks and structure are used only as filters or features the member chose.

## 4.3 Model inventory

*Source: A §6.3, §19.3, §21*

| ID | Model | Type | Serving | Target |
|---|---|---|---|---|
| M1 | Intent classifier | Multi-label transformer, 9 classes | Batch + on edit | Macro F1 > 0.82 |
| M2 | Two-tower retrieval | Dual encoder, 256-d, ANN | < 40 ms p95 | Recall@200 > 0.91 |
| M3 | Cross-encoder ranker | GBDT + neural blend | < 120 ms p95 / 200 candidates | Mutual-reply AUC > 0.78 |
| M4 | Meet propensity | Survival (time-to-meet) | Nightly | C-index > 0.70 |
| M5 | No-show / flake risk | GBDT on on-device conversation features | Pre-meet | Precision@20% > 0.55 |
| M6a–e | Guardian behavioural family | §7 | **On device** (+ server graph) | §7.6 |
| M7 | Authenticity (bot/catfish) | Ensemble: image, text, device, graph | Sign-up + continuous | Catch rate > 0.93 |
| M7b | Ban-evasion graph | Style similarity, device/network adjacency | Server | Human review before any anchor extension |
| M8 | Discretion risk | Contextual bandit | Per session | Reduction in Burn invocations |
| M9 | Exposure fairness monitor | Gini + constraint solver | Hourly | Inbound Gini < 0.55 |

## 4.4 Reward

*Source: A §6.4*

```
R = 0.10·mutual_reply + 0.15·sustained_thread(≥6 turns, both sides) + 0.20·logistics_agreed
  + 0.35·meet_confirmed + 0.25·aftercare_positive
  − 0.40·report − 0.20·block − 0.15·no_show − 0.10·ghost_after_intent
  − 0.05·session_time_beyond_8min
```

Time in app is a **cost**. A model that improves AUC but lowers ΔR or the meet rate is rejected (§9).

## 4.5 Cold start and exploration

- **Turns 1–20:** content-based from the IntentVector; α = 0.15.
- **Exploration:** a permanent 15% of every slate, chosen by Thompson sampling.
- **New-profile boost:** 72 h decaying multiplier, capped by the inbound limiter.

- **Couples:** a blended vector from both partners plus a learned `joint_veto_model`. The true preference is the **intersection** of the two partners', not the union.

# 5. Matching and ranking (Broker)

## 5.1 Pipeline

*Source: A §7*

```
STAGE 0  HARD GATES (non-scored, non-bypassable, bidirectional)
  ├─ verification tier ≥ V2 and ≥ each side's min_counterparty_tier
  ├─ hard-limit intersection: zero collisions
  ├─ structure compatibility matrix (02 §2.3) and couple VC validity
  ├─ ExclusionRing (PSI + heuristics)
  ├─ partner_secret: never own other profile, partner's profiles or partner shield (FR-107)
  ├─ geofence exclusion zones (both sides)
  ├─ block graph / report holds / safety_state
  ├─ jurisdiction gate
  └─ visibility (incognito: only if caller already received their intent)
STAGE 1  RETRIEVAL (M2)          ~50k → 200     < 40 ms
STAGE 2  RANKING (M3 + M4)       200 → 40       < 120 ms
STAGE 3  CONSTRAINTS             exposure fairness, inbound caps, diversity, paid labels
STAGE 4  SLATE                   ≤ 18 cards incl. 15% exploration, 2–4 explanation codes each
```

## 5.2 Launch baseline (P1, before M2/M3 are trained)

Source B's transparent weighted score is the **P1 ranker** and later the fallback:

```
score = 0.24·reciprocal_attraction + 0.20·intent_fit + 0.15·discretion_fit
      + 0.12·communication_fit + 0.10·availability_logistics + 0.08·reliability
      + 0.06·novelty + 0.05·model_confidence − risk_penalties
```

## 5.3 Multi-person scoring (THIRD/QUAD)

Edge scores are computed for every required pairing. The entity score is a **max-min** (soft-min with $\tau \approx 0.1$ for differentiability) over required edges, so one person's strong interest cannot mask another participant's poor fit [B §6.2]. Each couple's veto rules (02 §9) and the solo's veto apply on top.

## 5.4 Exposure fairness

1. **Inbound cap:** 12 intents per 24 h by default (member-adjustable 4–40). Overflow is queued and re-scored, never delivered in a burst, and the cap is never revealed to the sender.
2. **Gini constraint:** M9 runs hourly per city and segment. If Gini > 0.55, the ranker's fairness penalty rises until it recovers. Fairness is a constraint, not the objective.
3. **Asymmetric outreach cost:** couple→solo costs 3× the Keys (15 vs 5), fully refunded on reply.

S4 inbound above the cap is a release-blocking regression (§9).

## 5.5 Hard-limit inviolability

Stage 0 is implemented as a pure function with **property-based tests**: for random entities and constraint sets, no output may violate a gate. These tests run on every PR touching `broker/` or `shared/contracts/`. A failing case is a P0 incident, even in staging [A §6.2].

# 6. Security, cryptography and discretion (server side)

## 6.1 Threat model

*Source: A §9.1*

| ID | Adversary | Likelihood | Primary server-side controls |
|---|---|---|---|
| A1 | Partner with physical access to the device | Very high | Device revocation, Burn endpoint, session TTLs, masked push payloads (no content in APNs/FCM) |
| A2 | Partner reading a shared bank statement | Very high | Neutral truthful descriptor, voucher path, 7-day pre-renewal notice |

| ID | Adversary | Likelihood | Primary server-side controls |
|---|---|---|---|
| A3 | Recognition through the shared social graph | High | ExclusionRing PSI + heuristics, progressive reveal, perturbation, geofence |
| A4 | Mass data breach | Medium / existential | E2EE, client-side media encryption, identity/profile split, cryptographic erasure, short TTLs |
| A5 | Targeted extortion by a counterparty | Medium | Watermarked media, screenshot signals, M6e freeze, evidence preservation |
| A6 | Civil discovery in divorce proceedings | Medium | Minimal retention, erasure, published legal-process policy, transparency report |
| A7 | Insider | Medium | Zero standing access, dual-authorised break-glass, WORM audit, no content access by design |
| A8 | Face-search de-anonymisation | Medium, rising | Adversarial perturbation on public-tier photos; private photos never served unencrypted |

## 6.2 Cryptographic design

*Source: A §9.2*

- **Messaging:** MLS (RFC 9420). The server is the Delivery Service and Authentication Service: it stores key packages and ciphertext only. It **cannot** read content.
- **Media:** the client generates a per-media AES-256-GCM key; ciphertext goes to the object store; the key is wrapped per recipient and delivered in band. **Revoke = destroy the wrapped key.**
- **Identity split:** IDENTITY-DB and PROFILE-DB use separate credentials and KMS domains. The join key is `HMAC(identity_id, pepper_join)`, computed in `identity-svc` from an HSM-held pepper. Neither dump alone identifies anyone.
- **Peppers** (`contact`, `join`, `device`, `ban`) are HSM-resident and non-exportable, with yearly rotation and dual-run.
- **Field encryption:** sensitive PROFILE-DB columns (`bio_ct`, `policy_ct`, zones, transcripts, Briefs) use envelope encryption under the **member's data key**, which is derived from the member's root key in KMS.

## 6.3 Erasure (< 60 s p99)

`DELETE /v1/account` runs `deletion_job`:

1. Mark the profile deleted and remove it from Qdrant and slates **synchronously**.
2. Revoke all devices and tokens.
3. **Destroy the root key** (KMS schedule-deletion with the minimum window, plus immediate disable; the HSM-wrapped data key is zeroised).
4. Delete rows and object keys (best effort; they are already undecryptable).
5. Drop features from Feast online and mark the pseudo-subject for training exclusion.
6. If no ban applies, delete `anchor_candidate`. Revoke all authenticators and request deletion of the provider-held B2 login reference; the provider's deletion receipt is attached to the proof (it may arrive after the 60 s on-platform erasure).
7. Write a signed `completion_proof` (key-destruction receipt + purge summary).

**Exceptions** (02 §7): ban anchors, legal hold, Panic preservation. Each is written to the job record.

## 6.4 ExclusionRing PSI (server half)

*Source: A §9.3*

- OPRF over ristretto255 (RFC 9497). The server key `k` lives in the HSM.
- Round 1: the server evaluates blinded points.
- Round 2: the client uploads unblinded PRF outputs. The server intersects them with the member-identifier PRF set (each member's own contact hash, PRF-evaluated at enrolment) and writes **bidirectional** `exclusion_ring` rows.
- The server **returns nothing** about the intersection, and stores no uploaded PRF outputs beyond the intersection computation.
- Rate-limit enrolment (contacts ≤ 5,000 per call; ≤ 4 calls per day) to block membership-oracle attacks.
- **Heuristic suppression** (suppress only, never notify): shared payment fingerprint, sustained shared home geohash, device-graph adjacency, shared Wi-Fi BSSID history (only where the client opts in).

## 6.5 Authorisation (ABAC)

Every read evaluates `(requester, resource, reveal_grant, block graph, ExclusionRing, discretion version, safety_state, jurisdiction, tier)` in a central policy engine (OPA/Cedar) shared by all `core-svc` modules [B §9]. Denials

are indistinguishable from not-found (02 §5.10). Policy tests are generated per read path; the Privacy Auditor runs them continuously against staging and production canaries.

## 6.6 Engineering non-negotiables

*Source: A §12*

- No third-party analytics, advertising or attribution SDK (server or client); NFR-09.
- Zero standing production data access; break-glass needs dual authorisation and writes `staff_access_log` (WORM); NFR-10.
- Staff cannot read message content; this is an architectural property.
- Quarterly external pen test; annual red team scoped to A4/A7. OWASP ASVS L3.
- 72-hour breach playbook, rehearsed twice a year, with specific runbooks for outing, sextortion, intimate-media leak, insider abuse, account takeover and mass breach [B §9].

## 6.7 Authentication — account holder only (v1.2)

Implements 02 §3.3 (FR-056–FR-062, D-16).

- **WebAuthn relying party** in `identity-svc`. `userVerification=required`. Attestation is verified for native authenticators; the AAGUID allow-list is maintained.
  - B1 credentials must be platform authenticators flagged `bio_enrolment_bound`. The native apps send an App Attest / Play Integrity statement that the key was created with biometric-only access control and invalidation on enrolment change.
  - On the mobile PWA the browser cannot prove biometric-only verification. The server therefore requires B2 on **every** PWA login and on every step-up, while native B1 attestation lets step-ups inside an existing session use B1 alone, except for device add and recovery.
- **Login state machine** (Redis, 5 min TTL): `begin → factor1_ok → (liveness_pending | approval_pending) → session`. **No session token exists until both factors pass.** Partial states are bound to the DPoP key that started them.
- **Surface decision** is made on the server: native attestation → `mobile_app`; a registered platform authenticator on a mobile UA with no attestation → `mobile_pwa` (B1 + B2); anything else → `desktop` (F1 + F2). An unrecognised authenticator falls back to the strictest path available.
- **B2 provider adapter:** shares its interface with the two age-assurance providers (02 §3.1). Uses a randomised challenge and a 1:1 match against `login_reference`. Only `{match: bool, score, pad_pass: bool}` comes back to TRYST; no image or template. **Fail closed:** a provider outage blocks new logins, not existing sessions. An in-session unlock never needs B2.
- **Cross-device approval (F2):** the QR code carries a single-use 60 s token bound to the desktop's DPoP key and coarse location. The approving app shows the desktop's browser, approximate city and time, and needs a fresh B1 assertion. No push notification is sent.
- **Risk controls:** rate limits per contact hint, device and IP; lockout escalation (5 failures → 15 min; 10 → recovery only). Every success and failure writes `auth_event`. A new-device login sends a masked in-app notice to the other registered devices. Impossible-travel and new-AAGUID signals force recovery-grade checks.
- **Recovery:** B2 + fresh V2 whose HMAC `anchor_doc` must equal the stored candidate (02 §4.1), then a 24 h hold. The hold is cancellable from any registered device and is never bypassable by staff (no break-glass path exists for authentication).
- **Lawful basis:** B2 is biometric processing for unique identification (Art. 9). It uses explicit consent `biometric_login`, recorded in the ledger. The accessible alternative (D-17) keeps the consent freely given (ToS Q14).
- **Cost:** about 1–2 B2 checks per mobile MAU per month (30 d sessions plus new devices and step-ups). At an assumed £0.10–0.30 per check this is £0.10–0.60 per MAU per month; it is added to the infra line in 01 §12. Replace with the vendor quote in P0.

## 6.8 Source B §9–§10 control coverage (v1.2)

Every control in the founder's Security and privacy doctrine (§9) and Trust, safety and misuse controls (§10) (07) maps to an implementation.

| Source B control | Implementation |
|---|---|
| Article 6 + Article 9 + DPIA + consent records + transfers | 01 §14.2; consent ledger (FR-040); UK/EU residency (NFR-06) |
| Minimisation | FR-002; age band, not DOB; geohash-5; no contact upload (PSI only) |

| Source B control | Implementation |
|---|---|
| Separation (identity, profile, media, analytics, billing) | Isolated clusters and peppered join (§6.2); media-svc and ciphertext-only store; ClickHouse pseudonymous; `billing_ref` only in IDENTITY-DB |
| Encryption, key rotation, access telemetry | §6.2; **NFR-18** |
| Authorisation (ABAC) | §6.5; FR-005; **FR-070** role separation |
| Private media | Signed short-lived access + recipient-bound wrapped keys (FR-018); no public CDN; watermarking; revocation < 5 s (NFR-04); **FR-069** format allow-list and re-encode on device, server malware scan for public tier |
| Payments | Tokenised PSP, neutral truthful descriptor (§10); **FR-070** finance staff cannot browse profiles |
| Admin | Zero standing access, dual-approved break-glass, WORM log (NFR-10); **FR-071** dual approval for intimate evidence |
| Deletion | §6.3; backups 35 d disclosed (02 §7); legal holds narrowly scoped (`report_case.legal_hold`) |
| Incident readiness | §6.6 runbooks: outing, sextortion, intimate-media leak, insider abuse, account takeover, mass breach |
| Assurance | ASVS L3 / MASVS L2+R (NFR-08); threat model (P0); **NFR-19** bug bounty + annual privacy audit |
| Fake profiles / bots | §8 L1, M7, M7b, fake-profile stack, human review |
| Blackmail / sextortion | M6e freeze, evidence preservation, victim resources, Action Fraud path (§7.3) |
| Stalking / doxxing | Coarse location + rotating cells (FR-065); visibility (FR-009); **no free-text member search exists**, and slate size is capped; M6d; targeted network blocks as an enforcement action only (VPNs are scored, never blanket-blocked); M7b repeat-account detection |
| Non-consensual media | Hash matching where lawful (D-10, StopNCII); **FR-069** upload warning; reveal/revoke controls; 1 h takedown; sanctions |
| Coercion in threesomes | Independent accounts and VC (FR-006); per-person approval and veto; private withdrawal from group threads (02 §9); either partner dissolves; no "couple owner" |
| Underage access | V2 gate (FR-001), re-check triggers (02 §3.2), 15 min escalation and mandatory reporting |
| Commercial sex / trafficking | No member-to-member payments; solicitation detection; specialist review; jurisdictional reporting (FR-037) |
| Bias / predatory targeting | No advertising at all; exposure audits (M9, fairness audits); **FR-072** protected-trait harassment rule |
| Retaliatory reports | Reporter-reputation scoring; evidence review; appeal; no permanent ban from one uncorroborated report (§8) |

# 7. Guardian — safety models (M6a–M6e)

## 7.1 Central problem

*Source: A §21.1*

**Consensual power exchange looks identical to coercion at the token level.** Guardian therefore classifies the **trajectory** of a conversation, not its content:

```
consent_state(t) = f(explicit_affirmations, explicit_refusals, limit_declarations,
                     enthusiasm_markers, reciprocity, initiative_balance)
RISK fires on:   refusal(t) ∧ escalation(t+k) · limit_stated(t) ∧ limit_approached(t+k)
                 disengagement(t) ∧ persistence(t+k) · sustained asymmetric initiative
RISK never fires on: intensity, vocabulary, kink taxonomy, power-exchange framing, explicitness
```

Any model that separates consensual from coercive only through topic vocabulary is rejected at eval.

## 7.2 Models and thresholds

*Source: A §19.3 L4, §21.2*

| ID | Target | Threshold action |
|---|---|---|
| M6a | Coercive control (isolation, monitoring, guilt leverage, secrecy framing imposed on the counterparty, identity erosion) | > 0.75 → queue; > 0.92 → thread freeze pending review |
| M6b | Boundary violation (escalation after a refusal, repeated declined request, approaching a hard limit, recasting a "no" as a "maybe") | > 0.70 → send-block + warning; 2nd → strike; 3rd → suspend |

| ID | Target | Threshold action |
|---|---|---|
| M6c | Off-platform pressure | > 0.65 → caution banner to the counterparty; feeds M5 and M6a |
| M6d | Identity/location pressure | Auto-redact in transit (client) + banner + strike on repeat |
| M6e | Image coercion and sextortion | Any hit > 0.60 → **immediate freeze**, human within 1 h. Tuned for recall |

**Serving:**

- M6a–e run **on device** for E2EE threads, inline < 80 ms p95. Only a score + reason code + model version is sent to `/v1/guardian/signals`.
- Server-side: cross-account correlation on reason codes (the same script used against many people), M7/M7b, and profile/media moderation.
- Scores are calibrated (isotonic) so moderators can triage by probability. Thresholds are set per model, locale and segment, and reviewed monthly against the overturn rate.

## 7.3 Escalation matrix

*Source: A §8.4*

| Signal | Automatic | Human SLA | External |
|---|---|---|---|
| Suspected minor | Immediate full freeze of both accounts; content preserved under legal hold | 15 min | Mandatory report; law-enforcement liaison |
| Intimate image abuse / NCII | Media quarantine, hash to StopNCII, sender frozen | 1 h | Takedown log; victim-support routing |
| Sextortion / coercion | Thread freeze, evidence preserved, victim safety banner | 1 h | Action Fraud referral path |
| Threat of violence / stalking | Account suspended, mutual geo-suppression, device ban | 1 h | Police referral on request |
| Romance fraud pattern | Payment-link stripping, shadow-limit, cohort sweep | 4 h | Bank/PSP intelligence sharing |
| Commercial sexual services | Immediate removal | 4 h | — |
| Harassment (M6 > 0.9) | Send-block, warning, strike | 24 h | — |

**Evidence.** Server-side evidence exists only when a member reports and **chooses** to disclose decrypted content, or when Panic preserves it. Reporter identity is stripped before evidence reaches labelling.

## 7.4 Training data

*Source: A §21.3–21.4*

**Permitted sources only:**

- D1: expert-authored synthetic corpus — 12k threads, **matched consensual/coercive pairs**, written with DV and kink-education specialists.
- D2: published taxonomies, used as the label schema.
- D3: public toxicity transfer, **not** as a source of coercion labels.
- D4: reported content with separate, revocable training consent (from P3).
- D5: active learning on the moderator queue (overturns are the most informative labels).

**Never:** scraped platform conversations without a lawful basis, purchased corpora of uncertain provenance, or survivors' disclosures collected for another purpose.

**Annotation:**

- Triple annotation on the coercion classes; Krippendorff's $\alpha > 0.70$ to accept a batch.
- Senior adjudication.
- Annotator welfare budgeted: rotation caps, clinical supervision, exposure limits on M6e material.

**Bootstrapping:**

| Phase | Data | Expected performance |
|---|---|---|
| P1 | Rules + D3 | recall ~0.55 / precision ~0.30 |
| P2 | + D1, D2 | ~0.82 / 0.61 |
| P3 | + D4, D5 | ~0.91 / 0.74 |
| P4 | Per-language evaluation | |

## 7.5 Profile and media moderation (server side)

Public-tier profile photos and bios are **not** E2EE and are moderated on the server:

- EXIF strip
- AI-generation detector and reverse-image search on **every** upload
- face consistency across the photo set
- C2PA provenance where present
- nudity classification (explicit content is web-only and V2-only)
- CSAM hash matching (IWF/NCMEC lists) before storage
- adversarial perturbation for A8

Private-tier media is client-encrypted; the sending client runs on-device checks before encrypting, including hash matching against licensed lists where licensing permits (D-10).

## 7.6 Evaluation gates and limits

*Source: A §21.5–21.9*

**Ship gates:**

| Gate | Requirement |
|---|---|
| Matched-pair separation (hard gate) | AUC > 0.85 |
| M6b | Recall > 0.90 at FPR < 0.03 |
| M6e | Recall > 0.95, precision ≥ 0.35 |
| Dialect FPR parity | Within 1.5× across groups |
| Counterfactual gender swap | Mean score delta < 0.05 |
| Appeal overturn | < 8% |
| Moderator agreement | > 75% |

Fairness slices: dialect/register (AAVE, MLE, regional), non-native English, gender, orientation/structure across S1–S6, age band. Audited quarterly.

**Adversarial resistance:**

- Quarterly red-team retainer.
- Rolling windows across messages and sessions.
- Cross-account correlation.
- Weekly drift checks. A sudden drop in positives means an evasion technique has been found, not that behaviour improved.

**Guardian never:**

- takes a permanent action without a named human;
- scores protected or inferred characteristics;
- produces a public or counterparty-visible score;
- reads message content on the server;
- flags on vocabulary alone.

## 7.7 Fake profiles and criminal misuse (v1.3)

*Founder request (11 Oct 2026): block fake profiles, keep members safe when meeting strangers, and keep criminals, groomers and illegal activity off TRYST.* No platform can guarantee safety or screen out every criminal: most people who harm others have no record, and TRYST cannot see anyone's criminal record (ToS 5.2). The design therefore makes fake identities expensive, catches **patterns of behaviour**, and gives members strong tools at the moment of risk. Every layer below is either already specified (marked) or added in v1.3.

**A. Fake and duplicate profiles**

| Layer | Control | Status |
|---|---|---|
| Real person | Liveness with randomised challenge; deepfake detection on selfie and video | Specified (§8) |
| Real adult with a real ID | ID document with NFC chip read where available, face matched to the document (FR-094) | v1.3 |
| No camera injection | V2 capture only in the native app with platform attestation, or through a provider certified for injection-attack detection (CEN/TS 18099); on the web, V2 hands off to the phone by QR (D-44, FR-101) | v1.3 |
| One person, one account | ID-document anchor indexed across active accounts: a second account on the same document is refused; lost access goes through recovery, not a new account (D-41, FR-097; `backend/internal/admission/unique.go`) | **Built** |
| No banned returnees | Ban anchors on document, device and card (§8 L2) | Built |
| Real photos only | Face-matched main photo; AI, borrowed and third-party images refused (FR-093) | Built (rules) |
| Account not sold or lent | Every mobile sign-in repeats the face match (B2) | Built |
| Cost of faking | £9.99 deposit; 3 free intents a week; Keys per intent | Specified |
| Bots and farms | Sign-up bursts, shared device or card, referral-chain anomalies, behaviour cadence (§8) | Specified |

**B. Control networks: trafficking, pimping, scam farms.** One controller running several profiles is the common signature. A card may pay for at most two accounts (a member and their verified partner); a third is refused, and a card or phone shared with a non-partner is sent to review (`unique.go`). Further signals for review, never automatic bans: the same profile text or photos style across accounts, one account always answering for another, logistics always arranged by a third party, frequent city hopping. THIRD and QUAD use couple verification (FR-095), so a "couple" cannot be a cover for one person presenting another.

**C. Profile text.** Names, bios and couple descriptions are screened before anyone sees them (FR-098; `backend/internal/profile/text.go`): contact details and payment or crypto details are refused (they push people off-platform, where scams and coercion happen); commercial sex, drug supply and **any reference to a minor or sexualisation of children** are refused and sent to Trust & Safety within 15 minutes. The same test vectors drive the on-device Guardian for messages.

**D. In messages (on device; the server never reads them).** New Guardian models alongside M6a–e (FR-102):

| Model | Detects | Action |
|---|---|---|
| M6f Romance and financial fraud | Requests for money, gift cards or crypto; investment pitches; sob-story escalation; moving to another app early | Warning banner to the recipient; payment links stripped; pattern across many recipients → account review (romance-fraud row, §7.3) |
| M6g Child safety | Interest in a member's children, requests for photos of children, attempts to arrange access to children, age-play involving minors | Immediate freeze, human within 15 min, report to the police and NCA where required (suspected-minor row, §7.3) |
| M6h Exposure extortion | Threats to tell a partner, family or employer; demands linked to secrecy | Thread freeze, evidence preserved with the victim's consent, victim support; permanent removal on confirmation |
| On-device image check | An image that appears to contain a child is **never sent**; known CSAM hashes are blocked and reported | Blocked on the sender's device |

**E. Meeting strangers.** Safe Meet, Share My Plan, check-ins and Panic are specified (01 §8.3). v1.3 adds: in-app video call before a first meet, which a member can make a hard limit; an on-device warning when a first meet is at a private address (the venue is never sent to TRYST); the **door check** (both phones show the other's verified photo and the same three words, FR-099); a **duress PIN** that looks like a normal check-in but silently raises the alarm; escalation to the trusted contact, then, if the member opted in, to TRYST's 24/7 safety team with location for that meet only (FR-100; `backend/internal/meet`); Panic guidance including the UK Silent Solution (dial 999, then press 55 if you cannot speak).

**F. After a meet.** The private aftercare prompt asks whether the member felt safe. Two "felt unsafe" answers about the same member from different people within 90 days send that member to review; one answer starts a quiet watch. Never shown to the counterparty, never a public rating (FR-104).

**G. Working with the authorities** (FR-105). A lawful-request process with legal review; emergency disclosure when life is at risk, approved by the DPO and Head of T&S; preservation on request; mandatory reporting of child sexual

abuse material to the NCA and IWF; counts published in the transparency report. Court orders (SHPO, restraining or non-molestation) and police notifications are grounds for immediate permanent removal (01 §8.2).

**H. Launch risks closed (v1.3).** (1) *Message-safety models:* a deterministic on-device baseline ships first and must pass every labelled vector; trained models replace a rule only through the gate in D-47 (`backend/internal/guardian`, `shared/contracts/vocab/guardian_vectors.json`). (2) *24/7 safety line:* staffed from launch by a contracted alarm-receiving centre with on-call backup, 60-second acknowledgement and heartbeat failover (D-48, `backend/internal/meet/escalation.go`). (3) *Fake camera feeds:* certification-gated provider routing; native-app capture with attestation when no injection certificate is on file; V2 fails closed without a liveness certificate (D-49, `backend/internal/assurance`).

# 8. Admission control (L1–L5)

| Layer | Server responsibilities |
|---|---|
| **L1 Identity binding** | Liveness with a randomised challenge (provider); ID-document match through the provider; device attestation verification (App Attest / Play Integrity), emulator/root detection; payment-instrument fingerprint (token); £9.99 deposit. VPN/datacentre IPs are **scored, never blocked** |
| **L2 Ban anchor** | At V2, `identity-svc` stores `anchor_candidate` HMACs (E-02). On a permanent ban (human decision, `reason_code`), the candidates are copied to BAN-DB. On `auth/verify` (new identity), attestation and payment checks, and V2 completion, every anchor is checked; a match → **silent refusal** with a generic error that never names the anchor. Biometric anchor only if counsel confirms a lawful basis (D-08). A successful appeal destroys the anchors |
| **L3 Attestation** | Conduct declaration stored in the consent ledger; Basic DBS verified through the issuing route (no PDF uploads) and stored as `{dated_fact}`; Clare's Law content is static, with **no field** for the outcome |
| **L4 Behavioural** | Guardian M6a–e (on device), M7b ban-evasion graph → shadow-limit → human review → anchor extension |
| **L5 Consortium** | Interface built behind a feature flag: anchors + reason code only. Disabled until competition-law and data-protection opinions (ToS Q8) |

**Fake-profile stack [A §19.4]:**

| Stage | Checks |
|---|---|
| Sign-up | Liveness · ID match · GAN/deepfake detection on selfie and video · attestation · deposit |
| Media | C2PA · reverse-image · EXIF anomaly · face consistency · AI-generation classifier on every upload |
| Network | Score, never block |
| Graph | Sign-up bursts · shared device or payment · referral-chain anomalies |
| Behaviour | Typing cadence · templating · copy-paste · latency uniformity · slate-interaction entropy |

Detectors are refreshed quarterly; a static detector is a known future failure.

**Enforcement pipeline (FR-035):** warn → shadow-limit → suspend → permanent + anchor → law-enforcement referral. Grounds g1, g3 and g4 go straight to permanent. `enforcement.decided_by` is required for `permanent` (DB constraint). Appeals are assigned to a different reviewer (enforced in the console) within 10 working days. Reporter-reputation scoring down-weights coordinated or retaliatory reports; one uncorroborated report never leads to a permanent ban [B §10].

# 9. MLOps and release gates

**Model ship gates:**

- Offline replay on held-out cohorts measuring **ΔR**, not AUC alone.
- Shadow → 5% → 25% → 100% rollout, with automatic rollback on report-rate or S4-churn regression.
- Model card + DPIA annex for each model.

**Agent gates:**

- 400-case golden set per agent: Envoy negotiation fidelity, Guardian adversarial recall, Cartographer extraction accuracy.
- Prompt-injection corpus.
- Run on every PR touching a prompt, policy file or agent code.

**Audits:**

- Quarterly fairness audit per protected characteristic and segment.

- Monthly counterfactual audit for popularity collapse (the 15% exploration floor is the structural defence).

**Privacy Auditor [B §5]:** continuous probes. It **blocks a release** if any of the following holds:

| Probe | Blocks release if… | Mapped to |
|---|---|---|
| Media access | Media is reachable without an active grant | G-NG-1 |
| Erasure | Erasure proof is missing or slow | G-NG-2 |
| Location | Location can be triangulated (distance-band oracle tests) | G-NG-3 |
| Tier | Any gated endpoint is reachable below V2 | G-NG-4 |
| Couple co-sign | A same-device co-sign is accepted | G-NG-5 |
| Hard gates | Any hard-gate property test fails | G-NG-7 |
| Client SDKs | A third-party SDK appears in a client SBOM | G-NG-8 |
| Staff access | Any staff role can reach message plaintext | G-NG-9 |

# 10. Commerce

- **PSP (v1.2): Stripe** is the primary processor, subject to Stripe's written approval in P0 (D-22). A dedicated high-risk acquirer (MCC 7273, Visa IRP Tier 1) is integrated as the **backup MID from day one**. Card data is tokenised and never touches TRYST.
- **Payment abstraction:** `commerce` talks to a `PaymentProvider` interface (`create_checkout`, `create_subscription`, `cancel`, `refund`, `webhook_verify`, `descriptor`). The Stripe adapter is implemented first and the high-risk acquirer adapter second. Entitlements live in `commerce.entitlement` and never depend on a single processor, so switching is a configuration change with token migration where the processors support it.
- **Stripe usage:** Checkout Sessions / Payment Element (web only; native follows D-11); Billing (Products/Prices for TRYST+, ENVOY, DUO, GHOST; one-off Prices for Keys packs and the £9.99 deposit); Customer Portal configured for one-step cancel with no retention flow; Radar rules for card testing and burner patterns (feeding L1); Stripe Tax for UK/IE VAT; refunds through the API to the original method within 14 days (ToS 16.7).
- **Statement descriptor:** neutral, truthful prefix with a customer-service URL, set per account and per charge suffix; it never includes "TRYST" (ToS 16.2).
- **Webhooks:** `POST /v1/billing/stripe/webhook` (sys), with signature verification, idempotent processing of event IDs, and entitlement updates only from verified events. Stripe metadata carries **only** the opaque `billing_ref`: no profile ID, segment, intent or anything that reveals the nature of the service beyond the product name.
- **Data minimisation at Stripe:** the Stripe Customer is created with the billing email chosen by the member (it may differ from the contact handle) and no name unless the card network requires it. Stripe is a processor for payment data only and receives no Article 9 data.
- **Descriptor:** neutral and truthful, with a customer-service URL; enforced per MID.
- **Vouchers:** offline codes redeemed through `/v1/vouchers/redeem`, single-use, with rate limits and fraud scoring.
- **Subscriptions** (TRYST+, ENVOY, DUO, GHOST add-on): state machine with pre-contract information, cooling-off notice (CCR 2013), pre-renewal email (≥ 7 days), one-step cancel and end-of-contract notices. Built to the full DMCC regime now.
- **Keys ledger:** double-entry, idempotent. Intent spend is held and **refunded on reply**. Keys don't expire while the account is open. They are refunded on removal unless the ground is in ToS cl. 17.3, and are never forfeited before an appeal ends.
- **Chargebacks:** Ethoca/Verifi alerts → auto-refund rules. Alert at 0.5%; hard stop review at 0.65%.
- **Payment fingerprint** feeds L1 and the ExclusionRing heuristics (suppress only).
- **App-store purchases:** web-first. Where a store build must offer in-app purchase, entitlements are unified in `commerce.entitlement` (D-11).

# 11. Compliance engineering and operations

- **Consent ledger:** append-only, hash-chained (`entry_hash = H(prev_hash ‖ record)`); verified nightly; exportable on SAR.
- **DSR service:** SAR export, rectification, erasure (§6.3) and portability, all built in sprint one [A §14.2].
- **OSA:** report SLAs are measured and published. Transparency data is produced from SAFETY-DB (FR-052). A named accountable manager owns the on-call escalation.
- **Article 22:** human review path for suspensions; decisions record `decided_by`.
- **Jurisdiction gate:** GeoIP at the edge + sign-up declaration + travel detection from coarse client location. The block list is versioned config, and each enabled market references its legal opinion ID.
- **Legal process:** published policy. Warrants or court orders are required. The member is notified where lawful. Only what exists is disclosed (ciphertext and minimal metadata).
- **Observability:** OpenTelemetry. Logs carry no content and truncate IPs at ingest (NFR-11). SIEM, plus anomaly alerts on staff access.

- **SLOs:** NFR-01, -02, -05, -13.

## 12. Backend backlog by phase

| Phase | Epics (backend) | Definition of done |
|---|---|---|
| **P0** (M0–M2) | Threat model; architecture review; assurance-provider adapters (×2) spike; PSP + backup MID integration spike; IaC landing zone (eu-west-2), KMS/HSM, isolated clusters; contracts repo (OpenAPI + Protobuf) generated from 02 | Threat model signed off; G-P0 legal items done by others |
| **P1** (M2–M6) | `edge-gateway` (DPoP, gates); `identity-svc` (sign-up OTP, devices, **passkeys + two-factor login, step-up, recovery**, assurance, anchors, join HMAC); `core-svc` modules: profile, couple (VC), intent (Keys, caps), discretion (policy, zones), reveal, threads (MLS DS), meet, consent, deletion, commerce (TRYST+, Keys, deposit, vouchers); Cartographer; Broker P1 (Stage 0 + weighted baseline); Curtain v1; Guardian server (signals intake, escalation, M7, media moderation); Aftercare; `safety-svc` + trust console; Privacy Auditor probes; DSR | FR-001–009, 011–014, 016–023, 026–044, 046–047, 049–051, 054, 056–062, 064–065, 069–072 met (backend side); NFR-01/02/05/06/10/11 met; no-go list clear; control cohort running (no Envoy) |
| **P2** (M6–M10) | Envoy (agent + Briefs); Mirror v1 (M1–M4, α, reset/insights); ExclusionRing PSI; Guardian P2 models (D1/D2); FR-024/025 | **G-P2:** meets per intent sent ≥ +40% vs control |
| **P3** (M10–M15) | DUO, ENVOY, GHOST billing; ENVOY proposals; travel mode; DBS attestation; transparency report; 24/7 T&S tooling; scale to 25k verified | G-P3 |
| **P4** (M15–M24) | Multi-market jurisdiction config; localisation; per-language Guardian; consortium interface (if cleared); scale to 150k | G-P4 |

# 04 — TRYST Frontend Specification v1.1

Part of the TRYST v1.1 baseline. Consumes the contracts in 02. Product intent is in 01.

## 1. Scope

This document covers the native iOS and Android apps, the web PWA, the shared client crypto core, on-device models, UX flows, discretion and safety UI, copy rules, accessibility and store compliance. It does not redefine API shapes, enums or retention; those live in 02.

## 2. Two-surface strategy

Apple Guideline 1.1.4 and Google Play's age-restricted and anonymous-chat policies make two surfaces a **requirement** [A §14.3]:

| | **Native store builds (iOS, Android)** | **Web PWA** |
|---|---|---|
| Role | Discreet companion: discovery, Briefs, threads, meets, safety, discretion | **The full product** and the **primary revenue surface** |
| Content | **Sanitised.** No nudity, no explicit imagery or copy in the app, listing or screenshots | Explicit media allowed **behind V2 only**, never shown during verification |
| Messaging | Matched only — never random or anonymous chat | Same |
| Billing | Web-first; in-app purchase only if a store requires it (D-11) | All billing, vouchers, deposit |
| Positioning | "Discreet dating"; 18+; Play Console minor-blocking on; Apple age questionnaire done | Full brand |
| Discretion strength | **Strongest:** decoy skin, duress PIN, Secure Enclave/StrongBox, FLAG_SECURE, backup exclusion | **Reduced** (browser limits): quick exit, neutral title/favicon option, session lock, private-browsing guidance |

Explicit media sent from the web is delivered to native clients as a placeholder ("View on web"). It is never rendered in the store build (FR-051).

**Store basics** that cause most rejections: in-app account deletion, a web deletion link, privacy manifests, a working reviewer demo account (sanitised seeded data), and a Data Safety form that exactly matches the Privacy Notice.

### 2.1 Public marketing site and SEO surface (v1.2)

- **Separate host** from the app (e.g., `www.` marketing vs `app.` product) so search indexing, caching and analytics never touch member surfaces (FR-076).
- **Next.js SSG/ISR** with a headless CMS fed by Herald drafts after editor approval (FR-073, FR-074). XML sitemaps, canonical tags, hreflang, schema.org, clean URLs and breadcrumb navigation. City pages exist only for launched or waitlisted cities and carry real local content (waitlist status, safety resources), never doorway pages.
- **Performance and accessibility:** Core Web Vitals and WCAG targets in NFR-20. Brand tokens and the logo per §7.2.
- **Discretion on a public site:** quick exit, a neutral-favicon option, no third-party trackers or pixels, and cookieless analytics. "Join" leads to the app origin, which is `noindex`.

## 3. Client stacks

*Source: A §12*

| **Surface** | **Stack** | **Notes** |
|---|---|---|
| iOS | **Swift / SwiftUI**, iOS 17+ | Keys in Secure Enclave; `NSFileProtectionComplete`; files excluded from backup; alternate app icons for the decoy |
| Android | **Kotlin / Jetpack Compose**, Android 10+ | Keys in StrongBox where present (TEE fallback); `FLAG_SECURE`; `allowBackup=false` and data-extraction rules; activity-alias for the decoy |

| Surface | Stack | Notes |
|---|---|---|
| Web | **Next.js PWA** (installable), TypeScript | No third-party scripts; strict CSP; non-extractable WebCrypto keys in IndexedDB; service worker caches no personal data |
| Crypto core | **Rust** (OpenMLS, AES-GCM, OPRF client) compiled to Swift (UniFFI), Kotlin (JNI) and WASM | One audited implementation across all three surfaces |
| On-device ML | Core ML (iOS), TFLite/NNAPI (Android), ONNX Runtime Web (WASM/WebGPU) | Guardian M6a–e, nudity pre-send check, conversation-feature extraction |
| API client | Generated from `shared/contracts/openapi` | DPoP proof per request, signed with the device key |

**React Native is not used.** Source A rejects cross-platform shells because Secure Enclave/StrongBox, FLAG_SECURE, screenshot detection, decoy skin and backup exclusion are unreliable through them (E-07).

**Client non-negotiables:**

- **NFR-09** — no third-party analytics, advertising, attribution or crash SDKs that send data off-platform. Crash reporting is self-hosted with scrubbed payloads.
- **No social login. No contact upload** — contacts are only ever blinded on device for PSI.

# 4. Screens and flows (by loop)

## 4.0 Sign-in — account holder only (v1.2)

Implements 02 §3.3 (FR-056–FR-062).

**Native app and mobile PWA — two biometric factors:**

1. **B1:** a system biometric prompt (Face ID / Touch ID / BiometricPrompt `BIOMETRIC_STRONG`) unlocks the device-bound passkey. Device-passcode fallback is **disabled** for login.
2. **B2:** an in-app liveness capture with a randomised challenge (turn your head, read a short phrase) from the provider SDK (native) or web flow (PWA). The camera view uses brand colours with the `night` background. No logo is shown if a decoy skin is active.
3. The session is issued only after both succeed. Failure copy never says which factor failed.

**Desktop browser / desktop PWA — two factors:**

1. **F1:** the browser passkey prompt (Windows Hello / Touch ID / security key).
2. **F2:** a QR code appears on screen. The member opens TRYST on their phone, goes to **Approve sign-in**, scans it, and confirms with B1. The phone shows the desktop's browser, approximate city and time. Nothing is pushed to the phone's lock screen. Alternative: tap a second registered security key.

**Other screens:**

- **Biometric change detected:** "Your phone's fingerprints or face settings changed, so we've signed you out to protect your account." Then a full B1 re-registration + B2 login.
- **Unlock** (existing session): biometric or PIN per FR-027. The duress PIN opens the decoy.
- **Step-up sheet** for sensitive actions (02 §3.3). **Burn, Panic, report, block, cancel and delete never show a step-up.**
- **Recovery:** liveness → age/ID check with the same document → a 24 h countdown that any registered device can cancel → new passkey. The copy explains that support cannot bypass this.
- **Consent:** a separate `biometric_login` explicit-consent screen before V1, alongside the Article 9 consent, with a link to the accessible alternative (D-17).

## 4.1 Loop A — Quiet entry and intake

1. **Neutral landing / first launch.** On native, the member picks a decoy skin and neutral name at first launch.
2. **Contact (V0).** Email or phone OTP. Device key generated in the secure element; attestation sent.
3. **Discretion setup** (before any personal data): app PIN/biometric, duress PIN, notification mode (default **off**), Burn gesture, home/work zones (map picker → geohash-6 cells), and an honest **"What discretion can't cover"** card (P9).
4. **Liveness (V1)** through the provider SDK/web flow.
5. **Age assurance (V2)** with the ID match, then the **conduct declaration** (separate screen, logged) and the **Article 9 explicit consent** (separate from the ToS accept).
6. **Cartographer interview** (~7 min, conversational). Each proposed structured field is shown as an editable chip; the member confirms (FR-003). Desire tags offer three levels: yes / curious / no. Hard limits come from a controlled list with plain-language descriptions.

7. **ExclusionRing enrolment** (P2+). Opt-in. Explains that contacts are blinded on the device and that nobody learns who matched. Runs the OPRF client.
8. **Profile:** pseudonym, pronouns, free-text gender, age (from the verified ID, D-37), area (district or city), and 1–10 photos: a main photo that clearly shows the member's face (both faces for a couple) and is always shown, plus up to 9 more, each shown or blurred (D-38). Location and device data are stripped on device before upload; provenance metadata is kept for the AI check and stripped on the server (FR-093). Uploads that are AI-generated, AI-edited, borrowed or show other people are refused with a plain reason; reveal ladder defaults come from the Discretion Policy.
9. **Safety notice** (FR-054) → first slate, or the waitlist if the city is gated.

**Couples (VC).** Partner A creates the couple and shows a QR or link (24 h). Partner B must complete V2 **on their own device**. Both review and approve the exact profile version. Veto mode is chosen jointly. The UI explains that either partner can dissolve the couple at any time without giving a reason.

### 4.2 Loop B — Discovery

- **Slate view:** up to 18 cards; no infinite scroll, no swipe mechanic.
- **Tonight** (FR-109): "I'm free tonight" for 1–6 hours within about 5–50 km; a list of members who are also free (photo, name, age, area, approximate distance) with an "Interested" button; "It's mutual" only when both said yes; the safety reminder above the list; "Stop now" hides the member at once.
- **Each card shows:** main photo, pseudonym, age, area and approximate distance ("About 10 km away"), modes, verification tier (and the dated "both partners verified" statement for couples), and 2–4 reason chips with a "not quite" correction control (FR-025). Paid placement is labelled visibly.
- **Actions:** Send Intent (shows the Keys cost and the "refunded if they reply" promise), Pass, Save.
- Intent sending is **never** blocked by the counterparty's inbound cap, and the UI never reveals it.
- **My Signals** (P2): categories the system has learned, with correct, reset and personalisation on/off (FR-024).

### 4.3 Loop C — Handshake

- **Brief screen:** a persistent **"Prepared by Envoy (automated)"** label; aligned items; friction items with suggested resolutions; blocking items; estimated meet probability shown as a band (low / medium / high), never a precise number to the member.
- **Decisions:** Accept / Decline / Amend (amend chooses alternative values from the schema; no free text).
- **Couples:** the decision UI reflects the veto mode (e.g., "Waiting for your partner").
- **ENVOY tier** (P3): a proposal inbox where every proposed intent needs **one-tap approval**. Nothing is sent automatically (D-04).

### 4.4 Loop D — Thread and resolution

- **Thread (MLS):** text, view-once/timed media, voice/video calls (reveal-ladder gated). Retention selector (7/30/90 days; the shortest wins). Burn-thread action.
- **Reveal ladder control:** grant or revoke per recipient and scope. A revoked item immediately shows as unavailable on the recipient's device.
- **Meet planner:** propose/confirm. Safe Meet checklist (public venue first). Check-in timer. **Share My Plan** (FR-021). Clare's Law explainer before the first meet (P3).
- **Aftercare** (48 h): a two-tap private prompt (happened? as represented? would repeat? + optional safety flag).

### 4.5 Account

Pause, Vanish, Delete (shows the erasure promise **and** the declared exceptions in plain words), Export, Devices, Consents, Subscription (one-step cancel), Vouchers, Appeals.

## 5. Client discretion controls

| Control | Native | Web | Req |
|---|---|---|---|
| **Decoy skin** — generic utility (calculator / notes) with a neutral icon and name; the real app needs a distinct PIN or biometric | ✓ | Neutral title/favicon option only | FR-027 |
| **Duress PIN** — opens a populated, innocuous decoy state; silent | ✓ | — | FR-027 |
| **Quick exit** — one action hides content and clears the view in < 500 ms (web: replace history and navigate to a neutral page) | ✓ | ✓ | FR-029 |
| **Emergency lock** — if a phone is lost or taken, the member visits a neutral web page and enters their contact handle + emergency code (shown once at sign-up, to store offline) to freeze everything (FR-064) | — | ✓ | FR-064 |

| Control | Native | Web | Req |
|---|---|---|---|
| **Location veil** — distance bands only, from rotating cells (FR-065) | ✓ | ✓ | FR-065 |
| **Burn** — long-press, confirm in < 2 s: wipe local storage, revoke device keys (`POST /v1/burn`), sign out everywhere. **Visually and gesturally distinct from Panic** | ✓ | ✓ | FR-028, E-21 |
| **Notification masking** — off by default; if on, the payload is content-free ("1 update") and the push contains no name, preview or image | ✓ | ✓ (web push) | FR-026 |
| **Screenshot protection** — Android `FLAG_SECURE`; iOS capture detection that blurs content and notifies the counterparty; obscured app-switcher snapshot | ✓ | Best-effort blur on visibility change | FR-030 |
| **No cloud backup** — excluded from iCloud/Google backup; keys non-exportable | ✓ | Keys non-extractable | FR-030 |
| **Zone awareness** — coarse client location checked against zones on device; "You're inside your work zone — hiding profile for 2 h" | ✓ | Optional | FR-011 |
| **Jurisdiction auto-lock** — entering a blocked country switches to the decoy and hides the profile | ✓ | Edge-enforced | FR-031 |
| **Watermarking** — recipient-specific visible/invisible watermark on revealed media; no-download viewer | ✓ | ✓ | A §9.1 A5 |

Location never leaves the device at better than geohash-5, except in the Panic flow.

## 6. Client cryptography and on-device intelligence

- **Device identity:** a key pair generated in the secure element, used for DPoP proofs and as the MLS credential. Rotated on re-install; revoked by Burn.
- **Messaging:** OpenMLS. One MLS group per thread (2, 3 or 4 members). Key packages are uploaded to the delivery service.
- **Media:** a per-media AES-256-GCM key; ciphertext uploaded through a pre-signed URL; the key is wrapped per recipient (MLS exporter secret) and sent in band. **Revocation** asks the server to destroy the wrapped key, and the recipient client purges any cached plaintext.
- **PSI client:** normalise contacts (E.164 / lowercased email) → hash → blind with a random `r` → server evaluates → unblind → upload the PRF set. Raw contacts never leave the device; nothing is shown to the member about matches.
- **Guardian on device (FR-033):** M6a–e run on each thread turn over a rolling window (< 80 ms p95). Only `{model_id, version, score, reason_code}` is posted. Local UI responses:
  - M6d auto-redacts addresses and phone numbers in outgoing text and asks the sender to confirm;
  - M6c shows a caution banner to the counterparty;
  - M6e locks the thread pending review.
- **Pre-send media check:** on-device nudity classifier (explicit media only to V2 web, with the counterparty's media-view consent), plus licensed hash matching where permitted (D-10).
- **Conversation features** for M5 and Mirror (length bucket, latency, question ratio) are computed on device. **No content leaves the device.**
- **Reporting:** the reporter may choose to attach decrypted messages or media. This is an explicit, separately confirmed disclosure, with a separate opt-in for safety-model training (never a condition of action).

## 7. Safety UX

**Safety notice** (FR-054; shown at intake and before a first meet) [A §20.3]:

> **Before you meet anyone.** We verify that members are real adults. We do not — and cannot — check anyone's criminal record, their honesty, or whether they are who they say they are once you are off this app. No UK platform can. Meet in public the first time. Tell someone where you are going; Share My Plan does it privately. Trust your instincts and leave if something feels wrong. If anyone pressures you, threatens you, or pushes past a boundary you set, report them — we act on it, and we do it fast.

- **Panic** (FR-022): a prominent, distinct control in threads and the meet screen. It confirms with a hold, sends live location + preserved evidence through `POST /v1/safety/panic`, and offers a one-tap call to 999. It works even when notifications are masked or the app is in decoy mode (reachable through a gesture from the decoy).
- **Share My Plan:** pick a trusted contact (stored locally only). It sends a neutral, unbranded, auto-deleting message with venue and time window through the device's share sheet or an encrypted link. The wording is chosen for someone who cannot tell their partner where they are.

- **Check-in timer:** a missed check-in triggers silent escalation to the trusted contact.
- **Check-in PINs** (FR-100): a check-in PIN and a different duress PIN; both show "Thanks, checked in." A meet can't start until a trusted contact or the TRYST safety line is set.
- **Door check** (FR-099): an "I'm here" button shows the other member's verified main photo and three shared words, with "This isn't them, I'm leaving" one tap away (it starts a check-in and offers Panic).
- **Video first** (FR-103): an in-app video call is offered before every first meet; members can make it a hard limit. A private-address venue for a first meet shows an on-device warning. Panic shows the Silent Solution (dial 999, then press 55).
- **Report / block:** one tap on every profile, Brief, thread and media item. The reporter is never revealed.

### 7.1 Copy rules (claims discipline, P6)

*Source: A §19.8*

| Never | Use |
|---|---|
| "Background checked", "Safe", "Vetted", green "safe" ticks | "Identity verified", "Age assured", dated facts ("Submitted a Basic DBS dated 14 Mar 2026") |
| "No sex offenders" | "We permanently remove and block re-registration where we find harmful conduct" |
| "Guaranteed real" | "Every member completes liveness and ID verification" |
| "Undetectable", "No trace" | "We minimise what we store, and here's what we can't control" |
| "Cheat better" or any affair-shaming or affair-glamorising copy in the store build | "Discreet dating"; "Discretion is the product" (web) |

### 7.2 Brand application (v1.2)

**Logo.** Use `shared/brand/tryst-logo.png` **exactly as supplied**: no redraws, recolours, crops or effects. Place it on `night`, `oxblood-deep` or `oxblood` only. Never show it in decoy mode, on lock screens, in notifications, app-switcher snapshots or Share My Plan (FR-063; 01 §3.1). For small sizes (favicon, ≤ 48 px) use the PNG scaled down. If it is illegible at that size, the web favicon defaults to the neutral option (FR-027) rather than a modified logo.

**Colour.** Import `shared/brand/tokens.css` (web) or generate native colour assets from `tokens.json`. Defaults:

| Element | Token |
|---|---|
| Background | `night` |
| Cards | `oxblood-deep` |
| Body text | `cream` |
| Headings and accents | `gold` |
| Primary button | `oxblood` with `champagne` text |
| Borders | `oxblood-light` |
| Disabled | `bronze` |

**Type:** serif display with tight tracking for headings, matching the wordmark; a clean sans for body text. **Never** pink, hearts or silhouettes [A §2]. The decoy skins use their own neutral system palettes, never brand tokens.

## 8. Accessibility, localisation, performance

- **Accessibility:** WCAG 2.2 AA on web (brand text pairs pass AA, 01 §3.2); VoiceOver/TalkBack labels on native; Dynamic Type; reduced motion. The decoy and quick-exit controls must be operable by assistive technologies **without announcing "TRYST"** (NFR-07). Members who cannot use face or fingerprint biometrics get the accessible sign-in alternative (D-17).
- **Localisation:** EN-GB/EN-IE at P1; NL, DE, SV, DA, ES, PT at P4 (NFR-14). Brief and Guardian copy is code-based for localisation.
- **Performance:** cold start < 2 s on mid-tier devices; slate first paint < 1 s after the API response; quick exit < 500 ms; Burn confirmable < 2 s (NFR-04).
- **Platforms:** iOS 17+, Android 10+, evergreen browsers (NFR-15).

## 9. Client testing and release

- Contract tests against generated mocks of 02. A UI tier-gate test checks that no screen shows other members' content below V2.

- Security: MASVS L2 + R checks, jailbreak/root behaviour, screenshot and backup tests, SBOM scan with zero third-party telemetry SDKs (G-NG-8).
- On-device model benchmarks per device class (NFR-03).
- **Store review pack:** sanitised build flag, reviewer demo account, privacy manifest, Data Safety form diffed against the Privacy Notice in CI.

## 10. Frontend backlog by phase

| Phase | Epics (frontend) | Definition of done |
|---|---|---|
| **P0** (M0–M2) | Design system (oxblood/bone); discretion UX prototypes (decoy, duress, quick exit, Burn vs Panic) usability-tested; Rust crypto core spike on three targets; store pre-review consultation | Prototypes validated; crypto core builds on iOS, Android and WASM |
| **P1** (M2–M6) | Web PWA (full product) + native apps (TestFlight / internal track): onboarding V0–V2, conduct and Article 9 consent, Cartographer UI, profile/media with client encryption, couple co-sign, slate, intents/Keys, threads (MLS), reveal ladder, meet/Safe Meet/Share My Plan/Panic, Aftercare, discretion suite, on-device Guardian baseline, report/block, account/DSR, web billing (TRYST+, Keys, deposit, vouchers) | FR-001–009, 011–013, 016–023, 026–033, 037–039, 041–042, 044, 046–047, 049, 051, 054, 056–065, 069, 072 met (client side); NFR-03/04/07/09/15 met |
| **P2** (M6–M10) | Brief screens + decisions; My Signals; ExclusionRing enrolment (PSI client); reason chips | FR-010, 015, 024, 025 |
| **P3** (M10–M15) | DUO, ENVOY (proposal inbox), GHOST UI; travel mode; DBS attestation and Clare's Law explainer; store submissions approved on both platforms | G-P3 store approval; FR-045, 048, 053 |
| **P4** (M15–M24) | Localisation (6 languages); market-specific copy and assurance flows | NFR-14 |

# 05 — TRYST Terms of Service — Draft 0.9.5

Part of the TRYST v1.1 baseline.

> **Draft for counsel review. Not legally reviewed. Do not publish or rely on in this form.** Prepared by: Product. For review by: UK consumer, Online Safety Act and data-protection counsel. Governing law assumed: England & Wales.
>
> **Changes from draft 0.9 (Source A, Part B)** are marked **[v1.1]**. They align the terms with specification v1.1 (06 §3: E-02, E-09, E-10, E-11) and add counsel questions Q11–Q13. Clause numbers are unchanged; one clause (3.5) is added.

**Note to counsel.** This draft is written by the product team to be reviewed, not approved. Clauses carrying the highest legal risk are marked **REVIEW** with a specific question. Three areas need particular attention:

- **clause 15** — retention of exclusion identifiers after account deletion: the lawful-basis question;
- **clause 16** — the subscription regime, whose commencement date is unsettled;
- **clauses 21–23** — the liability structure, drafted deliberately narrow so that it survives s.62 rather than broad so that it gets struck.

## 1. These terms, and who we are

1.1 TRYST is operated by [SPV NAME] LIMITED, a company registered in England and Wales (No. [——]), registered office [——]. In these terms, "we", "us" and "our" mean that company. "You" means the person using TRYST.

1.2 These terms are a contract between you and us. They apply whenever you use the TRYST website, apps or any related service.

1.3 They are written to be readable. Where a clause matters to you, we have added a plain-English box explaining it. Those boxes are part of these terms and can be relied on.

1.4 Our Privacy Notice, Community Rules and Safety Policy form part of these terms.

## 2. Definitions

2.1 **Member** — a person with a TRYST account. **Couple Profile** — a profile representing two Members who have each independently confirmed the link. **Keys** — the prepaid credits described in clause 16. **Intent** — an outbound expression of interest. **Brief** — the agent-generated summary described in clause 7. **Exclusion Identifier** — the irreversible identifier described in clause 15.

## 3. Who can use TRYST

3.1 You must be 18 or over. We verify this using age-assurance methods that meet the "highly effective" standard under the Online Safety Act 2023. If we cannot verify that you are an adult, you cannot use TRYST, and there is no appeal against that.

3.2 You must have the legal capacity to enter this contract, and you must not be prohibited from using a service of this kind by any court order, licence condition or notification requirement.

3.3 TRYST is available only in the countries listed at [URL]. We block access elsewhere, including in countries where using a service of this kind could expose you to criminal liability. You must not attempt to circumvent that block.

3.4 You may hold one account. If you previously held an account that we permanently closed under clause 17, you may not open another.

3.5 **[v1.1]** When you verify your age, we ask you to declare that you have no unspent convictions for sexual or violent offences, and that you are not subject to a Sexual Harm Prevention Order, a restraining order or a non-molestation order. We record that declaration separately. A declaration you knew to be false is grounds for permanent removal under clause 17.3.

## 4. What TRYST is

4.1 TRYST is an introduction and discovery platform. We provide software that lets adults find one another, communicate, and decide for themselves whether to meet.

4.2 We are not a matchmaking agency, an introduction agency acting on your behalf, an escort or companionship service, or a party to anything you arrange with another Member. We do not act as your agent and we owe you no duty to find you anyone.

4.3 We do not select, endorse, recommend, approve or vouch for any Member. Our software ranks and suggests profiles; that is a computational output, not a recommendation from us that a person is suitable, honest or safe.

> **IN PLAIN ENGLISH** — We introduce people. What happens after that is between you and them. Nothing we show you is us telling you that someone is a good idea.

## 5. What we verify — and what we do not

5.1 We do verify, before a Member can send an Intent or exchange media: that they are an adult, by an identity-document check matched to their face; that they are a real, living person, by liveness check; that their photographs are real photographs of them; and, for a Couple Profile, that both partners are two different verified adults who have each confirmed the link from their own device, have been photographed together live in the app, and reconfirm the link every 90 days. **[v1.3]**

5.2 We do not verify, and cannot verify:

- your relationship or marital status;
- whether a partner of yours knows about, or consents to, your use of TRYST;
- your criminal record, or whether you are subject to any order or notification requirement;
- your employment, income, health or personal circumstances;
- the truth of anything you or any other Member says.

5.3 There is no lawful route by which a UK platform can check a Member against the sex offenders register or obtain a criminal-record check on them. We do not claim to do so, and you should treat any platform that claims otherwise with caution.

5.4 Membership of TRYST is not, and must never be read as, a statement by us that a Member is safe, honest, available, unattached, or suitable for you.

> **IN PLAIN ENGLISH** — We check you are a real adult who looks like your photos. We do not check your marriage, your record, or your honesty. No UK app can check a criminal record on you — and we will never pretend we have.
>
> **REVIEW** — Clause 5 is drafted to anchor the whole liability structure and to keep us clear of the CPUT Regulations and the DMCC Act consumer regime on misleading practices. Please confirm the wording is strong enough to defeat an argument that our verification badges, ranking or marketing create an implied representation of safety.

## 6. Your account

6.1 Everything you tell us about yourself must be accurate, and your photographs must be current and of you. Your profile shows your main photo, which must clearly show your face (both faces, for a Couple Profile), your age, your area and an approximate distance, to Members who are allowed to see it. You may show up to 10 photographs. **You must not upload images that are computer-generated or altered with image-generation software, images of anyone other than you (and your partner, for a Couple Profile), or images taken from elsewhere.** We check every photograph and remove any that break these rules. Profiles that misrepresent who you are will be removed. **[v1.3]**

6.2 Keep your access credentials, PIN and device secure. Tell us immediately if you think someone else has access to your account.

6.5 **[v1.2]** Only you may sign in to your account. Signing in needs two checks. On a phone (app or website), these are your phone's fingerprint or face unlock **and** a live face check matched to you. On a computer, they are a passkey **and** approval from your registered phone. We never let anyone sign in by text message or email code, and our staff

cannot sign in for you or bypass these checks. If you cannot use face or fingerprint checks, we offer an alternative (see our Accessibility page at [URL]).

> **IN PLAIN ENGLISH** — Even someone holding your unlocked phone cannot get into your account. If anyone adds their fingerprint or face to your phone, we sign you out.

6.3 You are responsible for everything done through your account, unless someone gained access through our failure to take reasonable care.

6.4 You may not sell, transfer, rent or share your account.

## 7. Couple Profiles, and our agent features

7.0 You can join TRYST on your own. If you are in a relationship, your partner does not need to join, agree or know, and we will never contact them. A Couple Profile is optional and only for partners who want to use TRYST together. **[v1.3]**

7.1 A Couple Profile requires both partners to hold their own verified accounts and each to confirm the link from their own device. We will not create a Couple Profile on one person's say-so. Either partner may dissolve the link at any time, and we will act on that immediately without telling the other partner why.

7.2 Some features use automated agents. Before you and another Member speak, our agents may exchange structured information about intentions, boundaries, availability and verification, and produce a Brief for each of you.

7.3 Our agents never pose as you, and never speak to another Member as if they were you. Every Brief is labelled as automatically generated. A Brief is information to help you decide; it is not advice, and it is not a judgement about whether someone is safe. **[v1.1]** Where you use a paid agent feature that suggests people to contact, nothing is sent until you approve it.

7.4 A conversation only opens when both of you have seen your Brief and accepted.

> **IN PLAIN ENGLISH** — Our software does the awkward pre-screening so you don't waste weeks. It never pretends to be you, and it never tells you someone is safe.

## 8. Community Rules — what you must not do

You must not, on TRYST or in any contact that begins on TRYST:

- be under 18, or attempt to contact anyone you believe or suspect is under 18;
- share, request, or threaten to share intimate images of anyone without their consent;
- pressure anyone for images, contact, money, or sexual activity, or continue after someone has said no;
- threaten, harass, stalk, intimidate, or attempt to coerce or control another person;
- misrepresent your identity, age, or appearance, or use another person's images;
- offer or seek sexual services in exchange for money or anything of value;
- attempt to identify, locate, contact, or expose a Member outside TRYST without their agreement, or disclose that someone is a Member to anyone;
- solicit money, investment, or financial information;
- record, screenshot or copy another Member's private content or messages;
- use TRYST for any commercial, promotional or research purpose;
- scrape, reverse-engineer, or automate access to TRYST;
- fetishise or harass anyone because of their race, ethnicity, religion, disability, age, sex, gender identity or reassignment, sexual orientation, or any other protected characteristic **[v1.2]**;
- evade a suspension or removal.

8.1 Exposing a Member's use of TRYST to a third party is one of the most serious things you can do on this platform, and we treat it as grounds for immediate permanent removal.

## 9. Your conduct and your decisions

9.1 You decide who to speak to, what to tell them, whether to meet, where, when, and what happens when you do. Those are your decisions.

9.2 You are responsible for your own conduct. Another Member is responsible for theirs. We are not responsible for what any Member says, does, or fails to do — subject always to clause 22.

9.3 You accept that other Members may misrepresent themselves despite our checks, and you agree to take reasonable care of your own safety, including using the safety features in clause 11.

## 10. Consequences outside TRYST

10.1 We are not responsible for the effect of your use of TRYST on your relationships, marriage, family, employment, finances or reputation. Those consequences are yours.

10.2 No person who is not a party to this contract acquires any right under it. The Contracts (Rights of Third Parties) Act 1999 does not apply.

> **REVIEW** — Clause 10.2 is intended to head off a claim by a Member's spouse or partner. Please advise whether it is sufficient, and whether any free-standing duty could arise in tort notwithstanding it.

## 11. Safety features — and their limits

11.1 We provide safety features including Safe Meet guidance, Share My Plan (which privately tells a contact of your choosing where you are going), a check-in timer, in-app reporting, blocking, and a Panic control that contacts emergency services.

11.2 These features are aids. They depend on your device, your network, and third parties we do not control. We cannot guarantee that any of them will work at the moment you need it, and you must not rely on any of them as your only safeguard. If you are in danger, call 999.

11.3 Using a safety feature does not make a meeting safe, and choosing not to use one does not make what happens to you your fault.

> **REVIEW** — Clause 11.2 is a statement about technical limits, not an exclusion of liability for negligent design or operation of the features themselves — which we accept we cannot exclude under CRA 2015 s.65 where personal injury results. Please confirm the drafting does not stray across that line, since a term that did would be void and would jeopardise clause 21.

## 12. Your content

12.1 You keep ownership of everything you upload. You give us a limited, non-exclusive licence to host, store, encrypt, transmit and display your content solely to operate TRYST for you. That licence ends when your content is deleted, save as set out in clause 15.

12.2 Your private messages are end-to-end encrypted. We relay them; we cannot read them. This means we cannot recover them for you, and it also means we cannot moderate their content directly — we rely on your reports and on signals available to us outside the message content.

12.3 Media you send is encrypted on your device. You can revoke access at any time, which makes it permanently unreadable to the recipient. We cannot stop someone photographing their own screen with another device, and you should assume anything you send may be kept.

> **IN PLAIN ENGLISH** — We genuinely cannot read your messages. That protects you, and it also means we can only act on what you report. Assume any photo you send could be kept, whatever our software does.

## 13. Intimate images

13.1 Sharing or threatening to share an intimate image of someone without their consent is a criminal offence. On TRYST it results in immediate permanent removal, preservation of evidence, and referral to the police.

13.2 If an intimate image of you has been shared without your consent, report it to us. We will act within the time stated in our Safety Policy, support you in submitting a hash to StopNCII where you wish, and preserve evidence for any investigation.

## 14. Your personal data

14.1 Information about your sex life and sexual orientation is special category data under the UK GDPR. We process it only on your explicit consent, which you give separately from accepting these terms, and which you can withdraw at any time.

14.2 Our Privacy Notice explains what we collect, why, how long we keep it, and your rights. It is not a summary — it is the operative document, and it prevails over anything in these terms about personal data.

14.3 We do not sell your data, we do not show advertising, and we do not embed third-party tracking in our apps.

14.4 We will never confirm or deny to anyone else, including your partner, family or employer, whether you have an account. We share account information only with you, when the law requires it (for example, a court order), or in an emergency under clause 20. You can ask us to hide you from your partner if they ever join (the partner shield), and we will do so without telling either of you about the other. **[v1.3]**

> **REVIEW (Q16):** if a partner makes a data subject access request, the partner-shield entry is a keyed hash of their contact details. We intend to withhold it under the third-party exemption (DPA 2018 Sch 2 para 16), because disclosing it would reveal information about the member. Please confirm.

## 15. Keeping and deleting your information

15.1 You can delete your account at any time. When you do, we destroy the encryption key that protects your data, which makes it permanently unreadable. This happens in under a minute and cannot be reversed. We cannot restore a deleted account.

15.2 Messages are deleted after 30 days by default, or after 7 or 90 days if you choose. Media **[v1.1] that you send in a conversation** is deleted after 7 days by default. **[v1.1] Your profile photos stay until you remove them or delete your account.**

15.3 There is one exception, and we want you to read it. If we permanently remove you because your conduct endangered another person, we keep a small set of Exclusion Identifiers — irreversible one-way codes derived from your identity document, device and payment method. We cannot reverse them into your personal details. We keep them so that you cannot open another account, and we keep them after your account is deleted. We do this to protect other people. We keep no evidence, no messages and no profile alongside them — only the codes, a category of reason, and the date. **[v1.1]** To make this possible, we create these codes when you verify and keep them protected with the rest of your account. If you delete your account and have not been removed under clause 17.3, they are destroyed with everything else.

15.4 If you are removed on that basis you may appeal under clause 18, and if your appeal succeeds we destroy the Exclusion Identifiers.

> **IN PLAIN ENGLISH** — Delete your account and it is genuinely gone. The one thing that survives is a code that stops a removed predator coming straight back under a new name. If that is you and we got it wrong, appeal and we delete it.
>
> **REVIEW** — This is the highest-risk clause in the document. We need: (a) the specific DPA 2018 Sch. 1 condition relied on — we have assumed Pt. 2 para. 18 (safeguarding of individuals at risk) — confirmed in writing; (b) a view on whether retention after erasure is defensible against an Art. 17 request; (c) confirmation that the disclosure is prominent enough, given that the rest of clause 15 promises complete erasure. We have deliberately refused to bury this. Please tell us if it needs to be more prominent still. **[v1.1]** See also Q13 on creating the codes for every verified member.

## 16. Paying for TRYST

16.1 Basic membership is free. Replying to any Member is always free. Paid tiers and Keys are described at [URL], with prices shown before you pay.

16.2 **Billing discretion.** Your card or bank statement will show a neutral descriptor that does not name TRYST. You can also pay using prepaid vouchers bought elsewhere. We do this because your privacy matters, not to obscure what you are paying for — the descriptor includes a customer service address.

16.3 **Cancelling.** You can cancel a subscription at any time, from inside the app or website, in one step. We will not ask you to call us, email us, or answer questions to cancel. Cancellation takes effect at the end of your current paid period.

16.4 **Your 14-day right to cancel.** Under the Consumer Contracts Regulations 2013 you normally have 14 days to cancel a distance contract. If you ask us to start the service immediately, you may lose that right for digital content, or owe us a proportionate amount for services already supplied. We tell you this clearly at checkout and ask you to confirm it separately.

16.5 **Reminders.** We email you before any renewal and before any trial converts to a paid subscription. The reminder says what you will be charged, when, and how to stop it.

16.6 **Keys.** Keys spent on an Intent are refunded in full if the Member replies. Unused Keys do not expire while your account is open. If we permanently remove you, unused Keys are refunded unless removal was on a ground in clause 17.3.

16.7 **Refunds.** Where we owe you a refund we pay it to the original payment method within 14 days.

> **REVIEW** — The DMCC Act 2024 subscription regime is not yet in force, and its commencement date has moved repeatedly. We have drafted to comply with the full regime now, on the view that pre-contract information, reminder notices, cooling-off notices, end-of-contract notices and one-step cancellation are things we want anyway, and that retrofitting a payments flow is expensive. Please confirm the current commencement position and whether clause 16 already meets it, particularly on the form and prominence of the notices. Note CMA fining powers of up to 10% of global turnover.

## 17. Suspension and removal

17.1 We may warn you, limit your account, suspend it, or remove you permanently if you break clause 8, these terms, or the law, or if we reasonably believe you present a risk to another person.

17.2 We will tell you what ground we acted on, unless telling you would put someone at risk or prejudice an investigation. A permanent removal is always decided by a named person at TRYST, never by software alone.

17.3 Immediate permanent removal, with Exclusion Identifiers retained under clause 15.3, applies where:

- you are under 18, or sought contact with someone you believed to be under 18;
- you shared or threatened to share intimate images without consent;
- you coerced, threatened or attempted to control another person;
- you exposed a Member's use of TRYST;
- you are subject to a relevant court order; or
- you knowingly gave a false declaration under clause **[v1.1] 3.5**.

17.4 We may preserve evidence relating to a removal beyond the periods in clause 15, where we need it for an investigation, an appeal, or a legal claim.

17.5 Reporting another Member falsely, or organising others to report someone, is itself grounds for removal.

## 18. Appeals

18.1 You can appeal any suspension or removal by [route]. A different person from the one who made the decision will review it, and we will respond within 10 working days.

18.2 If we were wrong, we restore your account, refund anything you lost, and destroy any Exclusion Identifiers.

18.3 We publish, twice a year, how many accounts we removed, on what grounds, how many appealed, and how many appeals succeeded.

## 19. Reporting, and what we do about it

19.1 Report anything from inside any conversation or profile. Reporting takes one tap and you never have to explain yourself to the person you are reporting.

19.2 Our response times for each category of report are published in our Safety Policy. We do not hide them.

19.3 We will never tell the person you reported that it was you.

## 20. Emergencies come before privacy

20.1 Our privacy and deletion commitments are strong. But if there is a risk to someone's life or of serious harm, or where the law requires it, we will preserve and disclose whatever is necessary to the emergency services, the police, or a court.

20.2 We publish what we disclose, in aggregate, in our transparency report.

> **IN PLAIN ENGLISH** — If someone's life is at risk, safety wins over discretion. Every time.

## 21. Our liability to you

21.1 We will supply TRYST with reasonable care and skill, as the Consumer Rights Act 2015 requires. Nothing in these terms limits that obligation.

21.2 We are not liable to you for the acts or omissions of another Member, or for anything that happens between you and another person, except where our own failure to take reasonable care caused it.

21.3 Where we are liable to you for financial loss, our total liability is limited to the greater of (a) the amount you paid us in the 12 months before the event, or (b) £100.

21.4 We are not liable for loss of profit, loss of opportunity, loss of reputation, or any indirect or consequential loss.

21.5 We are not liable for failures caused by events outside our reasonable control, or by your device, network or operating system.

## 22. What we do not exclude

22.1 Nothing in these terms limits or excludes our liability for:

- death or personal injury caused by our negligence, including any impairment of mental health;
- fraud or fraudulent misrepresentation;
- any breach of the obligations the Consumer Rights Act 2015 says we cannot exclude;
- our duties under the Online Safety Act 2023 and data protection law;
- anything else that cannot lawfully be limited or excluded.

22.2 Your statutory rights as a consumer are not affected by these terms. Agreeing to these terms does not mean you have accepted any risk.

> **REVIEW** — Clause 22 is deliberately included and deliberately broad. We understand it removes any argument that we tried to exclude what CRA 2015 s.65 bars, and that s.65(2) means a "use at your own risk" framing would buy us nothing anyway. Our working assumption is that a narrow, honestly carved limitation survives the s.62 fairness test where an all-encompassing one would be struck out in full, taking clause 21 with it. Please confirm — and please push back if you think clause 21.3's cap is too low to be reasonable given what Members pay.

## 23. Your liability to us

23.1 If you break these terms or the law and that causes us financial loss — including a claim by another Member, a fine, or the cost of responding to an investigation — you agree to cover that loss.

23.2 This covers financial loss only. It does not apply where the loss was caused by our own failure to take reasonable care, and it is limited to what is reasonably foreseeable.

## 24. Changing these terms

24.1 We may change these terms. If a change materially affects you, we will tell you at least 30 days before it takes effect and explain what has changed and why.

24.2 If you do not accept a material change, you can close your account before it takes effect, and we will refund any unused prepaid amount in full.

24.3 We will not change these terms retrospectively.

## 25. Ending this agreement

25.1 You can close your account at any time, from inside the app, in one step.

25.2 Clauses 9, 10, 12, 13, 15, 17.4, 21, 22 and 23 survive the end of this agreement.

## 26. Complaints

26.1 Complain to [email]. We acknowledge within 2 working days and respond substantively within 10.

26.2 If you are not satisfied, you may refer the matter to [ADR provider], or contact Citizens Advice. Nothing here stops you going to court.

26.3 Our Online Safety Act complaints route, and the name of the senior manager accountable for it, are at [URL].

## 27. Law and courts

27.1 These terms are governed by the law of England and Wales.

27.2 You can bring proceedings in the courts of England and Wales. If you live in Scotland or Northern Ireland, you can also bring proceedings there. If you live elsewhere in a country where consumer law gives you the right to sue locally, that right is not affected.

27.3 There is no arbitration clause and no class-action waiver in these terms.

> **REVIEW** — We have deliberately not included mandatory arbitration or a class-action waiver. Our view is that both are vulnerable under CRA 2015 s.62 and Sch. 2 in a consumer contract, and that including them invites CMA attention for limited benefit. Please confirm or overrule.

## 28. Contacting us

28.1 General: [email]. Safety and urgent reports: [route], monitored 24 hours.

28.2 Data protection: our Data Protection Officer at [email]. You can also complain to the Information Commissioner's Office.

28.3 Online Safety Act accountable senior manager: [name/role], [email].

## 29. Open questions for counsel

| # | Question | Clause |
|---|---|---|
| Q1 | Confirm the DPA 2018 Sch. 1 condition for retaining Exclusion Identifiers after erasure, and its resilience against an Art. 17 request. | 15.3 |
| Q2 | Does any part of clause 11 stray into excluding liability for negligent design of a safety feature, which would be void under s.65 and could taint clause 21? | 11.2 |
| Q3 | Is the £100 / 12-month cap reasonable, or does the low free-tier ARPU make it vulnerable under s.62? | 21.3 |
| Q4 | Current commencement position for the DMCC subscription regime, and whether clause 16 meets it in full. | 16 |
| Q5 | Could a Member's spouse establish a free-standing duty of care in tort notwithstanding clause 10.2? | 10.2 |
| Q6 | Do our verification badges, ranking outputs or marketing create an implied representation of safety that clause 5 fails to displace? | 5 |
| Q7 | Does clause 12.2 (we cannot read E2EE messages) weaken our OSA position, and how should the risk assessment address content moderation without content access? (See spec D-10.) | 12.2 |
| Q8 | Is a cross-platform exclusion consortium (spec **[v1.1] Source A §19.3 L5**; v1.1 03 §8) viable under competition law and joint controllership? | — |
| Q9 | Confirm the geo-block list, and whether operating in any listed market creates exposure for directors. | 3.3 |
| Q10 | Review the Community Rules and Safety Policy as incorporated documents for consistency with these terms. | 1.4 |

| # | Question | Clause |
|---|---|---|
| Q11 **[v1.1]** | Is scarce-side seeding that offers free paid features to women-identifying members lawful under the Equality Act 2010 (services), or must it be segment-based? (Spec D-06.) | 16 |
| Q12 **[v1.1]** | Does gating all discovery, Intents, conversations and media at age assurance (V2), with no other members' content visible before then, satisfy Ofcom's highly-effective-age-assurance expectations for dating services, including the May 2026 dating guidance? | 3.1, 5.1 |
| Q13 **[v1.1]** | Is creating Exclusion Identifier codes for **every** verified member at verification (destroyed on deletion unless the member is removed) proportionate, and does it need its own Art. 9/10 and Sch. 1 analysis separate from post-removal retention? Should a biometric code ever be used (spec D-08)? | 15.3 |
| Q14 **[v1.2]** | Biometric login (clause 6.5) processes biometric data to identify the account holder. Is explicit consent valid (freely given) when login requires it, given the accessible alternative? Is a provider-held face reference compatible with clause 15's erasure promise if the provider's deletion completes after our 60-second erasure? | 6.5, 15 |
| Q15 **[v1.2]** | Does requiring biometrics to sign in, with the alternative path, meet the Equality Act 2010 reasonable-adjustment duty for disabled members? | 6.5 |
| Q16 **[v1.3]** | Partner shield: may we withhold a partner-shield entry from a partner's subject access request under the third-party exemption (DPA 2018 Sch 2 para 16), and is never confirming or denying an account's existence consistent with our transparency duties? | 14.4 |

# 06 — Decisions, errata and change log (v1.1)

Part of the TRYST v1.1 baseline.

## 1. How v1.1 was reconciled

- **Precedence:** Source A (consolidated Spec + ToS, 4 Oct 2026) > Source B (Developer Specification, 17 Sep 2026) > Source C (PRD draft v0.1). See 00 §2.
- **Where A is silent,** B's requirements are kept: the Discretion Policy object, reveal ladder, preference transparency, quick-exit timing, Privacy Auditor, no-go conditions, the weighted P1 ranker and mode names.
- **From C:** non-functional requirements, the couple dissolution and data-export APIs, and the competitor rows. C's US expansion, its pricing and its unit economics are dropped.
- **Where A contradicts itself or contains an arithmetic error,** v1.1 fixes it and records it in §3.

## 2. Decision log

**Status:** *Resolved* = decided by a source document. *Default* = decided in v1.1 to remove ambiguity, and reversible by the owner. *Open* = needs an owner decision by the gate shown; build against the stated default until then.

| ID | Decision | Status | Resolution / default | Owner · deadline |
|---|---|---|---|---|
| D-01 | Are unattached singles allowed? | **Open** (v1.2) | The founder scope statement (01 §1) says TRYST is designed for adults already in a relationship, while Source A §3 includes solos open to couples (S4) and the curious (S6), who may be unattached. **Default:** the product and marketing target partnered adults and couples; unattached solos are *accepted* as S4 (needed for THIRD liquidity) and S6, but not targeted. Partner awareness is self-declared and never verified or displayed. | Founder · before P1 public beta |
| D-02 | Chat encryption vs server-side scanning | **Resolved** (A §9.2, §21.6) | Full E2EE (MLS). Guardian runs on device and sends score + reason code only. Content reaches the server only through member-disclosed reports or Panic. Source B FR-009's "media scanning in real time" is met on device. | — |
| D-03 | Financial base case | **Resolved** (A §15.3) | A's illustrative model is the base case (CAC £38, 11% payer rate, 19% churn). B's targets (< 7% churn, > 3× LTV:CAC) are superseded. Thresholds corrected in E-03. | — |
| D-04 | What does the ENVOY tier's "runs outreach" mean? | **Default** | Envoy *proposes* intents with rationale; every outbound intent needs a one-tap human approval. Envoy never sends anything to a human as the member (P4; ToS cl. 7.3). | Head of Product · before P3 |
| D-05 | GHOST add-on charges for decoy skin, duress PIN and voucher billing, which conflicts with B's "never monetise safety" and C's "discretion is free" | **Open** | Default: core decoy, duress PIN, Burn, masking, zones and voucher billing are **free**. GHOST sells multiple decoy skins, custom TTLs and extended ExclusionRing heuristics at £7.99. Revenue impact is to be modelled. | CEO · before P3 pricing |
| D-06 | "Free ENVOY for 6 months for women-identifying users" vs gender-neutral pricing (B) and the Equality Act 2010 | **Open** (counsel) | Default: scarce-side seeding by **segment** (S4) and city-balance need, not gender. The gender-based variant ships only with a written counsel opinion. | DPO/Counsel · before P1 public beta |
| D-07 | Contract formats | **Default** | OpenAPI 3.1 at the edge; Protobuf for gRPC, the agent bus and events (schema registry); generated types on both sides. | Principal Eng · P0 |

| ID | Decision | Status | Resolution / default | Owner · deadline |
|---|---|---|---|---|
| D-08 | Biometric ban anchor | **Open** (counsel) | Default **off**. Anchors use document, device and payment HMACs only. V1 retains no biometric template (A §8.1). | DPO/Counsel · before P1 |
| D-09 | Microservices vs modular monolith for core domain services | **Default** | Agents are separate deployables (as A requires). Core domain services form a modular monolith (`core-svc`) with enforced module boundaries, given a 2-person backend team; split on evidence. Identity, ban, media and safety are always separate. | Principal Eng · P0 |
| D-10 | Hash matching of private (E2EE) media | **Open** (counsel + vendor) | Default: on-device pre-send nudity classifier always; on-device perceptual hash matching against licensed lists where licensing permits. Otherwise rely on reports, StopNCII and the NCII escalation path. Must be addressed in the OSA risk assessment (ToS Q7). | Head of T&S · P0 |
| D-11 | In-app purchase in store builds | **Default** | Web-first. Store builds use reader/link-out entitlements where rules allow; where IAP is required, offer TRYST+ only through IAP, with entitlements unified server-side. | Head of Product · P3 |
| D-12 | Delivery timeline | **Resolved** (A §17) | A's P0–P4 over 24 months, with phase gates, replaces B's 68-week sequential plan. | — |
| D-13 | Launch markets | **Resolved** (A §14.5) | UK + IE, then EU wave 2, then CA/AU/NZ. US out of scope; never Africa or MENA. | — |
| D-14 | Mode naming | **Default** | B's SPARK/EMBER/THIRD/QUAD/OPEN as UI labels; A's intent shapes as data values (02 §2.3). | Design · P1 |
| D-15 | Concierge tier (B, C) | **Default** | Deferred beyond P4. A's tiers are canonical. | CEO · P4 review |
| D-16 | Who can sign in, and with what | **Resolved** (founder, v1.2) | Only the account holder. App and mobile PWA: two biometric factors (device-bound biometric passkey + liveness face match). Desktop: two factors (passkey + registered-phone approval or a second security key). No passwords, SMS or email codes, or staff overrides (02 §3.3). | — |
| D-17 | Members who cannot use face or fingerprint biometrics (disability, device) | **Open** (counsel) | Default alternative: two registered FIDO2 security keys with PIN, plus a provider video liveness check with assisted human review in place of B2. Required so biometric consent is freely given and to meet the Equality Act (ToS Q14, Q15). | DPO/Counsel · before P1 beta |
| D-18 | Where the B2 face reference is held | **Open** (counsel + vendor) | Default: held by the liveness provider under contract (TRYST stores only a token); deleted at the provider on erasure. Alternative rejected by default: TRYST-held encrypted template (contradicts A §8.1 "no biometric template"). | DPO/Counsel · P0 |
| D-19 | Brand identity | **Resolved** (founder, v1.2) | Founder-supplied logo used exactly as supplied; palette sampled from it (oxblood and gold on night, cream replacing "bone"). Discretion rules still keep the logo off decoy, lock-screen and notification surfaces (01 §3). | — |
| D-20 | Source B's Conversation Agent (suggested openers and replies) is not among Source A's seven agents | **Default** | Ship in P3 as an opt-in, on-device, draft-only assistant inside the member's own client. It never sends anything and never talks to another member as the member (FR-066; P4). | Head of Product · P3 |
| D-21 | SEO approach for "dynamic AI agent SEO, hyperlinks, backlinks and top ranking" (founder request, v1.2) | **Default** | Build Herald as a dynamic AI SEO agent with human editorial approval, isolated from member data. Links are earned through digital PR, partnerships and open-source work, never bought or spammed. Top-3 rankings are targets tracked weekly, not guarantees. Black-hat tactics are prohibited because a penalty would remove the business's main low-CAC channel (FR-073–FR-077). | Growth lead · P1 |
| D-22 | Payment processor | **Open — conditional** (founder chose Stripe, v1.2) | Stripe is primary, **conditional on Stripe's written approval** of TRYST's business model in P0, because Source A §14.4 states Stripe prohibits adult content and the web surface carries explicit media. A high-risk acquirer is integrated as the backup MID from day one and becomes primary if Stripe declines. Stripe's restricted-businesses policy could not be checked from the build environment. Fallbacks if Stripe approves dating but not explicit media: (a) keep explicit media off the Stripe-billed surface, or (b) bill everything through the high-risk acquirer. | CEO + Head of Payments · G-P0 |

| ID | Decision | Status | Resolution / default | Owner · deadline |
|---|---|---|---|---|
| D-23 | Source B's final directive ("partnered adults, affairs and threesomes are explicit product categories — not hidden behind generic dating language") vs Source A §14.3 (store builds positioned as "discreet dating" to survive Apple 1.1.4) | **Default** | Explicit categories (SPARK/EMBER/THIRD/QUAD/OPEN, affairs, threesomes) on the **web PWA, marketing site and Herald SEO content**. Only **app-store listings and in-store-build copy** use neutral "discreet dating" wording, with no explicit imagery. Positioning never says "cheat better". | Head of Product · before store submission (P3) |
| D-24 | Identity service iteration 1 scope | **Default** | Implemented and tested: contact OTP sign-up (dev returns the code), passkey registration (user verification required, discoverable), mobile login B1 + B2 (pluggable liveness provider; fails closed; dev provider refused in prod), desktop login F1 + F2 (registered-phone approval or a second security key), session limits, lockout, Burn. **Next:** DPoP-bound tokens (bearer over TLS until then), PostgreSQL IDENTITY-DB store (in-memory now), native biometric-only attestation, real liveness provider, step-up and recovery endpoints. | Principal Eng · P1 |
| D-25 | The founder OS brief asks for a platform that runs "without requiring human intervention" | **Default** (founder brief, v1.3) | Adopted with **bounded autonomy**: autonomy levels L0–L3 let agents observe, recommend, make reversible changes and run pre-approved runbooks on their own; irreversible, member-safety, money-movement and production-change actions always need a named human, and no agent may act as a member. Required by UK GDPR Art 22 and principle P4; enforced in code (`aigov`, FR-080) | Principal Eng + DPO · P1 |
| D-26 | BitriPay as a core payment gateway | **Default** (founder brief, v1.3) | BitriPay is integrated as a third `PaymentProvider` adapter (built, sandbox-tested). Live use is refused in code unless a market is enabled for both TRYST and BitriPay, with a legal opinion and BitriPay's written acceptance, because its documented rails serve markets TRYST excludes (D-13). Near-term use: partner commissions and licensee flows via connected accounts | CEO + Head of Payments · P0 check, P4 use |
| D-27 | AI credit / ACU system | **Default** | ACU meters partner and licensee API usage only. Members never buy ACU: Keys already serve that role, and a second credit currency would breach P8 ("unreadable credit mechanics"). The founder's earlier instruction to ignore the ACU sections of the pasted KODA/BitriPay docs is respected: TRYST's ACU is defined here, not copied | CEO · P4 pricing |
| D-28 | "Auto-Repair Agent automatically patches issues and redeploys components" | **Default** | Auto-Repair runs pre-approved runbooks (rollback, restart, scale out, halt canary, rotate a leaked key) on its own within a budget. It may open a fix pull request; that PR follows normal review and CI, and promotion to production is a human decision | Principal Eng · P1 |
| D-29 | Connectors that would expose members (WhatsApp, member data in CRM, data enrichment, ad platforms, live location) | **Default** | Declined for member data: each would reveal a pseudonymous member to a third party or on a shared device (FR-002, P3). Operator- and B2B-only uses are kept (CRM for licensee pipeline, enrichment for B2B leads) | DPO · P1 |
| D-30 | Dynamic pricing and data-intelligence revenue | **Default** | Pricing experiments are market-level, published and identical for every member in a market; no personalised or surge pricing. No revenue from member data (P8); the alternative is free published research using differential privacy, and licensing of technology trained on licensed or synthetic data | CEO + DPO · P3 |
| D-31 | Executive agents (CEO, COO, CFO, CTO, CMO, CRO) | **Default** | Analyst copilots for the named executive, reading aggregate data only, with no actions beyond recommendations. Accountability stays with people | CEO · P1 |

| ID | Decision | Status | Resolution / default | Owner · deadline |
|---|---|---|---|---|
| D-32 | KYC, KYB and AML agents | **Default** | Members get age assurance and verification, not identity KYC (pseudonymity, FR-002). TRYST holds no customer funds, so AML duties sit with regulated processors; TRYST runs KYB and sanctions/PEP screening on licensees and commission partners | DPO/Counsel · P4 |
| D-33 | Should TRYST's name or brand mention AI? | **Resolved** (founder, v1.3: "Do not add AI on TRYST name or brand") | Never. No "AI", "A.I." or "artificial intelligence" in the name, tagline, logo, store listings, marketing, Herald content, UI or notifications (01 §3.3). Internal engineering docs keep technical terms. Enforced by a build test. Doc 09 is renamed "Operating System (internal engineering)" | — |
| D-34 | Are people in open relationships in scope? | **Resolved** (founder, v1.3) | Yes, explicitly welcome as S2 (solo) or S3/S5 (couples), shown on the marketing site and in the OPEN mode. Complements D-01 | — |
| D-35 | Launch model: Source A's 9-month invite-only period and London-first city sequence | **Resolved** (founder, v1.3: open public sign-up, keep the gender-balance waitlist; "if this is the best and proven strategy, go for it") | **Public sign-up from launch** in London, Manchester, Birmingham and Brighton, with **matching opening one city at a time** in that order (London first), each at 2,000 verified members once the previous city is live. This is the proven density-first pattern for two-sided products (campus-by-campus and city-by-city launches, public waitlists); opening four cities to matching at once was considered and rejected as less proven because it splits density and seeding spend. Kept: a balance waitlist (now gender-neutral, D-36); referrals as a growth channel; the P1 control cohort without Envoy (London). Enforced in `backend/internal/launch` (FR-089, FR-090). **Risks — closed in v1.3:** (1) acquisition cost without the invite loop is capped by the automatic paid-acquisition brake (FR-091); (2) the Equality Act exposure of a gender-based waitlist is removed by replacing it with the gender-neutral demand-balance rule (D-36, FR-090) | Founder · closed |
| D-36 | How to keep cities balanced without admitting people by gender | **Resolved** (founder, v1.3: "close these risks") | The waitlist no longer reads the applicant's gender or any other characteristic. It paces admission by the load on the **groups the applicant asked to meet** (seekers per group member, cap 2.2), applied identically to everyone; a person waits only when the people they want to meet are already saturated. This removes direct discrimination (which, for sex, cannot be justified under the Equality Act 2010 s.13). Any uneven effect between groups is a proportionate means to legitimate aims (members' safety from harassment volume; OSA duties), the standard s.19 justification. Confirmation is part of the written UK legal opinion that is already a G-P0 launch condition, not a separate gate. The gender ratio KPI stays monitored. D-06 is unaffected | Founder · closed (confirmed in the G-P0 opinion) |
| D-37 | Showing a member's age (founder, v1.3) vs "age band only, no DOB" (Source A minimisation) | **Resolved** (founder) | Age is shown **in whole years**. TRYST stores only the verified birth **year and month** from the ID document, never the day, which is enough to show the age and is never more than one month late (never early). The age band stays for matching filters | — |
| D-38 | Main photo always visible (founder, v1.3) vs face-blur by default (FR-047) | **Resolved** (founder) | The main photo is always shown clearly and must show the member's face (both faces for a couple). Up to 9 further photos may each be shown or blurred behind the reveal ladder. **Discretion trade-off, accepted:** a recognisable face is visible to other verified members. Mitigations: visible only to V2 members inside the Stage 0 gates; the ExclusionRing hides the profile from people in the member's contacts; no public profile URLs and no indexing (FR-076); adversarial perturbation against face search (A8); screenshot protection on native apps (04 §5); incognito and pause remain available | — |

| ID | Decision | Status | Resolution / default | Owner · deadline |
|---|---|---|---|---|
| D-39 | How to make sure nobody under 18 can join | **Resolved** (founder: "no under 18 can sign up") | **An ID document is required for everyone**: passport, UK/EU photo driving licence, national ID card or PASS card, with the NFC chip read where the document has one, plus liveness and a face match to the document photo. Facial age estimation alone is **not** accepted on TRYST (it is an Ofcom-recognised method, but TRYST also needs the document for ban anchors, E-02, and an adult-only platform warrants the strongest check). TRYST re-checks the provider's decision from the birth year-month and refuses anyone whose 18th birthday could still be ahead. Every mobile sign-in repeats the face match (B2), so an adult's account cannot be passed to a minor. Members without photo ID are not admitted at launch; members who cannot use face checks follow D-17 | Head of T&S · P0 vendor selection |
| D-40 | How to verify that someone who signs up as a couple is a couple | **Resolved** (founder) | TRYST verifies what can be proved and matters to other members: **two different real adults** (separate verified accounts, phones, ID documents and faces), **both consenting** (each co-signs with their own biometric sign-in), **together** (a live in-app photo of both, each face matched, plus in-person phone pairing in the same session) and **still a couple** (either can dissolve instantly; both reconfirm every 90 days). It does not ask for marriage or relationship documents: they prove nothing members need, exclude unmarried and open couples, and would be sensitive data (ToS 5.2). The two-face live check must be confirmed with the liveness vendor in P0 | Head of T&S · P0 vendor confirmation |
| D-41 | Can one person hold more than one account? | **Resolved** (founder: block fake profiles) | No. One active account per ID document. Someone who loses access recovers their account (02 §3.3) instead of opening another. Built in `admission/unique.go` | — |
| D-42 | Who is alerted when a meet goes wrong, given TRYST never knows where meets are? | **Default** | First the member's trusted contact (stored only on their phone). If the member opts in, TRYST's 24/7 safety team is the second step and receives the location for that meet only, deleted after the meet. Available from P1 through the on-call T&S rota, 24/7 from P3 | Head of T&S · P1 |
| D-43 | Criminal-record checks | **Resolved** (law and P6) | TRYST cannot check members' criminal records and will not imply that it does; there are no "background-checked" badges. The defence is identity binding, behaviour detection, member tools and fast action on court orders and police notifications. The voluntary Basic DBS dated fact (§8 L3) remains optional | — |
| D-44 | Deepfake and virtual-camera injection during identity checks | **Default** | V2 capture only in the native app with platform attestation, or through a provider certified for injection-attack detection (CEN/TS 18099); the web hands off to the phone. Confirm the certification with both age-assurance vendors in P0 | Head of T&S · P0 |
| D-45 | Members in a relationship who want a secret affair | **Resolved** (founder: "one person in a couple can want a secret affair without the other partner knowing; the platform must keep people's secrets buried") | Joining alone is the default and needs nothing from the partner; couple verification applies only to the optional joint couple profile. Secret-keeping rules in 01 §9.1: partner shield, a private solo profile kept apart from a joint couple profile (built as the `partner_secret` gate), never confirming or denying an account, no internal signal ever reaching another member. The honest limits stay stated (P9). The partner's subject-access position is ToS Q16 | — |
| D-46 | One-night stands on demand: "see who is close and free now" (founder, v1.3) | **Resolved** (founder) | Built as **Tonight** inside SPARK (FR-109; `profilesvc/tonight.go`, web `/tonight`): opt-in for 1–6 hours, reciprocal visibility only, approximate distance, interest private until mutual, 10 interests an evening, every Stage 0 gate (partner shield, ExclusionRing, blocks, hard limits) applies; the safety floor (public first meet, check-ins, door check) is shown before every meet. No live map and no exact distance, because both enable stalking and trilateration | — |

| ID | Decision | Status | Resolution / default | Owner · deadline |
|---|---|---|---|---|
| D-47 | Message-safety models need training data before launch | **Resolved** (risk closed by design) | Launch does not depend on trained models. A deterministic on-device baseline for fraud, child safety and extortion ships first (`backend/internal/guardian`, reference implementation; client ports share `shared/contracts/vocab/guardian_vectors.json`, 40 labelled vectors including look-alike benign messages such as "don't tell my wife"). A trained model replaces a rule only after it beats the rule on a held-out set: recall at least equal (child safety: never lower) at equal or better precision, on data from the expert-written synthetic corpus (03 §7.4 D1), consented member reports labelled by T&S, and quarterly red-team sets. Every new miss found in production becomes a vector | Head of T&S · P1 and every release |
| D-48 | Who staffs the 24/7 safety line at launch | **Resolved** (risk closed by design) | A contracted alarm-receiving centre accredited to BS EN 50518 and operating to BS 8484 (the UK lone-worker standard, whose alerts reach police as priority calls) staffs the line 24/7 from day one; TRYST's on-call T&S rota is the backup. Routing, 60-second acknowledgement, heartbeat failover and the minimum alert content are built and tested (`backend/internal/meet/escalation.go`). Contract and DPA with the ARC are P0 items; the ARC never learns what TRYST is beyond "personal safety service". Supersedes the staffing default in D-42 | Head of T&S · P0 contract |
| D-49 | Proving that identity providers resist fake camera feeds | **Resolved** (risk closed by design) | Certification is enforced, not assumed: providers are used for V2 only with a valid, evidenced liveness certificate; injection resistance comes either from the provider's injection-attack certificate or, without it, from native-app-only capture with platform attestation (virtual cameras cannot feed the native camera on an attested device); with no certified provider, V2 fails closed. Built and tested in `backend/internal/assurance`. Completes D-44 | Head of T&S · P0 evidence on file |
| D-50 | Persistence for the P1 build | **Default** | Each domain gets its own PostgreSQL database (identity, profile, keys, and later safety and commerce), which keeps the identity/profile split. Within a database, aggregates are stored as JSON documents written through at the end of every request (`backend/internal/store`); the relational schema generated from 02 §4 replaces them module by module as query needs grow. Photos are blobs sealed (AES-256-GCM) under a per-member data key; data keys are wrapped by a key-encryption key (KMS in production) in a separate keys database, so destroying a member's key erases their photos in primaries and backups. Production refuses to start without its databases and key. Tested against real PostgreSQL 16 in CI | Principal Eng · P1 |
| D-51 | Encryption scheme for P1 conversations | **Default** | MLS (RFC 9420) has no production-ready browser implementation today, so P1 uses a standard per-device scheme built only from the browser's own cryptography (WebCrypto): each device holds a non-extractable ECDH P-256 key; every message is encrypted separately for each device of both members with a fresh ephemeral key (ECDH → HKDF-SHA256 → AES-256-GCM), with the thread, message and device bound as associated data. The server holds ciphertext only. Limits, disclosed: no forward secrecy if a device's private key is stolen, and no post-compromise recovery; both arrive with MLS in P2, which also brings group threads for couples | Principal Eng · P2 |
| D-52 | Moderator console and enforcement for P1 | **Default** | A Trust & Safety service with its own database (SAFETY-DB): member reports and on-device signals become cases with deadlines from the escalation matrix; reporters are never shown to moderators; profile photos stay blurred until the moderator records why they need to see them; decisions follow the enforcement ladder (warn → shadow limit → suspend; immediate removal only with corroboration or a ground); a permanent removal is proposed by one moderator, applies an interim suspension, and takes effect only when a different moderator confirms; appeals go to someone not involved; every console action is written to a hash-chained log that is verified on start-up. Staff sign in through the company sign-in proxy (Cloudflare Access or oauth2-proxy) on a separate staff-only host; dev builds use hashed tokens that production refuses | Head of T&S · P2 (SSO groups, case assignment, evidence vault) |

| ID | Decision | Status | Resolution / default | Owner · deadline |
|---|---|---|---|---|
| D-53 | Payments build for P1 | **Default** | A commerce service with its own database (COMMERCE-DB) behind the processor-agnostic interface: the Stripe adapter is plain HTTPS against the documented API (Checkout Sessions, subscriptions, refunds; Idempotency-Key on every POST) and is tested against a fake Stripe server; the BitriPay adapter stays sandbox-only. Entitlements and the Keys ledger change only from verified events, processed once each and safe out of order. Cooling-off: members confirm, separately from reading the plan details, that they want the plan to start now; cancelling within 14 days ends it immediately and refunds the days not used, which is the "proportionate amount" route in ToS 16.4. Without Stripe credentials purchases answer 503; dev builds use a local test checkout that production refuses | Head of Finance · P0 (Stripe approval, live Prices, Stripe Tax) |
| D-54 | Export and erasure for P1 | **Default** | Each service implements one `Part` (export, idempotent erase) and a coordinator runs them in a fixed order: destroy the member's data key and leave discovery first, identity last. Conversations are erased for both members (the server copy is ciphertext; each device keeps its own copy until its retention expires). Reporters are replaced on cases about other people by a code that differs per subject, so corroboration still counts without linking to anyone. Open safety cases about the member and permanent-removal records are kept as the declared exceptions and named in the proof. The proof is signed with Ed25519 (key in KMS in production) and holds no personal data. The export is delivered over the signed-in session instead of as a separately encrypted file, because no copy is ever stored; step-up for export follows when 02 §3.3 step-up ships. Deleting ends live plans (cooling-off refund inside 14 days) and refunds an unspent deposit; legal to confirm the no-refund position on unused Keys and on paid periods after 14 days | DPO · P1 |
| D-55 | Notifications and email without holding contact details | **Default** | TRYST keeps contacts only as keyed hashes, so it cannot email members about activity, and won't start storing addresses to do so. Instead: (1) a masked in-app inbox; (2) optional Web Push with an **empty** payload, so Apple, Google and Mozilla see only that a push happened, and the device shows the member's own wording from local storage; endpoints are accepted only on the browser push services' hosts, so the server never calls an arbitrary URL; (3) billing emails (receipts, the ≥ 7-day renewal reminder) are sent by Stripe to the billing address the member chose at checkout, configured in Stripe Billing, with an in-app notice on `invoice.upcoming`; (4) sign-up codes go by Postmark (opens and link tracking off) or Twilio in neutral words. Production refuses to start without a code channel | Principal Eng · P1 (native app push via APNs/FCM in P2, same empty-payload rule) |
| D-56 | Vendor integration pattern | **Default** | Vendors with stable public APIs are called directly (Sightengine, PhotoDNA, Postmark, Twilio, Stripe). Vendors whose APIs are contract-specific (the identity/liveness provider, the alarm-receiving centre) are reached through one signed HTTPS gateway contract (`X-Tryst-Timestamp` + HMAC-SHA256 `X-Tryst-Signature`, bearer key): the vendor implements it, or TRYST runs a thin shim beside the vendor's SDK. Every adapter is tested against a fake server, fails closed, and logs neither member data nor secrets. Field names for Sightengine and PhotoDNA follow their public documentation and are confirmed against the live accounts in P0 | Principal Eng · P0 (vendor contracts, live keys) |
| D-57 | Deployment, monitoring and backups for P1 | **Default** | AWS London (eu-west-2): ECS Fargate behind an ALB (TLS 1.3 policy), three Multi-AZ PostgreSQL 16 instances (main; keys with 7-day recovery; the erasure ledger), KMS, Secrets Manager, object-locked backup buckets (`deploy/terraform`, validated). Backups resurrect deleted members unless handled, so every completed deletion is written to a ledger (one-way code and time, no personal data) kept apart from the service databases, and every restore runs `admin reapply-erasures` against the live ledger before taking traffic; the key database's backups expire after 7 days so crypto-erasure reaches them within a week. Safety alerts are delivered outside request locks with one retry and a failure metric that pages. Metrics are served on an internal port only and never carry identifiers | Principal Eng · P1 (SSO for the console host, WAF, multi-region DR in P2) |

| ID | Decision | Status | Resolution / default | Owner · deadline |
|---|---|---|---|---|
| D-58 | Security testing for P1 | **Default** | Automated gates catch known classes of problem on every change (docs/security/testing.md): the first run found and fixed 28 reachable Go standard-library vulnerabilities (toolchain pinned to the patched release), critical dev-dependency advisories, package managers left in the web runtime image, an unauthenticated route, a log-forging path and invisible characters in source. Automated tools don't replace people: an independent CREST penetration test and a cryptography review are launch blockers | CISO · P1 (before public launch) |
| D-59 | Trust & Safety as a standalone service | **Default** | `cmd/safety-svc` runs as its own process with its own database, image entrypoint, ECS service, security group, secrets and metrics, so moderation data and staff access are isolated from the member platform and a fault in one doesn't take down the other. The two talk only through signed internal APIs on private listeners (HMAC over caller, time, method, path and body; one secret per direction; contract `internal.v1.yaml`). Anything that must not be lost travels through a durable outbox in the sender's database: signals to safety; bans, freezes and notices back (latest standing wins). Staff sign in through the company proxy: the safety service verifies the proxy's signed token (Cloudflare Access JWT, RS256/ES256, JWKS, issuer, audience, expiry) and takes roles from a roster, not from the request. **Deadlines:** UK law requires illegal content to be dealt with swiftly but sets no minute-level deadlines; the 15-minute to 24-hour matrix (03 §7.3) is TRYST policy that meets and exceeds that duty. Reporting detected child sexual exploitation to the NCA is tracked as mandatory for every upheld suspected-minor case, with a 24-hour internal deadline; legal to confirm the statutory reporting regime and its commencement | Head of T&S · P1 |
| D-60 | Launch catalogue | **Resolved** (founder: "launch with Verified (free) and TRYST+ only") | At launch only TRYST+ (monthly, annual) is sold; Verified is free. DUO, ENVOY, GHOST, Keys packs and the deposit are hidden, refused at checkout (409 `not_on_sale`) and can't be granted by voucher until each is switched on with `SALE_ITEMS`, so nothing is sold before it exists (consumer law). The features are built and tested behind the switch | Founder · launch |
| D-61 | Identity and age assurance build | **Default** | The provider is reached through the signed gateway contract (`/assurance/sessions` → hosted check → signed callback), so either of the two shortlisted providers can be plugged in without code changes. V2 is granted only when the ID check passes **and** the conduct declaration is signed. TRYST re-checks the provider's over-18 decision from the birth year-month and refuses (and signs out) anyone under 18. The document number is turned into an HMAC under an HSM-held pepper (`ANCHOR_PEPPER`) on arrival and discarded; that code enforces one account per document, keeps banned people out after deletion (a permanent removal bans the document), and will anchor account recovery. Development uses a local stand-in provider; the old development shortcuts (automatic birth date, V0 discovery) are gone, so dev and the browser tests go through the same flow as production. Production refuses to start without a provider and refuses every check while no provider holds a valid certificate for web capture | Head of T&S · P0 (provider contract and certificates) |
| D-62 | Step-up and recovery build | **Default** | Step-up re-runs the sign-in ceremony bound to the current session and account, and marks that session (not a new one) stepped up for 5 minutes; other services read it through `Authenticate`. Device list, device add/remove and data export need it. "Start account recovery" is dropped from the step-up list: recovery is the path for someone with no working device. Recovery's first step is the provider's liveness check rather than a match to the stored B2 reference, because the reference may live only on the lost device; the ID check on the same document (one-way code match, constant-time) is what ties the person to the account. A mismatched document ends the attempt, so a recoverer can't try several. Responses are uniform for unknown contacts, `begin` is limited to 3 a day per contact, and the member gets masked notices at start and at hold. Only V2 accounts can be recovered; what a member who loses their only device before V2 can do is an open P1 item (their contact stays tied to the unverified account). The identity endpoints are `/v1/auth/devices*` because `/v1/devices/*` is already the E2EE device-key directory | Head of T&S · P1 |

| ID | Decision | Status | Resolution / default | Owner · deadline |
|---|---|---|---|---|
| D-63 | Consent ledger build | **Default** | The ledger lives with the profile data (core-svc) as one chain per member; each entry's hash is SHA-256 over the previous hash and the canonical record **including the account**, so entries can't be edited, dropped or moved between members undetected. Chains are verified at start-up and on every metrics scrape (`tryst_consent_chains_broken`, paging alert, runbook "Consent chain broken"), which meets and exceeds the nightly check. Members set three consents directly (Article 9, biometric, safety-tool training); the conduct declaration is written by identity with its wording version. Discovery reads the Article 9 answer at view time, so a withdrawal hides the member from others immediately. **On erasure the chain is deleted**, not kept: once the account is gone nothing is processed on those consents, so there is nothing left to demonstrate them for (DPO to confirm against the retention table, which says "life of account + statutory period"). **Not yet enforced:** biometric consent at sign-in (B2) for accounts created before this change, `media_view`, `meet`, `couple_link` and `retention` consents (recorded when those features use them). A recovering member ticks a consent box before the face check but, having no session, it isn't written to the ledger (open item) | DPO · P1 |
| D-64 | Discretion build | **Default** | Built on today's discovery (Tonight), which uses chosen areas rather than live location: **hidden areas** are area IDs, applied both ways, in place of home/work geofences with "hide while inside" (that needs live location and comes with the location work). Broadening is decided field by field (visible after incognito, a longer distance, a lower counterpart tier, a removed hidden area, a cleared shield, coming back after pause or vanish) and needs the 5-minute step-up rather than a separate `confirm_broaden` flag. The **partner shield** uses a keyed hash in P1: the device sends SHA-256 of the normalised contact, the server keys it with the contact pepper at once and keeps only that; every new account stores the same keyed value of its own contact at sign-up (accounts created earlier get none, so they can't be matched until re-keyed: open item). PSI stays the P2 upgrade. The **emergency lock** code is 12 characters from a 32-letter alphabet (60 bits), stored only as a keyed hash per account, single-use, rate-limited to 5 attempts a day per contact; a lock ends sessions, refuses sign-in ("account locked"), hides the profile and stops photos being served, and only recovery lifts it, after which the member comes back paused with a new code. An account locked before it reaches V2 can't be unlocked yet, because recovery needs V2 (open item) | Head of T&S · P1 |
| D-65 | Introductions, couples and ENVOY build | **Default** | Built inside the profile service so every introduction path reuses the same Stage 0 gates as Tonight (blocks, discretion, partner shield, hidden areas, tier floors, Article 9 consent). **Intake** is structured choices from controlled lists in P1; the conversational Cartographer (`/intake/turn`) needs the self-hosted model and stays P2. **Scoring** is the weighted baseline; learned preferences, pass/save signals as training data and the "why this slate" insights view come with the Broker. **Intents** follow FR-013: free 3 a week, unlimited on TRYST+, DUO or ENVOY, else Keys through the commerce ledger, refunded on any reply (an instant mutual counts as a reply). At launch Keys can't be bought (D-60), so a Verified member has 3 free intents a week and TRYST+ is unlimited. **Couples:** a link between two verified members (no joint profile or separate solo/couple presence yet, FR-107 stays open); the link changes how others see both partners ("couples"), prices couple→single intents at 15 Keys, and gives both partners a say on handshakes under the veto mode; device distinctness uses a per-browser random ID until device attestation exists. **ENVOY** proposals are computed on request from the slate, with the D-04 tap required for each send; ENVOY stays off sale (D-60) | Founder · Head of Product |

| ID | Decision | Status | Resolution / default | Owner · deadline |
|---|---|---|---|---|
| D-66 | Hosting with existing providers only | **Resolved** (founder: "only these": Hostinger VPS, Vercel, Google Cloud, Firebase) | Production and staging on **Google Cloud, London**: one Compute Engine VM per environment running the member site, console, API and safety service (`deploy/gcp/compose.yml`); Cloud SQL (main, keys, ledger) on private IPs; Secret Manager; Artifact Registry; the external Application Load Balancer with a Google-managed certificate and Cloud Armor in place of a CDN/WAF vendor; **Identity-Aware Proxy** for staff sign-in to the console in place of Cloudflare Access (`STAFF_ACCESS_PROVIDER=iap`; security keys enforced by Google 2-Step Verification). **Hostinger** runs a dev-mode demo copy, holds an encrypted off-site backup copy (never the keys database) and checks uptime from outside Google. **Vercel** and **Firebase** aren't used at launch: Vercel would carry members' Article 9 traffic as another processor and hide members' addresses from the rate limits; Firebase Auth conflicts with passkey-only sign-in and Firestore can't do per-member crypto-erasure. FCM joins with the native apps. The AWS Terraform stays as an alternative. Supersedes the edge vendors named in 09 §11–§13 for launch | Founder · engineering lead |
| D-67 | Set once: email-only launch and self-running operations | **Resolved** (founder: "something which will be set once for all") | **Email only at launch**: sign-up codes and trusted-contact alerts go through the Hostinger mailbox over SMTP with TLS (no email or SMS vendor). Without an SMS channel the API refuses phone numbers at sign-up (`email_only`) and for meet trusted contacts, so no code or safety alert can silently go nowhere; adding `TWILIO_*` later turns phones back on. **One-time setup**: `deploy/gcp/setup.sh <env>` builds an environment from Terraform (`deploy/gcp/terraform`: network, NAT, Cloud SQL ×3, VM, load balancer, Cloud Armor, IAP, Secret Manager, Artifact Registry, monitoring, deploy identity) and creates every key and database password directly in Secret Manager, never in Terraform state or on disk. **Afterwards nothing is manual**: merges to main deploy themselves (staging, then production after one approval) with keyless GitHub credentials; the VM applies security updates with a Tuesday reboot window, rotates logs and prunes images; certificates renew; Cloud SQL, VM snapshots and a weekly encrypted Hostinger copy back everything up; Google and the Hostinger VPS both alert on outages. Database users are per database but hold Cloud SQL's default privileges; narrowing them is a follow-up | Founder · engineering lead |
| D-68 | Public website and journal | **Resolved** (founder: a blog on each feature that sells it with its USP) | A separate static site (`site/`) on Vercel at `www.<domain>`, apart from the app (FR-075): indexable, no cookies, no trackers, no member data, with the app's quick exit. Programmatic: each Markdown post becomes a page, a topic listing, a "why TRYST" line, sitemap and RSS entries. Every post has a "Why it's different" section (the USP) and a "What it doesn't do" section (honest limits). Tests enforce the claims discipline (01 §15.1), no "AI" (01 §3.3), no comparative superlatives, launch prices only, and that unreleased plans (ENVOY, DUO, GHOST, Keys) appear only as not available. Writing it surfaced that the TRYST+ catalogue description promised unbuilt features (filters, travel mode, extended media, read receipts) and a free one (incognito); it now says only what TRYST+ unlocks: unlimited intents | Founder · Head of Product |

## 3. Errata fixed in v1.1

| ID | Issue (source) | Fix in v1.1 | Where |
|---|---|---|---|
| E-01 | A §8.1 lets **V1** (liveness only) send intents and open threads, contradicting ToS cl. 5.1 ("adult verified before Intent"), B FR-001 and the OSA expectation that age assurance covers the inbox. | **V2 required** for discovery, intents, Envoy, threads, media and meets. V0/V1 = onboarding only. `min_counterparty_tier` default raised to V2. | 02 §3.2; FR-001 |
| E-02 | A §19.3 L2 computes ban anchors from the ID document number and payment token **at ban time**, but A §8.1/§10 retain neither, so anchors could never be written. | `anchor_candidate` HMACs are computed at V2 and held in IDENTITY-DB under the member's keys. They are erased with the account unless a permanent ban copies them to BAN-DB. Disclosed in ToS cl. 15.3. | 02 §4.1; 03 §8 |
| E-03 | A §15.3 says viability requires "blended CAC < £12". At the stated 11% payer rate and 52% V2 rate, break-even blended CAC per sign-up is **£8.18** (£143 × 0.11 × 0.52). £12 breaks even only at ≥ 16% payer rate. | Thresholds table added: £8.18 at 11%, £11.90 at 16%, £13.38 at 18%; 3× LTV:CAC needs £2.73–£4.46. | 01 §10.3 |
| E-07 | B specifies React Native for mobile; A requires native Swift/Kotlin for security. | Native (A). React Native not used. Shared Rust crypto core instead. | 04 §3 |

| ID | Issue (source) | Fix in v1.1 | Where |
|---|---|---|---|
| E-09 | ToS Q8 cites "spec §19.5" for the consortium; it is §19.3 L5. | Corrected in ToS draft 0.9.1. | 05 cl. 29 |
| E-10 | ToS cl. 17.3 relies on "a false declaration under clause 3.2", but cl. 3.2 contains no declaration. A §19.3 L3 defines a conduct attestation at V2. | New ToS cl. 3.5 (conduct declaration); cl. 17.3 now refers to it. | 05 cl. 3.5, 17.3 |
| E-11 | A §9.2 media retention of "7 d default" was ambiguous between profile and thread media. | 7 d applies to **thread** media; profile media persists until removed. | 02 §7 |
| E-12 | A §8.1 says V1 retains "no biometric template", but A §19.3 L2 lists `anchor_biometric`. | Biometric anchor off by default (D-08). | 02 §4.2 |
| E-13 | Sources A and B both call themselves "v1.0 / 17 Sep 2026" (A's cover says 4 Oct 2026, its footer says 17 Sep). | Renamed Source A / Source B with file dates. | 00 §2 |
| E-14 | B's tiers (Black £24.99, Duo £34.99, Signals, Vault+, Concierge Black) conflict with A's. | A's tiers are canonical; Signals ≈ Keys; Vault+ folded into TRYST+ (extended media); Concierge deferred (D-15). | 01 §10.2 |
| E-16 | C planned a US launch, which A excludes. | US out of scope. C's US legal notes archived for reference only. | 01 §11 |
| E-21 | A §11 `POST /v1/panic` performs a discretion wipe, while A §19.7 defines Panic as emergency escalation and says it must be "distinct from Burn". | Wipe endpoint renamed `POST /v1/burn`; emergency is `POST /v1/safety/panic`. Distinct UI controls. | 02 §5.3, §5.8; 04 §5, §7 |
| E-23 | A §10 `couple_link` requires both co-sign timestamps to be NOT NULL but has no pending state for the invite flow. | `couple_invite` table added; `couple_link` written only on the second co-sign. | 02 §4.3 |
| E-26 | Slate size given as "12–18" (A §4) and "18" (A §11). | "Up to 18" cards including a 15% exploration floor. | 02 §5.5 |
| E-29 | A §11 lists `POST /v1/handshake` as client-callable, but handshakes must start only on mutual intent. | System-initiated only; clients read Briefs and post decisions. | 02 §5.6 |
| E-30 | A's §17 budget (£5.9M) excludes the £85–140k/yr insurance from A §20.5. | Called out as an addition in 01 §12. | 01 §12 |
| E-32 | Ashley Madison membership cited as 91M+ (B §1) and 80M+ (A §1). | Both kept as attributed, unaudited claims; external materials must use a current, dated figure. | 01 §2 |
| E-33 | Source B §11.1 targets verification + safety cost of £1.20–£2.20 per MAU alongside gross margin > 72%. At B's own conversion (7–10%) and ARPPU (£27–£34), revenue per MAU is only about £1.89–£3.40 before fees, so that cost alone consumes most of the revenue and makes 72% unreachable. | B's economics remain superseded by Source A's model (D-03); the inconsistency is recorded so B's table is not reused externally. | 01 §10.3; 07 |
| E-31 | B places THIRD/QUAD in delivery Phase 4; A treats S3/S5 as first-class and ships VC in P1. | THIRD/QUAD matching in P1 (A); DUO **billing** in P3. | FR-049 |

(Gaps in the E-numbering are intentional; IDs are never reused.)

# 4. Change log

| Version | Date | Change | Author |
|---|---|---|---|
| 1.0 (Source B) | 17 Sep 2026 | Developer Specification | Founder |
| 0.1 (Source C) | 4 Oct 2026 | PRD & business plan draft | Claude Code (draft) |
| 1.0 (Source A) | 4 Oct 2026 | Consolidated Spec + ToS draft 0.9 | Office of the Group CEO |
| 1.1 | 4 Oct 2026 | Merged A + B + C; split into Product / Shared Contracts / Backend / Frontend / ToS; decisions D-01–D-15; errata E-01–E-31; baseline and change control established | Claude Code, for founder review |

| Version | Date | Change | Author |
|---|---|---|---|
| **1.2** | **4 Oct 2026** | Founder logo added exactly as supplied (`shared/brand/`); brand palette and tokens from the logo; account-holder-only login: two biometric factors on app/mobile PWA, two factors on desktop (D-16–D-18, FR-056–FR-063, NFR-16/17, ToS 0.9.2 cl. 6.5, Q14–Q15); source register (00 §5); D-23 market-clarity vs store wording; Stripe as primary processor, conditional on approval (D-22, FR-078); intent change history (FR-079); E-33; Herald dynamic SEO agent and marketing site (FR-073–FR-077, NFR-20, D-21); full Source B added verbatim as appendix 07 with traceability; Source B §9–10 coverage (03 §6.8), Article 6 bases, FR-069–FR-072, NFR-18–19, ToS 0.9.3; FR-064–FR-068, D-20; founder product-scope statement, executive product decision, one-sentence pitch and market thesis added verbatim (01 §1–§2), D-01 reopened, E-32; spec folder renamed `docs/spec` | Claude Code, for founder review |
| **1.3** | **4 Oct 2026** | Operating system for TRYST (new doc 09, internal engineering) from the founder's Master founder OS brief: brief coverage register, market-gap review, user ecosystem, command centres for every user type, agent workforce and core agents, self-managing layer, BitriPay API door, connector register, architecture, ops and partner schemas, ops and partner APIs, monetisation, security, Admin Super Control Centre, roadmap; D-25–D-32, FR-080–FR-088. Implemented and tested: AI Governance gate with workforce registry, kill switch and hash-chained audit (`backend/internal/aigov`); BitriPay payment adapter, sandbox-only (`backend/internal/payments/bitripay.go`) ; no "AI" in name or brand (D-33, 01 §3.3, build test); open relationships explicitly welcome (D-34); public sign-up in four UK cities, matching opening city by city from London, with a balance waitlist (D-35, FR-089, FR-090, `backend/internal/launch`) ; launch risks closed: gender-neutral demand-balance waitlist (D-36, FR-090) and automatic paid-acquisition brake (FR-091) ; profiles show main photo, age, area and distance with up to 10 photos, no AI images (D-37, D-38, FR-092, FR-093); ID-document age verification with TRYST re-check (D-39, FR-094); couple verification and 90-day reconfirmation (D-40, FR-095, FR-096); ToS draft 0.9.4 cl. 5.1, 6.1 ; fake-profile and criminal-misuse defences (03 §7.7, D-41–D-44, FR-097–FR-105): one person one account, control-network detection, profile text screening, door check, duress PIN, safety line, new Guardian models ; secret-keeping for members in relationships (01 §9.1, D-45, FR-106–FR-108, `partner_secret` gate, ToS draft 0.9.5 cl. 7.0, 14.4, Q16) ; profile and photo API (02 §5.3, OpenAPI) with profile editor and card preview screens ; Tonight (D-46, FR-109); launch risks closed: message-safety baseline with labelled vectors and model gate (D-47, FR-110), ARC-staffed 24/7 safety line (D-48, FR-111), certification-gated identity checks (D-49, FR-112) | Claude Code, for founder review |

# 07 — Source B: Founder Developer Specification (verbatim) and traceability

Part of the TRYST specification baseline.

This appendix reproduces **Source B** — *TRYST AI Discreet Relationship Platform — Developer Specification, v1.0, 17 September 2026* — **word for word**, extracted directly from `source/TRYST_Developer_Specification_2026-09-17.docx`. The founder re-confirmed it on 4 October 2026.

- **Headings, tables and callouts** keep the original wording. Only the formatting has been converted to Markdown.
- **Precedence:** where Source B conflicts with Source A (the consolidated Spec + ToS), 00 §2 decides, and 06 records the outcome.
- **Traceability:** §1 below shows where each Source B section is implemented and what v1.2 added to cover its gaps.

## 1. Traceability — where each Source B section lives

| Source B section | Implemented in | Notes |
|---|---|---|
| Product scope | 01 §1 (verbatim) | Unattached solos: D-01 |
| Executive product decision, pitch | 01 §1.1 (verbatim + mapping) | |
| 1. Market thesis | 01 §2 (verbatim) | Member counts: E-32 |
| 2. Users and modes | 01 §5.2, 02 §2.3, 02 §9 | Mode names are the UI labels (D-14) |
| 3. Experience architecture | 04 §4; loops in 01 §6 | Stage 9 "emergency lock" → **FR-064 (new in v1.2)** |
| 4. Discretion product system | 04 §5, 02 §6.4 | New in v1.2: **FR-064** emergency lock, **FR-065** rotating location cells; FR-026 wording and FR-029 disclosure updated |
| Privacy reality | 01 §4.2 P9, 01 §9 | |
| 5. AI agentic operating system | 01 §7, 03 §3 | Agent mapping in §2 below; new **FR-066** (conversation drafts) and **FR-067** (member-provided windows only) |
| 6.1 Learned dimensions | 03 §4 | New **FR-068** behaviour decay |
| 6.2 Ranking model | 03 §5.2 (P1 baseline), 03 §5.3 | Optimisation target: Source A's QCAM (meets) is the north star; B's "qualified reciprocal conversations" is a secondary KPI (01 §13.1) |
| 7. Functional requirements (FR-001–015) | 02 §10.1 | B's FR numbers were folded into the v1.1+ catalogue (each row cites "B") |
| 8. Architecture and data, 8.1 entities, 8.2 API | 02 §4, 02 §5, 03 §2 | Stack: Source A's native apps replace React Native (E-07) |
| 9. Security and privacy doctrine | 03 §6, 01 §14.2; full coverage table 03 §6.8 | New in v1.2: Article 6 bases, FR-069–071, NFR-18–19, backup disclosure |
| 10. Trust, safety and misuse controls | 03 §7, 03 §8; coverage table 03 §6.8 | New in v1.2: FR-072 (protected-trait harassment), FR-069 upload warning |
| 11. Business model, 11.1, 11.2 | 01 §10, 01 §11 | Tiers and economics superseded by Source A (E-14, D-03); the revenue ethic is kept as P8 |
| 12. Delivery plan, 12.1 team | 01 §12 | Source A's P0–P4 and 17-person team replace B's plan (D-12) |
| 13. MVP backlog and acceptance | 03 §12, 04 §10 | |
| 14. KPIs, governance, no-go | 01 §13 (G-NG-1 to G-NG-7 come from B) | |
| 15. Source register | §3 below (verbatim) | Revalidate before launch |
| Final directive | 01 §4, 01 §12, no-go list 01 §13.2 | Market clarity vs store wording: D-23. Readiness = gates G-P0–G-P4 and G-NG-1–10 |

## 1.1 Requirement-ID crosswalk (Source B FR → catalogue FR)

**Caution:** Source B numbers its own FR-001–FR-015, and those numbers do **not** mean the same as the catalogue's (02 §10.1). Inside the verbatim text in §3, an FR number is Source B's. Everywhere else, FR numbers are the catalogue's.

| Source B ID | Source B requirement | Catalogue requirement(s) |
|---|---|---|
| B FR-001 | 18+ entry | FR-001 (V2 gate) |
| B FR-002 | Pseudonymous identity | FR-002 |
| B FR-003 | Intent modes | FR-004 |
| B FR-004 | Discretion policy | FR-005 |
| B FR-005 | Couple representation | FR-006 |
| B FR-006 | Reveal ladder | FR-008 |
| B FR-007 | Private discovery | FR-009 |
| B FR-008 | Contact suppression | FR-010 |
| B FR-009 | Chat safety | FR-032 (report, block), FR-033 (real-time on-device scanning, D-02), FR-034 (escalation), FR-013 (rate and inbound limits) |
| B FR-010 | Behaviour controls | FR-024 |
| B FR-011 | Quick exit | FR-029 |
| B FR-012 | Deletion | FR-038 |
| B FR-013 | Neutral notifications | FR-026 |
| B FR-014 | Reports/appeals | FR-034, FR-035 |
| B FR-015 | No commercial sex | FR-037 |

## 1.2 Architecture, entity and endpoint crosswalk (Source B §8 → contracts)

**Layers.** Every Source B layer is kept. The one exception is "React Native iOS/Android", which is replaced by native Swift/Kotlin apps with a shared Rust crypto core (E-07, 04 §3).

- "OIDC/passkeys" → OAuth2 + DPoP with passkey-only, two-factor login (02 §3.3).
- "Alias service" → pseudonymous `display_name` in PROFILE-DB, joined to identity only through the HSM pepper.
- "Relationship/block graph projection" → the Stage 0 gates (03 §5.1).

| Source B entity | Contract entity (02 §4) |
|---|---|
| User | `identity` (IDENTITY-DB) + `profile.status` |
| AliasProfile | `profile` (`display_name`, `bio_ct`, `visibility`, `version`) + `media` |
| IntentProfile | `intent_vector` |
| DiscretionPolicy | `discretion_policy` (versioned) |
| CoupleUnit | `couple_link` + `couple_invite` |
| Introduction | `slate_item` |
| RevealGrant | `reveal_grant` |
| Room | `thread` (MLS group) |
| BehaviourEvent | event envelope (02 §8) |
| ReportCase | `report_case` + `enforcement` |
| DeletionJob | `ops.deletion_job` |

| Source B endpoint | Contract endpoint (02 §5) |
|---|---|
| `POST /v1/identity/verify` | `POST /v1/assurance/session` (+ `/v1/assurance/callback`) |
| `PUT /v1/discretion-policy` | `PUT /v1/discretion/policy` |
| `POST /v1/intents` | `POST /v1/intake/vector/confirm` (member-confirmed intent profile); outbound interest is `POST /v1/intent` |
| `POST /v1/couple-units` | `POST /v1/couple/invite` + `POST /v1/couple/cosign` |

| Source B endpoint | Contract endpoint (02 §5) |
|---|---|
| `GET /v1/discovery` | `GET /v1/slate` |
| `POST /v1/introductions/{id}/decisions` | `POST /v1/intent` · `/v1/pass` · `/v1/save` · `/v1/preferences/correction` |
| `POST /v1/reveal-grants` / `DELETE …/{id}` | Same paths |
| `POST /v1/reports` | `POST /v1/report` |
| `POST /v1/preferences/reset` | Same path |
| `DELETE /v1/users/me` | `DELETE /v1/account` |

## 2. Agent mapping (Source B's ten → v1.2's seven)

| Source B agent | v1.2 home | Boundary carried over |
|---|---|---|
| Chemistry Agent | Mirror (learning) + Broker (ranking) | Ranks; never fabricates interest or sends messages (FR-055) |
| Intent Agent | Cartographer | Member confirms every structured field (FR-003) |
| Discretion Agent | Curtain | May tighten, never loosen (02 §6.4) |
| Timing Agent | Envoy (logistics dimension) | **Member-provided windows only, never inferred routines (FR-067)** |
| Conversation Agent | On-device drafting assistant (D-20) | **Draft-only, opt-in, never auto-sent (FR-066)** |
| Authenticity Agent | Guardian (M7, M7b) + admission control L1 | Friction/hold automatic; permanent ban only by a human (FR-035) |
| Risk Agent | Guardian (M6a–e, escalation matrix) | Escalates, restricts, preserves evidence (FR-034) |
| Group Agent | Broker (max-min scoring) + Envoy + couple semantics | Cannot add anyone or reveal anyone without consent (FR-006, FR-049) |
| Learning Agent | Mirror | Approved features only; no message content (03 §4.2) |
| Privacy Auditor | Release gate (not an agent) | Can block a release (03 §9) |

## 3. Source B — full text (verbatim)

CONFIDENTIAL PRODUCT BLUEPRINT

> TRYST
>
> Private chemistry. Intelligent discretion.

AI-AGENTIC PLATFORM FOR AFFAIRS, EXTRA-RELATIONSHIP CONNECTIONS AND THREESOMES

Developer-ready product, AI, privacy, commercial and delivery specification Version 1.0 | 17 September 2026

> PRODUCT SCOPE
>
> TRYST is designed specifically for adults who are already in a relationship and want a discreet one-off affair, a continuing extramarital connection, another couple, or a threesome. Existing-partner permission is not a condition of membership. Every person using TRYST must nevertheless be an independently consenting adult; the platform prohibits coercion, stalking, blackmail, impersonation, minors, non-consensual imagery and commercial sexual services.

### Executive product decision

Build TRYST as a privacy-first, affair-specific connection platform rather than a generic dating app. Its strategic advantage is an AI relationship-intelligence layer that learns attraction, discretion requirements, availability, risk tolerance and interaction quality while deliberately collecting less identifying data than incumbents.

| Decision | Specification | Why it wins |
|---|---|---|
| Name | TRYST | One sharp word meaning a private romantic meeting; instantly communicates the category. |

| Decision | Specification | Why it wins |
|---|---|---|
| Audience | Partnered adults of any gender/orientation; couples seeking a third or another couple | Clear, high-intent niche rather than mass-market dating. |
| Promise | Private chemistry. Intelligent discretion. | Combines emotional benefit with the functional moat. |
| Core modes | One-off, Ongoing, Couple+, Threesome, Couple-to-Couple | Intent is explicit before matching. |
| Moat | Discretion Graph + Behavioural Compatibility Engine | Learns fit without exposing identity or partner data. |
| Revenue | Subscription-led with credits and premium privacy | Predictable recurring revenue plus high-margin intent transactions. |
| Launch | Web/PWA first, then native apps subject to store review | Reduces store dependency and permits rapid privacy iteration. |

> ONE-SENTENCE PITCH
>
> TRYST is the intelligent private network where attached adults and couples find precisely matched affairs, extra-relationship connections and threesome partners without exposing more of their identity than necessary.

## 1. Market thesis

The category is already validated. Ashley Madison markets private, anonymous connections and claims more than 91 million members. Gleeden uses a credit economy for extramarital connections; Victoria Milan markets a rapid-exit “panic button.” The opportunity is not to prove demand but to rebuild the category around modern privacy engineering, verified authenticity, gender-neutral pricing, transparent AI and higher-quality matching.

| Incumbent pattern | Observed weakness | TRYST response |
|---|---|---|
| Large anonymous inventory | Fake profiles, low trust and expensive dead-end messaging | Liveness, authenticity confidence and conversation-quality scoring. |
| Credit-heavy messaging | Revenue can conflict with real connection outcomes | Subscription provides core value; credits enhance but do not manufacture access. |
| Basic privacy theatre | A panic button cannot protect server-side data | Pseudonymity, data minimisation, isolated vaults, short retention and discreet billing. |
| Pairwise matching | Poor fit for couples and threesomes | Native multi-person matching and room consent. |
| Swipe engagement | High noise and fatigue | Small daily set of high-confidence, intent-aligned introductions. |

## 2. Users and modes

| Mode | User need | Eligibility / system rule |
|---|---|---|
| SPARK | Discreet one-off encounter | Attached status accepted; match on availability, distance and chemistry. |
| EMBER | Ongoing affair or recurring connection | Match on cadence, emotional intensity, communication windows and expectations. |
| THIRD | A couple seeks one additional person | Both couple members must separately verify the shared couple profile; the third is treated as an equal user. |
| QUAD | Two couples seek one another | Four independent accounts; shared match only after each side’s configured quorum. |
| OPEN | Flexible extra-relationship exploration | User selects allowed configurations and visibility rules. |

TRYST does not ask a user to prove permission from a spouse or external partner. It only requires consent from the people who are actually participating through TRYST. A couple profile cannot represent the second member without that member’s own account and confirmation.

## 3. Experience architecture

| Stage | User experience | Platform behaviour |
|---|---|---|
| 1. Quiet entry | Neutral landing page, email alias or private number, discreet notifications | No contact upload; no social-login requirement; risk-screen session. |
| 2. Adult/authenticity check | Age assurance and liveness; legal name stays private | Store verification token/result separately from profile. |

| Stage | User experience | Platform behaviour |
|---|---|---|
| 3. Discretion setup | Choose icon, notification wording, app lock, visibility and location fuzzing | Generate a Discretion Policy applied across all services. |
| 4. Intent map | Select SPARK, EMBER, THIRD, QUAD or OPEN and define boundaries | Build explicit intent vector and exclusions. |
| 5. Discovery | Receive a limited ranked set with compatibility explanations | Candidate retrieval excludes blocks, contacts hash list if opted in, risk conflicts and impossible schedules. |
| 6. Reveal ladder | Alias → blurred gallery → selected photos → voice/video | Each reveal is separately approved and revocable. |
| 7. Private room | Chat, disappearing media, availability coordination | Encrypted content, screenshot friction, abuse/scam detection. |
| 8. Outcome learning | Private “more/less like this” and quality feedback | Update preference model; feedback is not shown to the other user. |
| 9. Exit | Pause, vanish, delete or emergency lock | Immediate discovery removal; deletion and retention workflow starts. |

## 4. Discretion product system

| Control | Requirement |
|---|---|
| Neutral shell | Optional generic icon/name on device where technically possible; neutral web favicon and page title option. |
| Notification privacy | Default notification says “You have an update”; never includes names, images or message excerpts. |
| App lock | Independent PIN/biometric lock; session re-authentication after configurable inactivity. |
| Quick exit | Immediate neutral screen plus client cache clearing; clearly state this cannot hide network/device history. |
| Location veil | Use distance bands and rotating approximate cells; never reveal live or exact home/work coordinates. |
| Invisible mode | Only people the member explicitly likes can see them, subject to mutual eligibility. |
| Recognition shield | Optional on-device contact hashing to suppress known contacts; raw address book never uploaded. |
| Media vault | Face blur, selective reveal, recipient watermark, expiry, revocation and no public URLs. |
| Discreet billing | Neutral merchant descriptor where lawful and accurate; transparent receipt settings; no deceptive descriptor. |
| Emergency lock | Freeze logins and sessions, hide profile and disable media links from a separate recovery path. |
| True deletion | Free account deletion; documented purge and backup expiry; no false “full delete” claim. |

> PRIVACY REALITY
>
> TRYST must never promise that an affair is undetectable. It can minimise platform exposure, but cannot guarantee secrecy from a device owner, bank, employer, network administrator, recipient screenshot, legal process or determined third party.

## 5. AI agentic operating system

| Agent | Role | Autonomy boundary |
|---|---|---|
| Chemistry Agent | Learns attraction patterns from explicit choices and reciprocal outcomes | Ranks; never fabricates interest or sends messages. |
| Intent Agent | Transforms free-text goals into SPARK/EMBER/THIRD/QUAD/Open vectors | User confirms every structured field. |
| Discretion Agent | Creates and enforces each member’s privacy policy | May reduce exposure automatically; cannot weaken settings. |
| Timing Agent | Matches compatible communication and meeting windows | Uses user-provided windows, not inferred home routines. |
| Conversation Agent | Suggests openers, boundary questions and respectful replies | Draft-only; no impersonation or autonomous chat. |
| Authenticity Agent | Detects bots, scams, stolen images and identity inconsistency | Can add friction/hold; permanent ban follows policy/review. |
| Risk Agent | Detects harassment, blackmail, coercion, trafficking and underage signals | Escalates, restricts and preserves evidence under defined rules. |

| Agent | Role | Autonomy boundary |
|---|---|---|
| Group Agent | Solves multi-person compatibility and quorum for THIRD/QUAD | Cannot add anyone or reveal one user to another without product consent. |
| Learning Agent | Updates behavioural embeddings and experiment assignments | Uses approved features only; sensitive raw content excluded by default. |
| Privacy Auditor | Continuously tests access, retention and model leakage | Can block a release when thresholds fail. |

## 6. Behaviour-learning design

### 6.1 Learned dimensions

| Dimension | Signals | Treatment |
|---|---|---|
| Attraction | Likes, passes, private preference corrections | Embeddings; never disclose inferred sensitive traits. |
| Intent fit | Mode, desired duration, emotional depth, exclusivity expectation | Hard/soft constraints controlled by user. |
| Discretion fit | Visibility, response windows, reveal pace, distance bands | Mismatch strongly penalised. |
| Communication fit | Message cadence, length preference, voice/video comfort | Aggregate features; raw content short-lived and excluded from training by default. |
| Reliability | Mutual attendance feedback, cancellations, ghosting pattern | Private score with anti-retaliation safeguards. |
| Respect/safety | Blocks, reports, boundary violations, pressure patterns | Safety model; reports never become visible reputation badges. |
| Group symmetry | Each participant’s attraction and boundaries | Maximise minimum compatibility, not average score alone. |

### 6.2 Ranking model

> TRYST MATCH SCORE
>
> Eligibility filter first. Then: 24% reciprocal attraction + 20% intent fit + 15% discretion fit + 12% communication fit + 10% availability/logistics + 8% reliability + 6% novelty + 5% model confidence − risk penalties. THIRD/QUAD adds a max-min fairness constraint so one person’s strong interest cannot overwhelm another participant’s low fit.

- Hard exclusions: age uncertainty, block edges, missing participating-couple confirmation, prohibited purpose, incompatible mode, critical safety risk.
- Behaviour decays over time; the user can reset all inferred preferences.
- Every introduction displays two to four non-sensitive reasons and offers a correction control.
- No ranking uplift based on gender. Paid visibility applies only inside an already eligible set and is visibly labelled.
- Optimisation target: qualified reciprocal conversations and user-rated fit—not time spent, message volume or credit burn.

## 7. Functional requirements

| ID | Requirement | Acceptance criterion |
|---|---|---|
| FR-001 | 18+ entry | Discovery remains locked until age-confidence threshold and liveness pass. |
| FR-002 | Pseudonymous identity | Public profile never requires legal name, employer or exact address. |
| FR-003 | Intent modes | A member may enable multiple modes with separate visibility and filters. |
| FR-004 | Discretion policy | Every API returning profile data evaluates the requester against current policy. |
| FR-005 | Couple representation | THIRD/QUAD shared profile publishes only after all represented members approve exact version. |
| FR-006 | Reveal ladder | Each media/identity disclosure records grant, recipient, version and expiry. |

| ID | Requirement | Acceptance criterion |
|---|---|---|
| FR-007 | Private discovery | Invisible members are discoverable only following their outbound interest. |
| FR-008 | Contact suppression | Optional hashing occurs on device; server stores salted blinded tokens only. |
| FR-009 | Chat safety | Rate limits, block, report, media scanning and blackmail/threat escalation operate in real time. |
| FR-010 | Behaviour controls | Member can view categories, correct assumptions, disable personalisation and reset learning. |
| FR-011 | Quick exit | One action hides content and clears client view in under 500 ms on supported clients. |
| FR-012 | Deletion | Profile disappears immediately; purge jobs meet published retention SLA and generate audit proof. |
| FR-013 | Neutral notifications | Lock-screen content contains no relationship, profile or message detail. |
| FR-014 | Reports/appeals | 24/7 urgent queue; reasoned enforcement and appeal workflow. |
| FR-015 | No commercial sex | Solicitation/payment-for-contact patterns route to review and enforcement. |

## 8. Architecture and data

| Layer | Developer specification |
|---|---|
| Clients | Next.js PWA/web; React Native iOS/Android after policy clearance; local encrypted vault; biometric/PIN lock. |
| Edge | WAF, bot management, API gateway, rate limiting, device attestation and privacy-safe abuse fingerprints. |
| Identity plane | OIDC/passkeys, verification adapter, alias service and separated identity vault. |
| Core services | Profile, Intent, Discretion Policy, Discovery, Match, Group, Conversation, Media, Safety, Billing, Deletion. |
| Data plane | PostgreSQL transactions; relationship/block graph projection; Redis; Kafka-compatible events; encrypted object storage. |
| AI plane | Feature registry/store, vector retrieval, ranker, LLM gateway, model registry, evaluation and experiment platform. |
| Operations | Trust console with redacted defaults; SIEM; audit service; privacy/deletion orchestrator; incident command. |

### 8.1 Core entities

| Entity | Essential fields |
|---|---|
| User | id, status, jurisdiction, verification_state, deletion_state |
| AliasProfile | user_id, display_alias, bio, approved_media, visibility, version |
| IntentProfile | user_id, modes[], boundaries, cadence, emotional_depth, availability |
| DiscretionPolicy | user_id, visibility, distance_band, reveal_rules, notification_policy, version |
| CoupleUnit | id, member_ids, approval_version, active_state |
| Introduction | subjects, candidate, score, model_version, explanation_codes, paid_label |
| RevealGrant | resource_id, owner, recipient, scope, expires_at, revoked_at |
| Room | id, participant_ids, mode, membership_version, safety_state |
| BehaviourEvent | pseudonymous_subject, type, context, consent_basis, ttl |
| ReportCase | reporter, subject, taxonomy, severity, evidence_refs, decision, appeal |
| DeletionJob | user_id, systems[], due_at, completion_proof |

### 8.2 API surface

| Method / endpoint | Purpose / rule |
|---|---|
| POST /v1/identity/verify | Begin age/liveness flow; returns status token, not document. |
| PUT /v1/discretion-policy | Versioned update; cannot silently broaden exposure. |
| POST /v1/intents | Create user-confirmed mode-specific intent. |
| POST /v1/couple-units | Invite represented participant; no spouse approval requirement unless spouse is represented in-platform. |

| Method / endpoint | Purpose / rule |
|---|---|
| GET /v1/discovery | Policy-filtered ranked introductions; cache result re-authorised on read. |
| POST /v1/introductions/{id}/decisions | Private like/pass/correction; idempotent. |
| POST /v1/reveal-grants | Recipient-specific, expiring access. |
| DELETE /v1/reveal-grants/{id} | Immediate revocation and CDN/key invalidation. |
| POST /v1/reports | Create protected report and evidence references. |
| POST /v1/preferences/reset | Delete/neutralise learned vectors and rebuild from explicit choices. |
| DELETE /v1/users/me | Immediate disable and deletion workflow initiation. |

## 9. Security and privacy doctrine

TRYST processes exceptionally sensitive information: sex life, sexual orientation, relationship status, private messages, intimate media and location. Under UK GDPR, sex-life and sexual-orientation data is special category data. The controller needs an Article 6 lawful basis, an Article 9 condition, a DPIA, explicit-consent records where relied upon, strict retention, rights handling and international-transfer controls.

| Control family | Mandatory implementation |
|---|---|
| Minimisation | No real name on profile; no mandatory contact upload; no home/work address; age result instead of DOB where possible. |
| Separation | Identity vault, profile store, media vault, analytics and billing linked through scoped pseudonymous identifiers. |
| Encryption | TLS 1.3; envelope encryption; per-object media keys; HSM/KMS; key rotation and access telemetry. |
| Authorisation | ABAC using requester, resource, reveal grant, block graph, discretion version, safety state and jurisdiction. |
| Private media | Short-lived signed access, recipient binding, no public CDN, malware scanning, watermark option, rapid key revocation. |
| Payments | Tokenised PSP; store minimum references; truthful neutral descriptor; finance staff cannot browse profiles. |
| Admin | Just-in-time access, dual approval for intimate content, reason codes, immutable logs and anomaly detection. |
| Deletion | Free, simple, verified purge across primary stores; backup expiry disclosed; legal holds narrowly scoped. |
| Incident readiness | Specific runbooks for outing, sextortion, intimate-media leak, insider abuse, account takeover and mass breach. |
| Assurance | OWASP ASVS/MASVS, threat modelling, independent penetration tests, bug bounty and annual privacy audit. |

> ASHLEY MADISON LESSON
>
> The FTC reported that the 2015 Ashley Madison breach exposed information associated with 36 million users and alleged security and deletion failures. TRYST must treat privacy claims as verifiable product requirements: collect less, separate identity, delete truthfully and assume attackers will target the platform specifically because of its members' vulnerability to exposure.

## 10. Trust, safety and misuse controls

| Risk | Controls |
|---|---|
| Fake profiles / bots | Liveness, device risk, behaviour graph, photo provenance checks, friction and human review. |
| Blackmail / sextortion | Payment-demand and threat detection, rapid room freeze, evidence preservation, victim resources and law-enforcement policy. |
| Stalking / doxxing | Coarse location, visibility controls, search throttling, network-level blocks and repeat-account detection. |
| Non-consensual media | Hash matching where lawful, upload warnings, recipient controls, rapid takedown and account sanctions. |
| Coercion in threesomes | Independent accounts, individual approval, private withdrawal, no single "couple owner." |
| Underage access | Age assurance, re-check triggers, content/report triage and legally required reporting. |
| Commercial sex / trafficking | No payments between members, solicitation detection, specialist review and jurisdictional reporting. |
| Bias / predatory targeting | No sensitive-trait ad targeting; exposure audits; prohibit fetishisation/harassment based on protected traits. |

| Risk | Controls |
|---|---|
| Retaliatory reports | Reporter credibility signals, evidence review, appeal and no automatic permanent ban from one uncorroborated report. |

## 11. Business model

| Offer | Indicative UK price | Included value |
|---|---|---|
| TRYST Free | £0 | Verified profile, intent setup, limited introductions, mutual matches, block/report and deletion. |
| TRYST Black | £24.99/month or £179/year | Unlimited curated discovery, invisible mode, advanced filters, travel, preference insights and priority support. |
| TRYST Duo | £34.99/month or £249/year per couple | THIRD/QUAD tools, joint profile, multi-person matching and shared room coordination. |
| Private Signals | £6.99 / £14.99 / £29.99 packs | Labelled high-intent signals or temporary visibility; never bypass filters or consent. |
| Vault+ | £7.99/month | Extended encrypted media vault, granular expiry and multi-device recovery. |
| Concierge Black | £299-£799/month | Human-curated introductions for verified members; no escorting or outcome guarantee. |

> REVENUE ETHIC
>
> Do not monetise fake profiles, unreadable credit mechanics, gender discrimination, safety, deletion or access to one's data. TRYST earns more when members trust the platform enough to stay—not when it manufactures frustration.

### 11.1 Illustrative unit economics

| Metric | 12-month target | Scale target |
|---|---|---|
| Free-to-paid conversion | 7-10% | 12-16% |
| Blended ARPPU | £27-£34/month | £35-£45/month |
| Monthly paid churn | <7% | <4.5% |
| Gross margin | >72% | >82% |
| CAC payback | <8 months | <5 months |
| LTV:CAC | >3x | >4.5x |
| Verification + safety cost / MAU | £1.20-£2.20 | £0.55-£1.10 |
| Chargeback rate | <0.7% | <0.4% |

### 11.2 Go-to-market

1. Launch a private web beta in London, then Birmingham and Manchester only after local liquidity thresholds are met.
2. Acquire through privacy-led content, discreet affiliates, relationship/lifestyle publishers and invitation codes—not explicit advertising that triggers platform rejection.
3. Seed verified, balanced cohorts; never use synthetic personas or employees posing as members.
4. Lead PR with modern privacy engineering and authenticity rather than moral provocation.
5. Create referral rewards that reveal no referrer relationship to invitees and expire automatically.
6. Expand by city only when compatible inventory, moderation coverage and safety SLAs are proven.

## 12. Delivery plan

| Phase | Duration | Deliverables | Exit gate |
|---|---|---|---|
| 0. Discovery | 6 weeks | Research, legal/DPIA, naming clearance, threat model, prototypes, store review | No fatal legal/platform blocker; user value validated. |
| 1. Privacy core | 12 weeks | Identity vault, profile, intent, discretion engine, deletion, admin audit | Independent architecture/security review. |
| 2. Closed beta | 12 weeks | Discovery, chat, reveal ladder, billing, reports and moderation | High-severity response SLA and zero critical access failures. |

| Phase | Duration | Deliverables | Exit gate |
|---|---|---|---|
| 3. AI learning | 12 weeks | Retrieval/ranking, explanations, reset, experiments and model governance | Quality lift without safety/privacy regression. |
| 4. Group modes | 10 weeks | Duo profiles, THIRD/QUAD matching, quorum rooms | Independent-participant consent tests pass. |
| 5. City launch | 16 weeks | Growth, SRE, 24/7 operations, native app decision | Retention, paid conversion and liquidity gates. |

### 12.1 Initial team

| Function | Capacity |
|---|---|
| Leadership | Product Development Director, CTO/Engineering Director, Trust & Safety Director |
| Product/Design | Senior PM, UX researcher, 2 product designers |
| Engineering | Tech lead, 4 backend, 2 mobile/web, platform/SRE, QA automation, security engineer |
| AI/Data | ML lead, 2 ML engineers, data engineer/analyst |
| Trust/Operations | Policy lead, investigator lead, moderation coverage, customer operations |
| Legal/Privacy | DPO, product counsel, app-store counsel, external penetration/privacy specialists |
| Commercial | Growth lead, lifecycle marketer, partnerships/affiliate manager |

## 13. MVP backlog and acceptance

| Epic | P0 delivery | Definition of done |
|---|---|---|
| Quiet onboarding | Alias, private contact, age/liveness, device lock | No public/legal identity leakage; unverified users excluded. |
| Intent engine | Five modes, hard boundaries, availability and discretion | User confirms structured output; change history audited. |
| Discretion engine | Visibility, neutral notifications, location veil, invisible mode | Every read path policy-tested; stale caches cannot expose. |
| Discovery | Candidate retrieval, ranker baseline, explanations | Hard exclusions are deterministic; paid status cannot override. |
| Reveal ladder | Blurred/private media, grants, expiry and revoke | Revocation invalidates active access quickly and is measured. |
| Chat | Encrypted transport/storage, disappearing options, block/report | Blocked users lose all room access; evidence flow is isolated. |
| Safety console | Cases, severity, actions, appeals and audit | Urgent cases page on-call; admin access is least privilege. |
| Billing | Free, Black, Duo and signals | Clear prices/refunds; neutral truthful descriptor; safety remains free. |
| Deletion | Pause, vanish and full delete | Published SLA; primary-store purge verified; backups age out. |
| AI controls | Preference view/correct/reset/opt-out | Reset removes inferred vectors; model card and rollback exist. |

## 14. KPIs, governance and no-go gates

| Dimension | Metric |
|---|---|
| North star | Qualified reciprocal conversations per 1,000 verified weekly active members. |
| Match quality | Mutual interest, reply rate, private fit rating, repeat-connection rate, unwanted-contact rate. |
| Discretion | Exposure incidents, location inference success in red-team tests, notification leakage, deletion completion. |
| Authenticity | Verified ratio, bot prevalence, scam report rate, successful account-takeover rate. |
| Safety | Severe incidents per 10,000 rooms, response time, repeat offender, appeal overturn and victim-support SLA. |
| AI | Calibration, hard-boundary violation, explanation usefulness, exposure fairness, drift and privacy leakage. |
| Commercial | Conversion, ARPPU, churn, CAC payback, contribution margin, refunds and chargebacks. |
| Reliability | Crash-free sessions, p95 latency, message delivery, RPO/RTO and emergency-lock latency. |

> NO-GO CONDITIONS

> Do not launch or scale if private media can be accessed outside an active grant, deletion claims are not technically true, exact location can be triangulated, age assurance is ineffective, couple profiles can represent unverified people, high-severity reports lack 24/7 response, or ranking violates a hard boundary.

## 15. Source register

Accessed 17 September 2026. Policies, prices and legal requirements must be revalidated before launch.

| Source | URL |
|---|---|
| Ashley Madison official positioning | https://www.ashleymadison.com/ |
| Gleeden official site | https://en.gleeden.com/ |
| Victoria Milan official privacy features | https://www.victoriamilan.com/ |
| FTC Ashley Madison settlement and breach findings | https://www.ftc.gov/news-events/news/press-releases/2016/12/operators-ashleymadisoncom-settle-ftc-state-charges-resulting-2015-data-breach-exposed-36-million |
| ICO special category data guidance | https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/lawful-basis/special-category-data/what-is-special-category-data/ |
| UK GDPR Article 9 | https://www.legislation.gov.uk/eur/2016/679/article/9 |
| Apple App Review Guidelines | https://developer.apple.com/app-store/review/guidelines/ |
| Google Play inappropriate content policy | https://support.google.com/googleplay/android-developer/answer/9878810 |
| NIST AI Risk Management Framework | https://www.nist.gov/itl/ai-risk-management-framework |
| OWASP Mobile Application Security | https://mas.owasp.org/ |

## Final directive

> BUILD TRYST
>
> Build the platform the brief demands: an adult-only, gender-inclusive, privacy-first system for discreet affairs, continuing extra-relationship connections and threesomes. The investable difference is not secrecy theatre. It is the combination of high-intent modes, authentic users, a Discretion Policy enforced at every data access, multi-person matching, transparent behavioural learning and security designed for the consequences of exposure.

| Non-negotiable | Launch standard |
|---|---|
| Market clarity | Partnered adults, affairs and threesomes are explicit product categories—not hidden behind generic dating language. |
| Discretion | Every exposure path is controlled by policy, tested adversarially and described without false guarantees. |
| Intelligence | AI learns attraction, intent, timing and communication fit while users can inspect, correct, reset or disable learning. |
| Authenticity | Age, liveness and anti-fraud controls make the network credible without publishing legal identity. |
| Economics | Subscriptions fund core value; optional signals add margin without manufacturing frustration or overriding consent. |
| Readiness | No public launch until privacy, deletion, media access, safety response and city liquidity gates are proven. |

# 08 — Source A: traceability (consolidated Spec + ToS, 4 Oct 2026)

Part of the TRYST specification baseline.

Source A is the top-precedence source (00 §2). Its full text is in `source/TRYST_Spec_and_ToS_Consolidated_2026-10-04.pdf`. This table shows where each section lives in the specification and in the code scaffold, and what v1.2 changed.

| Source A section | Specification | Code scaffold | v1.2 changes |
|---|---|---|---|
| 1. Thesis & market gap; operating stance | 01 §2, 01 §4.1 | — | — |
| 2. The Name; brand codes | 01 §3 | `shared/brand/`, `frontend/` | "Oxblood and bone" → logo palette, oxblood + gold, cream for bone (D-19) |
| 3. Segments & jobs (S1–S6) | 01 §5.1 | `agents/.../broker/entities.py` | Unattached solos: D-01 |
| 4. Product loops | 01 §6 | — | — |
| 5. Agentic architecture (7 agents) | 01 §7, 03 §3 | `agents/.../envoy/` (schema-strict, no free text) | Herald SEO agent outside the member platform (D-21) |
| 6. Behaviour learning | 03 §4 | `agents/.../mirror/vectors.py` (α ∈ [0.15, 0.85], decay) | Decay FR-068 |
| 7. Matching & ranking; exposure fairness | 03 §5 | `agents/.../broker/gates.py` (property-tested), `slate.py`; `backend/internal/keys` (5/15 Keys, refund on reply, inbound cap) | — |
| 8. Trust, verification, consent | 02 §3, 03 §7.3 | `backend/internal/gate` (V2 gate), `backend/internal/couple` (VC co-sign) | **V2 required for intents and threads**, not V1 (E-01) |
| 9. Discretion architecture; threat model; crypto; ExclusionRing | 03 §6, 04 §5 | `backend/internal/erasure` (destroy key → undecryptable), `crypto-core` (per-media key wrap and revoke) | Two-factor login (D-16); emergency lock FR-064 |
| 10. Data model | 02 §4 | `backend/migrations/` (generated from 02 §4) | Anchor candidates, authenticators, couple invite, discretion policy, reveal grants, threads, safety tables |
| 11. API surface | 02 §5 | `shared/contracts/openapi/tryst.v1.yaml` | `/v1/panic` → `/v1/burn` + `/v1/safety/panic` (E-21); handshake system-only (E-29); login, emergency-lock and Stripe webhook endpoints |
| 12. Stack & infrastructure | 03 §2, 04 §3 | Go, Python, Rust, Next.js as specified; native apps documented in `mobile/` | Modular monolith for core services (D-09) |
| 13. MLOps | 03 §9 | Property and invariant tests in CI | — |
| 14. Compliance | 01 §14 | `backend/internal/gate` (jurisdiction gate) | Stripe as primary processor, conditional (D-22); Article 6 bases |
| 15. Business model | 01 §10 | `backend/internal/keys`, `backend/internal/payments` | CAC threshold corrected (E-03); GHOST scope (D-05) |
| 16. Liquidity & GTM | 01 §11 | `agents/.../broker/slate.py` (caps) | Gender-based seeding: D-06; organic search (Herald) |
| 17. Roadmap, team, budget | 01 §12 | — | Insurance and biometric-check costs added |
| 18. KPIs & risk register | 01 §13 | — | G-NG-8 to G-NG-10; new risks |
| 19. Admission control | 01 §8, 03 §8 | `backend/internal/admission` (anchors, silent refusal, human-only bans, appeal lifts) | Anchor candidates at V2 (E-02); biometric anchor off (D-08) |

| Source A section | Specification | Code scaffold | v1.2 changes |
|---|---|---|---|
| 20. Liability & disclaimer architecture | 01 §15 | `frontend/` safety copy | — |
| 21. Guardian classifier spec | 03 §7 | Reason codes in the OpenAPI contract; on-device only | — |
| Part B — Terms of Service draft 0.9 | 05 (draft 0.9.5) | — | cl. 3.5, 6.5, 15.2–15.3, 17.3, protected-trait rule; Q11–Q15 |

# 09 — TRYST Operating System (internal engineering) v1.3

Part of the TRYST v1.3 baseline. Written in response to the founder's *Master AI Operating System Architect* brief (4 Oct 2026), applied to TRYST. Decisions D-25–D-32; requirements FR-080–FR-088.

**How to read this document.** The brief asks for an autonomous, self-improving AI infrastructure OS with a full agent workforce, a BitriPay payment door, a connector ecosystem and a commercial engine. **This document keeps every item in the brief.** Each item is either built as asked, adapted so it fits TRYST's product principles (01 §4), or recorded with a stated reason it does not apply to a members-only discreet platform. The full register is in §0. Nothing in the brief has been dropped silently.

**The one rule that shapes everything here:** *the AI runs the machine; people make the decisions that cannot be undone.* Agents observe, predict, recommend, draft and carry out reversible or pre-approved actions on their own. A permanent action against a member, money movement, a production code change and any contact made on a member's behalf always need a named human. This is enforced in code by the AI Governance gate (`backend/internal/aigov`, tested), not by policy text (§5.4).

## 0. Brief coverage register

Status: **Built** = in the codebase and tested. **Spec** = fully specified here and scheduled. **Adapted** = delivered in a changed form, with the reason. **Not for members** = applies to operators or partners only, never to member data. **Declined** = conflicts with a v2.0-locked principle; recorded with the reason and a stated alternative.

| Brief item | Status | Where / why |
|---|---|---|
| Forensic review: modules, workflows, journeys, API dependencies, data flows, monetisation, automation | Spec | §2.3 platform weakness review (technical, commercial, scalability, security, operational, AI gaps), each with a fix |
| "Do not remove any existing functionality" | Built | No v1.2 requirement removed; FR-001–FR-079 unchanged |
| Proven patterns only, from the named companies | Spec | Every pattern below cites the company or standard it comes from (§9.1) |
| Learn, adapt, predict, optimise, automate, secure, scale, self-heal | Spec | §5.6 self-managing layer; §9 architecture; Mirror learning loop (03 §4) |
| "…without requiring human intervention" | **Adapted** | Autonomy levels L0–L3 (§5.2). Reversible and runbook actions run without a person; four action classes always need one. UK GDPR Art 22 and principle P4 make full autonomy over members unlawful and unsafe (D-25) |
| AI Command Centre for every user | Spec | §4: one per user type, including a **private Member Command Centre** |
| Chief of Staff, Analyst, Research, Automation, Growth, Security, Knowledge agents in each centre | Adapted | §4.1 maps all seven for members (Growth = "my chances", not acquisition); full set for operators (§4.2–§4.9) |
| Executive agents (CEO, COO, CFO, CTO, CMO, CRO) | Adapted | Analyst copilots for the named executive; no authority of their own (D-31) |
| Product, Engineering, Quality, Cybersecurity, Revenue, Customer, Compliance agents | Spec | §5.3 workforce register; §5.5 core agents |
| Self-managing layer: System Health, Bug Detection, Auto-Repair, Infra Optimisation, Release Management, AI Governance | Built (governance) · Spec (rest) | §5.6. Auto-Repair = runbooks + rollback; code fixes go through a reviewed pull request (D-28) |
| Cybersecurity Command Centre (zero trust, identity, threat, fraud, anti-hacking, data protection) | Built (identity) · Spec | §13; login factors already built (02 §3.3) |
| Data intelligence layer (lake, warehouse, vector DB, knowledge graph, streaming, analytics, predictive, behavioural, recommendation, decision engines) | Spec | §9.6. All ten built on the existing stack; behavioural data follows Mirror's privacy rules |

| Brief item | Status | Where / why |
|---|---|---|
| BitriPay Integration Gateway (merchant portal, keys, webhooks, sandbox, production, QR, wallet, card, bank, mobile money, SDKs, docs, testing, fees, revenue share, settlement) | Built (adapter, sandbox) · Spec | §7. Live use is gated by market (D-26) |
| Connector ecosystem (payments, banking, identity, comms, CRM, cloud, AI, productivity, storage) | Spec | §8.2 connector register, one row per provider, with data sent and received |
| WhatsApp, CRM for member data, data enrichment, maps tracking, logistics | Declined for member data | §8.2 states why for each (D-29); operator-only uses kept |
| Revenue engine (subscription, transaction, marketplace, AI usage, API, enterprise, licensing, white label) | Spec / Adapted | §12. Member revenue is the v1.2 tier set; B2B lines are licensing of the discretion stack, never member data |
| Dynamic pricing engine | Adapted | Experiments on list price per market, disclosed and identical for every member in a market; no personalised pricing (D-30) |
| AI revenue optimisation, CLV, churn prevention, upsell, cross-sell engines | Adapted | §12.5. Optimise for QCAM-weighted retention; no dark patterns; one-step cancel stays (ToS cl. 16) |
| AI credit / ACU system | Adapted | ACU meters B2B and partner API usage only. Members never buy ACU; Keys already serve that role (D-27) |
| Data intelligence revenue | Declined for member data | P8 forbids data sale. Alternative: licensing of models and privacy technology, and free published aggregate research (§12.4) |
| PRD, TRD, system, infra, AI, agent, security, DB, API, event, DevOps, monitoring, DR, BC, data governance, compliance, scalability, commercial architecture | Spec | §9–§13; index in §17 |
| Complete ERD, API specs, user journeys, agent workflows, DB schemas, security controls, deployment, testing, production-readiness review | Spec | §10 (ERD + DDL), §11 (API + webhooks), §3.2 journeys, §5.5 workflows, §13 controls, §9.9 deployment, §9.10 testing, §15.6 PRR |
| 17 required sections | Spec | §1–§17 below |

# 1. Executive product vision

## 1.1 What the OS is

The TRYST operating system is the operating layer that runs TRYST: **a governed workforce of specialised AI agents, the data and event fabric they work on, and the command centres through which members, operators, partners and regulators see and steer them.** It turns TRYST from an app with some models into infrastructure that runs its own operations. It matches, protects, bills, supports, secures, monitors and repairs itself, and puts people in charge of every decision that cannot be undone.

It is built for one product first. Discreet, verified, consent-first connection for partnered adults and couples is the hardest trust problem in consumer software. A system that can run that safely can be licensed to others (§12.3).

## 1.2 What problem it solves

| For | Problem today | What the OS does |
|---|---|---|
| Members (S1–S6) | Volume without outcome; exposure risk; harassment; fakes; endless chat that never becomes a meeting | Agents pre-qualify, negotiate and protect; the member decides. Measured by QCAM, not time in app |
| Couples (S3, S5) | Coordinating two people's consent with a third or another couple collapses | Envoy negotiates over a fixed schema; joint-veto modes; dual-consent controls |
| TRYST operations | A 17-person team cannot run 24/7 trust and safety, payments, SRE and growth by hand at 150k verified members | Agents carry the volume; people handle the exceptions (§5.6, §14) |
| Regulators and auditors | Opaque recommendation systems; unverifiable safety claims | Every agent decision is logged in a hash-chained audit trail; transparency reporting is generated from it (§4.10) |
| Partners and licensees | Discretion, verification and consent tooling is expensive to build | The same governed stack, licensed with no member data attached (§12.3) |

### 1.3 Why it is different

1. **Resolution over engagement (P1).** Every agent's reward is tied to QCAM, the confirmed and positively rated meets per active member per month. Competitors optimise for time in app.
2. **Agents negotiate; humans decide (P4).** The double opt-in agent handshake (Loop C) is the product. No competitor runs agent-to-agent pre-negotiation for one-to-one, threesome or couple-to-couple matching.
3. **Governance is code.** The always-human classes, the kill switch, autonomy budgets and the tamper-evident audit log are in `aigov` and covered by tests.
4. **Breach-assumed privacy (P3).** E2EE threads, the identity/profile split, cryptographic erasure in under 60 s and self-hosted models for anything touching special-category data.
5. **Payment-processor independence.** One `PaymentProvider` interface across Stripe, the high-risk acquirer and BitriPay. Entitlements never depend on one processor.

### 1.4 Why the market needs it and why it can win

Category leaders built on volume and on paid messaging, and they are held back by fake-profile and breach history (01 §2). The demand is proven (attributed, unaudited: Ashley Madison 80M+/91M+, E-32). The unmet need is **trust that is engineered, not claimed**. TRYST can win because the OS makes the trustworthy behaviour the cheapest to run:

- automation carries trust and safety and support volume, so gross margin survives verification costs;
- Envoy raises meets per intent (target +40% at G-P2), and that outcome is what members pay for;
- the governed agent stack becomes a licensable B2B asset with no member data in it.

## 2. Market gap deep review

### 2.1 Competitors

| Platform type | Does well | Fails to solve | Where users are underserved | Where businesses lose money | Missing automation | How the OS fills it |
|---|---|---|---|---|---|---|
| Affair sites (Ashley Madison, Gleeden, Victoria Milan) | Category awareness; explicit positioning | Fake and inactive profiles; breach legacy; pay-per-message mechanics | Women and couples face harassment volume; no real couple model | Chargebacks, refunds and trust loss from fake profiles; ads banned | No pre-qualification; manual moderation | V2 gate (E-01), Envoy handshake, Guardian on device, Keys refunded on reply, no fakes (P8) |
| Mainstream dating (Tinder, Hinge, Bumble) | Scale; polished UX; ranking ML | Will not serve the partnered; engagement-maximising loops | Couples, thirds and the discreet are pushed off-platform | Paywall churn; moderation cost per MAU | Agents limited to profile tips | Purpose-built segments S1–S6 and modes; agents tied to QCAM |
| Kink and couples platforms (Feeld and similar) | Inclusive structures; couple profiles | Weak verification; little discretion engineering | S4 harassment; discretion relies on member habits | Trust and safety cost; store risk | No negotiation layer; no exposure-risk model | ExclusionRing PSI, Curtain, S4 inbound caps, VC co-sign |
| Swinger directories and forums | Community; events | Unverified; open directories; scraping | Discretion; safety | Little monetisation beyond membership | None | Verified, private, agent-mediated |
| General AI agent platforms (OpenAI Agents, Microsoft Copilot Studio, Salesforce Agentforce, ServiceNow) | Orchestration tooling; enterprise governance | Not built for special-category data or member-to-member consent | Not applicable to members | High per-seat cost for SMEs | Domain policy is left to the customer | TRYST packages domain policy (consent, discretion, verification) with orchestration |

### 2.2 The four structural gaps (from 01 §2.2, extended)

| Gap | Evidence | OS answer | Measured by |
|---|---|---|---|
| Outcome gap: volume without meets | Reply rates, ghosting, message volume as a KPI | Broker + Envoy + Aftercare reward loop | QCAM; meets per intent |
| Trust gap: fakes, bots, sextortion | Category history; OSA duties | V2 gate, admission L1–L5, Guardian M6a–e, Fraud agent | Report rate per 1k threads; fake-profile prevalence |
| Discretion gap: exposure by collision, notification, device | Members' primary anxiety (S1) | Curtain, ExclusionRing, decoy/duress/Burn, emergency lock | Exposure incidents; leak tests |
| Operations gap: a small team cannot run 24/7 trust, payments and SRE | Team of 17 to P3 (01 §12) | §5.6 self-managing layer, §5.5 core agents, §14 control centre | Tickets per 1k MAU handled by agents; MTTR; on-call pages per week |

### 2.3 Platform weakness review (v1.2 baseline → fix)

The brief asks for a forensic review of TRYST itself. Findings against the v1.2 codebase and spec:

| Area | Weakness found | Fix (this document) | Phase |
|---|---|---|---|
| Technical | Identity store is in memory; DPoP not yet bound (D-24) | PostgreSQL IDENTITY-DB and DPoP are P1 items; OS adds no dependency on them before P1 | P1 |
| Technical | No central registry of which agent may do what | `aigov` registry and gate (built, FR-080) | P1 |
| Technical | Agent actions are not uniformly audited | Hash-chained audit log for every agent decision (built, FR-082) | P1 |
| Commercial | One processor family; Stripe approval uncertain (D-22) | `PaymentProvider` with three adapters: Stripe, high-risk acquirer, BitriPay (built, sandbox) | P1 |
| Commercial | Revenue limited to B2C | B2B licensing of the discretion and verification stack, metered in ACU (§12.3) | P4+ |
| Scalability | Modular monolith (D-09) with no stated split triggers | Split triggers in §9.8 | P2+ |
| Security | No automated containment for agent misbehaviour | Kill switch per agent and global (built) | P1 |
| Security | Connectors could leak member data to third parties | Connector register with a data map and a no-member-data rule per provider (FR-087) | P1 |
| Operational | On-call relies on people reading dashboards | System Health → Auto-Repair runbooks with SLO-burn rollback (FR-085) | P1 |
| Operational | No single admin view across safety, payments, agents and health | Admin Super Control Centre (§14, FR-086) | P1 |
| AI capability | No member-facing explanation surface for agent decisions | Member Command Centre "why" panels from reason codes (FR-083) | P2 |
| AI capability | Agent evals exist per agent but not for cross-agent workflows | Workflow-level evals and replay in the release gate (§9.10) | P2 |

# 3. Complete user ecosystem

### 3.1 User types

Every user type in the brief is listed. A type that does not exist in TRYST is marked as such and kept for the licensing model.

| # | User type (brief) | In TRYST | Examples | Authenticates with | Sees member data? |
|---|---|---|---|---|---|
| U1 | Customers | **Members** (S1–S6, solo and couple) | Attached solo; couple seeking a third | Two biometric factors (mobile) / two factors (desktop) (02 §3.3) | Their own, and what counterparties reveal |
| U2 | Businesses | **Licensees** (P4+) | A dating platform licensing the verification and discretion stack | OIDC SSO + hardware key; API keys | Never TRYST's members |

| # | User type (brief) | In TRYST | Examples | Authenticates with | Sees member data? |
|---|---|---|---|---|---|
| U3 | Admins | **Platform admins** | Head of T&S, Principal Engineer, DPO | Hardware security key + device posture + just-in-time role | Redacted by default; break-glass only |
| U4 | Operators | **T&S moderators, support agents, SRE on-call, payments ops** | Moderator on the trust console | As admins, with role scope | Case-scoped and redacted |
| U5 | Partners | **Assurance, payment and content partners** | Age-assurance providers; voucher resellers; digital-PR partners | Mutual TLS + signed webhooks | Only what the contract and data map allow |
| U6 | Agents | **AI agents** (§5) | Envoy, Guardian, Auto-Repair | SPIFFE workload identity + manifest | Only their manifest's scopes |
| U7 | Developers | **TRYST engineers; licensee developers** | Backend engineer; licensee integrator | SSO + hardware key; sandbox keys | Never in production without break-glass |
| U8 | Merchants | **Not in TRYST's member product.** Kept for BitriPay connected accounts in the licensing model (§7.4) | Voucher reseller receiving a commission | BitriPay account + TRYST partner portal | None |
| U9 | Service providers | **Processors and sub-processors** | Cloud, liveness, CDN, email | Contract + DPA | Per the data map (§8.2) |
| U10 | Regulators | **Ofcom, ICO, DPC (IE), card schemes, auditors** | Ofcom information request | Read-only regulator portal; time-boxed | Aggregates and specific lawful disclosures only |
| U11 | Third-party API partners | **Connector providers** | Stripe, BitriPay, Persona | Their own auth; our keys in the vault | Per the data map |

## 3.2 User journeys

The member journeys are Loops A–E (01 §6) and the screens in 04 §4. The operating system adds these journeys:

| Journey | Steps | Agents | Human checkpoint |
|---|---|---|---|
| J1 Member sees why | Opens Command Centre → "Why this slate?" → reason codes rendered as plain sentences → corrects a preference | Chief of Staff (member), Mirror, Broker | Member edits; P5 floor holds |
| J2 Member safety brief | Before a meet: Safe Meet checklist → venue sanity (public, open) → check-in timer → aftercare at 48 h | Guardian, Aftercare | Member sets the check-in; Panic is always available |
| J3 Operator case | Report → Guardian triage score → case queue with redacted evidence → moderator decision → appeal path | Guardian, Compliance | Moderator decides any removal (always-human) |
| J4 Incident self-heal | SLO burn alert → System Health opens incident → Auto-Repair runs rollback runbook → on-call is told, not woken, if the rollback resolves it | System Health, Auto-Repair, Release Manager | Human reviews the post-incident report; any code fix is a reviewed PR |
| J5 Payment exception | Webhook says dispute → Payment agent assembles evidence → Fraud agent scores → payments ops approves refund or contest | Payment, Fraud | Refund is money movement (always-human), unless covered by the pre-approved auto-refund rule (§5.5, Payment) |
| J6 Licensee onboarding | Partner applies → KYB → sandbox keys → integration tests → contract → live keys | Onboarding (B2B), Compliance, API Integration | Live keys need a named approver |
| J7 Regulator request | Request logged → Compliance agent assembles the lawful minimum from audit and transparency data → DPO approves → disclosure | Compliance | DPO approves every disclosure |
| J8 Content publish | Herald drafts → editor approves → publish → rank tracking | Herald (Marketing) | Editor approves every publish |

# 4. AI-agent command centres

Each command centre is a role-scoped surface over the same agent fabric. **The data a centre sees is decided by the caller's role and the agents' manifests, never by the UI.** All actions go through the governance gate.

## 4.1 Member Command Centre (U1)

**Design constraints that override the brief's defaults:** private by default; nothing is shown that would help someone holding the member's phone (P3); no engagement counters, streaks or "you're missing out" nudges (P1); the Leave control and decoy behaviour work on every screen; agents never act as the member (P4). Built on the existing `/v1/me` and `/v1/me/security` routes; web route `/account/insights` (FR-083).

| Brief agent | Member version | What it sees | Actions it can perform | What it may decide | Automations the member controls |
|---|---|---|---|---|---|
| Personal AI Chief of Staff | **Concierge brief**: one calm daily summary: new Briefs waiting, a meet to confirm, renewal date | Own Briefs, intents, meets, entitlement | Draft a reply (on device, D-20), set a check-in timer, remind | Nothing; it recommends | Summary time; quiet hours; off switch |
| AI Analyst | **My patterns**: charts of own activity (intents sent, mutual rate, meets, aftercare trend), security activity | Own aggregates only | Explain a chart | — | Personalisation on/off (FR-024) |
| AI Research Agent | **Explainers**: verification, discretion and safety guides; local laws for travel mode | Public content | — | — | — |
| AI Automation Agent | **ENVOY tier proposals**: Envoy pre-qualifies and drafts outreach; each needs one tap | Envoy proposals with rationale codes | Approve / discard | Never sends (D-04) | Cadence; filters |
| AI Growth Agent | **My chances**: which settings narrow the slate (radius, tier floor, modes) and the expected effect | Own settings; aggregate liquidity bands | Suggest a setting change | — | Accept or ignore |
| AI Security Agent | **Security activity**: sign-ins, factors, new devices, locks (built: `/v1/me/security`); session risk from Curtain | Own auth events (90 d) | Sign out everywhere; emergency lock; revoke device | Curtain may only tighten (02 §6.4) | Lock behaviour; decoy |
| AI Knowledge Agent | **My memory**: what TRYST has learned about me (stated vs revealed, α weight) with reset | Own IntentVector, RevealedPreferenceVector summary, version history (FR-079) | Correct, reset, export (DSR) | — | Reset learning |

## 4.2 Couple Command Centre (U1, VC)

Shared panel, visible to both partners, plus each partner's private panel. It shows the joint-veto state, pending thirds or couples, dual-consent requests and Envoy screening for a third. **Neither partner sees the other's private panel, private fields or security activity.** Actions are a co-sign (both partners, two devices; `same_device_cosign` is refused) and dissolve (either partner, immediate, 02 §9).

## 4.3 Operator Command Centre: Trust and Safety (U4)

| Element | Specification |
|---|---|
| Sees | Case queue ordered by Guardian severity and SLA; redacted evidence; member-disclosed content only; prior enforcement; appeal history |
| Agents | Guardian (triage, holds), Compliance (SLA and statement of reasons), Support (drafts), Risk (ban-anchor matches) |
| Actions | Hold (reversible, agent may do); warn, restrict, remove, ban, report to authorities (**always-human**); request more evidence |
| Automations | SLA routing; duplicate merge; known-hash auto-hold pending review |

| Element | Specification |
|---|---|
| Decides or recommends | Guardian recommends with a confidence and reason code; the moderator decides; a second moderator reviews permanent bans (03 §7.3) |

### 4.4 Operator Command Centre: Support (U4)

Sees ticket, entitlement and Keys-ledger state for the ticket's member only (case-scoped). The Support agent drafts and the person sends. Goodwill Keys and refunds are money movement (always-human), except for refunds covered by a published automatic rule (Keys refunded on reply; 14-day statutory refunds, ToS 16.7), which run as ledger operations.

### 4.5 Operator Command Centre: SRE and engineering (U4, U7)

Sees SLOs, error budgets, traces, deploys, cost and the agent decision log. Agents: System Health, Bug Detection, Auto-Repair, Release Manager, Infra Optimiser, Vulnerability. Automations: canary analysis, automatic rollback on SLO burn, scale-out, dependency PRs. A **production change** (promote, patch, rightsizing apply) is always-human.

### 4.6 Operator Command Centre: Payments and finance (U4)

Sees processor health per adapter, authorisation rates, chargeback ratio (alert 0.5%, hard stop 0.65%), disputes, settlement and VAT. Agents: Payment, Fraud, Revenue Analyst, Pricing. Actions: switch the primary processor (always-human), approve refunds and dispute responses, publish a price experiment (always-human, §12.2).

### 4.7 Executive Command Centre (U3)

The brief's CEO, COO, CFO, CTO, CMO and CRO agents are **analyst copilots** for the named executive (D-31). They read warehouse aggregates (never member-level data) and produce: the weekly QCAM and KPI pack (01 §13.1), phase-gate readiness (G-P0 to G-P4), no-go monitor (01 §13.2), unit economics against E-03 thresholds, budget burn and risk register deltas. They hold no actions beyond `recommend`.

### 4.8 Partner and Licensee Command Centre (U2, U5, U8)

API keys (sandbox and live), webhooks with delivery log and replay, usage in ACU, invoices, SLA status, integration test results, data-processing terms. Connected BitriPay accounts (for commission-earning partners such as voucher resellers) show settlement statements from BitriPay directly. **No member data is ever visible here.**

### 4.9 Developer Command Centre (U7)

OpenAPI reference (`shared/contracts/openapi/tryst.v1.yaml`), sandbox keys, webhook tester, the BitriPay sandbox magic numbers (§7.6), SDK downloads, changelog, status. Same surface for internal engineers and licensee developers, with scopes.

### 4.10 Regulator Portal (U10)

Read-only, time-boxed accounts. Shows the transparency report (OSA), the aggregate enforcement statistics, the agent register (which agents exist, what they may do, autonomy level and owner) and the audit-chain verification result. Specific disclosures are made only through J7 with DPO approval.

### 4.11 Agent Command Centre (U6)

Agents also have a "centre": the registry entry (manifest), budget use today, kill state, recent decisions and eval scores. It is rendered inside the Admin Super Control Centre (§14).

## 5. Core AI agents

### 5.1 Agent model

Every agent is a separately deployable service (03 §2.2) declared by a **manifest** in the agent registry. The manifest is the contract; anything not in it is denied.

| Manifest field | Meaning | Enforced by |
|---|---|---|
| `id`, `owner` | Agent name and accountable human team | Registry refuses a manifest without an owner |
| `level` | Autonomy level L0–L3 (§5.2) | Gate |

| Manifest field | Meaning | Enforced by |
|---|---|---|
| `actions` | Action name → effect class (read, recommend, reversible, runbook, irreversible, member_safety, money_movement, production_change) | Gate; unlisted action → deny |
| `data_scopes` | Stores and datasets it may read | Registry: a member-data scope (IDENTITY-, PROFILE-, SAFETY-, BAN-DB, event bus, feature store, vector store) is refused unless the agent runs inside the member platform **and** on a self-hosted model |
| `daily_budget` | Maximum autonomous reversible or runbook actions per UTC day | Gate; above budget → needs a human |
| `model_version`, `policy_file`, `eval_suite` | What it runs and how it is tested | Release gate (03 §9) |
| `act_as_member` | Not a valid class | Registry rejects any manifest that contains it (P4) |

Agents talk over typed Protobuf messages on the bus (`agent.*` topics), never free text (A §5), and call each other with gRPC + mTLS under SPIFFE identities.

## 5.2 Autonomy levels

This is how the brief's "without requiring human intervention" is delivered safely. Pattern: the levels of driving automation (SAE J3016, as used by Tesla and others), Google SRE's automation ladder, and Microsoft and Anthropic's published human-in-the-loop guidance for agents.

| Level | Name | Runs without a person | Typical agents |
|---|---|---|---|
| L0 | Observe | Read, report | Monitors in shadow mode |
| L1 | Recommend | Read, recommend, draft | Cartographer, Envoy, Support, Chief of Staff, executive copilots, Infra Optimiser |
| L2 | Reversible | + reversible changes inside a daily budget | Mirror, Broker, Curtain, Guardian (holds), Aftercare, Fraud (holds), System Health, Herald (link repair) |
| L3 | Runbook | + pre-approved runbooks (rollback, restart, scale out, halt canary) | Auto-Repair, Release Manager |

**Always-human classes** (no level unlocks them): `irreversible` (delete, publish, send to an outside party), `member_safety` (freeze, restrict, remove, ban), `money_movement` (refund, payout, price change, credit), `production_change` (code, model or prompt change reaching production). **Never-allowed class:** `act_as_member`.

## 5.3 Workforce register

All agents named in the brief, mapped to TRYST. "Plane" = **M** member platform (self-hosted models, member data allowed by manifest) or **O** operations plane (no member data). The first 23 rows are loaded from `aigov.Workforce()` and pinned by tests; the rest are specified for the phases shown.

| Brief category | Brief agent | TRYST agent | Plane | Level | Phase | Notes |
|---|---|---|---|---|---|---|
| Matching (01 §7) | — | Cartographer | M | L1 | P1 | Member confirms every field |
| Matching | — | Mirror | M | L2 | P2 | Sole writer of RevealedPreferenceVector |
| Matching | — | Broker | M | L2 | P1 | Stage 0 gates cannot be bypassed |
| Matching | — | Envoy | M | L1 | P2 | Never sends; advisory Briefs |
| Matching | — | Curtain | M | L2 | P1 | Tighten only |
| Matching | — | Guardian | M | L2 | P1 | Holds only; removals are human |
| Matching | — | Aftercare | M | L2 | P1 | Private outcome only |
| Core (brief §5) | Onboarding Agent | Onboarding | M | L2 | P1 | §5.5 |
| Core | Risk Agent | Risk | M | L2 | P1 | §5.5 |
| Core | Fraud Detection Agent | Fraud | M | L2 | P1 | §5.5 |
| Core / Customer | Customer Support Agent | Support | M | L1 | P1 | §5.5 |

| Brief category | Brief agent | TRYST agent | Plane | Level | Phase | Notes |
|---|---|---|---|---|---|---|
| Command centre | Personal AI Chief of Staff | Chief of Staff | M | L1 | P2 | §4.1; on device where possible |
| Core / Compliance | Compliance Agent, GDPR Agent | Compliance | M | L2 | P1 | §5.5 |
| Core | Payment Agent | Payment | M | L2 | P1 | §5.5 |
| Core / Marketing | Marketing Agent (Herald) | Herald | O | L2 | P1 | Isolated (FR-075) |
| Revenue / Core | Revenue Agent, CFO Agent | Revenue Analyst | O | L1 | P1 | Aggregates only |
| Self-managing | System Health Agent | System Health | O | L2 | P1 | §5.6 |
| Self-managing / Quality | Bug Detection Agent | Bug Detection | O | L2 | P1 | §5.6 |
| Self-managing | Auto-Repair Agent | Auto-Repair | O | L3 | P1 | §5.6 |
| Self-managing | Infrastructure Optimisation Agent | Infra Optimiser | O | L1 | P2 | §5.6 |
| Self-managing | Release Management Agent | Release Manager | O | L3 | P1 | §5.6 |
| Cybersecurity | Threat Hunter Agent | Threat Hunter | O | L2 | P1 | §13 |
| Cybersecurity | Vulnerability Agent | Vulnerability | O | L2 | P1 | §13 |
| Self-managing | AI Governance Agent | **The gate itself** + Governance reviewer | O | — | P1 | Deterministic code, not a model (§5.4) |
| Cybersecurity | SOC Agent | SOC triage | O | L2 | P1 | Alert dedupe and enrichment; containment runbooks |
| Cybersecurity | Identity Agent | Identity risk | M | L2 | P1 | Login risk, step-up triggers; never bypasses two factors |
| Cybersecurity | Fraud Agent | = Fraud | M | L2 | P1 | — |
| Core | Pricing Agent / Revenue: Pricing | Pricing | O | L1 | P3 | Market-level experiments only (§12.2) |
| Revenue | Monetisation Agent | Monetisation | O | L1 | P3 | Proposes packaging; never dark patterns |
| Revenue | Sales Agent | B2B Sales | O | L1 | P4 | Licensee pipeline; drafts only |
| Customer | Success Agent | Licensee Success | O | L1 | P4 | B2B only |
| Customer | Retention Agent | Retention | M | L1 | P3 | §12.5; no retention flow on cancel |
| Compliance | AML Agent | AML (payments) | O | L1 | P3 | Monitors processor alerts; AML duties sit with the regulated PSP (D-32) |
| Compliance | KYC Agent | = Onboarding (age assurance) + KYB for licensees | M / O | L2 | P1 / P4 | — |
| Compliance | Regulatory Agent | Regulatory | O | L1 | P1 | OSA codes, ICO guidance, store policies; change alerts |
| Core | Data Intelligence Agent | Data Intelligence | O | L1 | P2 | Warehouse aggregates; DP noise on member-derived metrics |
| Core | Operations Agent / COO Agent | Operations | O | L1 | P1 | Queue health, SLA, staffing forecast |
| Core | API Integration Agent | API Integration | O | L2 | P1 | Connector health, key rotation reminders, contract tests |
| Core | Workflow Automation Agent | Orchestrator | O / M | L2 | P1 | Runs declared workflows (§5.7) |
| Core | Predictive Growth Agent | Predictive Growth | O | L1 | P2 | Liquidity forecasts per city and segment |
| Core | Admin Control Agent | Admin Control | O | L1 | P1 | §14; summarises and proposes, never grants access |
| Executive | CEO, COO, CFO, CTO, CMO, CRO Agents | Executive copilots | O | L1 | P1 | §4.7; D-31 |

| Brief category | Brief agent | TRYST agent | Plane | Level | Phase | Notes |
|---|---|---|---|---|---|---|
| Product | Product Architect, UX, Journey, Feature Agents | Product copilots | O | L1 | P2 | Funnel and journey analysis on aggregates; design-review checklists (04 §7) |
| Engineering | Frontend, Backend, Infrastructure, API, Database Agents | Engineering copilots | O | L1 | P1 | Coding assistants that open PRs; every PR is human-reviewed and passes CI |
| Quality | QA, Testing, Performance Agents | Quality copilots | O | L2 | P1 | Generate tests and load profiles; run them in CI; cannot merge |

## 5.4 AI governance gate (implemented)

Code: `backend/internal/aigov` (Go, standard library only). Tests: `aigov_test.go`, 9 tests, including a mutation check that removing `member_safety` from the always-human set fails the suite.

| Behaviour | Implementation | Test |
|---|---|---|
| Unknown agent, unknown action → deny | `decideLocked` | `TestLevelCapsAutonomy` |
| Always-human classes → `needs_human` unless a **registered named human** approved | `alwaysHuman` set; approver allow-list | `TestAlwaysHumanClassesNeedAPerson` |
| An agent cannot approve its own action | Approver must be in the human allow-list | `TestUnknownApproverIsDenied` |
| Autonomy level caps classes | `minLevel` per class | `TestLevelCapsAutonomy` |
| Daily budget, then a person | Per-agent per-UTC-day counter | `TestBudgetThenHuman` |
| Kill switch per agent and global; global overrides approvals | `Kill`, `KillAll`, `Resume` (each recorded with who did it) | `TestKillSwitch` |
| Member-data scopes only for self-hosted member-plane agents; `act_as_member` rejected | `Register` | `TestManifestRules`, `TestOpsAgentsHoldNoMemberScopes` |
| Hash-chained, append-only audit log; any edit or deletion detected | `Entry.digest`, `VerifyChain` | `TestAuditChain` |

**Production wiring (P1):** the gate runs as a sidecar library in each agent and as a central `agent-registry` service. The audit chain is written to an append-only table (§10, `ops.agent_decision`) and anchored hourly to an object-lock (WORM) bucket, so even a database administrator cannot rewrite history unnoticed. Pattern: Certificate Transparency and AWS QLDB-style ledgers.

## 5.5 Core agents (the brief's fifteen)

Each entry gives purpose, inputs, outputs, permissions, triggers, workflow, escalation, APIs used and business value. "Gate" means the action passes through §5.4.

### Onboarding Agent

| | |
|---|---|
| Purpose | Get a new member from sign-up to V2 with the fewest drop-offs, without ever weakening verification |
| Inputs | Onboarding state, provider responses (age assurance, liveness), device type, jurisdiction |
| Outputs | Next-step routing, plain-language explanations, retry guidance, provider fallback choice |
| Permissions | L2; `identity_db` (state only), `profile_db` (onboarding fields); actions `route_verification_step` (reversible), `explain_step` (recommend) |
| Triggers | `auth.verified`, `assurance.failed`, onboarding idle > 10 min |
| Workflow | 1 read state → 2 choose next step (passkey, B2 enrolment, age assurance, Cartographer) → 3 if provider A fails or is down, route to provider B (03 §2.1) → 4 explain without revealing why a check failed (anti-gaming) |
| Escalation | Two provider failures → manual review queue; suspected minor → Guardian, onboarding stopped (always-human) |
| APIs | `/v1/auth/*`, `/v1/assurance/*`, provider adapters |
| Value | V2 completion 52% → 68% target (01 §13.1); fewer support tickets |

### Compliance Agent

| | |
|---|---|
| Purpose | Keep TRYST provably compliant: DSRs, retention, OSA duties, consent records |
| Inputs | DSR requests, retention policies (02 §7), consent ledger, enforcement records, regulatory feed |

| | |
|---|---|
| Outputs | DSR exports, retention violations, statements of reasons, transparency report drafts, regulator packs |
| Permissions | L2; `run_dsr_export` (reversible), `check_retention` (read), `erase_account` (irreversible → human, except member-initiated erasure, which is the member's own action) |
| Triggers | `dsr.requested`, nightly retention sweep, `enforcement.decided`, regulator request |
| Workflow | DSR: verify requester via step-up → assemble export across stores → member downloads (30-day statutory clock tracked). Retention: diff actual vs policy → open a ticket per violation → Privacy Auditor blocks release if critical |
| Escalation | Any regulator request, any breach indicator → DPO within 1 h; 72 h ICO clock starts on awareness |
| APIs | `/v1/me/export`, `/v1/me` DELETE, `ops.deletion_job`, safety-svc |
| Value | Avoids fines; makes the transparency report a by-product |

### Risk Agent

| | |
|---|---|
| Purpose | Score sign-up and account risk (ban evasion, fake profiles, coordinated abuse) |
| Inputs | Admission L1–L5 signals (03 §8), device and payment fingerprints (HMAC only), graph features |
| Outputs | Risk score with reason codes; step-up requirement; ban-anchor match proposals |
| Permissions | L2; `score_signup` (recommend), `require_step_up` (reversible), `ban_anchor_match` (member_safety → human) |
| Triggers | `auth.verified`, `assurance.passed`, graph anomaly |
| Workflow | Score → if medium, require step-up → if a ban-anchor match, open a T&S case with the evidence |
| Escalation | Every anchor match → moderator; false-positive appeals go to a second moderator |
| APIs | identity-svc admission, safety-svc |
| Value | Keeps fakes out (the category's main failure) |

### Revenue Agent

| | |
|---|---|
| Purpose | Explain revenue movement and forecast it |
| Inputs | Warehouse aggregates: entitlements, Keys ledger, processor settlements, churn |
| Outputs | Daily revenue pack, cohort LTV, forecast with intervals, anomaly alerts |
| Permissions | L1; `warehouse_aggregates` only |
| Triggers | Daily 06:00 UTC; anomaly > 3σ |
| Workflow | Aggregate → compare with forecast → explain drivers → post to the finance centre |
| Escalation | Chargeback ratio ≥ 0.5% → payments lead; revenue drop > 15% day on day → CFO |
| APIs | Warehouse SQL (read-only role) |
| Value | Finance runs on facts, not spreadsheets |

### Pricing Agent

| | |
|---|---|
| Purpose | Design and analyse **market-level** price experiments |
| Inputs | Conversion by market and tier, willingness-to-pay surveys, competitor price list |
| Outputs | Experiment proposals with power analysis; results with confidence intervals |
| Permissions | L1; recommend only; `change_price` is money_movement → human |
| Triggers | Quarterly review; G-P3 pricing decisions (D-05) |
| Workflow | Propose → pricing committee approves → Stripe Prices created by a person → measure → report |
| Escalation | Any proposal that personalises price per member is rejected by policy (§12.2) |
| APIs | Warehouse; Stripe Prices (human-operated) |
| Value | Better price points without eroding trust |

### Customer Support Agent

| | |
|---|---|
| Purpose | Answer members quickly and discreetly |
| Inputs | Ticket text (member-provided), the member's entitlement and Keys ledger (case-scoped), help centre |
| Outputs | Draft replies; ticket classification; suggested refunds under published rules |
| Permissions | L1; `draft_reply` (recommend); `issue_goodwill_keys` (money_movement → human) |

| | |
|---|---|
| Triggers | `ticket.created` |
| Workflow | Classify → retrieve help-centre answer (RAG over public docs) → draft → agent or person sends. Safety keywords → Guardian queue immediately |
| Escalation | Safety, legal or payment disputes → human queue with SLA |
| APIs | Support desk connector (§8.2), `/v1/entitlements` (case-scoped) |
| Value | Lower cost per ticket; faster first response |

**Marketing Agent (Herald)**

Specified in 03 §3.2. Purpose: organic growth through earned search visibility. Inputs: public web, Search Console, aggregate cookieless analytics. Outputs: drafts and refresh proposals. Permissions: L2 for internal-link repair; `publish_page` is irreversible → editor. Escalation: claims-discipline flags → editor. Value: low-CAC channel (D-21).

**Data Intelligence Agent**

| | |
|---|---|
| Purpose | Answer business questions over the warehouse with correct, privacy-safe SQL |
| Inputs | Natural-language question from an operator; semantic layer (metric definitions) |
| Outputs | Query, result, chart, caveats |
| Permissions | L1; read-only warehouse role over aggregate marts; member-level tables not granted |
| Triggers | Operator request; scheduled packs |
| Workflow | Map question to metric definitions → generate SQL → run with row-count floor ($k \geq 20$) → add DP noise to member-derived counts → render |
| Escalation | A question that needs member-level data → refused, with the route to a DPO-approved analysis |
| APIs | ClickHouse (read-only), semantic layer |
| Value | Self-serve analytics without exposing members |

**Operations Agent**

Purpose: keep queues inside SLA. Inputs: queue depths, SLA timers, staffing rota. Outputs: staffing forecasts, rebalancing proposals, SLA breach alerts. Permissions: L1. Triggers: every 5 min. Escalation: forecast breach of OSA-relevant SLAs → Head of T&S. Value: 24/7 coverage with a small team.

**Fraud Detection Agent**

| | |
|---|---|
| Purpose | Stop card testing, stolen cards, voucher abuse and Keys fraud |
| Inputs | Processor risk signals (Stripe Radar, acquirer scores, BitriPay status), payment fingerprint HMAC, velocity, device risk |
| Outputs | Transaction score, holds, block-list proposals |
| Permissions | L2; `score_payment` (recommend), `hold_payment` (reversible), `refund` (money_movement → human) |
| Triggers | `payment.attempted`, `voucher.redeem_attempted`, chargeback alert (Ethoca/Verifi) |
| Workflow | Score → hold above threshold → auto-refund on a confirmed fraud alert where the published rule allows (03 §10) → feed L1 admission |
| Escalation | Chargeback ratio ≥ 0.5% → payments lead; 0.65% → hard-stop review |
| APIs | `PaymentProvider` webhooks, voucher service |
| Value | Keeps the MID alive (above 0.9% it is lost, 01 §13.1) |

**Payment Agent**

| | |
|---|---|
| Purpose | Keep money flowing correctly across processors |
| Inputs | Webhooks from Stripe, the acquirer and BitriPay; ledger; processor health |
| Outputs | Reconciliation reports, processor routing proposals, dispute evidence packs |
| Permissions | L2; `reconcile_ledger` and `route_processor` (reversible: failover to the backup MID), `change_price` (money_movement → human) |
| Triggers | Webhook received; nightly reconciliation; authorisation-rate drop |

| | |
|---|---|
| Workflow | Verify signature → dedupe by event id → update entitlement and ledger → reconcile daily against settlement statements → if the primary's authorisation rate drops below its floor for 15 min, fail new checkouts over to the backup (reversible) and page payments ops |
| Escalation | Ledger imbalance → stop entitlement writes, page on-call; dispute deadline < 48 h → payments ops |
| APIs | `/v1/billing/*/webhook`, `PaymentProvider` |
| Value | Revenue continuity; dispute win rate |

**API Integration Agent**

Purpose: keep every connector healthy. Inputs: connector contract tests, error rates, key ages. Outputs: health board, rotation reminders, deprecation alerts. Permissions: L2 (open tickets, disable a failing optional connector). Escalation: a required connector failing (age assurance, payments) → on-call. Value: fewer outages caused by third parties.

**Workflow Automation Agent (Orchestrator)**

Runs declared workflows (§5.7) step by step, with retries, compensation and the gate at every action. It never invents a workflow; workflows are code-reviewed definitions. Value: reliable multi-step operations (DSR, erasure, dispute, incident).

**Predictive Growth Agent**

Purpose: forecast liquidity per city, segment and mode (S4 scarcity, gender ratio ≤ 2.2:1). Inputs: aggregates. Outputs: waitlist release forecasts, city-opening and seeding recommendations (01 §11). Permissions: L1. Escalation: a forecast breach of a no-go condition → CEO. Value: avoids launching cities that cannot work.

**Admin Control Agent**

Purpose: help admins run the Super Control Centre (§14). It summarises alerts, proposes actions and drafts runbook steps. It **never grants access**; just-in-time access is approved by a second admin. Permissions: L1.

## 5.6 Self-managing platform layer

| Agent | Monitors / does | Autonomous (inside budget) | Always a person | Pattern |
|---|---|---|---|---|
| **System Health** | Uptime, latency, errors, saturation (golden signals); SLO burn rates (multi-window, multi-burn-rate) | Open incident, page on-call, attach traces | — | Google SRE workbook |
| **Bug Detection** | Error-tracking clusters, regression detection on deploy, flaky-test detection, crash-free rate | File issue with repro and suspected commit (git bisect in CI) | — | Meta SapFix/Sapienz-style triage; Sentry clustering |
| **Auto-Repair** | Runs pre-approved runbooks: rollback the last release, restart a crash-looping pod, scale out, drain a bad node, rotate a leaked key | L3 runbooks (budget 50/day) | **Deploying a code patch** (production_change). It may *open* a fix PR, which follows normal review and CI (D-28) | Kubernetes self-healing; Argo Rollouts; Netflix Spinnaker automated canary analysis |
| **Infrastructure Optimisation** | Compute, storage, bandwidth, cloud spend; GPU utilisation of the vLLM pool | Proposals only | Applying rightsizing | AWS Compute Optimizer; FinOps Foundation |
| **Release Management** | Canary analysis, progressive delivery (1% → 10% → 50% → 100%), feature flags, freeze windows | Halt a canary; roll back | Promoting a release | Google, Facebook progressive rollouts |
| **AI Governance** | The gate (§5.4), model and prompt registry, eval results, drift monitors, red-team results | Deny; kill an agent on policy breach (e.g. a guardrail violation rate above threshold) | Resuming a killed agent; changing a manifest | NIST AI RMF; ISO/IEC 42001; EU AI Act logging duties |

**Self-healing sequence (J4):** SLO burn > 14.4× over 1 h → System Health opens INC → Auto-Repair checks whether a deploy happened in the last 2 h → if yes, rolls it back (runbook) → if the burn stops within 10 min, closes with a report for review; if not, pages on-call with everything gathered. Every step is a gate decision in the audit log.

### 5.7 Orchestration and agent memory

| Concern | Design | Pattern |
|---|---|---|
| Orchestration | Typed state machines per agent (LangGraph-style, 03 §2.1); cross-agent workflows on a durable workflow engine (Temporal) with compensation steps | Uber Cadence/Temporal; Stripe's idempotent job runners |
| Workflow catalogue (P1) | `onboarding`, `handshake` (Loop C), `meet_resolution` (Loop D), `dsr_export`, `erasure` (< 60 s), `report_to_decision`, `dispute`, `incident_selfheal`, `processor_failover`, `herald_publish` | — |
| Memory: short-term | Per-run state in the workflow engine; expires with the run | — |
| Memory: member long-term | Only the structured vectors (IntentVector, RevealedPreferenceVector) and the Discretion Policy. **No free-text memory of members**, no conversation memory (E2EE content is never available server-side) | P3 |
| Memory: operational | Knowledge graph of services, runbooks, incidents and decisions; vector index over runbooks, ADRs and the spec for retrieval | Palantir-style ontology; RAG |
| Tool use | Tools are gRPC methods listed in the manifest; arguments validated against Protobuf schemas | OpenAI and Anthropic tool-use with schema validation |
| Prompt and model registry | Versioned prompts and policies (`policies/<agent>.yaml`); a change is a production_change | MLflow-style registry |
| Injection defence | Untrusted text (profiles, tickets, web pages) is never placed in an instruction position; outputs are schema-validated; the injection red-team suite runs per release (03 §9) | OWASP LLM Top 10 |

## 6. Full platform modules

Every module the brief lists, mapped to TRYST. Existing member modules are in 04 §4 and 03 §2.2; this table adds the OS surfaces.

| Module | Users | What it does | Key screens / endpoints | Agents | Phase |
|---|---|---|---|---|---|
| Dashboards | All | Role-scoped overviews (§4) | `/account/insights` (member); `/ops/*` (operators) | Chief of Staff, executive copilots | P1–P2 |
| User accounts | Members | Sign-up, two-factor sign-in, devices, security activity, Burn, emergency lock, export, delete | `/join`, `/sign-in`, `/account`; `/v1/me`, `/v1/me/security` (built) | Onboarding, Identity risk | P1 (built in part) |
| Admin panels | Admins | Super Control Centre (§14) | `/ops/control` | Admin Control | P1 |
| Merchant portals | Partners (U8) | BitriPay connected-account view, commission statements | `/partners/merchant` | Payment | P4 |
| Partner portals | U2, U5 | Keys, webhooks, usage, invoices, contracts | `/partners` | API Integration, Licensee Success | P4 |
| API settings pages | U2, U7 | Create, scope and rotate keys; IP allow-list; webhook endpoints | `/developers/keys`, `/developers/webhooks` | API Integration | P4 |
| Payment settings | Members, payments ops | Member: method, billing email, cancel (one step). Ops: processor routing, descriptors | `/account/billing`; `/ops/payments` | Payment | P1 |
| Notification system | All | Masked push (no names or content, 04 §5), email for statutory notices, in-app inbox | Notification engine (§9.4) | Curtain decides masking | P1 |
| Reporting | Operators, regulators | Transparency report, KPI pack, finance pack | `/ops/reports`; regulator portal | Compliance, Revenue | P1 |
| Analytics | Operators | Semantic-layer metrics, funnels, cohorts, experiment readouts | `/ops/analytics` | Data Intelligence | P2 |
| Billing | Members | Invoices, receipts with neutral descriptor | `/account/billing` | Payment | P1 |

| Module | Users | What it does | Key screens / endpoints | Agents | Phase |
|---|---|---|---|---|---|
| Subscription | Members | TRYST+, ENVOY, DUO, GHOST; renewal notices; one-step cancel | `/v1/subscription*` | Payment, Retention | P1/P3 |
| Wallet | Members | **Keys balance** is TRYST's wallet: a closed-loop ledger, not stored value. No cash-out, no transfers between members | `/v1/entitlements` | Payment | P1 |
| Commission | Partners | Voucher-reseller and licensee referral commission, paid by split (BitriPay `application_fee`) or invoice | `/partners/commission` | Payment | P4 |
| Transaction | Ops | Ledger explorer: every entitlement and Keys movement with its processor event | `/ops/payments/ledger` | Payment, Fraud | P1 |
| Audit trail | Admins, regulators | Agent decisions (hash chain), admin actions, break-glass, data access | `/ops/audit` | AI Governance | P1 |
| Security | Members, SOC | Member: security activity, devices. SOC: alerts, incidents, containment | `/account`, `/ops/security` | Identity risk, SOC, Threat Hunter | P1 |
| Agent registry | Admins | Manifests, levels, budgets, kill switches, eval scores | `/ops/agents` | AI Governance | P1 |
| Connector registry | Admins | Each connector's data map, DPA status, health, kill switch | `/ops/connectors` | API Integration | P1 |

# 7. BitriPay payment gateway API door

## 7.1 Position in TRYST

BitriPay is integrated as a **core payment gateway layer behind the processor-agnostic `PaymentProvider` interface** (FR-078), next to Stripe and the high-risk acquirer (D-26, FR-084).

- **Built now:** the adapter (`backend/internal/payments/bitripay.go`), tested against a BitriPay-shaped sandbox server.
- **Live use is gated by market.** BitriPay's documented rails are mobile-money operators in markets TRYST will never enter (01 §4.3; D-13). Live keys are therefore refused in code unless a market is enabled for both TRYST and BitriPay, with a recorded legal opinion and BitriPay's written acceptance of the business model (as for Stripe, D-22).
- **Where BitriPay is commercially useful to TRYST without member exposure:** (a) settling **partner commissions** through connected accounts (voucher resellers, licensees) in any market BitriPay serves; (b) the **licensing model** (§12.3), where a licensee in a BitriPay market runs its own product and is the merchant of record.

## 7.2 API door: what TRYST implements against BitriPay

From the BitriPay developer documentation supplied by the founder. Base URL `https://api.bitripay.com/v1`; test and live keys share it.

| Capability (brief) | BitriPay surface | TRYST implementation | Status |
|---|---|---|---|
| API key generation | `POST /api_keys` (sk_, rk_, pk_ with scopes); `POST /api_keys/{id}/rotate` (live needs step-up) | TRYST holds an **rk_ restricted key** with only the scopes it needs (below), in the vault; rotation every 90 days by the API Integration agent's reminder, done by a person | Spec |
| Sandbox mode | `sk_test_…`; magic MSISDNs (§7.6) | Adapter accepts test keys; CI contract tests use a BitriPay-shaped server | **Built** |
| Live mode | `sk_live_…` / `rk_live_…` | Refused unless `LiveMarkets[market]` is set | **Built** (gate) |
| Webhooks | `POST /webhook_endpoints` (whsec_ once); `BitriPay-Signature` HMAC + platform Ed25519 key from `GET /keys`; at-least-once, dedupe by event id; replay | `VerifyWebhook` (HMAC, 5-min tolerance), shared `Dedup`; Ed25519 second check in P0 once the header is confirmed | **Built** (HMAC) |

| Capability (brief) | BitriPay surface | TRYST implementation | Status |
|---|---|---|---|
| Merchant onboarding | `POST /accounts` (business_name, type, email, country, application_fee_bps) → claim link `POST /accounts/{id}/account_links` | Partner portal creates the partner's connected account; the partner claims it and owns it | Spec (P4) |
| QR payment | `POST /qr_codes` (static BitriQR, EMVCo + signed extension); `qr_payload` on intents | Not used for members (QR payment at a venue would link a member to a place). Used for partner invoices only | Spec |
| Payment links | `POST /payment_links` | Licensee and partner invoices | Spec |
| Wallet payments | `GET /wallets`, `POST /transfers` | Not used for members (no stored value at TRYST). Partners can hold commission in their own BitriPay wallet | Spec |
| Settlement | `/settlement_profiles` (T0/T1/T2/weekly/manual), `/settlement_cycles/{id}/statement` (json, csv, pdf; numbered, hashed) | Payment agent reconciles statements against the ledger nightly | Spec |
| Refunds | `POST /refunds` (atomic reservation), `GET /payment_intents/{id}/refundable` | `Refund` (idempotent key per refund) | **Built** |
| Disputes | `GET /disputes`, `POST /disputes/{id}/respond` | Payment agent assembles evidence; payments ops submits | Spec |
| Commission split | `application_fee_minor` on intents; `BitriPay-Account` header for connected accounts; `/payment_intents/{id}/splits` | Licensee and reseller splits | Spec (P4) |
| Transaction monitoring | `GET /events`, `/payment_intents/{id}/timeline`, `/payment_resolution`, `GET /status` (degraded flags) | Payment agent watches `status` and fails over (reversible) | Spec |
| Developer documentation | API reference + OpenAPI 3.1 | Linked from the Developer Centre; our adapter's contract tests pin what we use | Spec |
| Plugin-ready integration logic | Hosted checkout, embedded widget (pk_), WooCommerce and Shopify plugins, SDKs | TRYST uses **hosted checkout** only (no third-party script on TRYST pages, NFR-20 and CSP) | Spec |

**Scopes TRYST requests (least privilege):** `payment_intents:write`, `payment_intents:read`, `checkout_sessions:write`, `refunds:write`, `refunds:read`, `subscriptions:read`, `subscriptions:write`, `disputes:read`, `disputes:write`, `settlements:read`, `balance:read`, `webhooks:manage`, `events:read`; for P4 partner payouts, `accounts:read`, `accounts:write`. **Never requested:** `payouts:approve` (four-eyes stays with people), `credit:read`, `remittances:*`, `ai:run`.

## 7.3 Merchant and partner onboarding flow

1. Partner applies in the partner portal → KYB by TRYST's KYB connector (§8.2) for licensees; resellers get a lighter check.
2. TRYST calls `POST /accounts` with the partner's business details and the agreed `application_fee_bps` → `acct_…`.
3. TRYST sends the claim link (`POST /accounts/{id}/account_links`, valid 7 days). The partner owns the account; TRYST appears under the partner's Team as a developer, with no access to settlement or payouts.
4. Sandbox integration tests pass (§7.6) → a person approves live mode in the connector registry (always-human).
5. The partner can remove TRYST at any time; `POST /accounts/{id}/detach` ends TRYST's access, and the money and history stay the partner's.

## 7.4 Commission split

For a partner sale billed through BitriPay, the intent carries `application_fee_minor` and the `BitriPay-Account: acct_…` header. The partner is the merchant of record; TRYST's fee is a transparent split shown on both statements. Refund behaviour on splits follows the intent's split-refund policy (`pro_rata` or `merchant_absorbs`, chosen per contract).

## 7.5 Payment state machine (as consumed by TRYST)

`requires_payment_method → processing → succeeded → settled`, with branches `ambiguous` (manual review at BitriPay; TRYST grants **no** entitlement until resolved), `failed` (back to requires_payment_method), `canceled`. Entitlements are written only from verified `payment_intent.succeeded` events; settlement events update the ledger only. An `ambiguous_hold` older than 24 h opens a payments-ops task.

### 7.6 Sandbox

BitriPay's magic MSISDNs drive the real attempt machine with test keys: `+243000000501` succeed; `+243000000404` fail (invalid_msisdn); `+243000000408` ambiguous → manual review; `+243000000500` timeout then succeed; `+243000000503` provider unavailable (retryable); any number ending `0000` declined. TRYST's P0 contract suite runs all six against BitriPay's sandbox and asserts the entitlement outcome for each (no entitlement on ambiguous, failed or declined).

### 7.7 Adapter implementation (built)

| Property | Code | Test |
|---|---|---|
| Bearer auth; `Idempotency-Key` on every money-moving POST, **derived deterministically** from the logical operation, so a retry can never charge twice | `post`, `idempotencyKey` | `TestBitriPayCheckoutSandbox` |
| Only `amount_minor`, `currency`, `description` are sent: no member identifier, nothing that reveals the service beyond a neutral descriptor | `CreateCheckout` | `TestBitriPayCheckoutSandbox` (asserts the exact field set) |
| Descriptor must be neutral and never name TRYST (ToS 16.2) | `ValidDescriptor` | `TestBitriPayRejectsPublishableKeyAndBadDescriptor` |
| Publishable keys refused server-side; live keys refused outside enabled markets; refused calls never reach the network | `check` | `TestBitriPayLiveRefusedOutsideEnabledMarkets` |
| Refunds and one-step cancel | `Refund`, `CancelSubscription` | `TestBitriPayRefundCancelAndErrors` |
| BitriPay error codes surfaced (`scope_denied` etc.) | `APIError` | same |
| Webhook HMAC with replay tolerance; empty secret fails closed | `VerifyWebhook` | `TestBitriPayWebhook` |

Two wire details are not in the supplied documentation and are marked **ASSUMED** in the code: the refund request field names and the `BitriPay-Signature` header layout. They are a P0 check against BitriPay's API reference (00 §5).

## 8. Third-party API connectors

### 8.1 Connector rules (FR-087)

1. **Every connector is registered** with: purpose, the module it connects to, the exact data sent and received, lawful basis, DPA and transfer mechanism, region, health check, kill switch and owner.
2. **No special-category or member-identifying data goes to a connector unless the connector is the processor for exactly that purpose** (e.g. the age-assurance provider). Nothing reaches CRM, marketing, enrichment, ad or messaging-app platforms.
3. **Two providers for anything on the critical path** (age assurance, payments, email for statutory notices).
4. **Adapters, not SDK sprawl.** Each category sits behind one internal interface (as `PaymentProvider` does), so switching providers is configuration.
5. **AI providers:** hosted frontier models only for generic copy with PII redacted at the boundary; anything touching member data runs on self-hosted open-weight models in the UK (03 §2.1).

### 8.2 Connector register

| Category | Why needed | Connects to | Sends / receives | Provider options (primary · alternative) | TRYST rule |
|---|---|---|---|---|---|
| Payments | Subscriptions, Keys, deposit, refunds | `commerce` via `PaymentProvider` | Sends amount, currency, neutral descriptor, opaque billing ref; receives payment events | **Stripe** (conditional, D-22) · high-risk acquirer (backup MID) · **BitriPay** (gated, D-26) · Adyen · Checkout.com · PayPal | Adyen and Checkout.com are evaluated as the high-risk backup in P0; PayPal is unlikely to accept the category (verify) |
| Banking-as-a-Service | Not needed for members (TRYST holds no stored value) | Treasury (ops) | Company accounts only | Business bank with API (e.g. Modulr, ClearBank partners) | Operator-only |

| Category | Why needed | Connects to | Sends / receives | Provider options (primary · alternative) | TRYST rule |
|---|---|---|---|---|---|
| Open banking | Optional pay-by-bank in UK/EU, lower fees, no card data | `commerce` | Payment initiation; no account data retained | TrueLayer · Yapily · Stripe (pay by bank) | P3 evaluation; descriptor rules apply |
| KYC / age assurance | Highly effective age assurance (OSA); V2 | identity-svc | Sends selfie/document to provider; receives pass/fail + token | Two providers: **Yoti** · **Persona** · **Veriff** · **Sumsub** · Onfido | No document image retained by TRYST (A §8.1) |
| KYB | Licensees and commission partners | Partner onboarding | Business registration data | Sumsub KYB · Persona · Companies House API | B2B only |
| AML screening | Sanctions and PEP screening of **businesses** (licensees, partners). Member AML duties sit with the regulated PSP | Partner onboarding | Business and director names | ComplyAdvantage · Sumsub | D-32 |
| Fraud prevention | Card testing, ATO, bots | Payment, identity, edge | Device signals, payment risk | Stripe Radar · Ethoca/Verifi alerts · Cloudflare Bot Management · Fingerprint (device, hashed) | Device IDs hashed; no cross-site tracking |
| Identity verification (liveness B2) | Login factor B2 (02 §3.3) | identity-svc | Liveness session; match result | iProov · FaceTec · Persona | PAD Level 2 (NFR-17); D-18 |
| Email | Statutory notices (renewal, cooling-off), sign-in alerts | Notification engine | Billing email (member-chosen), neutral subject lines | Postmark · Amazon SES · SendGrid · Brevo | No tracking pixels; neutral sender |
| SMS | **Sign-up OTP only**; never a login factor (D-16) | identity-svc | Phone number, code | Twilio Verify · MessageBird | Neutral sender ID |
| WhatsApp | — | — | — | — | **Declined for members** (D-29): exposes the contact on a shared device and to a third party. Operator alerts may use Slack/PagerDuty instead |
| Push notifications | Masked alerts | Notification engine | Opaque payload; content fetched in app | APNs · FCM | No names or content (04 §5) |
| Maps | Venue sanity (public venue), travel mode, zone drawing | Client, Envoy logistics | Coarse geohash only; no live tracking | Mapbox (self-hosted tiles where possible) · Google Maps Platform | Exact locations never leave the device (FR-067) |
| Logistics | Not applicable (no physical goods) | — | — | — | Recorded as not applicable |
| Accounting | Revenue recognition, VAT returns | Finance (ops) | Aggregated revenue journals; no member data | Xero · NetSuite | Aggregates only |
| Tax | VAT/OSS calculation | `commerce` | Country + amount | Stripe Tax · Avalara | — |
| CRM | **B2B pipeline only** (licensees, partners, press) | Sales copilot | Business contacts | HubSpot · Salesforce | **No member data, ever** (D-29) |

| Category | Why needed | Connects to | Sends / receives | Provider options (primary · alternative) | TRYST rule |
|---|---|---|---|---|---|
| Analytics | Product and marketing-site analytics | Warehouse; marketing site | Cookieless aggregate; pseudonymous product events | Self-hosted: ClickHouse + Plausible/Umami | No third-party tracking scripts (NFR-20) |
| AI model providers | Generic copy (Herald, help centre); coding copilots | `llm-gateway` | Redacted prompts | Anthropic · OpenAI · Google Gemini / Vertex AI · Cohere · Mistral; **self-hosted** open-weight (vLLM) for member data | Zero-retention terms required for hosted providers |
| Cloud | Compute, storage, KMS/HSM | All | — | **AWS eu-west-2** (primary) · Azure / GCP for DR evaluation | UK/EU residency |
| Cloud storage | Encrypted media, backups, WORM audit anchors | media-svc, ops | Ciphertext only | S3 (object lock) · Cloudflare R2 (egress-free CDN origin for marketing assets) | Client-side encryption for member media |
| Authentication | Members: passkeys (built, go-webauthn). Staff: SSO | identity-svc; ops | — | Members: in-house WebAuthn. Staff: Okta / Google Workspace SSO + hardware keys | No third-party IdP for members |
| Productivity | Staff collaboration | Ops | No member data | Google Workspace · Microsoft 365 | DLP rules block member identifiers |
| Document generation | Statements of reasons, DSR exports, invoices, transparency report | Compliance, Payment | Generated server-side | In-house (HTML → PDF with headless Chromium, as the spec PDF) | Not sent to third parties |
| E-signature | Partner, licensee and vendor contracts | Partner onboarding | Business signatories | DocuSign · Dropbox Sign | B2B only |
| Customer support | Ticketing | Support agent | Ticket text, opaque member ref | Zendesk · Help Scout · Intercom (without its tracking widget) | Case-scoped; neutral email domain |
| Data enrichment | — | — | — | — | **Declined for members** (D-29): enrichment would link a pseudonymous member to a real identity, breaking FR-002. B2B lead enrichment allowed in the CRM |
| Currency exchange | Display prices in EUR, SEK, DKK in P4 | `commerce` | Rates only | Processor-native pricing (Stripe multi-currency) · ECB reference rates | Prices set per market, not converted live |
| Subscription billing | Plans, renewals, notices | `commerce` | Via the payment adapters | Stripe Billing · BitriPay `/plans` and `/subscriptions` (gated) | DMCC/CCR notices (03 §10) |
| Observability | Metrics, logs, traces | All services | No member content; pseudonymous IDs | Self-hosted Grafana stack (Prometheus, Loki, Tempo) + OpenTelemetry | Logs scrubbed at source |
| Security | WAF, DDoS, secrets, scanning | Edge, CI | — | Cloudflare · AWS Shield · HashiCorp Vault / AWS Secrets Manager · Snyk / GitHub Advanced Security | — |
| Incident and on-call | Paging | System Health | Incident metadata | PagerDuty · Opsgenie | — |

# 9. Production-grade architecture

## 9.1 Proven patterns used, and where they come from

| Pattern | Proven at | Used for |
|---|---|---|
| Idempotency keys on every mutating request | Stripe | Edge API (02 §5), all payment adapters |
| Signed webhooks with timestamp tolerance and replay | Stripe, GitHub | Inbound processor webhooks; outbound partner webhooks (§11.4) |
| Zero trust / BeyondCorp: identity- and device-aware access, no trusted network | Google | Staff access; service-to-service mTLS (SPIFFE) |
| Event streaming with a schema registry | LinkedIn (Kafka), Uber | Redpanda + Protobuf registry (03 §2.1) |
| Durable workflows with compensation | Uber (Cadence → Temporal), Netflix (Conductor) | §5.7 workflow catalogue |
| Progressive delivery with automated canary analysis | Netflix (Kayenta), Google | Release Manager (§5.6) |
| SLOs and error budgets; multi-window burn-rate alerts | Google SRE | System Health |
| Feature store for train/serve parity | Uber (Michelangelo), Airbnb (Zipline) | Feast (03 §2.1) |
| Two-tower retrieval + learned ranking with constraints | YouTube, Pinterest, Airbnb search | Broker (03 §5) |
| Ontology / knowledge graph over operations | Palantir | Operational memory (§5.7) |
| Risk engine with explainable reason codes | Stripe Radar, Goldman Sachs Aladdin risk factors | Fraud, Risk |
| Cell-based architecture to cap blast radius | AWS, Slack | §9.8 (P4) |
| Lakehouse with governed semantic layer | Databricks, Snowflake | §9.6 |
| Edge WAF, bot management, DDoS absorption | Cloudflare | §13 |
| Endpoint and identity threat detection | CrowdStrike | SOC and Threat Hunter design |
| Workflow-centric operations consoles | ServiceNow | Operator command centres (§4) |
| Agent tool use with schema validation and human approval | OpenAI, Anthropic, Microsoft | §5 |

## 9.2 Layered architecture

```
 Clients — iOS / Android (native, Rust crypto core) · Web PWA (Next.js) · Marketing site · Ops console · Partner
portal
    │  TLS 1.3, passkeys, DPoP-bound tokens
 Edge — Cloudflare (WAF, DDoS, bot) → edge-gateway (Go): authN, jurisdiction, tier, consent, rate limit,
idempotency
    │  gRPC + mTLS (SPIFFE)
 Domain — identity-svc · core-svc (profile, couple, intent, discretion, discovery, reveal, threads/MLS, meet,
consent, deletion, commerce)
          media-svc · safety-svc · jobs · webhook-engine · notification-engine · partner-api (P4)
    │  typed Protobuf events (Redpanda + schema registry)
 Agents — member plane: Cartographer, Mirror, Broker, Envoy, Curtain, Guardian, Aftercare, Onboarding, Risk, Fraud,
Support, Payment, Compliance, Chief of Staff
          ops plane: Herald*, System Health, Bug Detection, Auto-Repair, Release Manager, Infra Optimiser, SOC,
Threat Hunter, Vulnerability, analysts
          every action → aigov gate → audit chain        (*Herald: separate cloud account)
 AI runtime — llm-gateway (vLLM pool, self-hosted, UK) · hosted LLM proxy (redacted, generic copy only) · model +
prompt registry · eval harness
 Data — IDENTITY-DB · PROFILE-DB · SAFETY-DB · BAN-DB (isolated PostgreSQL clusters) · Qdrant · Feast · ClickHouse
· S3 (ciphertext, object lock) · KMS/HSM
 Platform — Kubernetes (EKS) · Argo CD · Terraform · Vault · OpenTelemetry → Grafana stack · PagerDuty · Temporal
```

## 9.3 Component specification

| Component | Specification |
|---|---|
| Frontend | Native Swift / Kotlin with a shared Rust crypto core (E-07); Next.js 16 PWA (built: join, enrol, sign-in, approve, account); ops console and partner portal as separate Next.js apps on separate origins with their own CSP |
| Backend | Go services (03 §2.2); modular monolith `core-svc` with split triggers (§9.8) |

| Component | Specification |
|---|---|
| Database | PostgreSQL 16 clusters isolated per domain; pgvector; migrations generated from 02 §4 (`scripts/gen_migrations.py`, drift-checked in CI) |
| Authentication | Members: account-holder-only passkeys + second factor (built). Staff: SSO + FIDO2 hardware key + device posture. Services: SPIFFE mTLS. Partners: scoped API keys + mTLS for webhooks |
| Role-based access control | RBAC for staff roles, plus ABAC (03 §6.5) on case, purpose and data class; just-in-time elevation with a second approver; all access logged |
| AI orchestration layer | Agent services + Temporal workflows + `aigov` gate (§5) |
| Agent memory layer | Structured member vectors only; operational knowledge graph and runbook vector index (§5.7) |
| Vector database | Qdrant for candidate retrieval (filtered ANN after Stage 0 gates); a separate Qdrant collection in the ops plane for runbook and spec retrieval |
| Event-driven workflows | Redpanda topics `member.*`, `agent.*`, `payment.*`, `safety.*`, `ops.*`; Protobuf schemas with compatibility checks; outbox pattern from PostgreSQL to avoid dual writes |
| API gateway | `edge-gateway` (built skeleton): middleware order in 02 §5; per-key and per-subject rate limits (token bucket in Redis) |
| Webhook engine | Inbound: verify signature → dedupe → enqueue → process idempotently. Outbound (partners, P4): signed `TRYST-Signature` (§11.4), exponential back-off for 72 h, delivery log, replay, endpoint auto-disable after 5 days of failure |
| Payment gateway layer | `PaymentProvider` with Stripe, acquirer and BitriPay adapters; the Payment agent's failover (§5.5) |
| Notification engine | Channel router (push, email, in-app); Curtain-controlled masking; quiet hours; statutory notices bypass quiet hours but stay neutral |
| Audit log | Two chains: agent decisions (`aigov`) and admin actions; both anchored hourly to S3 object lock |
| Admin control layer | Super Control Centre (§14) over the ops API; break-glass with two-person approval |
| Security layer | §13 |
| Observability | OpenTelemetry traces, metrics and logs; member IDs replaced by rotating pseudonyms; content never logged |
| Monitoring | SLOs per user-facing journey (§9.5); synthetic probes for sign-in, slate, checkout; Privacy Auditor probes (03 §9) |
| Error handling | RFC 9457 problem details with stable codes (02 §5.10); uniform `404 not_found` for anything invisible; retries only on idempotent calls; circuit breakers per connector; fail closed for auth, payments and safety |
| Scalability logic | §9.8 |

## 9.4 Event architecture

| Topic family | Producers | Consumers | Retention | Notes |
|---|---|---|---|---|
| `member.*` (02 §8 taxonomy) | Clients via `/v1/signals:batch`, core-svc | Mirror, Broker, analytics | Raw 180 d, then purged | Pseudonymous; no content |
| `agent.*` | Agents | Agents, audit sink | 30 d | Typed turns (02 §6.1) |
| `payment.*` | Webhook engine | Payment, Fraud, ledger | 7 y (financial records), pseudonymised | — |
| `safety.*` | Guardian, safety-svc | T&S console, Compliance | Per SAFETY-DB policy | Access only via the trust console |
| `ops.*` | System Health, CI, deploys | Auto-Repair, Release Manager, Bug Detection | 90 d | No member data |
| `aigov.decision` | Gate | Audit sink, Admin Control | 7 y | Hash chain |

## 9.5 SLOs

| Journey | SLI | SLO |
|---|---|---|
| Sign-in (both factors) | Successful completions / attempts with valid factors | 99.9% / 30 d; p95 < 3 s excluding the member's biometric time |
| Slate | `/v1/slate` success and latency | 99.9%; p95 < 400 ms (NFR-02) |
| Thread delivery | MLS message relayed | 99.95% |

| Journey | SLI | SLO |
|---|---|---|
| Checkout | Checkout creation success | 99.9% across processors |
| Erasure | Completed < 60 s | 99% (NFR-01) |
| Emergency lock | Effective < 5 s | 95% (FR-064) |
| Agent gate | Decision latency | p99 < 5 ms in-process |

## 9.6 AI data intelligence layer

| Component (brief) | TRYST implementation | Privacy rule |
|---|---|---|
| Data lake | S3 (eu-west-2), Iceberg tables, partitioned by day; raw events land here pseudonymised | Raw behavioural events purged at 180 d |
| Data warehouse | ClickHouse marts (dbt-modelled); semantic layer of metric definitions (QCAM, mutual rate, etc.) | Aggregate marts only for analysts; k ≥ 20 row floor |
| Vector database | Qdrant (member plane) and a separate ops-plane collection | Member vectors never leave the member plane |
| Knowledge graph | Ops: services, runbooks, incidents, decisions (Neo4j or PostgreSQL + Apache AGE). Member plane: the block and exclusion graph used by Broker Stage 0 | The member graph is used for gates and abuse detection only |
| Event streaming platform | Redpanda + schema registry | §9.4 |
| Real-time analytics engine | ClickHouse materialised views over Redpanda for ops dashboards (queue depth, authorisation rate, SLOs) | No member-level real-time views outside T&S |
| Predictive intelligence engine | Liquidity forecasting (city × segment × mode), churn propensity (aggregate cohorts), capacity forecasting | Forecasts on aggregates; churn scores never shown to support staff as a label on a member |
| Behavioural intelligence engine | Mirror (03 §4): RevealedPreferenceVector, divergence, α weighting with the 15% stated-preference floor | Message content never used; personalisation can be switched off (FR-024) |
| Recommendation engine | Broker: Stage 0 gates → retrieval → M3/M4 ranking → fairness constraints (S4 caps, Gini) | Hard limits inviolable (P2) |
| Decision intelligence engine | Guardian triage, Risk and Fraud scoring, Payment failover rules, all with reason codes and gate decisions | Every decision explainable and audited |

**Data governance architecture:** a data catalogue with owner, classification (public, internal, personal, special-category, safety), lawful basis, retention and permitted purposes per dataset; column-level tags drive access policies; lineage from dbt; the Privacy Auditor tests that the catalogue matches reality each release.

## 9.7 Disaster recovery and business continuity

| Tier | Systems | RPO | RTO | Mechanism |
|---|---|---|---|---|
| T0 | identity-svc, edge, IDENTITY-DB, BAN-DB, KMS/HSM | 1 min | 30 min | Multi-AZ synchronous replicas; cross-region (eu-west-1) async replica; HSM cluster across AZs; quarterly restore drill |
| T1 | core-svc, PROFILE-DB, threads, payments | 5 min | 1 h | As above; Redpanda tiered storage |
| T2 | Agents, analytics | 24 h | 8 h | Rebuild from IaC and the lake |

Erasure must survive restore: deletion jobs are replayed against any restored backup before it serves traffic (crypto-shredded keys stay destroyed, 03 §6.3). **Business continuity:** backup MID live from day one; two age-assurance providers; staff runbooks for a full agent kill (the platform keeps running with agents at L0, falling back to the deterministic P1 baseline ranker, 03 §5.2).

## 9.8 Scalability

| Trigger | Action |
|---|---|
| A `core-svc` module > 40% of CPU or a separate team owns it | Split it into its own service behind the same gRPC contract |
| PROFILE-DB write p95 > 20 ms or > 2 TB | Partition by region cell, then shard by `profile_id` hash |
| > 500k verified members or a second region (P4) | **Cell-based architecture**: a cell = full stack for a market group (UK+IE, EU-North, EU-South); global services limited to identity routing and ban anchors |

| Trigger | Action |
|---|---|
| vLLM pool GPU utilisation > 70% p95 | Infra Optimiser proposes scale-out; a person applies it |
| Qdrant p95 retrieval > 40 ms | Add replicas; tighten Stage 0 pre-filters |

### 9.9 Deployment strategy

Trunk-based development; every merge runs CI (spec check, contracts lint, Go, Python, Rust, web, Playwright e2e, as in `.github/workflows/` (one pipeline each for shared, backend and frontend, plus integration)). Images are signed (Sigstore cosign) with SLSA provenance; Argo CD syncs from Git; progressive delivery 1% → 10% → 50% → 100% with automated canary analysis; feature flags for every user-visible change; freeze windows around launches. Agents ship with their eval suites as a release gate (03 §9). Infrastructure is Terraform with policy checks (OPA) in CI.

### 9.10 Testing strategy

| Layer | What | Where today |
|---|---|---|
| Unit | Each package | Go (`go test ./...`, including `aigov` and `payments`), Python (pytest + Hypothesis), Rust (`cargo test`), web (Vitest) |
| Property | Hard-limit inviolability, ranking invariants | `agents/tests` (Hypothesis) |
| Contract | OpenAPI lint; Protobuf compatibility; processor adapters against recorded sandbox behaviour | Redocly in CI; `bitripay_test.go` |
| End to end | Passkey sign-up and two-factor sign-in with virtual authenticators | Playwright (`frontend/e2e/passkey.spec.ts`) |
| Agent evals | 400-case golden set per agent; injection red team; workflow-level replay | 03 §9 (P1) |
| Governance | Always-human classes, kill switch, audit-chain tamper detection; mutation-checked | `aigov_test.go` |
| Privacy | Privacy Auditor probes: access, retention, model leakage | `jobs` (P1) |
| Load | k6 profiles per journey at 3× forecast peak | P1 |
| Chaos | AZ loss, connector outage (age assurance, payments), agent kill-all | Game days quarterly from P2 |
| Security | SAST, DAST, dependency and container scanning; quarterly pen test; annual red team; bug bounty (NFR-19) | CI + vendors |

## 10. Database schema

The member data model is owned by 02 §4 and is not repeated here. The operating system adds the **ops** and **partner** schemas below, in PROFILE-DB's cluster but with separate roles, so no member-plane role can read partner data and no ops role can read member tables.

### 10.1 ERD (OS additions)

```
agent ──< agent_action           agent ──< agent_decision >── staff_user (approver)
  │                                 │
  └──< agent_kill_event             └─ prev_hash → agent_decision.hash (chain)
connector ──< connector_secret_ref     connector ──< connector_health
partner ──< partner_api_key            partner ──< webhook_endpoint ──< webhook_delivery
partner ──< usage_record (ACU)         partner ──< partner_payout (BitriPay acct)
payment_event (all processors) ─> commerce.entitlement / commerce.keys_ledger (02 §4.5)
staff_user ──< admin_action            staff_user ──< access_grant (JIT)
```

## 10.2 DDL

```
CREATE SCHEMA ops; CREATE SCHEMA partner;

CREATE TABLE ops.agent (
  agent_id      TEXT PRIMARY KEY,                       -- e.g. 'guardian'
  owner_team    TEXT NOT NULL,
  level         SMALLINT NOT NULL CHECK (level BETWEEN 0 AND 3),
  plane         TEXT NOT NULL CHECK (plane IN ('member','ops')),
  self_hosted   BOOLEAN NOT NULL,
  daily_budget  INT NOT NULL CHECK (daily_budget >= 0),
  data_scopes   TEXT[] NOT NULL,
  model_version TEXT, policy_version TEXT,
  killed        BOOLEAN NOT NULL DEFAULT false,
  updated_at    TIMESTAMPTZ NOT NULL DEFAULT now(),
  CHECK (plane = 'member' OR NOT data_scopes &&
ARRAY['identity_db','profile_db','safety_db','ban_db','event_bus','feature_store','vector_store']),
  CHECK (plane = 'ops' OR self_hosted)
);
CREATE TABLE ops.agent_action (
  agent_id TEXT REFERENCES ops.agent ON DELETE CASCADE,
  action   TEXT NOT NULL,
  class    TEXT NOT NULL CHECK (class IN ('read','recommend','reversible','runbook','irreversible',
                                          'member_safety','money_movement','production_change')),
  PRIMARY KEY (agent_id, action)
);
CREATE TABLE ops.staff_user (
  staff_id UUID PRIMARY KEY, display_name TEXT NOT NULL, roles TEXT[] NOT NULL,
  can_approve BOOLEAN NOT NULL DEFAULT false, hw_key_enrolled BOOLEAN NOT NULL,
  disabled_at TIMESTAMPTZ
);
CREATE TABLE ops.agent_decision (                       -- append-only; hash chain (aigov)
  seq        BIGINT PRIMARY KEY,
  at         TIMESTAMPTZ NOT NULL,
  kind       TEXT NOT NULL,                             -- register | decide:allow | decide:needs_human |
decide:deny | kill | kill_all | resume
  agent_id   TEXT NOT NULL,
  action     TEXT,
  approver   UUID REFERENCES ops.staff_user,
  subject    TEXT,                                      -- pseudonymous reference only
  detail     TEXT,
  prev_hash  TEXT NOT NULL,
  hash       TEXT NOT NULL UNIQUE
);
CREATE INDEX agent_decision_agent_at ON ops.agent_decision (agent_id, at DESC);
CREATE INDEX agent_decision_pending ON ops.agent_decision (at) WHERE kind = 'decide:needs_human';
REVOKE UPDATE, DELETE, TRUNCATE ON ops.agent_decision FROM PUBLIC;

CREATE TABLE ops.admin_action (                         -- append-only; same chain design
  seq BIGINT PRIMARY KEY, at TIMESTAMPTZ NOT NULL, staff_id UUID NOT NULL REFERENCES ops.staff_user,
  action TEXT NOT NULL, target TEXT, justification TEXT NOT NULL, second_approver UUID REFERENCES ops.staff_user,
  break_glass BOOLEAN NOT NULL DEFAULT false, prev_hash TEXT NOT NULL, hash TEXT NOT NULL UNIQUE,
  CHECK (NOT break_glass OR (second_approver IS NOT NULL AND second_approver <> staff_id))
);
CREATE TABLE ops.access_grant (
  grant_id UUID PRIMARY KEY, staff_id UUID NOT NULL REFERENCES ops.staff_user, role TEXT NOT NULL,
  case_ref TEXT, approved_by UUID NOT NULL REFERENCES ops.staff_user,
  starts_at TIMESTAMPTZ NOT NULL, expires_at TIMESTAMPTZ NOT NULL,
  CHECK (approved_by <> staff_id), CHECK (expires_at <= starts_at + interval '8 hours')
);
CREATE TABLE ops.connector (
  connector_id TEXT PRIMARY KEY,                        -- 'stripe', 'bitripay', 'yoti', ...
  category TEXT NOT NULL, purpose TEXT NOT NULL, module TEXT NOT NULL,
  data_sent TEXT[] NOT NULL, data_received TEXT[] NOT NULL,
  member_data BOOLEAN NOT NULL, lawful_basis TEXT, dpa_signed_at DATE, region TEXT NOT NULL,
  live_enabled BOOLEAN NOT NULL DEFAULT false, live_markets TEXT[] NOT NULL DEFAULT '{}',
  live_approved_by UUID REFERENCES ops.staff_user, owner_team TEXT NOT NULL,
  CHECK (NOT member_data OR dpa_signed_at IS NOT NULL),
  CHECK (NOT live_enabled OR live_approved_by IS NOT NULL)
);
CREATE TABLE ops.connector_secret_ref (                 -- the secret lives in Vault; only the path is here
  connector_id TEXT REFERENCES ops.connector, environment TEXT CHECK (environment IN ('sandbox','live')),
  vault_path TEXT NOT NULL, rotated_at TIMESTAMPTZ NOT NULL, PRIMARY KEY (connector_id, environment)
);
CREATE TABLE ops.payment_event (                        -- every processor webhook, verified
  provider TEXT NOT NULL, event_id TEXT NOT NULL, type TEXT NOT NULL, billing_ref TEXT,
  received_at TIMESTAMPTZ NOT NULL, processed_at TIMESTAMPTZ, payload_hash TEXT NOT NULL,
```

```
  PRIMARY KEY (provider, event_id)                      -- idempotency
);

CREATE TABLE partner.partner (
  partner_id UUID PRIMARY KEY, kind TEXT NOT NULL CHECK (kind IN ('licensee','reseller','assurance','content')),
  legal_name TEXT NOT NULL, country TEXT NOT NULL, kyb_status TEXT NOT NULL DEFAULT 'none',
  bitripay_account TEXT, application_fee_bps INT CHECK (application_fee_bps BETWEEN 0 AND 3000),
  created_at TIMESTAMPTZ NOT NULL DEFAULT now()
);
CREATE TABLE partner.api_key (
  key_id UUID PRIMARY KEY, partner_id UUID NOT NULL REFERENCES partner.partner,
  prefix TEXT NOT NULL CHECK (prefix IN ('tk_test','tk_live')), secret_hash BYTEA NOT NULL,  -- Argon2id; secret
shown once
  scopes TEXT[] NOT NULL, ip_allowlist CIDR[], created_at TIMESTAMPTZ NOT NULL, revoked_at TIMESTAMPTZ
);
CREATE TABLE partner.webhook_endpoint (
  endpoint_id UUID PRIMARY KEY, partner_id UUID NOT NULL REFERENCES partner.partner,
  url TEXT NOT NULL CHECK (url LIKE 'https://%'), secret_ref TEXT NOT NULL, event_types TEXT[] NOT NULL,
  disabled_at TIMESTAMPTZ
);
CREATE TABLE partner.webhook_delivery (
  delivery_id UUID PRIMARY KEY, endpoint_id UUID NOT NULL REFERENCES partner.webhook_endpoint,
  event_id UUID NOT NULL, attempt INT NOT NULL, status_code INT, next_attempt_at TIMESTAMPTZ,
  delivered_at TIMESTAMPTZ
);
CREATE INDEX webhook_delivery_due ON partner.webhook_delivery (next_attempt_at) WHERE delivered_at IS NULL;
CREATE TABLE partner.usage_record (                     -- ACU metering (B2B only, D-27)
  usage_id UUID PRIMARY KEY, partner_id UUID NOT NULL REFERENCES partner.partner,
  operation TEXT NOT NULL, acu NUMERIC(12,3) NOT NULL CHECK (acu >= 0),
  idempotency_key TEXT NOT NULL, at TIMESTAMPTZ NOT NULL, UNIQUE (partner_id, idempotency_key)
);
CREATE TABLE partner.acu_balance (
  partner_id UUID PRIMARY KEY REFERENCES partner.partner, prepaid_acu NUMERIC(14,3) NOT NULL CHECK (prepaid_acu >=
0),
  updated_at TIMESTAMPTZ NOT NULL
);
```

**Permissions.** Roles `member_plane_rw` (02 §4 schemas only), `ops_rw` (ops), `partner_rw` (partner), `analyst_ro` (aggregate marts in ClickHouse, not PostgreSQL), `auditor_ro` (ops.agent_decision, ops.admin_action). No role spans member and partner schemas. **Audit requirements:** append-only tables have UPDATE/DELETE revoked; hourly hash anchoring to S3 object lock; every `access_grant` and break-glass event is itself an `admin_action`.

# 11. API specification

## 11.1 Surfaces

| Surface | Base | Auth | Who |
|---|---|---|---|
| Member API (existing) | `/v1` (02 §5; `shared/contracts/openapi/tryst.v1.yaml`) | Passkey session; DPoP from P1 | Members |
| Ops API | `/ops/v1` (internal origin, not internet-routable) | Staff SSO + hardware key + JIT role | Operators, admins |
| Partner API (P4) | `/partner/v1` | `Authorization: Bearer tk_live_…` + optional mTLS; scopes | Licensees, resellers |
| Inbound webhooks | `/v1/billing/{provider}/webhook` | Provider signature | Stripe, acquirer, BitriPay |
| Outbound webhooks | Partner URLs | `TRYST-Signature` | Partners |

## 11.2 Ops API endpoints (OS)

| Method | Path | Permission | Contract |
|---|---|---|---|
| GET | `/ops/v1/agents` | `agents:read` | Registry: manifests, level, budget used today, killed |
| POST | `/ops/v1/agents/{id}/kill` | `agents:kill` | `{reason}` → kill; audit entry. `id = *` kills all |
| POST | `/ops/v1/agents/{id}/resume` | `agents:resume` + second approver | Resume a killed agent |
| GET | `/ops/v1/decisions?agent=&outcome=needs_human` | `decisions:read` | Pending and past gate decisions |

| Method | Path | Permission | Contract |
|---|---|---|---|
| POST | `/ops/v1/decisions/{seq}/approve` | `decisions:approve` (named human with `can_approve`) | Approves a `needs_human` request; the agent retries with `approver` set |
| GET | `/ops/v1/audit/verify` | `audit:read` | Runs `VerifyChain`; returns `{ok, entries, last_anchor}` |
| GET | `/ops/v1/connectors` | `connectors:read` | Register with health |
| POST | `/ops/v1/connectors/{id}/live` | `connectors:live` + second approver | Enable live in listed markets |
| POST | `/ops/v1/payments/failover` | `payments:route` | Switch new checkouts to the backup processor |
| GET | `/ops/v1/slo` | `ops:read` | SLO status and error budgets |

**Example: approve a pending removal**

```
POST /ops/v1/decisions/18421/approve
Authorization: Bearer <staff session>
Idempotency-Key: 6f1c…
Content-Type: application/json

{"justification": "Case C-2207: verified sextortion evidence; second review by moderator M-114"}
```

```
{"seq": 18422, "kind": "decide:allow", "agent_id": "guardian", "action": "remove_member",
 "approver": "b6b1…", "reason": "member_safety approved by named human", "hash": "9c4e…"}
```

## 11.3 Partner API endpoints (P4)

| Method | Path | Scope | Contract | ACU |
|---|---|---|---|---|
| POST | `/partner/v1/consent/handshakes` | `handshake:write` | Run a schema-only agent handshake between two of the **licensee's own** users (the Envoy engine as a service) | 2.0 |
| POST | `/partner/v1/discretion/exclusion-check` | `psi:write` | ExclusionRing-style PSI round (client library does the blinding) | 0.5 |
| POST | `/partner/v1/safety/classify` | `safety:write` | On-premises Guardian model licence check-in (models run in the licensee's environment) | 0 (licence) |
| GET | `/partner/v1/usage` | `usage:read` | ACU used by day and operation | — |
| POST | `/partner/v1/webhook_endpoints` | `webhooks:manage` | Register an endpoint; secret returned once | — |

**Example: handshake request**

```
POST /partner/v1/consent/handshakes
{"a": {"intent_shape": "one_off", "hard_limits": ["no_photos"], "windows": [["2026-11-02T18:00Z","2026-11-
02T23:00Z"]]},
 "b": {"intent_shape": "one_off", "hard_limits": [], "windows": [["2026-11-02T20:00Z","2026-11-03T01:00Z"]]}}
→ 200 {"handshake_id": "hs_…", "outcome": "compatible", "blocking": [], "friction": ["reveal_pace"],
       "briefs": {"a": {...codes...}, "b": {...codes...}}, "acu": 2.0}
```

## 11.4 Webhooks

**Inbound** (processor → TRYST): verify signature (Stripe `Stripe-Signature`; BitriPay `BitriPay-Signature`; acquirer per contract) → 5-minute tolerance → dedupe on `(provider, event_id)` in `ops.payment_event` → process → 2xx. Unverified → 400 with no detail.

**Outbound** (TRYST → partner): header `TRYST-Signature: t=<unix>,v1=<hex HMAC-SHA256(secret, "<t>.<body>")>`; events `handshake.completed`, `usage.threshold_reached`, `invoice.issued`, `key.rotation_due`; at-least-once; partners dedupe on `event_id`; retries at 1 m, 5 m, 30 m, 2 h, 6 h, then every 12 h for 72 h; replay via the partner portal.

## 11.5 Rate limits

| Surface | Limit |
|---|---|
| Member API | Per endpoint (02 §5); sign-in begin 10/min per IP-range bucket and 5/min per contact hint |
| Ops API | 600/min per staff session; kill and approve endpoints 30/min |
| Partner API | Plan-based: Sandbox 60/min; Growth 600/min; Enterprise contractual; burst 2× for 10 s |

| Surface | Limit |
|---|---|
| Webhook intake | 2,000/min per provider; above that, 429 and the provider retries |

### 11.6 Error codes (additions to 02 §5.10)

| HTTP | code | Meaning |
|---|---|---|
| 403 | `scope_denied` | Key lacks the scope |
| 403 | `approval_required` | Action is always-human; a pending decision was created (`decision_seq` returned) |
| 409 | `agent_killed` | Agent is stopped by the kill switch |
| 402 | `acu_insufficient` | Partner prepaid ACU exhausted |
| 403 | `live_not_enabled` | Connector or key not enabled for live in this market |
| 400 | `signature_invalid` | Webhook signature failed (no further detail) |

## 12. Monetisation model

### 12.1 Principles that bind the model

Charge for agency and discretion; make resolution the profitable outcome (01 §10.1). P8 stays in force: no advertising, no data sale, no affiliates, no fake profiles, no unreadable credit mechanics, no engagement paywalls, no charge for deletion or data access, replying always free. Every revenue line below is checked against it.

### 12.2 Revenue lines (brief → TRYST)

| Brief line | TRYST line | Price | Status | Phase |
|---|---|---|---|---|
| Subscription plans | Verified (free + £9.99 refundable deposit), TRYST+ £24.99/mo (£14.99 annual), ENVOY £49.99/mo, DUO £39.99/mo per couple | 01 §10.2 | Canonical | P1/P3 |
| Add-ons | GHOST £7.99/mo (D-05) | 01 §10.2 | Canonical | P3 |
| Transaction fees | **Keys** packs £9.99/60 (intent costs refunded on reply) | 01 §10.2 | Canonical | P1 |
| AI credit / ACU system | **Partner API metering only** (D-27). Members never buy ACU | Illustrative: £0.04 per ACU prepaid; volume bands | Adapted | P4 |
| API usage fees | Partner API plans: Sandbox free; Growth £1,500/mo incl. 50k ACU; Enterprise contract | Illustrative | Spec | P4 |
| Commission model | Reseller commission on voucher sales (paid out, a cost to TRYST); licensee referral split via BitriPay `application_fee` or invoice | Contract | Spec | P3/P4 |
| Merchant fees | Not applicable to members (no merchants on the member platform). For licensees on BitriPay rails, BitriPay's fees apply to them; TRYST takes an application fee where it provides the integration | Contract | Adapted | P4 |
| Partner fees | Assurance and content partners are suppliers, not fee payers | — | Not applicable | — |
| Premium automation fees | The **ENVOY tier** is the premium automation product for members | £49.99/mo | Canonical | P2/P3 |
| Data intelligence revenue | **Declined for member data** (P8; D-30). Alternative: free published aggregate research with differential privacy as a PR asset (Herald) | — | Declined | — |
| White-label licensing | Licensing the governed stack (handshake engine, PSI exclusion, on-device safety models, governance gate) to other platforms; **no member data and no shared member pool** | Illustrative: £60–250k/yr per licensee + ACU | Spec | P4+ |
| Enterprise plans | Enterprise licensing with SLA, on-premises models, dedicated support | Contract | Spec | P4+ |
| BitriPay gateway revenue | Application fees on licensee and reseller flows routed through BitriPay connected accounts | bps per contract | Spec (gated) | P4 |

| Brief line | TRYST line | Price | Status | Phase |
|---|---|---|---|---|
| Marketplace revenue | No marketplace of people or services (commercial sexual services are prohibited, 01 §4.1). A **vetted integrations marketplace** for licensees (e.g. assurance providers) with referral fees is possible | Contract | Adapted | P4+ |
| Dynamic pricing engine | Market-level list prices tested by experiment; the same price for every member in a market; published; no personalised or surge pricing | — | Adapted (D-30) | P3 |

### 12.3 B2B licensing, white label and API revenue

**What is licensed:** the Envoy handshake engine (schema-only negotiation, asymmetric Briefs), the ExclusionRing PSI protocol and client library, the on-device Guardian models, Curtain's discretion policy engine and the `aigov` governance gate. **What is never licensed or shared:** TRYST members, their data, vectors or any model trained on them without a separate, lawful basis (models for licensing are trained on licensed or synthetic data). Licensees run the stack in their own environment; TRYST's Partner API meters calls in ACU.

### 12.4 Unit economics impact

The OS changes 01 §10.3 in three ways (to be measured in beta, not assumed):

1. **Cost per MAU down:** agent-handled support and T&S triage lower the variable ops cost, the main threat to gross margin identified in E-33.
2. **Payer rate up:** ENVOY's value depends on G-P2 (meets per intent +40%); the OS's job is to make that measurable and explainable.
3. **New revenue not dependent on member growth:** B2B licensing from P4, with near-zero marginal member risk.

### 12.5 Revenue optimisation, CLV, churn, upsell and cross-sell engines

| Engine | What it does | What it may never do |
|---|---|---|
| AI revenue optimisation | Finds revenue leaks: failed renewals (dunning through the processor), processor authorisation drops, refund causes | Raise price for a member individually; obscure costs |
| Customer lifetime value | Cohort CLV by acquisition channel and segment, for CAC decisions (E-03 thresholds) | Label individual members by value in any staff-facing view |
| Paid-acquisition brake (FR-091) | Stops paid seeding in a city automatically when cost per verified sign-up is above break-even for 2 weeks (or 1.5× in one week) | Restart without a named approver |
| Churn prevention | Detects cohort-level churn drivers; fixes product causes (slate quality, liquidity) | Retention flows on cancel (one step, ToS cl. 16); guilt copy; hiding cancel |
| Upsell | Shows the relevant tier when a member hits a real limit (e.g. the 3 weekly intents) | Engagement paywalls (P8); upsell during a safety flow |
| Cross-sell | GHOST to members who use discretion features; DUO to linked couples | Selling safety features (core discretion and safety are free, D-05) |

## 13. Security, compliance and risk

### 13.1 Cybersecurity Command Centre

| Brief element | TRYST control | Status |
|---|---|---|
| Zero trust: never trust, always verify | Every request authenticated and authorised; mTLS + SPIFFE between services; staff via SSO + hardware key + device posture; no VPN trust | Spec (P1) |
| MFA | Members: two factors always (02 §3.3). Staff: FIDO2 hardware key mandatory | **Built** (members) |
| Biometric authentication | B1 device-bound biometric passkey + B2 liveness match on mobile | **Built** (B2 provider pluggable; fails closed) |
| Device fingerprinting | Device binding by passkey and DPoP key (not cross-site fingerprinting); hashed device risk signals for admission L1 | Spec |
| Risk-based authentication | Identity risk agent can **add** step-up; it can never remove a factor | Spec |
| Real-time monitoring | SIEM over OpenTelemetry + audit chains; SOC agent triage | Spec |

| Brief element | TRYST control | Status |
|---|---|---|
| Behavioural analytics | Login anomaly (impossible travel, new device + new network), admin behaviour baselines | Spec |
| AI anomaly detection | Unsupervised models on ops telemetry and admin actions (not on member content) | Spec |
| Transaction scoring | Fraud agent + Radar + acquirer scores | Spec |
| Behaviour scoring | Admission L1–L5; Guardian graph signals | Spec |
| Device intelligence | Platform attestation (App Attest, Play Integrity) for native builds | Spec (P3) |

## 13.2 Anti-hacking framework

| Threat | Control |
|---|---|
| DDoS | Cloudflare and AWS Shield; per-route rate limits; autoscaling with caps |
| SQL injection | Parameterised queries only (Go `database/sql` placeholders, pglast-validated migrations); least-privilege DB roles; SAST rule |
| XSS | React escaping; strict CSP with no inline scripts on app origins (`frontend/next.config.ts`); no third-party scripts; Trusted Types in P1 |
| CSRF | No cookie-authenticated mutating endpoints without SameSite=Strict and Origin checks; tokens are DPoP-bound bearer (not ambient) |
| Session hijacking | Sessions bound to the device (DPoP); short lifetimes; sign-out everywhere; emergency lock (built) |
| Account takeover | No passwords, no SMS or email login codes; passkey + second factor; no staff overrides (D-16) |
| Credential stuffing | Nothing to stuff: no passwords exist |
| API abuse | Scoped keys, idempotency, rate limits, anomaly detection on partner usage |
| Bot attacks | Bot management at the edge; V2 verification before any interaction (E-01) |
| Prompt injection and model abuse | §5.7 injection defence; output schemas; red team per release |
| Supply chain | Signed images, SLSA provenance, dependency pinning and scanning, reviewed PRs only (including agent-authored ones) |

## 13.3 Data protection

| Brief element | Control |
|---|---|
| Encryption at rest | AES-256 via KMS for every store; per-member keys for profile data; crypto-shredding for erasure (03 §6.3) |
| Encryption in transit | TLS 1.3 at the edge; mTLS inside |
| Encryption in use | E2EE threads (MLS); client-side media encryption (Rust core, built); on-device Guardian; Nitro Enclaves evaluated for the PSI server (P2) |
| Tokenisation | Card data tokenised by processors (TRYST is SAQ-A scope); contact handles stored as HMAC with an HSM pepper |

## 13.4 Compliance

| Area | How the OS meets it |
|---|---|
| UK GDPR / DPA 2018 (Art 9 special category) | Explicit consent, DPIA, self-hosted models for member data, minimisation, DSR automation, < 60 s erasure |
| UK GDPR Art 22 (automated decisions) | Always-human classes; explanations from reason codes; appeal path (FR-035) |
| Online Safety Act 2023 | Highly effective age assurance; risk assessments; T&S SLAs; transparency reporting generated from audit data |
| EU AI Act (P4 markets) | Agent register, logging, human oversight and transparency labels ("machine-generated" on Briefs, P4) are already in place |
| KYC / KYB | Members: age assurance, not identity KYC (pseudonymous, FR-002). Partners and licensees: KYB |
| AML | TRYST holds no customer funds; AML obligations sit with regulated processors; TRYST screens business partners (D-32) |
| PCI DSS | SAQ-A: hosted checkout only; no card data touches TRYST |
| Audit logs | Hash-chained agent and admin logs; WORM anchoring |

| Area | How the OS meets it |
|---|---|
| Secure API keys | Shown once; Argon2id hashed; scopes; IP allow-lists; rotation; leaked-key scanning (GitHub secret scanning) |
| Webhook signing | HMAC with timestamp tolerance in and out; dedupe |
| Transaction monitoring | Payment and Fraud agents; chargeback thresholds |
| Admin action tracking | `ops.admin_action`, two-person break-glass |

### 13.5 AI risk register (additions to 01 §13.3)

| Risk | Likelihood | Impact | Mitigation | Owner |
|---|---|---|---|---|
| An agent takes a harmful action at scale | Medium | Severe | Gate, budgets, kill switch, canary rollout of agent versions | AI Governance |
| Model leaks special-category data | Low | Severe | Self-hosted models; Privacy Auditor leakage tests; no free-text member memory | DPO |
| Prompt injection via profile or ticket text | High | Medium | Injection defence and red team (§5.7) | Security |
| Auto-repair loop worsens an outage | Medium | High | Runbooks only; budget 50/day; rollback-first; pages a person if not resolved in 10 min | SRE |
| Over-reliance: staff rubber-stamp approvals | Medium | High | Approval sampling and second review for permanent bans; approval-rate monitoring per approver | Head of T&S |
| Connector sends member data to a third party | Low | Severe | Connector register checks; egress allow-list; DLP | Security |

## 14. Admin Super Control Centre

Internal origin, staff SSO + hardware key, redacted by default, every view and action logged (FR-086).

| Area | Visibility | Actions (and who may take them) |
|---|---|---|
| Users | Counts and cohorts by default; a specific member only through a case (JIT grant) | Hold (Guardian/moderator); permanent actions by moderator + second review |
| Businesses | Licensees and partners with KYB status, contracts, usage | Suspend keys (admin); terminate (two admins) |
| Transactions | Ledger explorer, payment events by processor | Refund (payments ops); failover (payments ops) |
| APIs | Traffic, errors, latency by route and key; deprecations | Throttle a key (admin); revoke (admin) |
| Payments | Authorisation rate, chargebacks, disputes, settlement by processor | Approve dispute responses; switch primary processor (two admins) |
| Agents | Registry, levels, budgets, decision stream, pending approvals, eval scores | Approve pending decisions (named approvers); kill (any on-call); resume (two people) |
| Automations | Workflow runs, failures, compensations | Retry, cancel (ops) |
| Disputes | Member appeals (FR-035) and payment disputes | Decide appeals (moderator not involved in the original decision) |
| Compliance | DSR clock, retention violations, OSA SLAs, regulator requests | Approve disclosures (DPO) |
| Revenue | Daily pack, forecasts, experiment results | Approve price experiments (pricing committee) |
| System health | SLOs, error budgets, incidents, deploys | Freeze deploys; approve promotion |
| Logs | Structured logs (scrubbed), traces | Read (engineers, JIT in production) |
| Alerts | Unified alert stream with dedupe and ownership | Acknowledge, assign, escalate |
| Platform performance | Web vitals, app crash-free rate, latency by journey | — |
| Audit | Chain verification status; last anchor; break-glass events | Export for auditors (DPO) |

**Break-glass:** a member-level view outside a case needs a justification and a second approver, expires in 8 hours (DDL CHECK), and is reported in the monthly access review.

# 15. Developer build roadmap

The OS phases align with TRYST's phases and gates (01 §12). The brief's five phases map as: **MVP = P1**, **Beta = P1 public beta → P2**, **Commercial launch = P3**, **Enterprise version = P4**, **Global scale version = post-P4**.

## 15.1 MVP (P1, M2–M6)

| | |
|---|---|
| Modules | Accounts and two-factor sign-in (built in part), Loops A, B, D, E2EE threads, V2 gating, VC co-sign, Guardian baseline on device, DSR and erasure, payments (Stripe + backup, BitriPay sandbox), agent registry and gate, audit chain, Admin Super Control Centre v1, connector register |
| APIs | Member API (02 §5), Ops API (§11.2), inbound webhooks |
| User flows | J1 (basic), J3, J4, J5, J7, J8 |
| AI agents | Cartographer, Broker (P1 baseline ranker), Curtain, Guardian, Aftercare, Onboarding, Risk, Fraud, Support, Compliance, Payment, Herald, System Health, Bug Detection, Auto-Repair, Release Manager, Threat Hunter, Vulnerability, SOC triage, executive copilots |
| Technical milestones | PostgreSQL IDENTITY-DB; DPoP; real liveness provider; gate as a central service with WORM anchoring; SLOs live; erasure < 60 s p99 |
| Commercial objectives | G-P1: matching live in London with 2,000 verified; sign-up open in all four launch cities; no-go list clear |

## 15.2 Beta (P2, M6–M10)

| | |
|---|---|
| Modules | Envoy, Mirror v1, ExclusionRing PSI, Member Command Centre (insights, "why" panels, my memory), analytics |
| AI agents | + Envoy, Mirror, Chief of Staff (member), Data Intelligence, Predictive Growth, Infra Optimiser, product copilots |
| Technical milestones | Workflow-level evals; chaos game days; Temporal in production |
| Commercial objectives | **G-P2:** meets per intent +40% vs the P1 control. If not met, stop and rethink |

## 15.3 Commercial launch (P3, M10–M15)

| | |
|---|---|
| Modules | DUO and GHOST billing, native apps in both stores, 24/7 T&S, Couple Command Centre, pricing experiments |
| AI agents | + Pricing, Monetisation, Retention, AML (payments monitoring) |
| Technical milestones | App attestation; open-banking evaluation; second processor live-tested |
| Commercial objectives | **G-P3:** 25,000 verified; payer rate ≥ 11%; both stores approved |

## 15.4 Enterprise version (P4, M15–M24)

| | |
|---|---|
| Modules | Partner API, partner and developer portals, ACU metering, KYB, BitriPay connected accounts for partner commissions, regulator portal, EU localisation |
| AI agents | + B2B Sales, Licensee Success, KYB onboarding |
| Technical milestones | Cell architecture design; EU AI Act conformity file; SOC 2 Type II and ISO 27001 / 27701 |
| Commercial objectives | **G-P4:** 150,000 verified; contribution-positive; first two licensees signed |

## 15.5 Global scale version (post-P4)

| | |
|---|---|
| Modules | Multi-cell deployment (UK+IE, EU-North, EU-South, then CA/AU/NZ per 01 §14.5), localised assurance and Guardian, licensee self-serve onboarding |
| AI agents | Per-cell agent instances with a global governance plane |
| Technical milestones | Cell isolation tests; regional key domains; follow-the-sun T&S |

| | |
|---|---|
| Commercial objectives | Licensing revenue ≥ 20% of total; per-market contribution margin positive within 12 months of launch |

### 15.6 Production readiness review (every phase gate)

| Area | Must be true |
|---|---|
| Reliability | SLOs defined and met for 30 days in staging/beta; rollback tested; DR restore drill passed this quarter |
| Security | Pen test closed (no high or critical open); threat model updated; secrets rotated; break-glass tested |
| Privacy | DPIA updated; Privacy Auditor green; erasure and DSR timings within NFRs |
| AI | Every agent registered with owner, level, budget, eval pass and red-team pass; kill-all drill done |
| Payments | Webhook replay and dedupe tested per processor; chargeback alerting live; backup MID transaction tested |
| Compliance | OSA risk assessment current; transparency report pipeline tested; store policy check (P3+) |
| Operations | On-call rota; runbooks for top 20 alerts; support macros reviewed against claims discipline (01 §15.1) |

## 16. Competitive advantage

| Dimension | How the OS wins | Why it is hard to copy |
|---|---|---|
| More powerful | Agent-to-agent negotiation turns intent into meetings; agents carry safety, support and operations volume | Needs the consent schema, the asymmetric Brief design and member trust built together |
| More profitable | Revenue tied to outcomes (ENVOY, QCAM); lower ops cost per MAU; B2B licensing from P4 | Competitors' revenue depends on message volume and paywalls they cannot drop |
| More scalable | Event-driven services, cell architecture, agents that scale with load rather than headcount | — |
| More intelligent | Learns from outcomes (aftercare reward), not clicks; stated-preference floor keeps members in control | Outcome data only exists if the product produces meetings |
| More trustworthy | Two-factor account-holder-only sign-in, E2EE, crypto-erasure, governance as tested code, no data sale | Incumbents carry breach history and ad-funded or volume-funded models |
| More compliant | OSA, GDPR Art 9 and 22, and EU AI Act controls designed in | Retrofitting into an engagement-optimised stack is slow and expensive |
| More commercially competitive | Processor independence (Stripe, acquirer, BitriPay) protects revenue; licensing opens a second business | Category players rely on a single high-risk processor relationship |

## 17. Final output format and index

This document is the developer-ready OS specification for TRYST. The brief's required technical outputs map as follows:

| Required output | Where |
|---|---|
| Product Requirements Document | 01 Product + §1–§4, §6, §12 here |
| Technical Requirements Document | 02 (FR/NFR) + FR-080–FR-088 |
| System, infrastructure, AI, agent architecture | §5, §9.1–§9.3; 03 |
| Security architecture; complete security controls | §13; 03 §6 |
| Database architecture; complete ERD and schemas | §10; 02 §4; generated migrations |
| API architecture; complete API specifications | §11; 02 §5; `shared/contracts/openapi/tryst.v1.yaml` |
| Event architecture | §9.4; 02 §8 |
| DevOps and deployment architecture | §9.9 |
| Monitoring architecture | §9.3 (observability, monitoring), §9.5 SLOs |
| Disaster recovery and business continuity | §9.7 |

| Required output | Where |
|---|---|
| Data governance architecture | §9.6 |
| Compliance architecture | §13.4; 01 §14 |
| Scalability architecture | §9.8 |
| Commercial architecture | §12 |
| Complete user journeys | §3.2; 01 §6; 04 §4 |
| Complete agent workflows | §5.5, §5.6, §5.7 |
| Complete testing strategy | §9.10 |
| Production readiness review | §15.6 |
| Code that implements this document today | `backend/internal/aigov` (governance gate, workforce registry, audit chain), `backend/internal/payments/bitripay.go` (BitriPay adapter), plus the v1.2 identity, payments and agent code |